

UNIVERSIDAD MAYOR DE SAN ANDRÉS
FACULTAD DE CIENCIAS PURAS Y NATURALES
CARRERA DE INFORMÁTICA
POSTGRADO DE INFORMÁTICA



TESIS MAGISTER SCIENTIARUM

**PROGRAMA DE MAESTRÍA EN INFORMÁTICA FORENSE,
SEGURIDAD DE LA INFORMACIÓN Y AUDITORÍA
INFORMÁTICA (MAE-FORSAI)
PRIMERA VERSIÓN, PARALELO B, GESTIÓN 2015-2016**

**MODELO DE SEGURIDAD DE LA INFORMACIÓN PARA
EL CONTROL DE ACCESO A LA RED A NIVEL DE LA
CAPA DE ENLACE DE DATOS APLICANDO EL
ESTÁNDAR IEEE 802.1X PARA EVITAR EL ACCESO
INDEBIDO A PERSONAL EXTERNO A LA RED DE DATOS
DEL BANCO NACIONAL DE BOLIVIA**

POR: Ing. Walquer Julio De La Cruz Uscamayta

TUTOR: M. Sc. Walter Ignacio Miranda Salazar

LA PAZ – BOLIVIA

2021

Dedicatoria

El presente trabajo va dedicado a mis señores padres Matilde y Lorenzo sin la guía de ellos no hubiera sido posible poder culminar mis estudios en esta nueva etapa de formación profesional, a mis hermanas por su constante apoyo y comprensión, a mis amigos y compañeros por su aliento, y a los docentes del postgrado de informática por sus enseñanzas y experiencias compartidas.

Walquer Julio De La Cruz Uscamayta.

ÍNDICE

ÍNDICE DE FIGURAS.....	vii
ÍNDICE DE CUADROS Y TABLAS.....	x
INTRODUCCIÓN	xii
CAPITULO I	1
1.1 ANTECEDENTES DEL PROBLEMA DE INVESTIGACIÓN	1
1.2 PLANTEAMIENTO DEL PROBLEMA	6
1.2.1 FORMULACIÓN DEL PROBLEMA DE INVESTIGACIÓN.....	7
1.3 PLANTEAMIENTO DE OBJETIVOS.....	7
1.3.1 OBJETIVO GENERAL.....	7
1.3.2 OBJETIVOS ESPECÍFICOS.....	8
1.4 JUSTIFICACIÓN.....	8
1.5 PLANTEAMIENTO DE HIPÓTESIS	9
1.5.1 VARIABLE DEPENDIENTE	9
1.5.2 VARIABLE INDEPENDIENTE.....	9
1.5.3 OPERACIONALIZACIÓN DE VARIABLES.....	9
CAPITULO II	11
2.1 MARCO CONCEPTUAL	11
2.1.1 SEGURIDAD EN LAS COMUNICACIONES.....	11
2.1.2 SEGURIDAD EN REDES TCP/IP	11
2.1.3 SEGURIDAD EN CAPA DE ACCESO DE DATOS.....	12
2.1.4 SEGURIDAD EN PUERTOS DE RED	14
2.1.5 MODELO DE SEGURIDAD EN REDES DE DATOS.....	15
2.1.6 CONTROL DE ACCESO.....	16
2.1.7 NAP PROTECCION DE ACCESO A LA RED	17
2.1.8 ESTÁNDARES IEEE.....	19
2.1.9 ESTÁNDAR IEEE 802.1X	20
2.1.10 SERVICIOS DE AUTENTICACIÓN.....	23
2.1.10.1 SERVICIO RADIUS.....	23
2.1.10.2 SERVICIO KERBEROS	24
2.1.10.3 SERVICIO TACACS	24
2.1.10.4 SERVICIO LDAP.....	25
2.1.11 ATAQUES DE DENEGACIÓN DE SERVICIO.....	26

2.2	MARCO REFERENCIAL	26
2.2.1	ESTADO DEL ARTE	27
2.2.2	ISO/IEC 27001 (SGSI) SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN.....	31
2.2.3	GUÍA METODOLÓGICA DEL SISTEMA DE SEGURIDAD DE LA INFORMACIÓN EN EL PROGRAMA DE MEJORAMIENTO DE LA GESTIÓN Y METAS DE EFICIENCIA (SSI-PMGMEI).	32
2.2.4	MODELO DE MADUREZ DE LA SEGURIDAD DE LA INFORMACIÓN EN EL CONTEXTO DE LAS ORGANIZACIONES INTELIGENTES (MMASI)	33
2.2.5	MODELO MEJORADO DE SEGURIDAD DE RED DISTRIBUIDA (P2DWR2).....	34
2.2.6	MODELO DE SEGURIDAD DE LA INFORMACION (MSGRC).....	35
2.2.7	MODELO DE SEGURIDAD DE LA INFORMACIÓN EN TIC (MSI-TIC)	37
2.2.8	MODELO DE DEFENSA DE SEGURIDAD DE RED (MDSR).....	39
2.2.9	MODELO (O-ISM3) DE MADUREZ DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN	39
2.2.10	MODELO DE SEGURIDAD DE RED BASADO EN MINERÍA DE DATOS (MSRBMD)	40
2.2.11	MODELO DE SEGURIDAD DE RED DE DEFENSA ACTIVA (P2DR2C)	42
2.2.12	MODELO CONTEXTUALIZADO DE COLADO & FRANCO (MCC&F).....	43
2.2.13	DIRECTIVA DE SEGURIDAD PARA LA PROTECCIÓN DE DATOS (DSI-PDP)	44
2.3	MARCO LEGAL O INSTITUCIONAL	45
CAPITULO III		47
3.1	DISEÑO DE LA INVESTIGACIÓN	47
3.2	MÉTODO DE INVESTIGACIÓN.....	47
3.3	TIPO DE INVESTIGACIÓN	47
3.4	FASES METODOLÓGICAS	48
3.5	POBLACIÓN DE ESTUDIO	49
3.5.1	DETERMINACIÓN Y ELECCIÓN DE LA MUESTRA.....	50
3.6	DELIMITACIÓN GEOGRÁFICA	50
3.7	DELIMITACIÓN TEMPORAL.....	51
3.8	ALCANCE DE LA INVESTIGACIÓN.....	51
3.9	TÉCNICAS DE INVESTIGACIÓN	51
3.10	FUENTES DE INVESTIGACIÓN.	52
3.10.1	ENTREVISTAS A PERSONAL ENCARGADO.....	52
3.10.2	ANÁLISIS DE ENTREVISTAS	53
3.10.3	OBSERVACIÓN Y RECOPIACIÓN DE INFORMACIÓN.....	55
3.10.3.1	DIAGRAMAS DE RED	56
3.10.3.2	REVISIÓN DE NORMATIVA INTERNA	58

3.10.3.3 POLITICA DE SEGURIDAD DE LA INFORMACIÓN	58
3.10.3.4 NORMATIVA DE GESTIÓN DE INCIDENTES DE SEGURIDAD BNB.....	59
3.10.3.5 NORMATIVA DE ADMINISTRACIÓN DE VULNERABILIDADES	60
3.10.3.6 METODOLOGÍA DE EVALUACIÓN DE RIESGO.....	61
3.10.3.7 NORMATIVA DE SEGURIDAD - REDES DE COMUNICACIONES	62
3.10.3.8 REPORTE DE EVENTOS DE SEGURIDAD	63
3.11 PROCESAMIENTO Y ANÁLISIS DE LA INFORMACIÓN.....	64
3.11.1 ANÁLISIS DE RESULTADOS DE LA ENTREVISTA.....	64
3.11.2 SITUACIÓN ACTUAL DE RED BNB	67
3.11.3 SITUACIÓN ACTUAL DE ACCESO EN RED CABLEADA.....	67
3.11.4 ANÁLISIS DE NORMATIVA INTERNA BNB	69
3.11.5 ANÁLISIS DE REPORTES DE SEGURIDAD DE LA INFORMACIÓN.....	70
3.12 DESARROLLO DEL MODELO.....	71
3.12.1 EVALUACIÓN DE LOS MODELOS.....	72
3.12.2 ELABORACIÓN DEL MODELO.....	75
3.13 MODELO DE SEGURIDAD DE LA INFORMACIÓN PARA EL CONTROL DE ACCESO A LA RED A NIVEL DE LA CAPA DE ENLACE DE DATOS	78
3.13.1 FASE DE PREPARACIÓN	79
3.13.2 COMITÉ DE SEGURIDAD DE LA INFORMACIÓN	79
3.13.3 APOYO DIRECTIVO.....	80
3.13.4 POLITICA DE SEGURIDAD DE LA INFORMACIÓN	80
3.13.5 OFICIAL DE SEGURIDAD DE LA INFORMACIÓN (OSI).....	81
3.13.6 FASE DE APLICACIÓN.	83
3.13.7 DEFINIR.....	83
3.13.8 EVALUAR.....	84
3.13.9 FORZAR.....	85
3.13.10 MONITOREAR Y DETECTAR.....	88
3.13.11 RESPONDER	89
3.13.12 CUMPLIR	90
3.13.13 DIFUNDIR.....	91
CAPITULO IV.....	92
4.1 DIAGNOSTICO ACTUAL DE LA EMPRESA	92
4.1.1 DIAGRAMA DE OBJETIVOS	92

4.1.2	ESTRUCTURA ORGANIZACIONAL.....	93
4.1.3	PLAN ESTRATÉGICO	94
4.2	APLICACIÓN DEL MODELO PROPUESTO CASO DE ESTUDIO BNB	96
4.2.1	COMITÉ DE GESTIÓN INTEGRAL DE RIESGOS BNB	97
4.2.2	APOYO DIRECTIVO BNB	99
4.2.3	POLITICA DE SEGURIDAD DE LA INFORMACIÓN BNB	101
4.2.4	SUBGERENTE DE SEGURIDAD DE LA INFORMACIÓN BNB.....	103
4.2.5	DEFINIR LA POLÍTICA DE CONTROL DE ACCESO A LA RED DE DATOS	105
4.2.6	EVALUAR EL RIESGO DEL ACCESO NO AUTORIZADO	106
4.2.7	FORZAR LA IMPLEMENTACION DE CONTROLES.....	116
4.2.8	MONITOREO Y DETECCIÓN	123
4.2.9	RESPUESTA A INCIDENTES.....	126
4.2.10	CUMPLIMIENTO DE CONTROLES.....	129
4.2.11	DIFUNDIR EL MODELO.....	132
4.2.12	ARQUITECTURA DE RED PROPUESTA.....	134
4.3	EVALUACIÓN DEL MODELO DE SEGURIDAD DE LA INFORMACIÓN.....	135
4.4	VALIDACIÓN DE RESULTADOS.....	142
4.4.1	VERIFICACIÓN DE HIPÓTESIS.....	150
4.4.2	PLANTEAMIENTO DE HIPÓTESIS.....	150
4.4.3	APLICACIÓN DE LA PRUEBA ESTADÍSTICA	150
4.5	RESULTADOS DE LA INVESTIGACIÓN.....	153
CAPITULO V.....		155
5.1	CONCLUSIONES Y RECOMENDACIONES.....	155
5.1.1	ESTADO DE LOS OBJETIVOS.....	155
5.1.2	ESTADO DE LA HIPÓTESIS.....	156
5.2	RECOMENDACIONES.....	157
5.3	PROPUESTAS DE MEJORAMIENTO	157
BIBLIOGRAFÍA.....		158
ANEXO I.		161
ANEXO II.		163
ANEXO III.		172
ANEXO IV.		176
ANEXO V.		183

ÍNDICE DE FIGURAS

Figura 1: Informe de riesgos mundiales 2019.....	2
Figura 2: Eventos de seguridad digital contra entidades bancarias medianas en el 2018	4
Figura 3: Modelo para la seguridad en el acceso a redes	15
Figura 4: Marco de trabajo NAP.....	18
Figura 5: Modelo de referencia IEEE 802.....	20
Figura 6: Conexión básica IEEE 802.1x.....	21
Figura 7: Proceso IEEE 802.1x.	22
Figura 8: Modelo de seguridad de red propuesto con VLAN y servidor TACACS + AAA.....	27
Figura 9: Estructura del modelo de seguridad de red sugerido para redes corporativas	29
Figura 10: Modelo PDCA aplicado a los procesos del SGSI	31
Figura 11: Cláusulas definidas en el estándar de acuerdo con el modelo PDCA	32
Figura 12: MMASI en el contexto de las organizaciones inteligentes	33
Figura 13: Componentes del modelo P2DWR2.....	35
Figura 14: Modelo de seguridad GRC.	36
Figura 15: Modelo de seguridad MSI-TIC.....	37
Figura 16: Estructura del modelo de defensa de seguridad propuesto.....	29
Figura 17: Estructura de niveles de reporte de la gestión de seguridad.	40
Figura 18: Modelo de detección de intrusiones basado en minería de datos.....	41
Figura 19: Estructura del modelo propuesto P2DR2C	42
Figura 20: Contextualización de la seguridad.	43
Figura 21: Contextualización de la seguridad para la protección de datos personales.....	44
Figura 22: Diagrama de red de comunicación entre oficinas a nivel nacional	56
Figura 23: Diagrama de red de comunicación entre oficina regional y agencias en oficina Sucre.....	57
Figura 24: Diagrama de red agencia Barrio Petrolero.	57
Figura 25: Estructura de política de seguridad de la información BNB	58
Figura 26: Etapas de análisis de riesgos tecnológicos BNB.	62
Figura 27: Notificación de evento de seguridad	63
Figura 28: Control de seguridad de la información.....	64
Figura 29: Diagrama lógico de acceso a la red BNB.....	67
Figura 30: Configuración de puerto de switch de acceso de la agencia 20 de octubre del BNB.....	68

Figura 31: Configuración DHCP de enrutador de la agencia 20 de octubre del BNB.....	68
Figura 32: Configuración de lista de acceso de enrutador agencia 20 de octubre del BNB	69
Figura 33: Diagrama de secuencias para elaboración del Modelo de seguridad de la información	76
Figura 34: Diagrama de estados para elaboración del Modelo de seguridad de la información.	77
Figura 35: Modelo de seguridad de la información para el control de acceso a la red.....	78
Figura 36: Reporte Gartner para sistemas de control de acceso a la red.....	87
Figura 37: Misión BNB.....	92
Figura 38: Visión BNB.....	92
Figura 39: Organigrama BNB.....	93
Figura 40: Organigrama Vicepresidencia de gestión de riesgos BNB.	93
Figura 41: Modelo de planificación estratégica BNB	94
Figura 42: Análisis de fortalezas BNB.....	94
Figura 43: Análisis de amenazas BNB.....	95
Figura 44: Mapa estratégico, seguridad de la información BNB	95
Figura 45: Mapa estratégico, continuidad de servicios BNB	96
Figura 46: Modelo de seguridad de la información para el control de acceso a la red del BNB	97
Figura 47: Consideración informe de análisis de riesgos.....	101
Figura 48: Convocatoria RRHH BNB	104
Figura 49: Configuración puerto de switch BNB.....	114
Figura 50: Asignación de dirección IP dentro de la red de datos.....	114
Figura 51: Verificación de dirección IP de servidor de dominio	115
Figura 52: Equipos conectados en el mismo segmento de red	115
Figura 53: Captura de tráfico Wireshark.....	115
Figura 54: Escaneo de puertos con Nmap.	116
Figura 55: Entidades de control de acceso	117
Figura 56: Diagrama lógico de sistema de control de acceso a la red ISE	118
Figura 57: Solicitud de credenciales para el acceso a la red	119
Figura 58: Autorización de equipo de red a través del estándar IEEE 801.1x	120
Figura 59: Denegación de acceso a la red a equipo externo	120
Figura 60: Proceso de solicitud de dirección IP	121
Figura 61: Registro de equipos en línea a través del sistema NAC.....	122
Figura 62: Autorización de equipo de red a través del sistema NAC.....	122
Figura 63: Log de eventos de autenticación y autorización de equipo de red	123

Figura 64: Autorización de equipo de red a través del sistema NAC.....	123
Figura 65: Log de eventos de autenticación y autorización de equipo externo	124
Figura 66: Configuración para mantener el log de eventos del servidor NAC.....	127
Figura 67: Configuración para mantener el log de conexión de equipos	128
Figura 68: Log de conexión de equipos.....	128
Figura 69: Monitoreo de eventos servidor ISE.....	129
Figura 70: Boletín informativo de Política de seguridad de la información	131
Figura 71: Boletín informativo del Modelo de Seguridad de la información.....	132
Figura 72: Arquitectura de red propuesta del sistema NAC	133
Figura 73: Reporte de autenticación del sistema NAC	134
Figura 74: Reporte de equipos rechazados del sistema NAC	136
Figura 75: Reporte de equipos autorizados por el sistema NAC	136
Figura 76: Reporte de usuarios conectados al sistema NAC.....	137
Figura 77: Reporte de equipos conectados antes de aplicar el modelo.....	140
Figura 78: Reporte de autenticación del sistema NAC	141
Figura 79: Reporte de equipos rechazados del sistema NAC	141
Figura 80: Registro de conexión y desconexión de equipos del sistema NAC.....	142
Figura 81: Reporte de conexiones antes y después de aplicar el modelo	143
Figura 82: Reporte de conexiones después de aplicar el modelo	144
Figura 83: Reporte de conexiones antes y después de aplicar el modelo.....	146
Figura 84: Porcentaje de reducción de eventos de seguridad luego de aplicar al modelo	146
Figura 85: Tabla de distribución Ji cuadrada.....	149

ÍNDICE DE CUADROS Y TABLAS

Cuadro 1: Operacionalización de variable independiente.....	9
Cuadro 2: Operacionalización de variable dependiente.....	10
Cuadro 3: Protección de puertos de switch.....	13
Cuadro 4: Opciones de configuración de filtrado de direcciones MAC.....	15
Cuadro 5: Pasos básicos de control de acceso.....	17
Cuadro 6: Comparación RADIUS y TACACS+.....	25
Cuadro 7: Fases metodológicas	48
Cuadro 8: Sucursales agencias y números de empleados	49
Cuadro 9: Cantidad de equipos de red por agencia.....	50
Cuadro 10: Análisis de entrevistas	53
Cuadro 11: Análisis de entrevista	65
Cuadro 12: Resumen normas BNB sobre seguridad de la información.....	69
Cuadro 13: Reporte de incidentes de seguridad del BNB.....	71
Cuadro 14: Modelos de seguridad de la información.....	73
Cuadro 15: Relación de elementos identificados por modelo.....	74
Cuadro 16: Selección de elementos por modelo estudiado	74
Cuadro 17: Selección de elementos para el modelo de seguridad de la información	75
Cuadro 18: Comparación de sistemas de control de acceso	88
Cuadro 19: Mapa de interrelación del Subgerente de Seguridad de la Información	103
Cuadro 20: Inventario de activos de acceso a la red de datos	106
Cuadro 21: Determinación de criticidad de activos.....	107
Cuadro 22: Criterios de valoración de los activos de información	108
Cuadro 23: Nivel de criticidad del activo de información.....	109
Cuadro 24: Valoración de activos relacionados al control de acceso a la red.....	109
Cuadro 25: Determinación de vulnerabilidades y amenazas sobre los activos de información	110
Cuadro 26: Valoración de la probabilidad en términos de ocurrencia.....	111
Cuadro 27: Descripción del impacto	111
Cuadro 28: Valoración del riesgo en términos de probabilidad e impacto	112
Cuadro 29: Valoración del riesgo en términos numéricos de probabilidad e impacto	113
Cuadro 30: Valoración de los riesgos de seguridad asociados a los activos de información	113
Cuadro 31: Valoración de incidentes de seguridad	126

Cuadro 32: Usuarios autorizados para acceso al sistema NAC.....	130
Cuadro 33: Cantidad de equipos de red por agencia.....	133
Cuadro 34: Reporte de conexiones sistema de control de acceso a la red	135
Cuadro 35: Eficacia del control	137
Cuadro 36: Modelos de seguridad de la información.....	138
Cuadro 37: Evaluación del modelo de seguridad de la información para el control de acceso a la red de datos	138
Cuadro 38: Operacionalización de variable dependiente.....	139
Cuadro 39: Reporte de conexiones antes de aplicar el modelo	139
Cuadro 40: Reporte de conexiones luego de aplicar el modelo en el mes de octubre 2019	142
Cuadro 41: Reporte de conexiones antes y después de aplicar el modelo	144
Cuadro 42: Reporte de conexiones pico antes y después de aplicar el modelo	144
Cuadro 43: Operacionalización de variable independiente.....	145
Cuadro 44: Reporte de incidentes de NEOSECURE antes de aplicar el modelo	145
Cuadro 45: Reporte de incidentes de NEOSECURE luego de aplicar el modelo	145
Cuadro 46: Reporte de conexiones antes y después de aplicar el modelo	146
Cuadro 47: Cálculo de frecuencias de la variable independiente.....	147
Cuadro 48: Cálculo de frecuencias de la variable dependiente.....	148
Cuadro 49: Cálculo de frecuencias de la variable independiente y dependiente	148

INTRODUCCIÓN

Desde la aparición de las computadoras junto al crecimiento de las redes de datos nace la necesidad de intercambiar información de manera fiable debiendo ser la seguridad de la información uno de los puntos neurálgicos de las actividades de una empresa, son varios los aspectos a considerarse al tratarse este tema, y uno de ellos es la seguridad a nivel de la capa de enlace de datos. Hablar de la confidencialidad de la información es garantizar que la información personal será protegida para que no sea divulgada sin consentimiento alguno. Dicha garantía se lleva a cabo por medio de protocolos que limitan el acceso a esta información.

Al existir diferentes tipos de ataques que pueden afectar las redes de datos de empresas que tienen extendida sus redes de acceso, resulta necesario implementar controles que mitiguen estos ataques para lo cual surge esta propuesta de un modelo de seguridad de la información a nivel de la capa de enlace de datos que haga uso de la tecnología del estándar IEEE 802.1x, esta propuesta se debe adecuar al entorno del caso de estudio de la red de datos del Banco Nacional de Bolivia.

En este documento en el segundo capítulo se hace un repaso de las bases teóricas relacionadas al control de acceso a la red de datos junto a una descripción del estándar IEEE 802.1x sus componentes y su modo de trabajo, se hace la revisión de sistemas de control de acceso a la red.

En el capítulo tres se hace un reporte de la metodología utilizada en esta investigación donde se detalla cada una de las técnicas de investigación desarrolladas en este estudio, se destaca el análisis de 12 modelos de seguridad de la información, de donde se logra obtener el modelo de seguridad para el control de acceso a la red, se hace una descripción de las fases de este modelo.

En el quinto capítulo el modelo propuesto es aplicado en el Banco Nacional de Bolivia, por ser una institución que pertenece al grupo de bancos múltiples de acuerdo con la clasificación hecha por el ente regulador local ASFI. Posterior a este desarrollo se hace una contrastación de resultados de conexiones e incidentes de seguridad antes y después de aplicar el modelo, con lo que se muestra la efectividad de este.

CAPITULO I

ASPECTOS GENERALES

1.1 ANTECEDENTES DEL PROBLEMA DE INVESTIGACIÓN

El uso de los medios tecnológicos e información digital está en incremento creando nuevos nexos de comunicación entre las empresas y personas, facilitando el manejo y almacenamiento de información. De igual forma que se aprovechan los beneficios que brinda la tecnología, existen grupos o personas que hacen uso de estos medios con otros fines que implican nuevos riesgos y amenazas ante los cuales las empresas demandan nuevas soluciones que sean flexibles y eficaces que eviten ataques como: infecciones de malware ¹, phishing ², denegación de servicio, explotación de vulnerabilidades y acceso indebido a redes de datos.

De acuerdo a lo reportado por el (Foro Económico Mundial 2009-2019, 2019, pág. 16) en la encuesta de percepción de riesgos mundiales GRPS ³, el "fraude y robo de datos masivo" se ubicó en el número cuatro de los riesgos mundiales, en un lapso de 10 años, con los "ataques cibernéticos" situados en el número cinco. Esto mantiene un patrón que se registró el año pasado, con la consolidación de la posición de los riesgos cibernéticos junto a los riesgos ambientales en el cuadrante de alto impacto y alta probabilidad del panorama de riesgos mundiales.

Un ejemplo de estos ataques cibernéticos dio lugar a una de las fugas masivas de información personal en el año 2018, esta se produjo en India, donde la base de datos de identificaciones del gobierno sufrió múltiples filtraciones que potencialmente pusieron en riesgo los registros de todos los 1100 millones de ciudadanos inscritos. Meses posteriores se informó que había delincuentes vendiendo acceso a la base de datos a un precio de 500 rupias por 10 minutos, en tanto que, en el mes de marzo, una filtración en una compañía de servicios públicos estatal permitió que cualquiera pudiera descargar nombres y números de identificación de acuerdo con el (Foro Económico Mundial 2009-2019, 2019, pág. 3). En la figura 1 se describen los niveles de incidentes reportados.

¹ Malware Tipo de programa maligno que trata de afectar a un ordenador.

² Phishing Método utilizado para obtener información confidencial de forma fraudulenta.

³ GRPS Global Risks Perception Survey.

Los cinco principales riesgos mundiales en términos de probabilidad



Fuente: (Foro Económico Mundial 2009-2019, 2019, pág. 8)

Figura 1: Informe de riesgos mundiales 2019

De acuerdo con el reporte de (Rodríguez V., 2018):

“Los bancos en la región están enfrentando un avance tecnológico a pasos agigantados que no ha parado, continúa y continuara más fuerte que nunca. En este campo ya se viene experimentando y enfrentando retos como la digitalización que representa un desafío para el sector financiero, tanto por su giro de negocio como por su seguridad. El sistema financiero se ha convertido en una vía indispensable para tener acceso a los satisfactores básicos y a las oportunidades de desarrollo. Hay diferentes estudios que concluyen que el acceso a los servicios financieros mejora la calidad de vida de las personas e impulsa el desarrollo económico de los países. La innovación y la tecnología han tomado el reto de desarrollar nuevos esquemas y formas de dar un mayor y mejor acceso a las finanzas, pero acompañado de un fuerte esquema en seguridad” (pág. 33).

Si bien los informes públicos sobre ataques cibernéticos sofisticados en bancos de América Latina y el Caribe son menos frecuentes que en América del Norte, Europa y Asia, hay evidencia reciente que muestra que la relativa tranquilidad de la región está llegando a su fin. A mediados de 2018, los bancos en México fueron blanco de grupos con las características de Amenaza Persistente Avanzada APT ⁴ de acuerdo con (Oerting & Doyle, 2018, pág. 20). También en 2018, al menos un banco en Chile fue víctima de un ataque, aunque no está claro si esto se atribuye más a delincuentes cibernéticos o a unos ataques APT más avanzados.

Los sistemas financieros mundiales y regionales están cada vez más interconectados, lo que da lugar a importantes economías de escala, una mayor eficiencia y menores costos de transacción para los consumidores según (Charles, 2018, pág. 37). Curiosamente, en general se cree que el sector de servicios financieros es el objetivo más lucrativo para los ataques cibernéticos. A medida que los bancos avanzan para cerrar la brecha tecnológica, los delincuentes cibernéticos también explotan estos avances para organizar ataques cada vez más sofisticados. De hecho, el Informe Global de Riesgos de 2018 del Foro Económico Mundial WEF ⁵, ha identificado las amenazas cibernéticas como uno de los cuatro principales riesgos en los que las organizaciones deben concentrarse.

De acuerdo con el reporte de la (Organización de los Estados Americanos, 2018) :

“Al revisar la frecuencia de ocurrencia de eventos relacionados con código malicioso o malware para el total de bancos medianos en la región, presentados en la figura 2, se apreció lo siguiente: i) un 28% de los bancos medianos identificaron ocurrencia de eventos de malware diariamente, ii) un 16% del total lo identificaron de forma semanal, iii) un 25% del total lo identificaron mensualmente, y iv) un 32% del total lo identificaron trimestralmente. Finalmente, se aprecia una dinámica de identificación de ocurrencia de algunos eventos de seguridad digital diariamente y del resto de eventos una dinámica de ocurrencia mensual y trimestralmente por parte de los bancos medianos” (pág. 62)

⁴ APT Advance Persistent Threat.

⁵ WEF World Economic Forum.

		Medianas				
		Diario	Semanal	Mensual	Trimestral	Total
Ingeniería social		23%	11%	21%	45%	100%
Código malicioso o Malware		28%	16%	25%	32%	100%
Phishing dirigido para tener acceso a sistemas del banco		21%	10%	26%	43%	100%
Pérdida de datos		4%	7%	14%	75%	100%
Pérdida o robo de equipos o dispositivos		0%	2%	18%	80%	100%
Ataque de negación del servicio (DoS / DDoS)		10%	10%	33%	47%	100%
Robo de DNS		10%	10%	30%	50%	100%
Violación de políticas de escritorio limpio (Clear Desk)		18%	11%	38%	33%	100%
Sabotaje interno		7%	7%	20%	67%	100%
Fraude interno		2%	0%	17%	81%	100%
Defacement		0%	14%	43%	43%	100%
Backdoor (código desarrollado para habilitar acceso posterior)		0%	0%	31%	69%	100%
SQL Injection		9%	9%	27%	55%	100%
Ataque de fuerza bruta		3%	7%	28%	62%	100%

Fuente: (Organización de los Estados Americanos, 2018, pág. 62).

Figura 2: Eventos de seguridad digital contra entidades bancarias medianas en el 2018

De acuerdo a (Woland & Heary, 2017, pág. 3) hoy en día, las redes son más seguras al estar protegidas por una red tradicional de perímetro. Sin embargo, la seguridad de las redes internas, especialmente las redes cableadas, que se encuentran detrás de grandes sistemas perimetrales, son muy deficientes. En general, una vez que un usuario obtiene acceso a las redes internas, a este se le brinda acceso libre y sin restricciones a la red corporativa. Además, con la llegada de nuevas tecnologías que promueben la movilidad como herramienta ha dado lugar que los dispositivos deambulan entre redes internas y externas. Nunca antes un empleado promedio ha estado tan conectado de tantas maneras y en distintos lugares. Tratar eficazmente los riesgos de seguridad que surgen de esta nueva realidad resulta ser un punto importante a tomar en cuenta al momento de implementar nuevas soluciones tecnológicas ⁶.

La seguridad de la información es un campo de estudio que continua creciendo y madurando. Según (Dildy, 2016, pág. 40) en la medida que la tecnología avanza, habrá también crecimiento en nuevas técnicas de seguridad y soluciones que ayuden a proteger los datos ante variados ataques. El sistema NAC ⁷ de control de acceso a la red, es la técnica para la administración de

⁶ Traducido del original en inglés (Woland & Heary, 2017, pág. 3) traducido por el investigador.

⁷ NAC Network Access Control.

red y seguridad de acceso que hace cumplir las políticas, el cumplimiento y la gestión del control de acceso a una red. También monitoriza y controla la actividad de los dispositivos y/o las personas una vez que ingresan a la red ⁸.

Existe el antecedente normativo sobre la seguridad en control de acceso de acuerdo a lo indicado por (Disterer, 2013):

“Debido a la importancia que estan tomando las tecnologías de la información, existe una necesidad de tomar medidas para brindar la seguridad adecuada a la información que esta siendo manipulada. La gestión sistemática de la seguridad de la información es una de las iniciativas más importantes para la gestión de las tecnologías de la información. Al menos desde que los informes sobre violaciones de privacidad, prácticas contables fraudulentas y ataques a sistemas de tecnologías de la información se hicieron públicos, las organizaciones han reconocido sus responsabilidades para salvaguardar los activos físicos y de información. Los estándares de seguridad se pueden utilizar como guía o marco de trabajo para desarrollar y mantener un sistema adecuado de gestión de seguridad de la información SGSI ⁹. Las normas ISO/IEC ¹⁰ 27000, 27001 y 27002 son normas internacionales que reciben un reconocimiento y una adopción cada vez mayores. Se les conoce como "lenguaje común de las organizaciones de todo el mundo" para la seguridad de la información” ¹¹ (pág. 92).

Según (Gonzales Manzano & De Fuentes Garcia-Romero de Tejada, 2014, pág. 17) la seguridad de la información tiene como objetivo el establecimiento de medidas que controlen, mitiguen y prevengan distintos problemas de seguridad de un sistema, como pueden ser el acceso de datos no autorizados o la recepción de datos maliciosamente modificados. Por ello se debe saber salvaguardar uno de los principales activos de una empresa que es la información, son varios los aspectos a considerarse al tratarse este tema, y uno de ellos son los recaudos que se debe tener con los dispositivos que se conectan a una red corporativa.

⁸ Traducido del original en inglés (Dildy, 2016, pág. 40) traducido por el investigador.

⁹ SGSI Sistema de Gestión de Seguridad de la Información.

¹⁰ ISO / IEC International Organization for Standardization / International Electrotechnical Commission.

¹¹ Traducido del original en inglés (Disterer, 2013, pág. 92) traducido por el investigador.

En los últimos años la tecnología ha cambiado considerablemente con el surgimiento y consolidación de nuevas tendencias, como la aparición de una gran cantidad de dispositivos que se conectan a la red, grandes volúmenes de datos, nuevas aplicaciones y servicios según (Kreutz, y otros, 2015, pág. 14). Debido a esto, las redes se ven obligadas a soportar unas exigencias para las que no fueron diseñadas originalmente, lo que hace que tengan la necesidad de modificar su enfoque ¹². Resulta muy importante considerar la protección física que se debe dar a una red de datos, este resguardo es muy a menudo sobreestimado.

De acuerdo con lo indicado por (Bosworth, Kabay, & Whyne, 2014):

“Al hablar de redes de datos se debe indicar que las redes tradicionales funcionan sobre una topología lógica de broadcast ¹³ donde se hace una difusión de datos a todos los equipos conectados a la red. En esta topología cada equipo de red escucha cada transmisión de datos. Cuando un equipo conectado a esta red opera en modo promiscuo, podrá acceder a cada trama de datos que pase por la red LAN ¹⁴ independientemente de que esta trama este o no este dirigida al equipo indicado. Debido a que muchas de las aplicaciones de red operan sobre el protocolo TCP / IP ¹⁵ : transmiten contraseñas y archivos en texto plano sin formato” ¹⁶ (pág. 774).

1.2 PLANTEAMIENTO DEL PROBLEMA

En la actualidad las organizaciones cuentan con una gran cantidad de dispositivos de red como son los equipos computadores, equipos portátiles, impresoras, teléfonos IP y dispositivos biométricos, a través de los cuales se pueden acceder a las redes internas de estas organizaciones. Las empresas tienen cada vez redes de datos más extendidas y distribuidas en oficinas y agencias repartidas en distintas ubicaciones geográficas. Así mismo se ha intensificado el uso de aplicaciones con acceso a servidores que requieren condiciones mínimas de seguridad y confidencialidad para el tráfico de datos existente entre los dispositivos finales y la red de datos.

¹² Traducido del original en inglés (Kreutz, y otros, 2015, pág. 14), traducido por el investigador.

¹³ Broadcast Modo de transmisión de información donde un nodo emisor envía información a una multitud de nodos receptores de manera simultánea.

¹⁴ LAN Local Area Network.

¹⁵ TCP / IP Transmission Control Protocol / Internet Protocol.

¹⁶ Traducido del original en inglés (Bosworth, Kabay, & Whyne, 2014, pág. 774), traducido por el investigador.

Se ha evidenciado que personal técnico descuida el aseguramiento de los dispositivos a nivel de la capa de acceso y de la capa de enlace de datos, por enfocarse sólo a proteger las capas superiores del modelo de referencia OSI, dejando huecos de seguridad que pueden ser aprovechados por un atacante, creyendo que la red de acceso LAN dentro de su organización es segura frente a cualquier posible ataque externo.

La presente investigación se centra en el sector financiero nacional y se enfoca en los bancos múltiples, de acuerdo con la clasificación hecha por la ASFI ¹⁷, y se considera al campo de la seguridad de la información ya que se analiza las posibles vulnerabilidades existentes en las redes de acceso de las organizaciones, los riesgos que conlleva los accesos no autorizados de dispositivos dentro de una red cableada de datos.

La red de acceso del caso de estudio en su configuración de red hace uso de servidores DHCP¹⁸ para la asignación automática de direcciones IP a los equipos que se conectan a sus puertos de red, siendo este un hueco de seguridad ya que cualquier personal ajeno podría conectar un dispositivo a la red y así poder comunicarse con los equipos y servicios de la red corporativa, a causa de esto los dispositivos externos de red que se conectan pueden afectar la red corporativa con algún tipo de virus informático o malware que se puede expandir en la red interna.

1.2.1 FORMULACIÓN DEL PROBLEMA DE INVESTIGACIÓN

¿De qué manera se podrá evitar el acceso indebido a nivel de la capa de enlace de datos a personal externo a la red de datos del Banco Nacional de Bolivia?

1.3 PLANTEAMIENTO DE OBJETIVOS

1.3.1 OBJETIVO GENERAL

Desarrollar un modelo de seguridad de la información para el control de acceso a la red a nivel de la capa de enlace de datos aplicando el estándar IEEE 802.1x para evitar el acceso indebido a personal externo a la red de datos del Banco Nacional de Bolivia.

¹⁷ ASFI Autoridad de Supervisión del Sistema Financiero.

¹⁸ DHCP Dynamic Host Configuration Protocol.

1.3.2 OBJETIVOS ESPECÍFICOS

- Realizar un diagnóstico de la red de comunicaciones del caso de estudio, determinando los niveles de seguridad con los que cuenta para evitar el acceso a personal externo.
- Analizar los modelos de seguridad de la información existentes para poder seleccionar el más adecuado en relación con el caso de estudio.
- Definir un modelo de seguridad de la información que controle los accesos indebidos a la red.
- Establecer un entorno de pruebas para aplicar la nueva propuesta para definir el nivel de seguridad alcanzado.
- Valorar los resultados alcanzados.

1.4 JUSTIFICACIÓN

El presente trabajo tiene justificación tecnológica, debido a la información crítica que manejan las instituciones financieras, se desea comprobar y limitar el acceso a equipos o dispositivos que no cumplen con los requisitos corporativos de seguridad antes de acceder a su red de datos, esto debido al riesgo que implica conectar dispositivos de red externos a la red corporativa.

El cumplimiento normativo es otra de las justificaciones que se tiene debido a que el ente regulador nacional ASFI, con su normativa de “Modificaciones al reglamento para la gestión de seguridad de la información” (Autoridad de Supervisión del Sistema Financiero ASFI, 2017) instruye: “Desarrollar políticas y procedimientos para la correcta administración de la infraestructura de redes y telecomunicaciones para lo cual se deben establecer controles de acceso para redes corporativas” (pág. 26).

La justificación científica de esta investigación radica en la profundización del estudio acerca de los ataques que se pueden dar a consecuencia de conexiones indebidas de equipos de personal externo. Esto con la finalidad de crear conciencia respecto a la importancia que se debe dar a los controles que se deberían implementar para mitigar este tipo de ataques.

1.5 PLANTEAMIENTO DE HIPÓTESIS

La implementación de un modelo de control de acceso a la red a nivel de la capa de enlace de datos basado en el estándar IEEE 802.1x evitara el acceso indebido a personal externo a la red de datos del Banco Nacional de Bolivia

1.5.1 VARIABLE DEPENDIENTE

Para la propuesta de investigación se tiene identificada como variable dependiente:

- Control de acceso a la red de datos.

1.5.2 VARIABLE INDEPENDIENTE

Para la propuesta de investigación se tiene identificada como variable independiente:

- Modelo de seguridad de la información en la capa de enlace de datos.

1.5.3 OPERACIONALIZACIÓN DE VARIABLES

En las siguientes tablas se muestran cómo operan tanto la variable dependiente como la variable independiente en la investigación realizada.

Cuadro 1: Operacionalización de variable independiente

VARIABLE Y DEFINICIÓN CONCEPTUAL	DIMENSIÓN	INDICADOR	ÍNDICE
<u>Modelo de seguridad de la información en la capa de enlace de datos de una red corporativa</u>	- Disponibilidad en comunicaciones	- Reporte e informe de incidentes	- Cantidad de eventos de incidentes DoS denegación de servicio.
Conjunto de medidas tomadas sobre las redes de datos que permitan resguardar y proteger la información buscando mantener la confidencialidad, la disponibilidad e integridad de esta.	- Confidencialidad en comunicaciones	- Reporte e informe de incidentes	- Cantidad de eventos de incidentes de Escaneo de trafico de red.

Fuente: Elaboración propia usando Excel 2019.

Cuadro 2: Operacionalización de variable dependiente

VARIABLE Y DEFINICIÓN CONCEPTUAL	DIMENSIÓN	INDICADOR	ÍNDICE
<u>Control de acceso a la red de datos</u> Proporcionan herramientas que permitirán brindar o denegar acceso a los equipos que se conecten a una red corporativa a nivel de capa de enlace de datos	Dispositivos autorizados para acceder a la red de datos.	- Reporte de conexiones	- Cantidad de equipos conectados. - Cantidad de equipos conectados autorizados. - Cantidad de equipos rechazados. - Cantidad de eventos de conexión

Fuente: Elaboración propia usando Excel 2019.

CAPITULO II

MARCO TEÓRICO

2.1 MARCO CONCEPTUAL

A continuación, se detallan las bases teóricas que se utilizaron en la investigación, se describen conceptos sobre control de acceso a redes, el protocolo IEEE 802.1x, modelos de seguridad en redes de datos.

2.1.1 SEGURIDAD EN LAS COMUNICACIONES

Como indica (Ciampa, 2015, pág. 19) La seguridad de la información es importante tanto para las empresas como para personas particulares. Debido a que la seguridad de la información puede ser útil para prevenir el robo de datos, impedir la sustracción de datos de identidad, evitar las consecuencias legales de no asegurar la información, mantener la productividad de las operaciones de las empresas y frustrar el terrorismo cibernético ¹⁹.

Al ser la información un recurso importante en toda institución debemos entender su definición, según (Rossiñol Ruiz, 2015, pág. 64) la información permite gestionar, formalizar y condicionar el conocimiento nuevo. De aquí que la información tenga un sentido pragmático, pues se materializa en informes investigativos, noticias u otras formas de transmisión de conocimiento. Dejando de esta manera distinguir que esta generación y comunicación de la información forma parte vital de cualquier empresa.

2.1.2 SEGURIDAD EN REDES TCP/IP

Uno de los primeros ataques contra las dos primeras capas del modelo TCP/IP son las escuchas de tráfico de red. Se trata de un ataque que permite la obtención de una gran cantidad de información sensible esto mediante el uso de aplicaciones que se encargan de capturar e interpretar tramas en entornos de red basados en difusión de datos, conocidos como escuchas de red o sniffers, es posible realizar el análisis de la información contenida en los paquetes TCP/IP que se interceptan para poder extraer todo tipo de información.

¹⁹ Traducido del original en inglés (Ciampa, 2015, pág. 19), traducido por el investigador.

De acuerdo con (García Alfaro & Perramón Tornil, 2007)

“Las técnicas de sniffing también se conocen como técnicas de eavesdropping y técnicas de snooping. La primera, eavesdropping, es una variante del sniffing, caracterizada por realizar la adquisición o intercepción del tráfico que circula por la red de forma pasiva, es decir, sin modificar el contenido de la información. Por otra parte, la técnica de snooping se caracteriza por el almacenamiento de la información capturada en el ordenador del atacante, mediante una conexión remota establecida durante toda la sesión de captura. En este caso, tampoco se modifica la información” (pág. 21).

Por lo indicado por (Jean-Marc, 2004, pág. 23):

“La transferencia de archivos mediante una red que no sea segura, resulta una amenaza para la empresa si estos datos que pueden ser confidenciales son interceptados por un delincuente informático. La gran mayoría de los datos que pasan por una red no han sido cifrados por tal motivo pueden ser capturados por un tercero que logre infiltrarse en una red. Hoy en día existe una gran variedad de programas que permiten capturar y observar todo el tráfico que circula por una red informática, estos programas se denominan packet Sniffer ²⁰ que son husmeadores de la red que tienen la capacidad de capturar todo el tráfico que circula a través de esta” (pág. 23).

2.1.3 SEGURIDAD EN CAPA DE ACCESO DE DATOS

Las primeras redes de área local LAN hicieron uso de concentradores de red denominados hub²¹, los cuales son dispositivos de red que son utilizados para conectar múltiples dispositivos de red para que trabajen en un segmento de red. Un hub que recibe tramas de paquetes entrantes, regenera la señal eléctrica y luego envía estas tramas recibidas a todos los demás dispositivos conectados, cada dispositivo decidirá si la trama de datos enviada está destinada a este y en ese caso la retendrá o si está destinado a otro dispositivo la ignorará (Ciampa, 2015, pág. 274). Es por esta causa que los hubs son un riesgo de seguridad debido a que un atacante podría instalar

²⁰ Packet Sniffer Programa para monitorizar y analizar el tráfico en una red de computadoras.

²¹ Hub Dispositivo que permite centralizar el cableado de una red de computadoras para luego poder ampliarla.

un software o un dispositivo de hardware que capture paquetes y logre decodificar los mismos para luego poder ver todo el tráfico que circula a través del hub. Debido a que la mayoría de los analizadores de protocolos pueden filtrar paquetes no deseados y reconstruir flujos de paquetes, un atacante podría capturar una copia de un archivo que fue transmitido, leer mensajes de correo electrónico, ver el contenido de páginas web entre otros riesgos ²².

Al igual que un hub, un switch de red es un dispositivo que conecta dispositivos de red entre sí. Sin embargo, a diferencia de un hub, un switch trabaja en la capa de enlace de datos, capa 2 del modelo de referencia OSI, un switch puede aprender qué dispositivo está conectado a cada uno de sus puertos y luego reenviar solo las tramas de datos destinadas a un dispositivo específico, este proceso se denomina unicast ²³, o tramas de datos enviados a todos los dispositivos, proceso denominado broadcast ²⁴. Un switch retiene esta información al examinar la dirección MAC ²⁵ de tramas que recibe y luego las asocia a un puerto con la dirección MAC del dispositivo conectado a ese puerto. Estos dispositivos mejoran el rendimiento de la red y proporcionan una mejor seguridad (Ciampa, 2015, pág. 274). En el cuadro 3 se muestra un listado de tipos de ataques y controles que se deberían implementar para proteger los puertos de un switch.

Cuadro 3: Protección de puertos de switch

TIPO DE ATAQUE	DESCRIPCIÓN	CONTROL
MAC Flooding ²⁶	Un atacante puede desbordar las tablas de direccionamiento de un switch con direcciones MAC falsas.	Utilizar un switch que pueda bloquear puertos con muchas direcciones MAC.
Interpretación de dirección MAC	Sucede cuando dos dispositivos de red tienen la misma dirección MAC en un mismo switch que puede enviar las tramas de datos a ambos dispositivos, un atacante puede modificar su dirección MAC que coincida con la dirección del dispositivo de red a atacar.	Configurar el switch para que solo pueda ser asignada una dirección MAC por cada puerto de red.

²² Traducido del original en inglés (Ciampa, 2015, pág. 274), traducido por el investigador.

²³ Unicast Envío de información desde un único emisor a un único receptor.

²⁴ Broadcast Transmisión de información donde un nodo emisor envía información a una multitud de nodos receptores.

²⁵ MAC Medium Access Control.

²⁶ MAC Flooding Técnica de ataque para comprometer la seguridad de un switch de red.

ARP ²⁷ Poisoning	Un atacante envía un paquete ARP haciéndose pasar por el dispositivo de origen sustituyendo su dirección MAC.	Utilizar un equipo de detección ARP.
Port mirroring ²⁸	Un atacante conecta su equipo a un puerto de red que tenga configuración Port Mirroring.	Asegurar el switch de red en un ambiente adecuado
Network Tap ²⁹	Un equipo de escucha de paquetes está conectado a la red para interceptar las tramas de datos de toda la red.	Mantener las conexiones de red seguras restringiendo su acceso físico.

Fuente: (Ciampa, 2015, pág. 276).

2.1.4 SEGURIDAD EN PUERTOS DE RED

De acuerdo con (Ciampa, 2015, pág. 332) el aseguramiento físico de los puertos de red es importante para limitar los accesos indebidos, los puertos de red pueden ser protegidos deshabilitando interfaces no utilizadas, haciendo uso de filtrado y limitando el uso de direcciones MAC, y también a través del estándar IEEE 802.1x.

- Deshabilitando puertos de red sin uso es una técnica de seguridad para apagar los puertos de red de un equipo de red como es un switch de acceso, este es un importante paso de protección de redes que a menudo se lo pasa por alto. Un switch o enrutador de red sin la configuración anteriormente indicada permite a los atacantes conectarse a puertos sin uso para acceder a la red empresarial. El administrador de red debería deshabilitar cada puerto de red que no esté en uso.

- Limitación y filtrado MAC, luego de deshabilitar los puertos de red sin uso se debería limitar y filtrar la cantidad de direcciones MAC permitidas por cada puerto de red. Un puerto puede ser configurado para que solo permita la conexión de una sola dirección MAC específica. Esto permitirá que el dispositivo de red autorizado se conecte a través de este puerto, denegando de esta forma la conexión de cualquier dispositivo de red que no sea el que este configurado para su acceso. Existen diferentes opciones de configuración para limitar y filtrar direcciones MAC que se describen en la tabla 4.

²⁷ ARP Address Resolution

²⁸ Port Mirroring Configuración de puerto de red de un switch para poder escuchar todo el tráfico de una determinada red.

²⁹ Network Tap Punto de acceso terminal o punto de acceso de prueba

Cuadro 4: Opciones de configuración de filtrado de direcciones MAC

CONFIGURACIÓN	EXPLICACIÓN
Estática	Las direcciones MAC son agregadas de forma manual.
Dinámica	Las direcciones MAC se aprenden y almacenan automáticamente, cuando el switch se reinicia las configuraciones son eliminadas.
Sticky ³⁰	Las direcciones MAC se aprenden automáticamente y se almacenan junto con las direcciones que se aprendieron antes de usar la configuración Sticky. Si las direcciones se guardan en la memoria, pero se eliminan de la tabla.

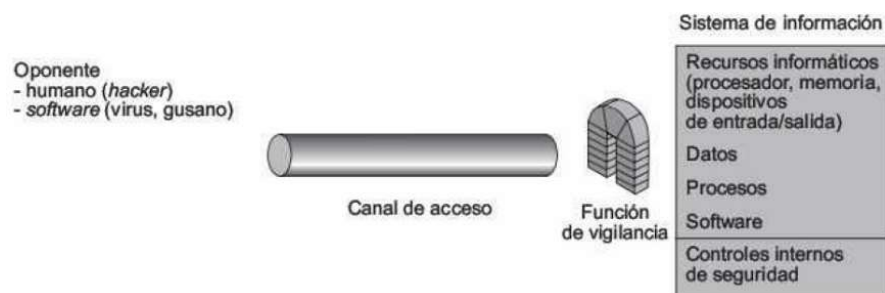
Fuente: (Ciampa, 2015, pág. 332).

2.1.5 MODELO DE SEGURIDAD EN REDES DE DATOS

De acuerdo con (Stallings, 2004):

“Los mecanismos de seguridad necesarios para enfrentarse a accesos no deseados se dividen en dos grandes categorías. La primera categoría puede denominarse función de vigilancia. Incluye los procedimientos de conexión mediante clave, diseñados para negar acceso a usuarios no autorizados, y los software de ocultación, diseñados para detectar y rechazar gusanos ³¹, virus ³² y ataques similares. Una vez que un usuario o software no deseado accede, la segunda línea de la defensa consiste en una serie de controles internos que monitorizan la actividad y analizan la información almacenada” (pág. 16).

En la figura 3 se describe la estructura de este modelo de seguridad.



Fuente: (Stallings, 2004, pág. 17)

Figura 3: Modelo para la seguridad en el acceso a redes.

³⁰ Sticky Configuración de puerto de red en switches

³¹ Gusanos Un gusano informático es un programa maligno que tiene la propiedad de duplicarse a sí mismo.

³² Virus Software que tiene por objetivo alterar el funcionamiento de cualquier tipo de dispositivo informático.

2.1.6 CONTROL DE ACCESO

De acuerdo con (Bosworth, Kabay, & Whyne, 2014)

“Los sistemas de control de acceso, se usan junto a sistemas de detección IDS y sistemas de control perimetral con el fin de proporcionar alerta temprana para prevenir problemas antes de que estos sucedan. El control de acceso efectivo requiere tres niveles de soporte que se describen a continuación. La fortaleza de cada nivel y su integración con otros niveles de seguridad determinan la efectividad de un sistema de seguridad.

- Privilegios. Este nivel determina si una persona está autorizada para ingresar a un determinado sistema. Es el proceso inicial de solicitud de entrada que se puede usar es por ejemplo una tarjeta de acceso o proximidad.

- Autenticación. Por lo general, es necesario identificar a una persona que busca ingresar con cierto grado de certeza. Para hacer esto, la persona debe poseer o saber algo único que otros no pueden duplicar fácilmente. Se tienen por ejemplo los PIN ³³, llaves electrónicas, tarjetas de entrada y dispositivos biométricos.

- Pista de auditoría. Se requiere un registro para cada intento de entrada para mostrar la fecha y la hora, la identificación de la persona y la acción tomada por el sistema.

Donde se requiere implementar un mejor control de acceso, la salida de cada persona también debe ser autenticada y registrada” (pág. 712).

El control de acceso consiste en restricciones tecnológicas que limitan a los usuarios de los equipos a acceder a los datos. Un usuario que accede a un sistema informático presenta sus credenciales de identificación, como un nombre de usuario, al iniciar sesión en un determinado sistema, posterior a ello los usuarios de computadoras deben tener sus credenciales autenticados para asegurarse de que son quienes dicen ser, a menudo introduciendo una contraseña, escaneo de huellas dactilares u otros medios de autenticación ³⁴ (Ciampa, 2015, pág. 444). El siguiente paso es la autorización donde se conceden permisos para tomar una determinada acción por ejemplo iniciar sesión en un determinado sistema, posterior a ello se concede a los usuarios el

³³ PIN Personal Identification Number

³⁴ Traducido del original en inglés (Ciampa, 2015, pág. 444), traducido por el investigador.

acceso sólo a los servicios, dispositivos, aplicaciones y archivos específicos necesarios. Los pasos básicos del proceso de control de acceso se muestran en el cuadro 5.

Cuadro 5: Pasos básicos de control de acceso

ACCIÓN	DESCRIPCIÓN	PROCESO
Identificación	Revisión de credenciales	Una persona ingresa su nombre de usuario
Autenticación	Validar que las credenciales son legítimas	El usuario proporciona su contraseña de acceso
Autorización	Se aprueban permisos de acceso	El usuario es autorizado para acceder al sistema
Acceso	Derecho de acceso a recursos específicos	Se permite el acceso al usuario a datos específicos.

Fuente: (Ciampa, 2015, pág. 444).

Los sistemas de control de acceso a la red NAC examinan el estado actual de un sistema o dispositivo de red antes de que se le permita conectarse a una red de datos de una empresa. Cualquier dispositivo que no cumpla con un conjunto específico de criterios de seguridad, como tener las actualizaciones de antivirus más recientes o la configuración de firewall habilitada correctamente, solo puede conectarse a una red denominada de cuarentena, donde se corrigen las deficiencias de seguridad. Una vez resueltos los problemas, el dispositivo es autorizado para conectarse a la red de datos. El objetivo de NAC es evitar que las computadoras con seguridad inadecuada ingresen a la red de datos e infecten potencialmente otras computadoras a través de una red empresarial ³⁵ (Ciampa, 2015, pág. 292).

2.1.7 NAP PROTECCION DE ACCESO A LA RED

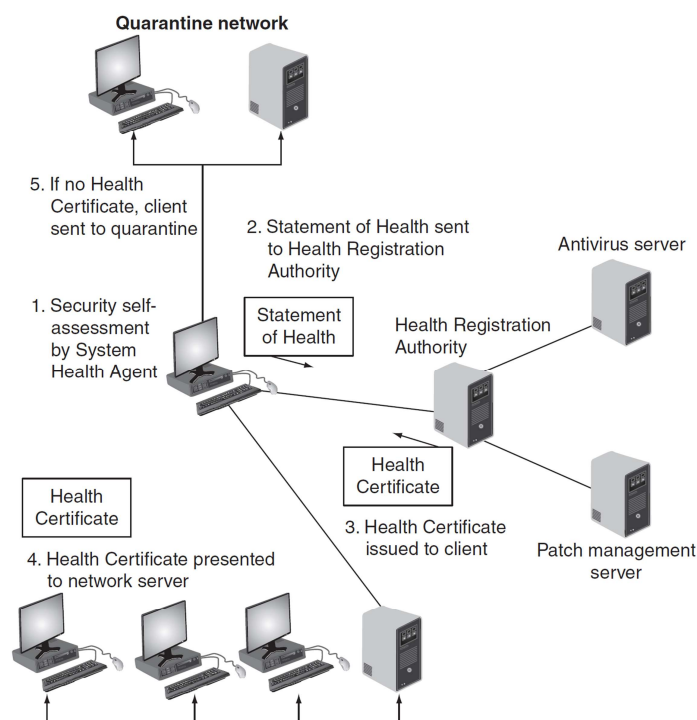
El sistema de control de acceso denominado NAP ³⁶, es una plataforma que controla el acceso a los recursos de la red, basándose en la identidad de una computadora cliente y el cumplimiento de las políticas de acceso dentro una red corporativa. NAP permite a los administradores de red poder definir los niveles granulares de acceso a la red, en función de que cliente desea acceder, los grupos a los que pertenece este cliente y el grado en que este cliente cumple con las políticas del gobierno corporativo de la red insitucional (Microsoft Corporation, 2019). Según el grado

³⁵ Traducido del original en inglés (Ciampa, 2015, pág. 292), traducido por el investigador.

³⁶ NAP Network Access Protection.

de cumplimiento, NAP puede implementar diferentes métodos de aplicación que puede restringir o limitar el acceso de un cliente a la red de datos ³⁷.

A continuación se detalla el proceso utilizado por NAP de acuerdo a (Ciampa, 2015, pág. 291) el mismo es presentado en la figura 4.



Fuente: (Ciampa, 2015, pág. 292)

Figura 4: Marco de trabajo NAP.

1° El cliente realiza una autoevaluación de su estado de seguridad haciendo uso de un Agente de Salud de Sistema SHA ³⁸ para determinar su postura de seguridad actual.

2° La evaluación conocida como Declaración de Salud SoH ³⁹ se envía a un servidor llamado Autoridad de Registro de Salud HRA ⁴⁰. Este servidor hace cumplir las políticas de seguridad dentro de la red. También se integra con otras entidades externas como el servidor de antivirus y el servidor de administración de parches para obtener la información de configuración actual.

3° Si el cliente es aprobado por la HRA, este le extiende un certificado de salud de acceso.

³⁷ Traducido del original en inglés (Microsoft Corporation, 2019) traducido por el investigador.

³⁸ SHA System Health Agent.

³⁹ SoH Statement of Health.

⁴⁰ HRA Health Registration Authority.

4° El certificado de salud es entonces presentado a los servidores de red quienes validaran que las condiciones de seguridad han sido aprobadas previamente.

5° Si el acceso del cliente no es aprobado, entonces el equipo es enviado a una red de cuarentena para que las deficiencias de seguridad sean corregidas, para permitir su posterior acceso a la red.

El sistema NAC utiliza típicamente uno de dos métodos para dirigir el cliente a una red de cuarentena y luego a la red de producción. El primer método es la asignación dinámica de una dirección IP a través de un servidor DHCP. Al cliente no aprobado primero se le asigna una dirección IP de la red de cuarentena y luego se le asigna una dirección IP a la red de producción. El segundo método hace uso de una técnica utilizada a menudo por los atacantes conocido como envenenamiento ARP. Con este método se manipula la tabla ARP en el cliente para que se conecte a la red de cuarentena ⁴¹ (Ciampa, 2015, pág. 292).

2.1.8 ESTÁNDARES IEEE

El desarrollo del mercado de las redes de acceso local LAN debe estar enmarcado en la disponibilidad de una interfaz de bajo coste, el costo de conectar un equipo a una red LAN debe ser mucho menor que el equipo en sí. Un estándar LAN ampliamente aceptado asegura un gran mercado para la demanda de equipos que posibilita la interconexión de estos y de distintos fabricantes. Este es el objetivo principal del comité IEEE ⁴² 802.

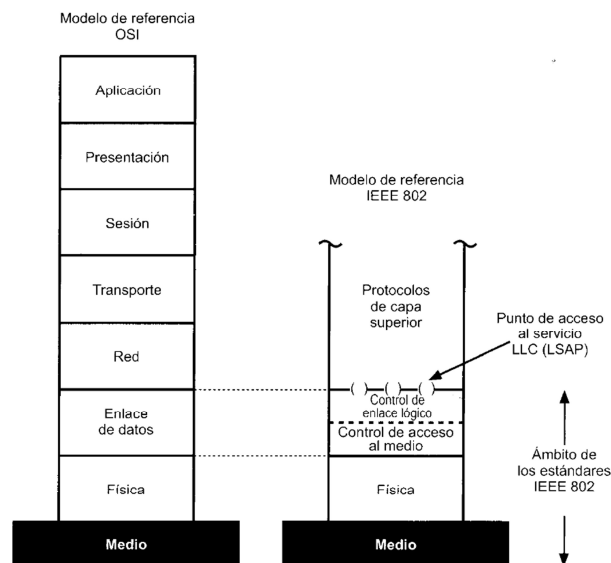
Este comité ha definido varias normas adoptadas en el año 1985 por el Instituto de Estandarización Nacional Americano ANSI ⁴³ como Estándares Nacionales Americanos. Estos estándares han sido sucesivamente revisados y redefinidos como estándares internacionales por la ISO ⁴⁴ en el año 1987, bajo la denominación ISO 8802. Desde entonces, el comité IEEE 802 ha continuado con la revisión y ampliación de estos estándares, adoptados últimamente por ISO. El comité llegó a la conclusión de que la tarea de comunicaciones a través de una red local es demasiado compleja para ser descompuesta en subtarefas manejables (Stalling, 2000, pág. 435). El resultado de esto fue el modelo de referencia IEEE 802 que es presentado en la figura 5.

⁴¹ Traducido del original en inglés (Ciampa, 2015, pág. 292), traducido por el investigador.

⁴² IEEE Institute of Electrical and Electronics Engineers.

⁴³ ANSI American National Standard International.

⁴⁴ ISO International Standard Organization.



Fuente: (Stalling, 2000, pág. 402)

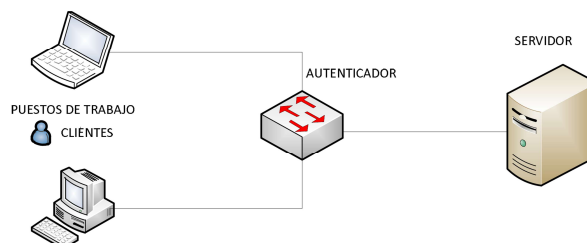
Figura 5: Modelo de referencia IEEE 802.

Otra conclusión a la que llego este comité fue que ninguna aproximación técnica cumplirá con todos los requerimientos, es así como el comité realizo la normalización de todas las propuestas serias en lugar de solo establecer una norma genérica. El estado actual de normalización se refleja en la existencia de numerosos subcomités en IEEE 802 (Stalling, 2000, pág. 435). En el presente estudio se considera al grupo de trabajo de protocolos LAN de capas superiores IEEE 802.1 donde se consideran sus generalidades, arquitectura, interconexión con gateways y redes virtuales de área local.

2.1.9 ESTÁNDAR IEEE 802.1X

Los sistemas de control de acceso trabajan bajo el estándar IEEE 802.1x, este estándar define un conjunto de protocolos, que trabajan a nivel de capa 2 del modelo OSI, utilizados para determinar si las credenciales proporcionadas por un dispositivo, que desea conectarse a una red en específico, son suficientes para permitir su conexión. 802.1x consta de tres entidades: un dispositivo intentando conectarse a una red, un segundo dispositivo que alberga un punto de conexión y una base de datos que contiene información de credenciales utilizada para validar la conexión. Estos dispositivos se denominan suplicante, autenticador, y servidor de autenticación, respectivamente (Lyle Brown, 2007, pág. 4). Estos nombres cambiarán dependiendo de qué especificación particular se hace referencia, pero estos son los términos comúnmente utilizados.

Indistintamente del nombre las funciones seran las mismas. En la figura 6 se describen las tres entidades que forman parte de este estándar.



Fuente: Elaboración propia según descripción de (Lyle Brown, 2007, pág. 4).

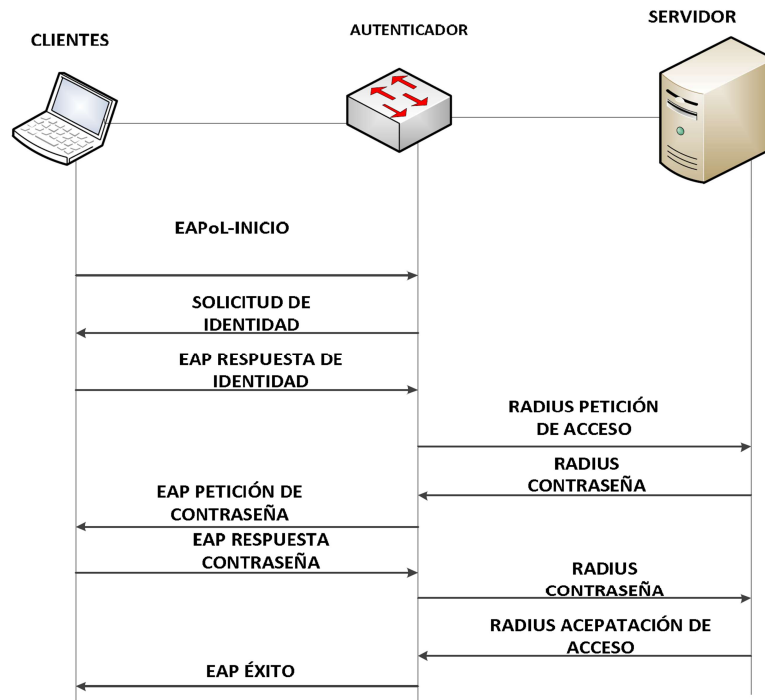
Figura 6: Conexión básica IEEE 802.1x.

De acuerdo con (Cisco Systems, 2011)

“El estándar 802.1X ofrece visibilidad y control de acceso seguro basado en la identidad en redes de acceso. Con el diseño apropiado y los componentes bien elegidos, puede cumplir las necesidades de una política de seguridad mientras se minimiza el impacto en la infraestructura de red y a usuarios finales. La necesidad de acceso seguro a la red nunca ha sido tan grande. Consultores, contratistas e invitados requieren acceso a recursos de red a través de las mismas conexiones de acceso a la red LAN que tienen los empleados regulares de una empresa. A medida que las redes de datos se vuelven cada vez más indispensables en las operaciones comerciales diarias, la posibilidad de que personas o dispositivos no autorizados obtengan acceso a información controlada o confidencial también aumenta. La mejor solución y la más segura en las redes de acceso es aprovechar la inteligencia de la red. 802.1X que es un estándar IEEE para control de acceso a nivel de capa de enlace de datos, que ofrece la capacidad de permitir o negar la conectividad a la red en función de la identidad del usuario final o dispositivo” (pág. 4).

Este estándar proporciona el mayor grado de protección en puertos de red con la implementación de la autenticación basada en puertos, este protocolo autentica a los usuarios por puerto de switch permitiendo el acceso a usuarios válidos y deshabilita el puerto de red si la autenticación es fallida. Esto evita que un dispositivo no autenticado no reciba ningún tipo de tráfico hasta que su identidad pueda ser verificada. También se limita el acceso al servidor que proporciona la autenticación para evitar el acceso de los atacantes (Ciampa, 2015, pág. 333).

En la figura 7 se describe los pasos en el proceso de autenticación de un equipo a una red de datos haciendo uso del estándar IEEE 802.1x



Fuente: Elaboración propia según descripción de (Ciampa, 2015, pág. 333)

Figura 7: Proceso IEEE 802.1x.

- 1° El equipo cliente, llamado suplicante, envía un paquete EAPoL ⁴⁵ solicitando al autenticador permiso para acceder a la red
- 2° El autenticador solicita al suplicante verificar su identidad.
- 3° El suplicante envía su información de identidad al autenticador.
- 4° El autenticador reenvía los datos de identidad del suplicante al servidor de autenticación, quien se encarga de verificar la autenticación de dispositivos. La información de identidad es enviada en formato encriptado.
- 5° El servidor de autenticación solicita al autenticador la contraseña del usuario que desea acceder a la red.
- 6° El autenticador solicita al suplicante la contraseña del usuario que desea acceder a la red.
- 7° El suplicante envía al autenticador su contraseña de acceso.

⁴⁵ EAPoL Extensible Authentication Protocol (EAP) over LAN.

8° El autenticador reenvía al servidor de autenticación las credenciales de acceso.

9° El servidor de autenticación verifica o rechaza las credenciales de identidad del suplicante y retorna esta información al autenticador.

10° Si las credenciales de identidad son aprobadas el autenticador permite que el suplicante acceda a la red de datos y transmita datos.

2.1.10 SERVICIOS DE AUTENTICACIÓN

Una persona que quiera acceder a un sistema informático debe presentar credenciales o su cuenta de usuario de identificación al iniciar sesión en un sistema determinado. Se verificarán las credenciales de la persona para asegurarse de que son genuinas y el usuario es en realidad quien dice ser, a este proceso se denomina de autenticación. Los servicios de autenticación pueden realizarse dentro de una red de datos mediante un servidor dedicado AAA que realiza las tareas de autenticación, autorización y registro de actividad. Los tipos más comunes de servidores AAA son el RADIUS, Kerberos y TACACS.

2.1.10.1 SERVICIO RADIUS

De acuerdo con (Ciampa, 2015, pág. 458) RADIUS ⁴⁶ o Servicio de Usuario de Marcación de Autenticación Remota, fue desarrollado en 1992 y se convirtió en un estándar con un amplio apoyo de los proveedores de equipos de red. Fue diseñado originalmente para el acceso telefónico remoto a una red corporativa. Con el desarrollo del estándar IEEE 802.1x para redes cableadas RADIUS ha sido utilizado con mayor frecuencia. Un cliente RADIUS es típicamente un dispositivo inalámbrico como un Punto de acceso AP ⁴⁷ o un switch de acceso que es responsable de enviar las credenciales de usuario y los parámetros de conexión en forma de un mensaje RADIUS a un servidor RADIUS. Este servidor autentica y autoriza la petición de un cliente, y devuelve una respuesta del mensaje RADIUS. Los clientes también envían mensajes de registro de actividad a los servidores RADIUS. La virtud de RADIUS es que los mensajes nunca se envían directamente entre el dispositivo cliente y el servidor de RADIUS. Esto evita que un atacante penetre en el servidor de autenticación y comprometa su seguridad ⁴⁸.

⁴⁶ RADIUS Remote Authentication Dial In User Service.

⁴⁷ AP Access Point.

⁴⁸ Traducido del original en inglés (Ciampa, 2015, pág. 458), traducido por el investigador.

2.1.10.2 SERVICIO KERBEROS

Kerberos es un sistema de autenticación desarrollado por el Instituto Tecnológico de Massachusetts MIT ⁴⁹ en la década de 1980 y se utilizó para verificar la identidad de los usuarios dentro una red, utiliza el cifrado y autenticación para la seguridad. Funciona bajo las plataformas de Windows, Apple Mac OS X, y Linux.

Se utiliza normalmente cuando un usuario intenta acceder a un servicio de red y ese servicio requiere autenticación. Al usuario se le proporciona un boleto que es emitido por el servidor de autenticación Kerberos. Este boleto contiene información que lo vincula al usuario. El usuario presenta este boleto a la red para acceder a un servicio. A continuación, el servicio examina el boleto para verificar la identidad del usuario. Si se valida la identidad del usuario entonces se brinda el acceso al servicio solicitado. Los boletos Kerberos son difíciles de copiar al estar encriptados, contienen información específica del usuario, restringen lo que un usuario puede hacer y caducan después de unas pocas horas o al día. La emisión y envío de boletos en un sistema Kerberos se gestionan internamente y es transparente para el usuario (Tanenbaum & Wetherall, 2012, pág. 722).

2.1.10.3 SERVICIO TACACS

El Sistema de Control de Acceso por Terminal de Acceso TACACS ⁵⁰ es un servicio de autenticación comúnmente utilizado en dispositivos con sistema operativo UNIX que se comunica reenviando la información de autenticación de un usuario a un servidor centralizado. El servidor centralizado puede ser una base de datos TACACS o un servidor de base de datos en Linux o UNIX que soporte de protocolo TACACS. La primera versión se llamó simplemente TACACS, mientras que una versión posterior se introdujo en 1990 y fue conocida como TACACS Extendido (XTACACS). La versión actual es TACACS+. Existen algunas diferencias entre TACACS+ y RADIUS ⁵¹ (Hodeghatta Rao & Nayak, 2014, pág. 75) . En la tabla 6 se presenta la comparación entre los estándares RADIUS y TACACS+.

⁴⁹ MIT Massachusetts Institute of Technology.

⁵⁰ TACACS Terminal Access Control Access Control System.

⁵¹ Traducido del original en inglés (Hodeghatta Rao & Nayak, 2014, pág. 75), traducido por el investigador.

Cuadro 6: Comparación RADIUS y TACACS+

CARACTERÍSTICA	RADIUS	TACACS+
Protocolo de transporte	UDP ⁵² De datagrama de usuario	TCP De Control de Transmisión
Autenticación y autorización	Combinada	Separada
Comunicación	No encriptada	Encriptada
Interactúa con kerberos	No	Si
Autentica dispositivos de red	No	Si

Fuente: (Ciampa, 2015, pág. 461).

2.1.10.4 SERVICIO LDAP

El Protocolo ligero de acceso a directorios LDAP ⁵³ es un servicio de directorio que consiste en un servidor de base de datos que contiene información sobre usuarios y dispositivos de red. Contiene información como el nombre del usuario, dirección de correo electrónico, nombre de inicio de sesión y otros atributos. El servicio de directorio también realiza un registro de actividad de todos los recursos en la red y los privilegios de acceso de un usuario a esos recursos, y concede o deniega acceso basado en la información del servicio de directorio. Los servicios de directorio facilitan la posibilidad de conceder privilegios o permisos a los usuarios de red ⁵⁴ (Ciampa, 2015, pág. 462).

La Organización Internacional de Normalización ISO ⁵⁵ creó un estándar para servicios conocidos como X.500, cuyo propósito era estandarizar la forma en que los datos se almacenaban para que cualquier sistema informático pudiera acceder a estos directorios. Proporciona la capacidad de buscar información por nombre y buscar información por categoría. La información se mantiene en un directorio de información base DIB ⁵⁶. Las entradas en este directorio se organizan en una estructura de árbol llamada directorio árbol de información DIT ⁵⁷. Cada entrada es un objeto con nombre y consta de un conjunto de atributos. Cada atributo tiene un tipo de atributo definido y uno o varios valores. El directorio define los atributos

⁵² UDP User Datagram Protocol.

⁵³ LDAP Lightweight Directory Access Protocol.

⁵⁴ Traducido del original en inglés (Ciampa, 2015, pág. 462), traducido por el investigador.

⁵⁵ ISO International Organization for Standardization.

⁵⁶ DIB Directory Information Base.

⁵⁷ DIT Directory Information Tree.

obligatorios y opcionales para cada clase de objeto. Cada objeto con nombre puede tener una o más clases de objeto asociadas a él.

Por defecto el tráfico LDAP se transmite en texto claro no cifrado. El tráfico LDAP se puede proteger mediante el uso de SSL ⁵⁸ o TLS ⁵⁹. Esto se conoce como LDAP seguro o LDAP sobre SSL LDAPS ⁶⁰. LDAP hace posible que casi cualquier aplicación se ejecute prácticamente en cualquier plataforma informática para obtener información de directorio. Debido a que LDAP es un protocolo abierto, las aplicaciones no necesitan preocuparse por el tipo de servidor que aloja este directorio.

2.1.11 ATAQUES DE DENEGACIÓN DE SERVICIO

Un ataque de denegación de servicio DoS ⁶¹ consiste en un incidente en el cual un usuario o una organización son privados de los servicios de un recurso que esperaban obtener. Normalmente, la pérdida de servicio corresponde con la imposibilidad de obtener un determinado servicio de red como, por ejemplo, el acceso a una página web. Los ataques de denegación de servicio pueden ser provocados tanto por usuarios internos de la organización como por usuarios externos. Dentro del primer grupo podríamos pensar en usuarios con pocos conocimientos que pueden colapsar el sistema o servicio de forma inconsciente, o usuarios malintencionados que aprovechan su acceso al sistema para causar problemas de forma premeditada, usuarios que han conseguido un acceso al sistema de forma ilegítima (García Alfaro & Perramón Tornil, 2007, pág. 34). El peligro de los ataques de denegación de servicio viene dado por su independencia de sistema operativo del equipo atacante, un ataque exitoso contra el protocolo IP se convierte inmediatamente en una amenaza real para todos los equipos conectados a la red, independientemente de la plataforma que utilicen.

2.2 MARCO REFERENCIAL

En esta sección se hará la descripción de algunos estudios, modelos de seguridad de la información con los cuales se hará una evaluación comparativa en el capítulo 3.

⁵⁸ SSL Secure Sockets Layer.

⁵⁹ TLS Transport Layer Security.

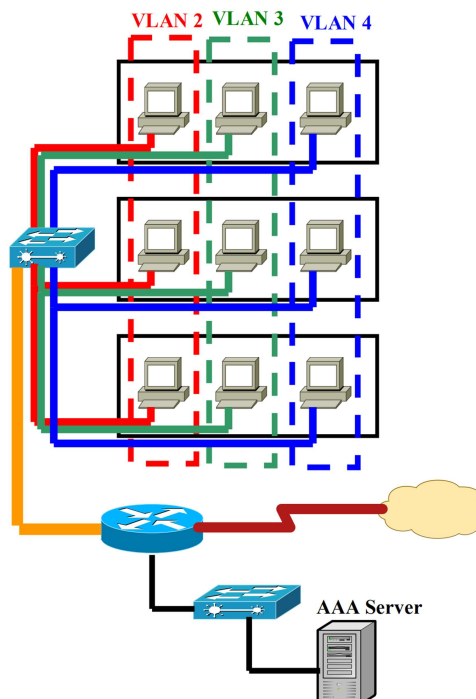
⁶⁰ LDAPS LDAP over SSL.

⁶¹ DoS Denial of Service.

2.2.1 ESTADO DEL ARTE

A continuación, se presenta una serie de artículos de estudios realizados con referencia a la seguridad informática, sistemas de control de acceso y protocolos de acceso a la red.

Como antecedente de propuesta de solución se tiene el siguiente artículo de (Salah A. Jaro, 2008, pág. 4) titulado “Diseño e implementación de un modelo de seguridad de red utilizando VLAN ⁶² estática y servidor AAA ⁶³” donde el autor propone un modelo de seguridad de red utilizando VLAN’s estáticas y un servidor de autenticación TACACS+ ⁶⁴ AAA. El modelo tiene como objetivo proteger la capa dos del modelo OSI ⁶⁵ de amenazas y ataques. El servidor AAA se usa para autenticar al usuario antes de obtener acceso a la red, cada usuario tiene acceso específico a la red de acuerdo con una política predefinida. El servidor AAA proporciona acceso a la red y gestión remota de dispositivos de red ⁶⁶. En la figura 8 se describe dicho modelo.



Fuente: (Salah A. Jaro, 2008, pág. 4)

Figura 8: Modelo de seguridad de red propuesto con VLAN y servidor TACACS + AAA.

⁶² VLAN Virtual Local Area Network.

⁶³ AAA Authentication, Authorization and Accounting.

⁶⁴ TACACS+ Terminal Access Controller Access Control System.

⁶⁵ OSI Open System Interconnection.

⁶⁶ Traducido del original en inglés (Woland & Heary, 2017, pág. 3) traducido por el investigador.

En el artículo de (Amiri, Afshar, Reza Naji, & Maleknasab Ardekani, 2012, pág. 2) titulado “Estudio sobre tecnologías de control de acceso en redes MANETs” indica que el uso de redes móviles ad hoc MANET ⁶⁷ está creciendo con los avances tecnológicos. Las redes MANET consisten en pocos nodos con recursos limitados y sin ninguna estructura especial. Cada nodo se puede conectar a otros nodos en el mismo periodo de transición. Los controles de acceso a la red con respecto al desarrollo de las redes de datos son muy importantes. En este artículo se explican los conceptos de los controles de acceso a la red, los mecanismos de acción en las redes y también compara algunos proveedores de soluciones NAC. Se describen cuatro protocolos de control de acceso a la red para redes MANET y también se hace su comparación en términos de eficiencia, comunicación complejidad, gastos generales y las técnicas que se utilizan. También se hace una descripción de los ataques que se pueden realizar en redes MANET.

En el artículo realizado por (Cuzme-Rodríguez, Yépez, Domínguez-Limaico, Cardenas, & Zambrano-Romero, 2018, pág. 43) titulado “Mejora de la red de acceso para una WLAN ⁶⁸ basada en los protocolos 802.1X y CAPsMAN ⁶⁹” describe la implementación de un método de acceso para acceder a una red inalámbrica basada en el protocolo Radius con equipos Mikrotik. Se aplica la autenticación EAP-TTLS ⁷⁰ basada en software de código abierto para proporcionar servicios AAA y un directorio LDAP ⁷¹ para guardar las cuentas de los usuarios. Este enfoque, de acuerdo con el autor, permite un mejor control de acceso y distribución de los recursos de una red de datos. El trabajo también incluye la implementación del protocolo CAPSMAN de la empresa Mikrotik que permite un control centralizado de todos los puntos de acceso AP ⁷² que irradian el mismo SSID ⁷³. Esta propuesta mejora el desempeño de la red y experiencia del usuario ⁷⁴.

⁶⁷ MANET Mobile Ad hoc Network.

⁶⁸ WLAN Wireless Local Area Network.

⁶⁹ CAPsMAN Controlled Access Point System Manager.

⁷⁰ EAP-TTLS Extensible Authentication Protocol - Transport Layer Security.

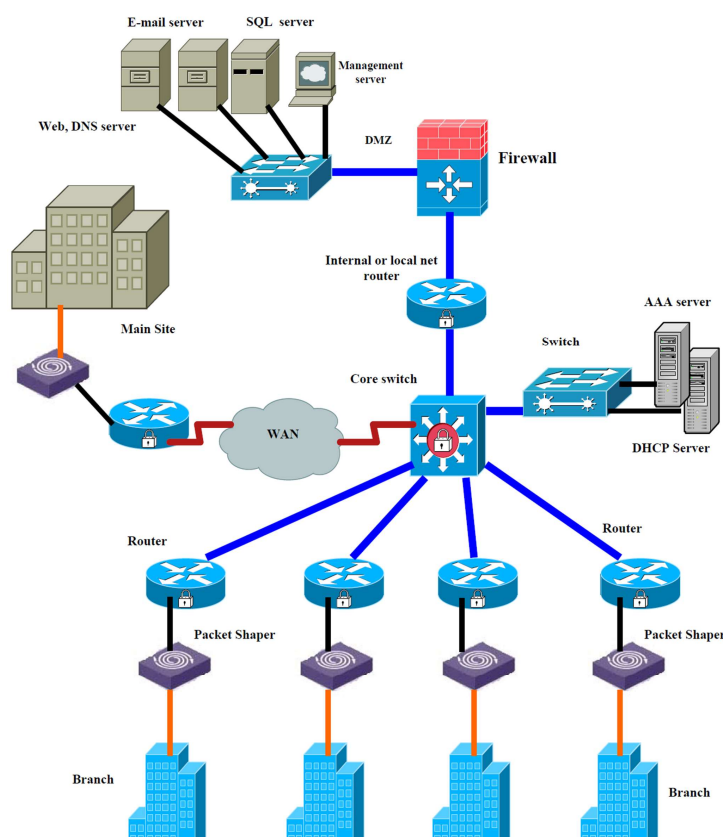
⁷¹ LDAP Lightweight Directory Access Protocol.

⁷² AP Access Point.

⁷³ SSID Service Set Identifier.

⁷⁴ Traducido del original en inglés (Cuzme-Rodríguez, Yépez, Domínguez-Limaico, Cardenas, & Zambrano-Romero, 2018, pág. 43), traducido por el investigador.

En el artículo presentado por (Alabady, 2009, pág. 26) titulado “Diseño e implementación de un modelo de seguridad de red para redes cooperativas” presenta un diseño e implementación de un modelo de seguridad de red haciendo uso de enrutadores de red y firewalls. En el documento también se hace un análisis de la seguridad en los enrutadores de red y firewall, los tipos de amenazas y acciones tomadas contra estas amenazas y se presenta un método para evitar que los ataques y los hackers accedan a la red corporativa. El documento también proporciona una lista de verificación para evaluar si una red se adhiere a las mejores prácticas en seguridad de red y confidencialidad de datos. El objetivo principal de esta investigación es proteger la red de vulnerabilidades, amenazas, ataques, de falencias en la configuración de equipos de red y deficiencias en las políticas de seguridad. En la figura 9 se presenta el modelo de seguridad de red propuesto por el autor.



Fuente: (Alabady, 2009, pág. 35)

Figura 9: Estructura del modelo de seguridad de red sugerido para redes corporativas.

En el estudio realizado por (Paredes S., Urbina G., & Espinoza O., 2016, pág. 35) titulado “Implementación de un plan piloto de seguridad bajo el protocolo IEEE 802.1x para el

departamento de gestión tecnológica del ministerio de telecomunicaciones y Sociedad de la Información”, el autor realiza un análisis a la seguridad actual de la red del Ministerio de Telecomunicaciones y sociedad de la información el trabajo también incluye la implementación de un plan piloto de seguridad para el acceso a la red, basándose en el estándar IEEE 802.1x, usando la plataforma Ubuntu 11.04 y herramientas como MySql para el manejo de base de datos y FreeRadius para el servidor AAA. La configuración del servicio de autenticación se realiza en un switch marca Cisco que es compatible con el estándar, también se indica como configurar los computadores de los usuarios que tienen el sistema operativo Windows en sus versiones XP y 7. Basándose en un análisis preliminar se escogen los métodos de autenticación EAP-MD5⁷⁵ y PEAP⁷⁶ como idóneos por la cantidad de usuarios dentro del ministerio. Para la administración de la red se usan aplicaciones como Daloradius para brindar control total sobre los recursos de la red.

Otro artículo referente al caso de estudio es el presentado por (Nunoo-Mensah, Kofi Akowuah, & Osei Boateng, 2014, pág. 28) titulado “Revisión de las herramientas de control de acceso a la red (NAC) de código abierto para redes educativas empresariales” donde indica que: en las redes empresariales, se fomenta el concepto de traer sus propios dispositivos BYOD⁷⁷ para trabajar y para también permitir que los equipos invitados se conecten a la red empresarial. Como factor se tiene la necesidad crítica de controlar el acceso a la red como también tener la visibilidad de los nodos conectados a la red para así determinar las posibles amenazas que puedan surgir a través de estas conexiones. El uso de la tecnología de código abierto no es muy frecuentado por el mundo corporativo debido al conocimiento que se debe tener y las supuestas complejidades involucradas en el uso de este software. Este documento muestra la necesidad del uso de código abierto para redes empresariales, especialmente para economías en vías de desarrollo. En este artículo se revisan tres herramientas principales de código abierto (OpenNAC, PacketFence y FreeNAC) para proporcionar un mecanismo para evaluar y seleccionar una opción de código abierto para una red del tipo educativo⁷⁸.

⁷⁵ EAP-MD5 Extensible Authentication Protocol - Message-Digest Algorithm 5.

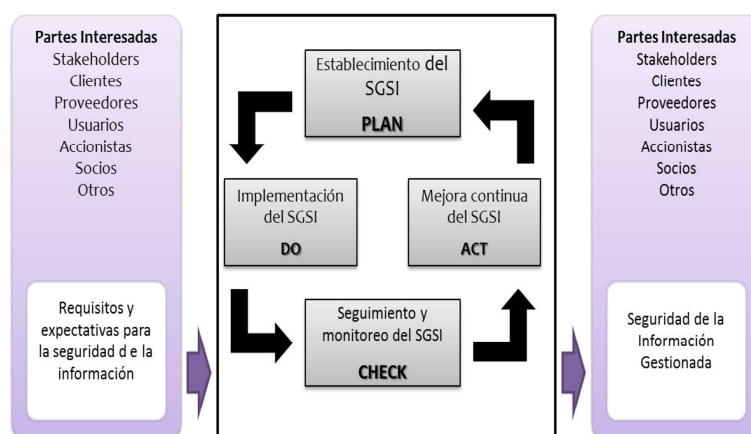
⁷⁶ PEAP Protected Extensible Authentication Protocol.

⁷⁷ BYOD Bring Your Own Device.

⁷⁸ Traducido del original en inglés (Nunoo-Mensah, Kofi Akowuah, & Osei Boateng, 2014, pág. 28), traducido por el investigador.

2.2.2 ISO/IEC 27001 (SGSI) SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN

Este modelo es considerado un estándar internacional que ha sido elaborado para establecer, implementar, operar, monitorear, revisar, mantener y mejorar la Gestión de Seguridad de la Información en las organizaciones. La adopción del SGSI ⁷⁹ debe ser una decisión estratégica para una organización. El diseño e implementación del SGSI de una organización es influenciado por las necesidades y objetivos, requerimientos de seguridad, los procesos empleados y el tamaño y estructura de la organización (International Organization for Standardization, 2013). El modelo del proceso adoptado es el de PDCA ⁸⁰ Planear, Hacer, Chequear, Actuar, el cual se aplica a todos los procesos del SGSI, en la figura 10 se muestra la estructura del modelo.



Fuente: (International Organization for Standardization). Consultado el 25 de septiembre de 2019, de www.iso.org

Figura 10: Modelo PDCA aplicado a los procesos del SGSI.

Este estándar internacional promueve la adopción de un enfoque de proceso, lo cual fomenta que sus usuarios resalten la importancia de:

- Entender los requerimientos de seguridad de la información de una organización y las expectativas de las partes interesadas.
- Implementar y operar controles para manejar los riesgos de seguridad de la información.
- Monitorear y revisar el desempeño y la efectividad del SGSI.
- El Mejoramiento continuo en base a la medición del objetivo.

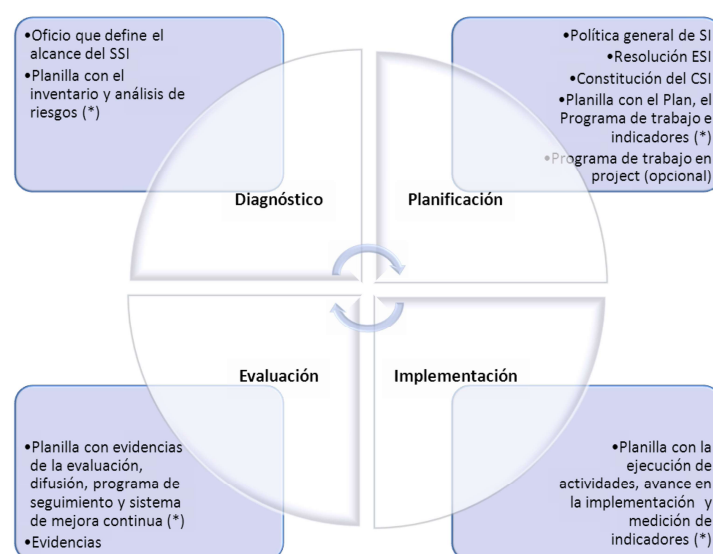
⁷⁹ SGSI Sistema de Gestión de Seguridad de la Información.

⁸⁰ PDCA Plan Do Check Act.

La organización debe establecer, implementar, operar, monitorear, mantener y mejorar continuamente un SGSI documentado dentro del contexto de las actividades comerciales generales de la organización y los riesgos que enfrentan, de acuerdo con los requisitos definidos en los capítulos del 4 al 10 de este estándar.

2.2.3 GUÍA METODOLÓGICA DEL SISTEMA DE SEGURIDAD DE LA INFORMACIÓN EN EL PROGRAMA DE MEJORAMIENTO DE LA GESTIÓN Y METAS DE EFICIENCIA INSTITUCIONAL (SSI-PMGMEI).

Esta guía presentada por la (Dirección de Presupuestos del Ministerio de Hacienda, 2013, pág. 8) plantea un modelo de seguridad de la información que permite ir conformando un marco de gobierno para la seguridad de la información institucional, al establecer políticas, procedimientos y controles en relación con los objetivos estratégicos de una institución, con objeto de mantener siempre el riesgo por debajo del nivel aceptable por la propia organización. El modelo plantea un esquema para su implantación y operación dividido en 4 etapas que se muestra en la figura 11.



Fuente: (Dirección de Presupuestos del Ministerio de Hacienda, 2013, pág. 10)

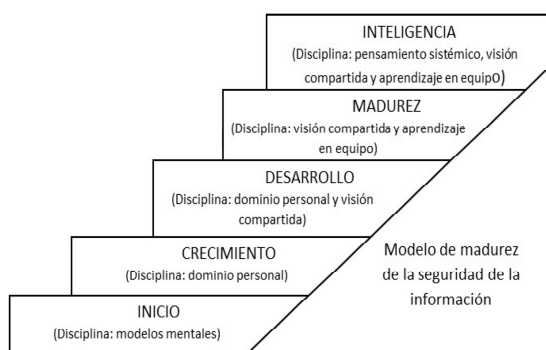
Figura 11: Cláusulas definidas en el estándar de acuerdo con el modelo PDCA.

Asimismo, establece una relación de actividades detalladas para el desarrollo de cada uno de los requisitos y controles de seguridad como ser: identificar los activos de información, realizar la evaluación de riesgos, establecer un marco de trabajo general, elaborar un plan de trabajo,

establecer indicadores para medir la efectividad, ejecutar las tareas planificadas, evaluar la implementación en general, difundir los resultados, programar el seguimiento de las recomendaciones y mantener el grado del desarrollo alcanzado.

2.2.4 MODELO DE MADUREZ DE LA SEGURIDAD DE LA INFORMACIÓN EN EL CONTEXTO DE LAS ORGANIZACIONES INTELIGENTES (MMASI)

Este modelo se encuentra integrado por cinco niveles de madurez a ser adoptado por las organizaciones inteligentes como un factor crítico de éxito. En la figura 12 se hace la descripción del modelo citado. A continuación, se describe cada uno de los niveles del modelo MMASI:



Fuente: (Villegas, Viloría, & Blanco, 2009, pág. 74)

Figura 12: MMASI en el contexto de las organizaciones inteligentes.

a) Nivel de inicio.

En este nivel es donde las organizaciones producen las acciones necesarias y suficientes para proporcionar un aprendizaje bajo un sentido de Seguridad de la Información. Existen altos niveles de confusión en la adopción de medidas básicas de seguridad, cada usuario instala herramientas de software en su computadora, sin estar alineado a ningún plan de seguridad, no hay actitudes proactivas sino reactivas (Villegas, Viloría, & Blanco, Modelo de madurez de la seguridad de la información en el contexto de las organizaciones inteligentes, 2009, pág. 74).

b) Nivel de crecimiento.

En este nivel del modelo, todavía no se han superado muchos de los problemas y situaciones presentes en el nivel de inicio; aún existe una barrera en la comunicación entre la alta gerencia y el departamento de sistemas o afines. Destacan las siguientes características:

- Encargado de la seguridad de la información.

- Herramientas básicas de hardware y software.

c) Nivel de desarrollo.

En este tercer nivel existe una visión más amplia y sistémica de seguridad de la información, aumenta la preocupación por el problema de la inseguridad de los activos informáticos. Cambia la estructura organizacional, se crea el departamento o unidad encargada de la gestión de Seguridad de la información con sus respectivos gerentes y personal dedicados exclusivamente a las actividades de la seguridad física o lógica. Este nivel tiene las siguientes características:

- Unidad organizacional o departamento de la seguridad de la información.
- Documento de seguridad de la información.

d) Nivel de madurez.

En este nivel los equipos de trabajo de seguridad de la información trabajan en conjunto y están bajo una visión común. Se tienen los siguientes indicadores:

- Sistema de activos informáticos.
- Adopción de las políticas de la seguridad de la información.
- Desarrollo de un plan estratégico.

e) Nivel de inteligencia organizacional

A este nivel la empresa alcanza su máximo nivel de madurez, es una organización que aprende a aprender, la cultura de la seguridad está arraigada, las disciplinas de las organizaciones inteligentes son aplicadas en el ámbito organizacional de la seguridad de la información, se tiene los siguientes indicadores:

- Cultura organizacional de la seguridad de la información.
- Monitoreo permanente a los activos informáticos.

2.2.5 MODELO MEJORADO DE SEGURIDAD DE LA INFORMACIÓN DE RED DISTRIBUIDA (P2DWR2)

En el artículo presentado por (Ping Ping, 2010, pág. 391) presenta un modelo de seguridad de alerta temprana dentro una red distribuida. Dicho modelo tiene cinco componentes los cuales

son protección, detección, alerta temprana, respuesta y recuperación. como se muestra en la figura 13.



Fuente: (Li, Wang, Han, & Jing, 2009, pág. 3)

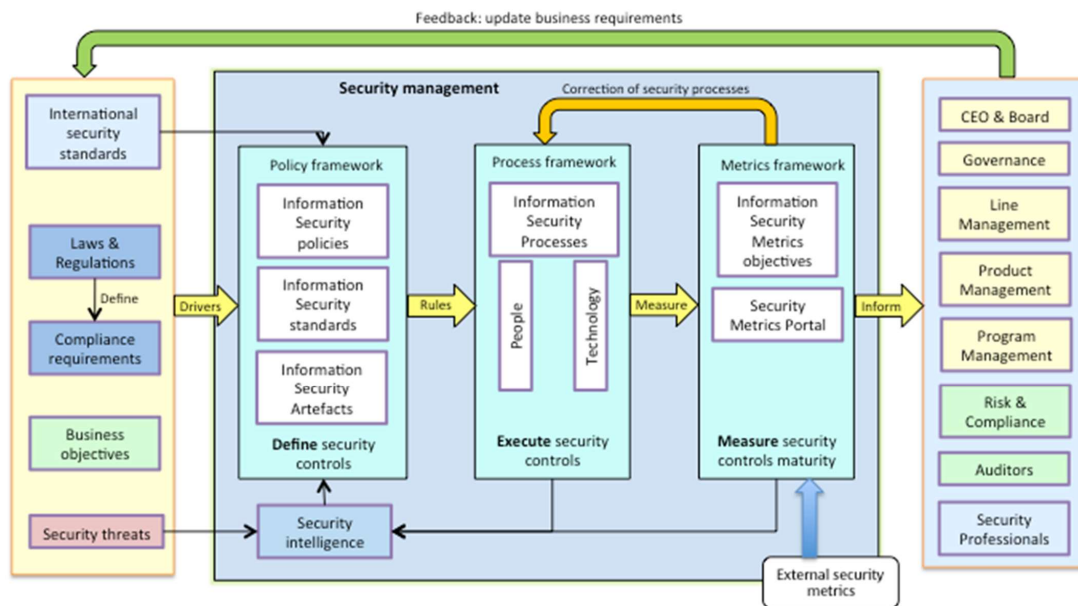
Figura 13: Componentes del modelo P2DWR2.

Este modelo utiliza detección dinámica para determinar el estado de la seguridad de la red. El modelo P2DR tiene diferentes limitaciones, no admite la alerta temprana activa. Necesita una interacción humana para proporcionar un modelo de seguridad dinámico, no existe una cooperación activa entre los componentes de seguridad. En este modelo la política de seguridad se la considera como su núcleo. Al tener una cooperación activa entre los componentes de seguridad es compatible con una red distribuida a gran escala. El modelo proporciona una respuesta automatizada a incidentes de seguridad, al tiempo que reduce la interacción humana. El modelo admite distribución automática. Utiliza cifrado, firewall, sistemas IPS para proteger la red distribuida. Sistemas IDS, la evaluación de vulnerabilidades y otros para detectar posibles ataques, envía información sobre algún ataque al sistema de defensa para una alerta temprana.

2.2.6 MODELO DE SEGURIDAD DE LA INFORMACION (MSGRC)

El modelo propuesto por (Jirasek, 2012, pág. 4) está compuesto por tres áreas: conductores de la seguridad, gestión de la seguridad y las partes interesadas. En la figura 14 se muestra el detalle de este modelo. Este modelo este compuesto por tres áreas que son detalladas a continuación.

Security GRC model



Fuente: (Jirasek, 2012, pág. 4)

Figura 14: Modelo de seguridad GRC.

a) Conductores de la seguridad. - El modelo tiene tres conductores de trabajo para la gestión de seguridad los cuales son:

- Leyes y reglamentos. Son algo más que simples tareas que una empresa debe cumplir o enfrentar en acciones legales o regulación local.
- Los objetivos del negocio. La empresa define un conjunto de objetivos, la seguridad apoya estos objetivos mediante la protección de los sistemas y la información que se utiliza.
- Amenazas de seguridad. Trabajan en contra de las leyes, regulaciones y objetivos de negocio.

b) Gestión de la seguridad. - Se tienen tres marcos de trabajo que permiten a la empresa alcanzar los objetivos definidos en la sección de los conductores de seguridad.

- Marco de políticas. Se trata de un conjunto de políticas, normas y directrices que describen cómo la empresa realiza el tratamiento de los conductores de seguridad de la información.
- Marco de procesos. Cualquier control de la seguridad, política o estándar es un proceso. Cada proceso es apoyado por los empleados y la mayoría están soportados por la tecnología. Sin

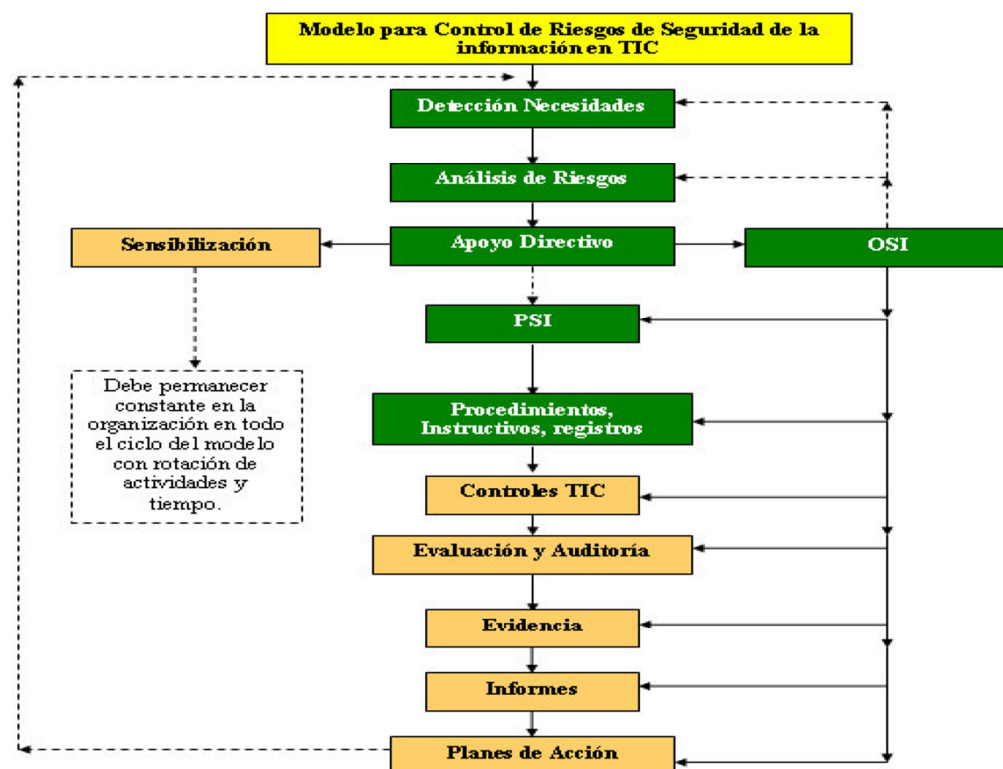
embargo, es necesario que haya alguna relación entre la tecnología que tiene la empresa, sus procesos y el control correspondiente en el marco de la política hasta el objetivo del negocio.

- Marco de métricas de seguridad. Resulta ser una declaración que se puede aplicar en el ámbito de seguridad de la información "Lo que no se puede medir, no se puede manejar". El profesional de la seguridad debe ser capaz de medir el estado de los controles de seguridad.

c) Las partes interesadas. - Son los destinatarios de los resultados de las métricas del marco de seguridad. Las partes interesadas tienen que saber que lo que se ha prometido se está entregando. Esta es el área donde los profesionales de la seguridad necesitan mejorar sus habilidades. Hablar con sus grupos de interés, preguntarles ¿cuáles son sus preocupaciones? y mostrarles cómo se están abordando sus preocupaciones respecto a su área o ambiente de desarrollo.

2.2.7 MODELO DE SEGURIDAD DE LA INFORMACIÓN EN TIC (MSI-TIC)

El modelo propuesto por (Burgos & Campos, 2011, pág. 20) agrupa un conjunto de actividades, muchas de las cuales llevan a un ciclo continuo de mejora que se muestran en la figura 15.



Fuente: (Burgos & Campos, 2011, pág. 20)

Figura 15: Modelo de seguridad MSI-TIC.

Este modelo que abarca a las TIC ⁸¹, considera en su estructuración, formación e implementación dos grandes fases las cuales son:

a) Fase de elaboración.

- Detección de necesidades. – Se hace el levantamiento de todas las actividades relacionadas con los impactos que la organización pueda tener en relación con su seguridad de la información.
- Análisis de riesgo. - Se evalúan los riesgos potenciales que impactan en la seguridad de la información de la organización por aspectos emanados de las tecnologías de la información.
- Apoyo directivo. – Se hace la presentación y revisión de los resultados de las etapas anteriores con el fin de conseguir el apoyo de la dirección de la organización para concretar la implementación de la seguridad de la información.
- Oficial de seguridad de la información (OSI). - La organización debe designar a un OSI ⁸² para que realice, apoye, dirija y pueda llevar el control de implementación y posterior seguimiento a todo el modelo. Además, el OSI estará presente en todas las actividades.
- Confección de política de seguridad de la información (PSI). - Corresponde al diseño de las Políticas de Seguridad de la Información de la organización.
- Confección de procedimientos, instructivos y registros. - Corresponde a la elaboración de documentos que formalicen como se deben realizar las actividades y que información es la que se debe retener como evidencia para dar conformidad a la PSI.

b) Fase de Aplicación.

- Controles TIC. - Se diseñan y definen los procesos, controles y evidencias formales de las actividades de seguridad que darán sustento a los procesos de revisión o auditorías del modelo.
- Evaluación y auditoría. - Se prepara, realiza y desarrolla la revisión que avale que todos los procesos de TI se están cumpliendo adecuadamente, lo cual será evaluado por auditoría.
- Planes de Acción. - Se aplican conforme a los plazos y actividades que fueron indicados. Estos pueden conformar la revisión y ajustes de actividades a nivel de procesos de seguridad.

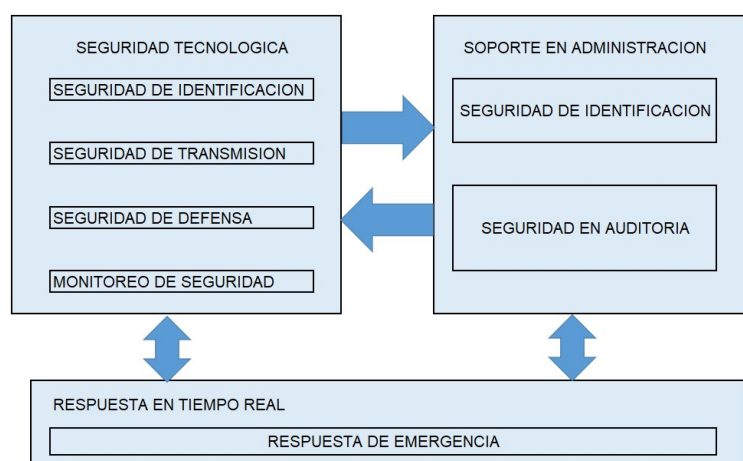
⁸¹ TIC Tecnologías de la Información y las Comunicación.

⁸² OSI Oficial de Seguridad de la Información.

- Sensibilización. - Esta etapa permite entregar constante información a la organización sobre la importancia de mantener la seguridad de la información y el resguardo de todas las actividades de TI. Debe recibir un apoyo directo de la dirección de la organización.

2.2.8 MODELO DE DEFENSA DE SEGURIDAD DE RED (MDSR)

Los autores (Li, Wang, Han, & Jing, 2009, pág. 1) proponen un modelo compatible con diferentes dispositivos de red, el modelo se aplica dependiendo del análisis de las características de seguridad para la capa física, la capa de red, y la capa de aplicación. Los enrutadores se usan en la capa de red, mientras que los conmutadores se usan en la capa de enlace de datos. Los resultados muestran que el modelo de seguridad proporciona una defensa adecuada, combina muchos aspectos de seguridad diferentes para proporcionar una seguridad adecuada. Utiliza listas de control de acceso para filtrar el tráfico que ingresa y sale de la red, la autenticación se utiliza para proporcionar acceso a los usuarios autorizados. Se proporciona la función de detección de ataques y escaneo de vulnerabilidades. Dicho modelo se describe en la figura 16.



Fuente: (Li, Wang, Han, & Jing, 2009, pág. 3)

Figura 16: Estructura del modelo de defensa de seguridad propuesto.

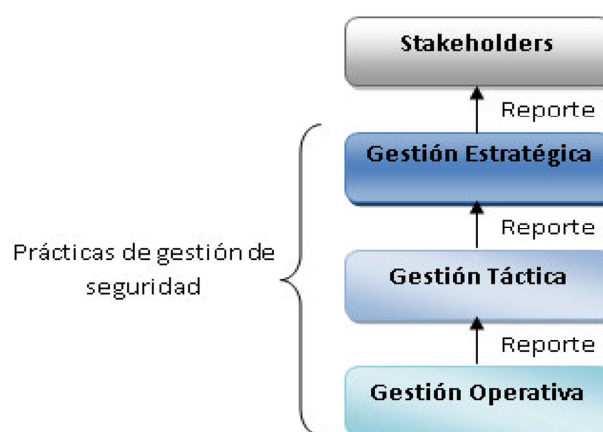
2.2.9 MODELO (O-ISM3) DE MADUREZ DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN

El modelo O-ISM3 ⁸³ propuesto por (The Open Group, 2011) está orientado a procesos que ofrece un enfoque cuantitativo para evaluar la gestión de un sistema de seguridad de la

⁸³ OISM3 Open Information Security Management Maturity Model.

información en una organización, debido a que establece niveles de madurez sobre 4 modelos conceptuales que son: gestión, organización, sistema de información y seguridad contextual y la aplicación de métricas para administrar los procesos de seguridad de la información.

La aplicación del modelo implica la implementación de cada uno de los procesos definidos de acuerdo con las prácticas de gestión de seguridad, el establecimiento de las métricas y el monitoreo del nivel de madurez en que se encuentra dicha implementación. Asimismo, la gestión de seguridad de la información debe ser reportada desde el nivel operativo. En la figura 17 se muestra la estructura de niveles de reporte de la gestión de seguridad de este modelo.



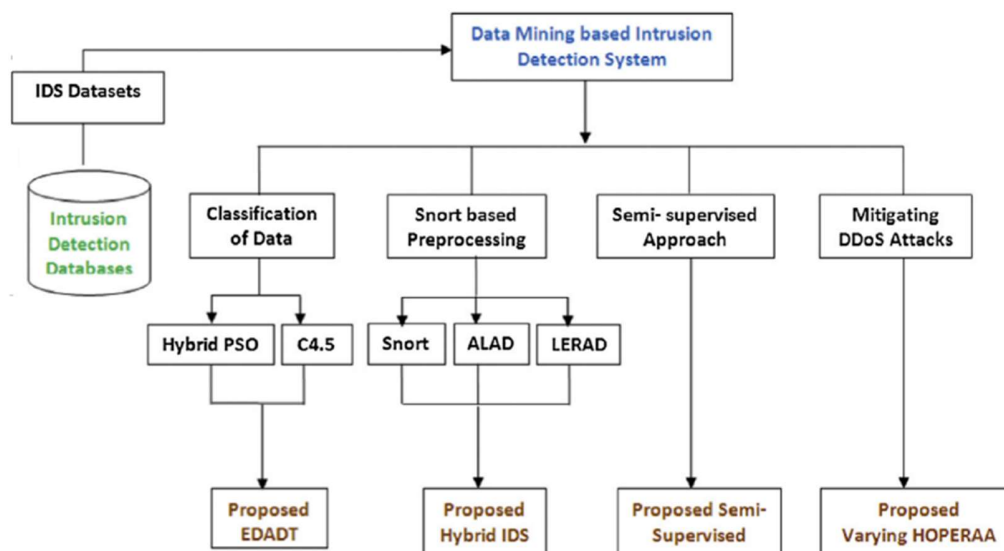
Fuente: (The Open Group, 2011). Consultado el 29 de septiembre de 2019, de www.opengroup.org.

Figura 17: Estructura de niveles de reporte de la gestión de seguridad.

Los procesos establecidos para las prácticas de gestión de seguridad están compuestos por la descripción del proceso, entradas, productos de trabajo, documentación, propietario del proceso, procesos y metodologías relacionados. Entre los procesos evaluados están: los procesos genéricos, gestión estratégica, gestión táctica y gestión operativa. Y los mismos se evalúan por su nivel inicial, administrado, definido, controlado y optimizado.

2.2.10 MODELO DE SEGURIDAD DE RED BASADO EN MINERÍA DE DATOS (MSRBMD)

El autor (Nadiammai & Hemalatha, 2013, pág. 38) propone este Modelo de Detección de Intrusiones, el cual tiene como objetivo reducir el esfuerzo de los administradores de red y optimizar la efectividad de detección de intrusiones. En la figura 18 se presenta dicho modelo.



Fuente: (Nadiammai & Hemalatha, 2013, pág. 40)

Figura 18: Modelo de detección de intrusiones basado en minería de datos.

A continuación, se hace una descripción de la función que realiza cada uno de estos modelos:

- Modelo de algoritmo EDAT

El código EDADT propuesto utiliza una técnica que busca los mejores valores para un número n de iteraciones y obtiene la solución más eficiente, la cual es obtenida a partir del cálculo de un valor promedio y al encontrar la característica más exacta y eficiente del conjunto de datos.

- Modelo de IDS híbrido

El modelo de IDS utiliza el software de detección de intrusiones SNORT⁸⁴ y la base de datos de prueba KDD Cup. SNORT realiza la detección de intentos de intrusiones basado en reglas, las cuales clasifican los paquetes recibidos de acuerdo con su base de datos de firmas. Al estar limitado por una base de datos de perfiles, se propone optimizar el rendimiento de SNORT a partir de la inclusión de nuevos enfoques como la detección de anomalías en: la cabecera de paquetes, en el tráfico de red, detección de anomalías en la capa de aplicación.

- Modelo de enfoque semi - supervisado

El modelo de enfoque semi - supervisado permite etiquetar datos no etiquetados a partir de datos etiquetados, basado en la división de un conjunto de datos definido. Para lograr ello, se utiliza

⁸⁴ SNORT Sistema de detección de intrusos en red.

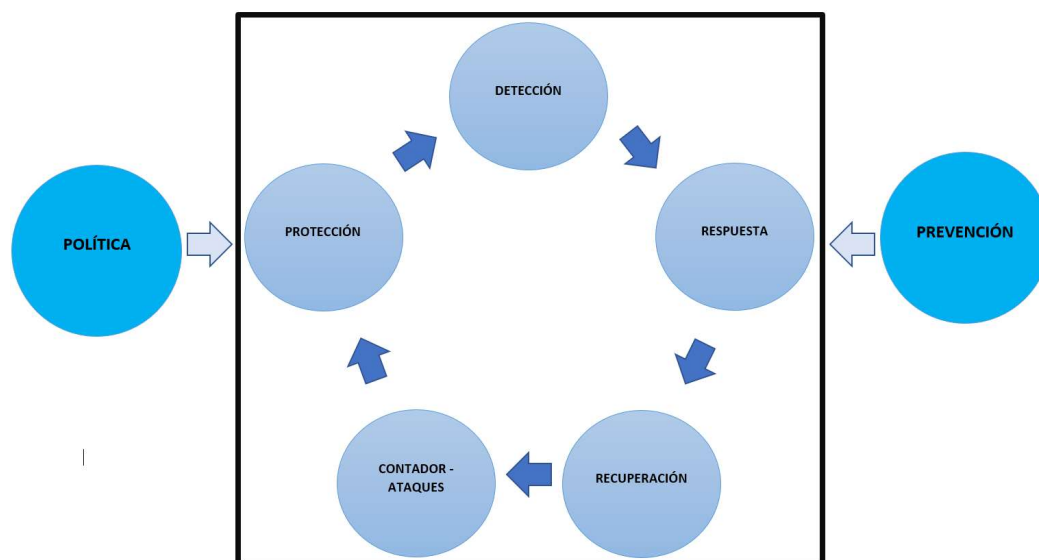
el Clasificador VSM ⁸⁵, que analiza el conjunto de datos de entrenamiento etiquetado y no etiquetado, de modo que sea posible asignar una nueva etiqueta a los datos de prueba.

- Modelo de variación HOPERAA

Este modelo está orientado a mitigar los ataques de denegación de servicio. El servidor define valores límites para identificar la naturaleza del mensaje. Si el cliente envía datos de forma continua, se asignará un ratio alto; si el cliente envía datos de forma moderada o poco frecuente, se asignará un ratio medio o bajo respectivamente.

2.2.11 MODELO DE SEGURIDAD DE RED DE DEFENSA ACTIVA (P2DR2C)

Los autores (Qu & Jia, 2008, pág. 2) propone este modelo que supera la limitación del modelo de seguridad P2DR de auto adopción, el modelo proporciona una respuesta dinámica contra ataques. Utiliza estrategias de división de tráfico de datos para determinar si el tráfico es normal o anormal. El tráfico normal será redirigido a la red interna mientras que anormal será enviado a otros subsistemas. Los subsistemas determinan el grado de ataque, por ejemplo, enviará tráfico anormal a una Honeynet ⁸⁶. El modelo tiene como objetivo encontrar nuevas vulnerabilidades y errores de los servidores y equipos de Internet. La figura 19 se muestra dicho modelo.



Fuente: (Qu & Jia, 2008, pág. 2)

Figura 19: Estructura del modelo propuesto P2DR2C.

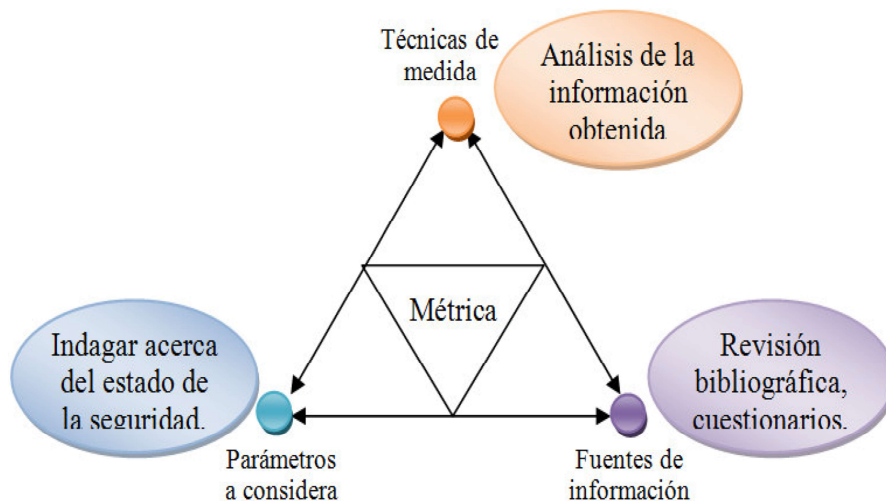
⁸⁵ VSM Vector Support Machine.

⁸⁶ Honeynet Red trampa de alta interacción diseñada para ser atacada.

2.2.12 MODELO CONTEXTUALIZADO DE COLADO & FRANCO (MCC&F)

El modelo de Colado & Franco, citado por (Villegas, Meza, & León, Las métricas, elemento fundamental en la construcción de modelos de madurez de la seguridad informática, 2011, pág. 3) que se muestra en la figura 20 tiene las siguientes condicionales para la triangulación.

- ¿Para qué? se refiere a la indagación del estado de la seguridad informática en la organización.
- ¿Cómo? tiene que ver con el análisis de los datos obtenidos en las fuentes de información.
- ¿Qué? se refiere a las fuentes de información utilizadas y se destacan la revisión bibliográfica, el cuestionario y las entrevistas.



Fuente: (Villegas, Meza, & León, Las métricas, elemento fundamental en la construcción de modelos de madurez de la seguridad informática, 2011, pág. 5)

Figura 20: Contextualización de la seguridad.

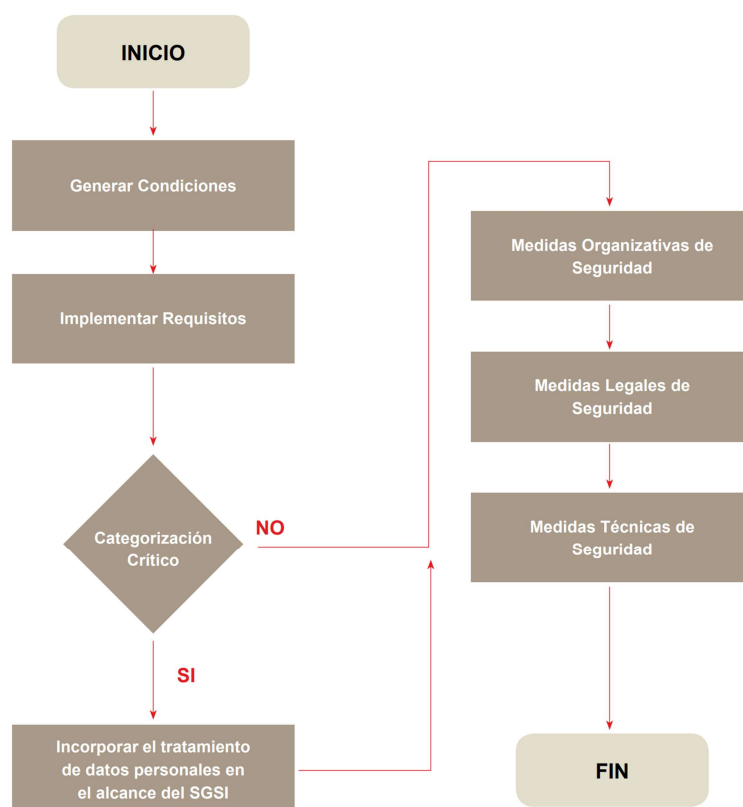
El resultado de la aplicación de este modelo contextualizado permita identificar y establecer los principales indicadores para la gestión de la seguridad y agruparlos en uno de los 4 niveles establecidos con la finalidad de poder medir el desempeño institucional frente a los retos que plantea la preservación y resguardo de la información. Dichos niveles son:

- Estado inicial de seguridad informática.
- Detección de necesidades.
- Planificación estratégica.
- Inteligencia organizacional.

2.2.13 DIRECTIVA DE SEGURIDAD DE LA INFORMACIÓN PARA LA PROTECCIÓN DE DATOS PERSONALES (DSI-PDP)

De acuerdo al (Ministerio de Justicia y Derechos Humanos, 2013, pág. 15) elaboro esta directiva de seguridad de la información que está orientada a la adopción de medidas de seguridad de la información, específicamente para la protección de los bancos de datos personales, para lo cual propone responsabilidades, requisitos de seguridad y establece medidas específicas de seguridad organizativas, jurídicas y técnicas de para asegurar la confidencialidad, disponibilidad e integridad de la información.

La adopción de las medidas de seguridad se debe realizar de acuerdo con la categorización establecida de: básico, simple, intermedio, complejo y crítico según el tipo, tiempo de tratamiento y tamaño de la información. Asimismo, para el caso de la información categorizada como crítica se indica que esta debe ser parte del alcance de un Sistema de Gestión de Seguridad de la Información. En la figura 21 se muestra la contextualización de esta directiva de seguridad.



Fuente: (Ministerio de Justicia y Derechos Humanos, 2013, pág. 34)

Figura 21: Contextualización de la seguridad para la protección de datos personales.

2.3 MARCO LEGAL O INSTITUCIONAL

En la regulación boliviana existen dos artículos del código penal referido a delitos informáticos de acuerdo con la gaceta oficial de Bolivia (Bolivia, 2015) cuyo contenido indica lo siguiente:

“(MANIPULACIÓN INFORMÁTICA). - El que con la intención de obtener un beneficio indebido para sí o un tercero, manipule un procesamiento o transferencia de datos informáticos que conduzca a un resultado incorrecto o evite un proceso tal cuyo resultado habría sido correcto, ocasionando de esta manera una transferencia patrimonial en perjuicio de tercero, será sancionado con reclusión de uno a cinco años y con multa de sesenta a doscientos días” (pág. 1).

Dicha modificación en el Código Penal boliviano, indica también lo siguiente (Bolivia, 2015)

“(ALTERACIÓN, ACCESO Y USO INDEBIDO DE DATOS INFORMÁTICOS). - El que sin estar autorizado se apodere, acceda, utilice, modifique, suprima o inutilice, datos almacenados en una computadora o en cualquier soporte informático, ocasionando perjuicio al titular de la información, será sancionado con prestación de trabajo hasta un año o multa hasta doscientos días” (pág. 1).

La ASFI, Autoridad de Supervisión del Sistema Financiero, tiene las siguientes directrices con respecto a la gestión de redes (Autoridad de Supervisión del Sistema Financiero ASFI, 2017)

“SECCIÓN 7: GESTIÓN DE SEGURIDAD EN REDES Y COMUNICACIONES
Artículo 1º - (Políticas y procedimientos) La Entidad Supervisada debe contar con políticas y procedimientos para la instalación y mantenimiento del hardware y su configuración base, con el propósito de asegurar que proporcionen la plataforma tecnológica que permita soportar las aplicaciones relacionadas con las redes y telecomunicaciones y minimicen la frecuencia e impacto de las fallas de desempeño de estas. Asimismo, debe desarrollar políticas y procedimientos para la correcta administración de la infraestructura de redes y telecomunicaciones. Para este efecto, la Entidad Supervisada debe considerar lo siguiente:

- a) Garantizar que los planes de adquisición de hardware y software reflejen las necesidades identificadas en el Plan Estratégico de TI.
- b) Garantizar la protección de los datos que se transmiten a través de la red de telecomunicaciones, mediante técnicas de cifrado estándar a través de equipos o aplicaciones definidas para tal fin.
- f) Establecer controles de acceso a redes compartidas, particularmente respecto a aquellas que se extienden a usuarios fuera de la Entidad Supervisada.” (pág. 2).

En cuanto a la normativa internacional sobre el aseguramiento de tarjetas de crédito (PCI Security Standards Council, 2018) sugiere lo siguiente:

“Rastree y supervise todos los accesos a los recursos de red y a los datos de los titulares de las tarjetas. Los mecanismos de registro y la posibilidad de rastrear las actividades del usuario son críticos para la prevención, detección o minimización del impacto de los riesgos de datos. La presencia de los registros en todos los entornos permite el rastreo, alertas y análisis cuando algo no funciona bien. Determinar la causa de un riesgo es muy difícil, si no imposible, sin los registros de la actividad del sistema.” (pág. 98).

CAPITULO III

MARCO METODOLÓGICO

3.1 DISEÑO DE LA INVESTIGACIÓN

En este capítulo se explica el fundamento metodológico en el que se sustenta el desarrollo de la presente investigación. Para esto, de acuerdo con la problemática presentada en la investigación el método utilizado fue de naturaleza no experimental y de corte longitudinal. El estudio es no experimental de acuerdo a lo que indica (Hernández Sampieri, Fernández Collado, & Baptista Lucio, 2014) “Estudios que se realizan sin la manipulación deliberada de variables y en los que sólo se observan los fenómenos en su ambiente natural para después analizarlos” (pág. 152), para el estudio realizado se hizo la obtencion de informacion acerca de los incidentes de seguridad con respecto al control de acceso a la red.

El estudio es de corte longitudinal ya que se hace una recopilacion de eventos de seguridad ocurridos en el Banco Nacional de Bolivia antes de aplicar el modelo propuesto y despues de aplicar el mismo para analizar los resultados obtenidos.

3.2 MÉTODO DE INVESTIGACIÓN

El método de investigación utilizado en la investigación es del tipo hipotético deductivo, debido a que se realizó un análisis de la problemática desde un enfoque general hacia uno particular.

Se hizo un análisis de la problemática de forma general en cuanto respecta a la ciberseguridad a nivel mundial, se analizó las estadísticas de ataques a entidades financieras a nivel latinoamericano, se recopilo información sobre los incidentes de seguridad informática dentro del Banco Nacional de Bolivia para realizar un análisis de los ataques a nivel de redes de acceso.

3.3 TIPO DE INVESTIGACIÓN

El método de investigación aplicado por su grado de abstracción es en principio del tipo exploratorio y del tipo descriptivo. Es del tipo exploratorio debido a que se hizo la consulta y revisión de material bibliográfico acerca de modelos de seguridad que se tienen con respecto a la problemática planteada de control de acceso a la red.

Es del tipo descriptivo debido a lo que indica (Hernández Sampieri, Fernández Collado, & Baptista Lucio, 2014) se “busca especificar propiedades y características importantes de cualquier fenómeno que se analice. Describe tendencias de un grupo o población” (pág. 92), se hizo la revisión de material bibliográfico descrito en el segundo capítulo de este documento, donde se obtuvo la información concerniente a los riesgos que se tienen al no contar con algún control adecuado en los puertos de red de acceso de una red de datos.

3.4 FASES METODOLÓGICAS

Luego de haber definido el tipo de investigación a continuación se muestra la estrategia que se llevó a cabo para el desarrollo de la investigación para el cumplimiento de objetivos descrita en las fases metodológicas, las cuales se describen en el cuadro 7:

Cuadro 7: Fases metodológicas.

FASE	DESCRIPCION	ACTIVIDAD
1	Realizar un diagnóstico de la red de comunicaciones del caso de estudio.	- Entrevistar a los subgerentes de seguridad de la información e infraestructura tecnológica del BNB. - Analizar los diagramas de arquitecturas de red. - Analizar las configuraciones de los equipos de red de acceso. - Recopilar información acerca de la normativa interna relativa al estado de seguridad de la información dentro del BNB. - Recopilar información acerca de los incidentes de seguridad de la gestión 2019 dentro de la red de datos del BNB.
2	Analizar los modelos de seguridad de la información existentes.	Recopilación de información de: - Fuentes primarias - Fuentes secundarias - Bibliografía - Publicaciones de artículos científicos
3	Definir un modelo de seguridad de la información para el control de acceso a la red.	En base al diagnóstico realizado y a la información recolectada: - Seleccionar el o los modelos acordes a la investigación. - Adecuar el o los modelos en base a los requerimientos. - Definir el modelo de la propuesta final.

4	Establecer un entorno de pruebas para aplicar de la nueva plataforma de red propuesta.	De acuerdo con el modelo propuesto: - Seleccionar un ambiente de pruebas adecuado. - Aplicar el modelo de seguridad propuesto. - Montar el sistema de control de acceso. - Adquirir datos proporcionados por el sistema de seguridad.
5	Valorar los resultados alcanzados	Con los datos recopilados: - Analizar los resultados. - Analizar la efectividad del modelo. - Definir tareas posteriores.

Fuente: Elaboración propia usando Excel 2019.

3.5 POBLACIÓN DE ESTUDIO

La propuesta de investigación se desarrollará en las agencias de las 9 oficinas principales de la red de la red de datos del Banco Nacional de Bolivia estos conforman la población de estudio. La distribución de agencias de acuerdo con el reporte del sitio web de la (Autoridad de Supervisión Financiera ASFI, 2019) se muestra a detalle en el cuadro 8.

Cuadro 8: Sucursales agencias y números de empleados.

BANCO NACIONAL DE BOLIVIASUCURSALES AGENCIAS Y NÚMERO DE EMPLEADOS AL 30 DE JUNIO DEL 2019	
SUCURSAL O AGENCIAS URBANAS	65
SUCRE	5
LA PAZ	13
COCHABAMBA	12
ORURO	4
POTOSÍ	3
TARIJA	4
SANTA CRUZ	13
TRINIDAD	2
COBIJA	1
EL ALTO	8
AGENCIAS PROVINCIALES	6
TOTAL DE SUCURSALES Y AGENCIAS URBANAS Y PROVINCIALES	71
TOTAL NUMERO DE EMPLEADOS	2122

Fuente: (Autoridad de Supervisión Financiera ASFI, 2019)

3.5.1 DETERMINACIÓN Y ELECCIÓN DE LA MUESTRA

En esta investigación se consideró como muestra a las 13 agencias que se tiene en la oficina La Paz de la red de datos del BNB esto debido a que en esta ciudad se encuentran la mayor cantidad de agencias del caso de estudio. Así también se consideró que en esta oficina se encuentra el centro principal de datos.

En la ciudad de La Paz el BNB cuenta con 13 agencias distribuidas en diferentes zonas geográficas donde se realizó el estudio, cada una de estas agencias cuenta en su red de datos por lo menos con un switch de acceso donde se conectan los diversos dispositivos de red de cada agencia. En el cuadro 9 se muestra la cantidad de switches de 24 puertos y cantidad de equipos de red por agencia donde se realizó el presente estudio.

Cuadro 9: Cantidad de equipos de red por agencia.

BANCO NACIONAL DE BOLIVIA SUCURSALES AGENCIAS OF LA PAZ		
AGENCIAS SUCURSAL LA PAZ	CANTIDAD DE SWITCHES DE ACCESO DE 24 PUERTOS	CANTIDAD EQUIPOS CONECTADOS
20 DE OCTUBRE	3	49
TORREZ DEL POETA	3	47
SAN MIGUEL	3	41
ACHUMANI	3	39
PEREZ VELASCO	2	38
BUENOS AIRES	2	37
VILLA FATIMA	2	32
EDIFICIO ANEXO	2	29
MIRAFLORES	2	27
OBRAJES	1	21
MEGACENTER	1	19
CEMENTERIO	1	18
GRAN PODER	1	14
TOTAL	26	411

Fuente: Elaboración propia con Excel 2019.

3.6 DELIMITACIÓN GEOGRÁFICA

El trabajo de investigación se desarrolló en la ciudad de La Paz del estado plurinacional de Bolivia, en esta ciudad se encuentra el centro principal de datos de la empresa y en esta región también se encuentra la mayor cantidad de agencias a nivel nacional del caso de estudio.

3.7 DELIMITACIÓN TEMPORAL

En la presente investigación se recopiló información de eventos de seguridad reportados por la empresa NEOSECURE quien hace el servicio de monitoreo externo sobre los IPS que tiene el BNB en su infraestructura de red, el periodo seleccionado fue de un año comprendido desde el mes de septiembre del 2018 hasta agosto de 2019 esto con el objetivo de tener una idea de la ocurrencia de estos incidentes a lo largo de un año.

3.8 ALCANCE DE LA INVESTIGACIÓN

El trabajo realizado se desarrolló en la capa dos del modelo OSI donde se consideraron los accesos de red a través de redes cableadas del BNB, el estudio de redes inalámbricas, de acceso remoto y de data center cuentan con otras especificaciones que quedaron fuera del estudio.

3.9 TÉCNICAS DE INVESTIGACIÓN

Para esta investigación, se desarrollaron tres técnicas para la recolección de datos basados en el tipo de investigación. Con estas técnicas se buscó establecer la necesidad de un modelo de seguridad de la información para el control de acceso a la red como también se buscó determinar la necesidad para llevar a cabo la implementación de dicho modelo.

- La Entrevista: Se recopiló información con entrevistas a los responsables de seguridad de la información y de infraestructura tecnológica de la organización, la entrevista fue del tipo cualitativo y semiestructurado, ya que según (Hernández Sampieri, Fernández Collado, & Baptista Lucio, 2014) en la “Entrevista cualitativa se pueden hacerse preguntas sobre experiencias, opiniones, valores y creencias, emociones, sentimientos, hechos, historias de vida, percepciones, atribuciones” (pág. 407).

- La observación. – En principio se establecieron los elementos a analizar: diagramas de red del caso de estudio, configuraciones de los equipos de red de acceso, documentación referente a la normativa interna sobre el estado de seguridad de la información dentro del BNB y sobre los incidentes de seguridad de la información dentro de la red de datos de la empresa.

- La documentación. – Se recopiló información de modelos de seguridad de la información y soluciones que fueron planteadas por diferentes autores y fabricantes. Se seleccionaron las fuentes primarias, fuentes secundarias, textos bibliográficos y publicaciones de artículos científicos para poder identificar los modelos de seguridad de la información existentes.

3.10 FUENTES DE INVESTIGACIÓN.

3.10.1 ENTREVISTAS A PERSONAL ENCARGADO

Para la realización de la entrevista se considera al siguiente personal: al SGSI ⁸⁷ Subgerente de seguridad de la información perteneciente a la Vicepresidencia de Gestión de Riesgos quien es la persona responsable de elaborar los planes operativos anuales del área de seguridad de la información dentro del BNB, también se encarga de la revisión, actualización y difusión de la política de seguridad de la información, es también responsable de gestionar y mantener actualizadas las políticas, normas procedimientos, estándares y guías que forman parte del sistema de gestión de seguridad de la información, es responsable de definir y administrar proyectos de tecnología que fortalezcan la gestión de seguridad dentro de la empresa.

Para esta evaluación también se consideró al SGIT ⁸⁸ Subgerente de Infraestructura tecnológica perteneciente a la Vicepresidencia de Innovación y Transformación Digital quien es el responsable de la administración de la red interna de comunicaciones del BNB, también es el responsable del análisis, diseño y ejecución de proyectos de infraestructura. Entre sus funciones de seguridad está la de administrar la seguridad sobre los recursos informáticos y los datos como son los accesos, respaldos y contingencias, también supervisa la seguridad de acceso a la red.

Estas entrevistas fueron realizadas el 26/09/2019 y 27/09/2019 al personal previamente descrito y tuvo una duración de 30 minutos y fue realizada siguiendo el protocolo de entrevista incluido en el anexo I de este documento, el objetivo de esta técnica de investigación era determinar la necesidad de un modelo de seguridad de la información para el control de acceso a la red, además se determinar los conocimientos de los entrevistados sobre el estándar IEEE 802.1x y sobre los sistemas de control de acceso a la red de datos.

⁸⁷ SGSI Subgerente de Seguridad de la Información.

⁸⁸ SGIT Subgerente de Infraestructura Tecnológica.

3.10.2 ANALISIS DE ENTREVISTAS

Para el análisis de los resultados obtenidos de este método de recolección de datos se realizará un rastreo de la entrevista en profundidad orientado a detectar la necesidad de un modelo de seguridad de la información para el control de acceso a la red y los conocimientos acerca el estándar IEEE 802.1x. En las categorías se pretende reflejar la información que se buscó obtener de los entrevistados y la evaluación brinda la percepción del investigador sobre este tópico. En el cuadro 10 se presenta el resumen y el proceso de las entrevistas realizadas.

Cuadro 10: Análisis de entrevistas.

ANÁLISIS DE ENTREVISTAS			
No.	1. Establecer conocimientos comunes:	Categoría:	Evaluación:
1	P: ¿Cuenta su organización con un Plan Estratégico Institucional? ¿Se tiene algún objetivo estratégico relacionado a seguridad de la información? Indicar el objetivo relacionado.	Estado de seguridad de la información	R SGSI: La organización en su PEI ⁸⁹ tiene definido objetivos relacionados al área de SI ⁹⁰ .
			R SGIT: Su área hace el apoyo con soluciones tecnológicas a los objetivos del área de SI.
2	P: ¿Cómo se gestiona la seguridad de la información en su organización? ¿Existe algún rol o responsable de la SI? ¿Cuáles son sus funciones? ¿Qué procesos se tienen implementados?	Responsables en el área de SI	R SGSI: El subgerente está a cargo de del tratamiento de SI dentro del banco y es apoyado por 3 analistas de seguridad.
			R SGIT: El área de tecnología no cuenta con algún personal dedicado a la seguridad de la información, solo se encarga de coadyuvar al área de seguridad en la gestión de riesgos
3	P: ¿Han adoptado algún estándar internacional o buenas prácticas para la implementación de la seguridad de la información en su organización? ¿Cuál?	Alineamiento a normas internacionales	R SGSI: Se apoya en las normas ISO 27001, ISO 27002, así también la ISO 31000 e ISO 27005 para la evaluación de riesgos.
			R SGIT: La organización está trabajando con el estándar PCI ⁹¹ ya que el banco es una entidad que trabaja con el manejo de tarjetas de débito y crédito.
4	P: ¿Tiene algún proyecto previsto relacionado a la seguridad de la información en su organización? ¿Qué presupuestos para estos temas de seguridad?	Presupuestos para la gestión de la SI.	R SGSI: Se está trabajando en la implementación de un sistema DLP ⁹² para el control de clasificación de información.
			R SGIT: Se está llevando al cabo de cambio de equipos de firewall de perímetro en la oficina nacional y en sucursales.

⁸⁹ PEI Plan Estratégico Institucional.

⁹⁰ SI Seguridad de la Información.

⁹¹ PCI Payment Card Industry.

⁹² DLP Data Loss Prevention.

5	P: ¿Cómo se maneja la cultura organizacional en temas de seguridad de la información?	Cultura de la SI.	R SGSI: Se desarrollan campañas de concientización sobre la seguridad de la información vía mail. R SGIT: El área apoya a la subgerencia de SI para las campañas de mail masivo.
No.	2. Capacidades y conocimientos del entrevistado:	Categoría:	Evaluación:
6	P: ¿Se administran y controlan las redes de datos de la organización para proteger la información en sistemas y aplicaciones?	Gestión de redes de datos	R SGSI: Se cuenta con normativa referente al control de acceso a los equipos de dominio de la organización. R SGIT: Se cuenta con controles a nivel de equipos de firewall de perímetro que limitan el acceso a la granja de servidores de la red.
7	P: ¿Las redes de datos son separadas en función de los grupos de servicios, usuarios y sistemas de información?	Segregación de redes de datos	R SGSI: Se cuenta con la separación de la red de servidores y red de usuarios a través de los firewalls de perímetro. R SGIT: Las redes de datos están separadas por VLAN's las cuales de acuerdo con la agencia solo se permite su propagación en puertos principales de comunicación.
8	P: ¿Existen políticas y procedimientos de control de acceso dentro de la organización? ¿Existen controles específicos?	Normativa para el control de acceso a la red	R SGSI: Se cuenta con normativa de control de acceso de usuarios al dominio de la organización. R SGIT: No se cuenta con controles dedicados al control de acceso a redes.
9	P: ¿Tiene conocimiento acerca de sistemas de control de acceso a la red?	Conocimientos sobre sistemas de control de acceso	R SGSI: Existen varios fabricantes a nivel mundial para este tipo de soluciones. R SGIT: Si se ha estado investigando sobre la solución del fabricante CISCO, por tener equipamiento de red son de esta marca.
10	P: ¿Conoce el funcionamiento del estándar IEEE 802.1x y sus componentes generales?	Conocimientos sobre el estándar de control de acceso	R SGSI: No tiene conocimiento al respecto. R SGIT: La solución del fabricante CISCO trabaja con este estándar en su sistema de control de acceso.
No.	3. Análisis de necesidad del modelo:	Categoría:	Evaluación:
11	P: ¿Se cuenta con algún procedimiento para la conexión de personal externo a la red de datos de la organización?	Procedimientos para el control de conexión de personal externo	R SGSI: No se cuenta con algún tipo de normativa al respecto R SGIT: A nivel de tecnología no se cuenta con algún procedimiento al respecto.
12	P: ¿De qué forma se controla la conexión de equipos externos a la red de datos de la empresa en agencias alejadas donde no se cuenta con personal de sistemas?	Procedimientos para el control de conexión de personal interno	R SGSI: Se tiene una normativa del área de seguridad física que controla el acceso de equipos computadores externos. R SGIT: Se está analizando implementar controles a nivel de puertos de acceso en las agencias alejadas.

13	P: ¿Recientemente han tenido algún evento de seguridad informática relacionado a infecciones o ataques de denegación de servicio dentro de la organización?	Reporte de incidentes	R SGSI: Se cuenta con el apoyo de una empresa externa que controla los IDS / IPS del banco quienes por procedimiento alerta al área sobre eventos de seguridad. R SGIT: A principios del 2019 se tuvo un evento de saturación de enlaces debido al alto tráfico generado por un servidor.
14	P: ¿Considera que se debería implementar algún tipo de control que limite el acceso indebido a la red de datos de la empresa?	Necesidad de implementación de controles	R SGSI: Si es importante poder contar con procedimientos que limiten y controlen el acceso indebido de personal externo. R SGIT: Es necesario poder implementar algún sistema que controle la conexión de equipos dentro de la red del banco.
No.	4. Desarrollo de tareas de prevención:	Categoría:	Evaluación:
15	P: ¿Se realizan tareas de hacking ético, test de penetración en la empresa?	Desarrollo de tareas de prevención	R SGSI: Dentro de las tareas estratégicas se tiene programado contratar a una empresa externa que se encargue de realizar un ethical hacking a la red de la organización. Los analistas también hacen test de penetración. R SGIT: Se realiza el apoyo técnico a las pruebas de penetración programados por el área de seguridad de la información.
16	P: Para el aseguramiento de la información de las operaciones bancarias, ¿Qué soluciones tecnológicas vienen utilizando? ¿Tiene planes de fortalecerlas? ¿Cuáles son?	Planificación de proyectos de seguridad	R SGSI: Se está en pleno despliegue de la solución DLP para evitar la fuga de información. Se está desplegando sistemas para el control DNS para la navegación. R SGIT: Se está desplegando una solución de un cliente antimalware y antivirus del fabricante CISCO para la protección de servidores de la red, se está terminando de cambiar los firewalls de perímetro que también realizan tareas de control de webfiltering ⁹³.

Fuente: Elaboración propia usando Excel 2019.

3.10.3 OBSERVACIÓN Y RECOPIACIÓN DE INFORMACIÓN

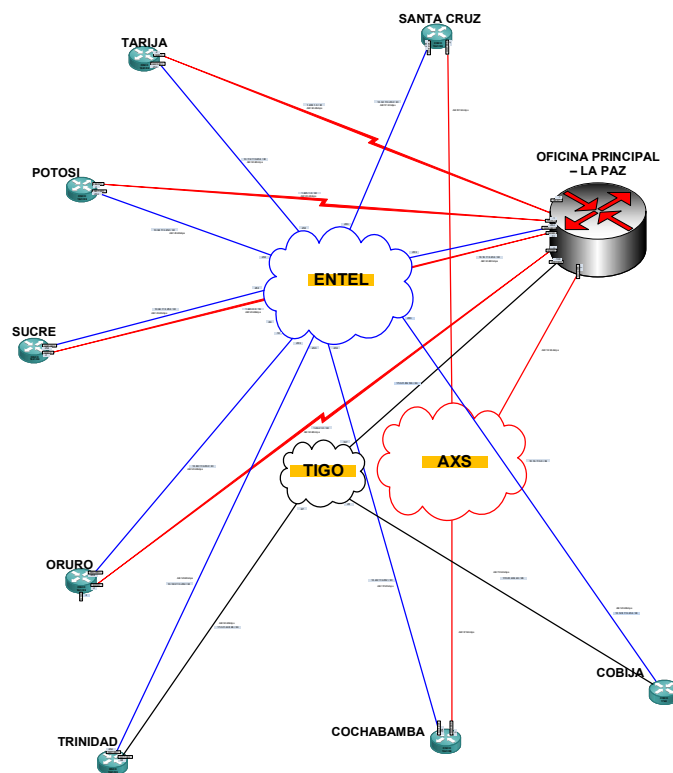
En esta sección se detallará la información recopilada dentro del BNB como son los: diagramas de arquitectura de red, configuraciones de los equipos de red de acceso, documentación referente a la normativa interna sobre seguridad de la información y sobre los incidentes de seguridad de la información dentro de la red de datos de la empresa.

⁹³ Webfiltering Filtrado de contenido, que determina qué contenido estará disponible en una máquina o red particular.

3.10.3.1 DIAGRAMAS DE RED

El diagrama de red representa de forma gráfica la interconexión que existe entre estas oficinas regionales y la oficina principal que para el caso de estudio tiene presencia en los 9 departamentos a nivel nacional. Esta comunicación entre oficinas es realizada a través enlaces MPLS ⁹⁴ que es una tecnología de comunicación a nivel de redes WAN ⁹⁵ ofrecidos por los proveedores de servicios ENTEL ⁹⁶ AXS y TIGO.

La empresa cuenta con su oficina principal en la ciudad de La Paz por lo que la topología lógica de comunicación con las otras regionales es el tipo estrella, esta arquitectura de red tiene un esquema de redundancia para que, en caso de que uno de estos enlaces tenga algún tipo de interrupción, un enlace secundario entre en funcionamiento de manera automática, en la figura 22 se muestra el diagrama de comunicación entre oficinas.



Fuente: Elaboración propia usando Visio 2019.

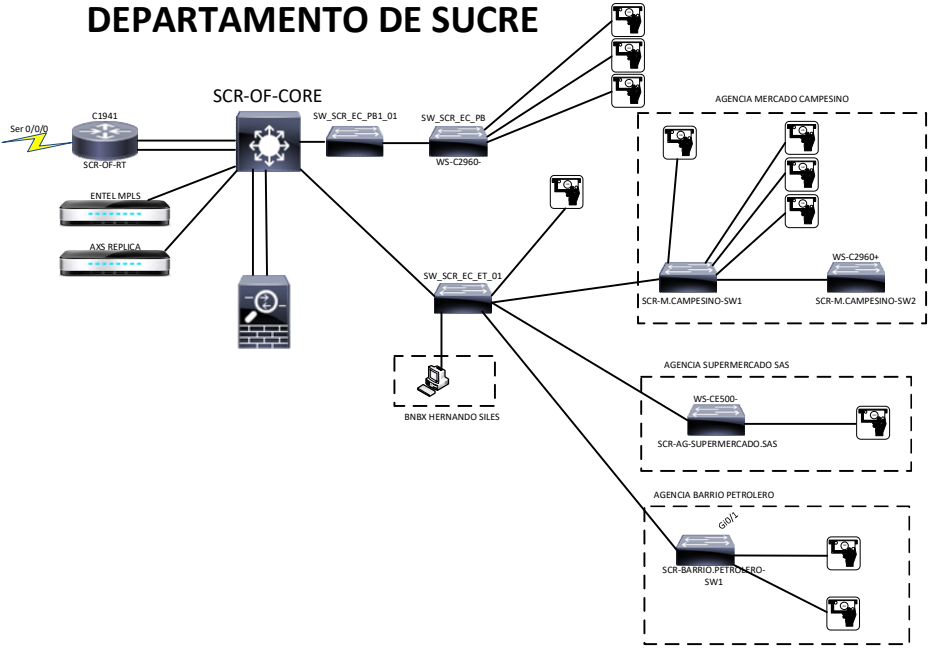
Figura 22: Diagrama de red de comunicación entre oficinas a nivel nacional.

⁹⁴ MPLS Multi-Protocol Label Switching.

⁹⁵ WAN Wide Area Network.

⁹⁶ ENTEL Empresa Nacional de Telecomunicaciones.

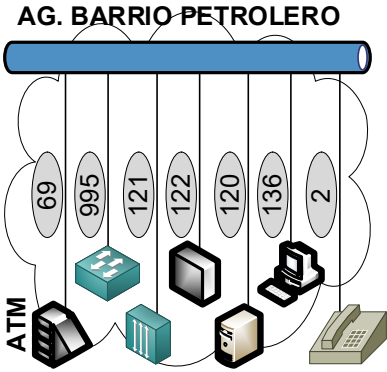
En cuanto a la arquitectura de comunicación entre las oficinas principales en cada departamento y las agencias la topología de comunicación es también del tipo estrella y lo hace a través de enlaces de fibra óptica que son alquilados a proveedores locales. En la figura 23 se muestra un ejemplo el diagrama de comunicación entre agencias y oficina regional en la ciudad de Sucre.



Fuente: Elaboración propia usando Visio 2019.

Figura 23: Diagrama de red de comunicación entre oficina regional y agencias en oficina Sucre.

En cuanto a la topología de comunicación en las agencias se cuenta con redes segmentadas para los diferentes servicios que se tiene en cada agencia como son: datos, telefonía, equipos de comunicación, equipos de energía eléctrica y para los cajeros automáticos. En la figura 24 se muestra la segmentación de redes de la agencia Barrio Petrolero.



Fuente: Elaboración propia usando Visio 2019.

Figura 24: Diagrama de red agencia Barrio Petrolero.

3.10.3.2 REVISIÓN DE NORMATIVA INTERNA

En este apartado se hará la revisión de la normativa interna con la que cuenta el BNB para así determinar sus lineamientos de seguridad y así desarrollar la propuesta del modelo de seguridad de la información de acceso a redes de datos. Se hace un análisis de la política de seguridad de la información y las normativas más relevantes relacionadas al estudio realizado.

3.10.3.3 POLITICA DE SEGURIDAD DE LA INFORMACIÓN

El caso de estudio cuenta con una política de seguridad de la información que tiene como objetivo el de formalizar el pensamiento de la empresa respecto de la importancia que la información tiene para la organización. Las medidas de protección a implementar para la protección de activos de información tecnológica a través del desarrollo de procedimientos concretos y específicos de seguridad.

Con esta política la organización busca divulgar y homologar la forma en que los trabajadores del banco y sus colaboradores en general entienden la importancia de la información para la organización, comprendiendo todas las reglas de seguridad que sigue el banco. En la figura 25 se muestra el índice de la política de seguridad de la información del caso de estudio.



INDICE

CAPITULO I.....	
ASPECTOS GENERALES	
A. CONCEPTO DE SEGURIDAD DE LA INFORMACIÓN.....	
B. ALCANCE	
C. BASE NORMATIVA	
D. OBJETIVO GENERAL.....	
E. DEFINICIONES.....	
F. DIRECTRICES.....	
G. INVENTARIO Y CLASIFICACIÓN DE ACTIVOS DE INFORMACIÓN	
H. ANÁLISIS DE RIESGOS EN SEGURIDAD DE LA INFORMACIÓN.....	
I. DETERMINACIÓN DEL MAPA DE RIESGOS	
J. DEFINICIÓN DEL PERFIL DE RIESGO.....	
K. CONTRATO CON PROVEEDORES DE TECNOLOGÍA DE INFORMACIÓN.....	
L. RESPONSABILIDADES.....	
M. SANCIONES.....	

Fuente: Política de seguridad de la información BNB.

Figura 25: Estructura de política de seguridad de la información BNB.

Esta política se aplica en todo ámbito de la organización, incluye todos los recursos de información sean estos tangibles como los recursos tecnológicos y de comunicación, e

intangibles como información de clientes, empleados, proveedores, personal temporal y otros. La política sustenta todas las normas complementarias relacionadas a la gestión de seguridad de la información dentro de la organización. En esta política se realiza la definición de conceptos de seguridad de la información como: activo de información, análisis y evaluación de riesgos en seguridad de la información, confidencialidad, integridad, disponibilidad, incidente de seguridad de la información y sistema de gestión de seguridad de la información.

Se establecen las directrices sobre: el resguardo que debe tener el banco sobre los activos tecnológicos de información frente a las amenazas a las que se ven expuestos, la clasificación y protección de la información de acuerdo a la importancia que posea dentro del negocio, el acceso restringido a información que sea necesaria a los empleados, proveedores o personal externos que preste servicios en el banco, la pertenencia del banco de toda la información que se genere, procese y transmita haciendo uso de los recursos tecnológicos de la organización, la responsabilidad del directorio ejecutivo del banco para determinar la respuesta y acciones a tomar a los riesgos relevantes una vez presentados y evaluados.

Esta política establece los lineamientos para el análisis de riesgos de seguridad de la información de acuerdo con la naturaleza y sensibilidad de la información, impacto de la pérdida de integridad, disponibilidad y confidencialidad de dicha información. El resultado de las evaluaciones de análisis de riesgos será expuesto en un mapa de riesgos donde se definirá como tal el perfil de riesgo de la organización.

La política fija las responsabilidades de los miembros de la organización como: el directorio ejecutivo, el comité de gestión integral de riesgos, la gerencia de división de auditoría, la subgerencia de seguridad de la información y los funcionarios del banco quienes deben velar por la protección de la confidencialidad integridad y disponibilidad de los activos de información de acuerdo con las responsabilidades que tengan dentro del banco.

3.10.3.4 NORMATIVA DE GESTIÓN DE INCIDENTES DE SEGURIDAD BNB

Esta normativa establece los lineamientos que debe considerar la organización para la gestión de incidentes de seguridad de la información que se trata desde el conocimiento del incidente hasta las acciones de análisis luego de la ocurrencia del incidente. La organización hace la

definición de evento de seguridad de la información como la ocurrencia identificada de un evento en un sistema de servicio o estado de red que indica una posible brecha de seguridad. Para el tratamiento de estos incidentes la organización designa a un grupo de funcionarios compuesto por la gerencia de tecnología, gerencia y subgerencias de servicios y operaciones y la subgerencia de seguridad de la información quienes son los responsables del manejo de incidentes de seguridad de la información. La subgerencia de seguridad de la información es la encargada de gestionar los procedimientos para la respuesta a incidentes, deberá también establecer los mecanismos necesarios que permitan identificar la tipología, los volúmenes y costos de los incidentes de seguridad de la información, así como las medidas asumidas para mitigarlos, garantizando que estos sean registrados, cuantificados y monitoreados.

Se debe contar con procedimientos para dar respuesta a los diferentes tipos de incidentes conocidos, entre los principales incidentes que deben considerarse están: sobrecarga o mal funcionamiento del sistema, errores humanos, incumplimiento de políticas o procedimientos, cambios incontrolables en el sistema, malfuncionamiento del software o hardware, ataque de virus y otros tipos de malware, ataques de denegación de servicios, ataques de intrusión u otros ataques de origen externo, pérdida de servicio equipo o instalaciones.

Entre las actividades que debe realizar la subgerencia de seguridad de la información ante cualquier incidente están: la identificación del tipo de incidente, ponderación de la gravedad de este, identificación y ejecución del procedimiento que aplique, registro de todas las acciones a ser implementadas, activación de las alertas adecuadas, escalamiento del incidente, dependiendo de su gravedad y permanencia en el tiempo, seguimiento a la evolución del incidente.

3.10.3.5 NORMATIVA DE ADMINISTRACIÓN DE VULNERABILIDADES

En esta normativa se establecen las disposiciones que deben ser aplicadas para la evaluación de vulnerabilidades y pruebas de intrusión controladas a los recursos tecnológicos de la organización, ya sean estos recursos tecnológicos nuevos o hayan sido actualizados, dispuestos a producción o previos a pase de producción, Se hará la priorización de estos recursos en base a los resultados del análisis de riesgos que se realice en la organización.

La subgerencia de seguridad de la información es la encargada de realizar las evaluaciones de vulnerabilidades técnicas a los recursos tecnológicos de la empresa esto a partir de los resultados del análisis de riesgos en seguridad de la información o a petición específica de alguna de las áreas de la organización que sea el encargado del recurso tecnológico que contenga información a proteger. Ninguna área distinta a la subgerencia de seguridad de la información podrá ejecutar, ni hacer uso de herramientas para la búsqueda o descubrimiento de vulnerabilidades y explotación de estas en los recursos tecnológicos del banco.

En esta normativa se establecen los lineamientos para las pruebas de intrusión dentro de la organización, con las que realizan la búsqueda de vulnerabilidades en uno o más sistemas que puedan ser utilizados para obtener accesos no autorizados a los recursos tecnológicos. Estas pruebas de intrusión podrán ser realizadas por la subgerencia de seguridad de la información o mediante la contratación de empresas externas que deban contar con personal con certificación CEH ⁹⁷ para realizar estas tareas. Los resultados de las evaluaciones deberán ser tratados de acuerdo con la severidad definida en los informes presentados por la subgerencia de seguridad de la información, los encargados de los recursos tecnológicos evaluados deberán elaborar un plan de acción que incluya las acciones a implementar los responsables y el tiempo estimado.

3.10.3.6 METODOLOGÍA DE EVALUACIÓN DE RIESGO

En esta norma se describe la metodología necesaria para identificar riesgos en los activos de información de la organización, en función a sus vulnerabilidades y amenazas. El marco referencial utilizado corresponde al estándar ISO 31000 e ISO 27005, referidos a la gestión de riesgos y gestión de riesgos en seguridad de la información.

En cuanto a la identificación del alcance se determina el ámbito sobre el que se aplica la evaluación, reconociendo el nivel general de los procesos y las interacciones con su entorno, la evaluación de riesgo se la realiza de forma progresiva, seleccionando un ámbito inicial que es ampliado en revisiones o esfuerzos posteriores, se hace la selección de entornos de activos de información más críticos como ámbito inicial de trabajo. En la figura 26 se muestran las etapas recomendadas para efectuar el análisis de riesgo dentro de la institución.

⁹⁷ CEH Certified Ethical Hacking.



Fuente: Normativa de Metodología de evaluación de riesgo BNB.

Figura 26: Etapas de análisis de riesgos tecnológicos BNB.

La etapa de relevamiento de información relacionada a los procesos del negocio tiene como objetivo conocer los componentes y funcionamiento del ámbito seleccionado de su área organizacional y, a partir de ello, reconocer los activos de información incluidos en el ámbito. Para la etapa de inventario de activos se realizan entrevistas al personal del área propietaria de los procesos seleccionados en el ámbito de análisis, a través de estas entrevistas se busca reconocer los diversos activos que participan de los procesos de negocios identificados en el ámbito de análisis, esta información puede ser complementada con antecedentes recopilados desde documentación que pueda estar disponible.

Para la valoración de activos de información, se hará una medición en términos del impacto en la organización, sus proveedores, clientes y otras partes interesadas, en función a los criterios de confidencialidad, integridad y disponibilidad según su importancia en el logro de los objetivos del negocio. En la etapa de valoración de activos relevantes a través de entrevistas con los funcionarios de las áreas de los procesos involucrados con los activos de información. En la fase de evaluación de riesgos se identifican, analizan y valoran a los riesgos que están expuestos los activos de información de la organización. Esta evaluación proporciona una priorización para la atención de los riesgos a los que se encuentran expuestos los activos de información de la empresa a través de la evaluación e implementación de medidas de mitigación.

3.10.3.7 NORMATIVA DE SEGURIDAD - REDES DE COMUNICACIONES

Esta normativa establece las definiciones, consideraciones y controles que se realizan en el diseño, implantación y la administración de redes de comunicaciones de datos, con el fin de proteger en forma la información que circula a través de estas redes de datos. Estos controles

son resultado del análisis de riesgo tecnológico que realiza la institución. La subgerencia de infraestructura tecnológica de la institución es la responsable de diseñar e implantar la arquitectura de red que considere los elementos y condiciones que protejan la información de la organización considerando la confidencialidad, integridad y disponibilidad de los sistemas de la empresa, esta subgerencia también es la encargada de revisar esta arquitectura de red y verificar que su diseño cumpla con las condiciones de seguridad de la institución.

En esta normativa se establece que se debe hacer la división de dominios de seguridad en los que se divide la red de datos, con el fin de reconocer el nivel de seguridad que corresponde a cada uno de estos dominios y así distinguir su nivel de confianza a nivel de comunicación, como ejemplos de dominios se tiene a las redes de datos de ambientes de producción, las comunicaciones con empresas externas. Esta división se la hace con el fin de implementar los controles adecuados que limiten los flujos y sentidos de comunicación entre estos.

3.10.3.8 REPORTE DE EVENTOS DE SEGURIDAD

La empresa en su estructura de red cuenta con un IPS que monitorea el tráfico interno y externo de su red corporativa, debido a los eventos que se generan de estos dispositivos el banco contrato los servicios de la empresa NEOSECURE para monitorear este tráfico de red es así que cuando se genera algún evento de seguridad en estos dispositivos se hace una notificación vía correo electrónico, un ejemplo de notificación es la que se muestra en la figura 27.

Ticket#7491997 - [BNB] MEDIA Actividad asociada a 192.168.0.11

De ofensas a P

Resumen	
Ofensa	124070
Riesgo	MEDIA
Origen de ofensa	192.168.0.11
Red Origen	Banco_Nacional_de_Bolivia_Z_interna_no_divulgada
Descripción	Malware - Detección de infección.
Start Time	2020-10-08 10:17:54 SCL

Estimado cliente **BANCO NACIONAL DE BOLIVIA**

Desde nuestro Cyber Defense Center (CDC) nos encontramos realizando constantemente análisis de anomalías de seguridad en vuestra infraestructura de red.

Consecuente a esto, se ha identificado actividad anómala proveniente desde la dirección IP **192.168.0.11**.

Descripción

La actividad se encuentra asociado a una posible detección de infección, la cual se utiliza para sabotear determinados sistemas informáticos o controlar ordenadores ajenos y utilizarlos para fines concretos. El malware intenta pasar desapercibido para poder utilizar el equipo invadido el máximo de tiempo posible. Esta actividad puede estar relacionada a posible uso de programa o código malicioso diseñado específicamente para infectar un ordenador y así realizar acciones determinadas como espiar, obtener datos y sacar provecho de ellos.

Destino involucrado

Las redes de destinos involucrados son:

IP Destino - Red Destino
 10.16.120.36 - Banco_Nacional_de_Bolivia_Red_Interna_Validar
 10.16.120.36 - Banco_Nacional_de_Bolivia_Red_Interna_Validar

Categorías

Las categorías de seguridad son:

Fuente: Correo electrónico de notificación

Figura 27: Notificación de evento de seguridad.

La subgerencia de seguridad de la información con los datos de incidentes de seguridad de la información, enviados por el SOC ⁹⁸ de NEOSECURE, genera informes mensuales de eventos de seguridad, en la figura 28 se muestra un ejemplo de informe del mes de enero del 2019.

Banco Nacional de Bolivia S.A. Gestión Integral de Riesgos			
Control - Seguridad de la Información ENERO 2019			
N°	Controles y proyectos ejecutados	Descripción del seguimiento	Acciones adoptadas
1	Monitoreo de Eventos de Seguridad en red interna y perimetral.	Se generaron 35 eventos con la siguiente distribución: - BNB - logger/FS, alerta de disponibilidad de servicio: 12 - BNB-IPS-MIPS: 4 - BNB - Borrado de archivos SWIFT: 4 - BNB - Creación de cuenta: 2 - Detección: DoS - High Volume Drops from External Network: 1 - Firewall - Host Port Scan: 1 - RM - RiskMonitor - Bloqueos: 1 - RM - Cisco: 2 - WAF - Detecciones múltiples técnicas de ataque: 6 - WAF - Inyección de sentencias SQL: 2	- Recuperación de monitoreo con todos los dispositivos afectados. - Se aplicaron los bloqueos a nivel del IPS y firewall . No se identificaron mayores indicios de intrusión.
2	Monitoreo de uso del Internet	- No se identificaron usuarios con uso de navegación por internet fuera de lo establecido en la política. - No se identificaron dominios de internet que por su contenido o cantidad de tráfico representan un riesgo para el Banco.	- Se realiza un monitoreo constante.
3	Monitoreo Anti Phishing.	- Se identificó la presencia en internet de 10 dominios similares al del Banco.	- Los dominios identificados presentaron actividad contra el Banco Nacional de Bolivia. Se realizaron las solicitudes de bloqueo de los sitios identificados, los cuales fueron dados de baja y bloqueados posteriormente a las solicitudes.
4	Monitoreo Antispam.	- Se identificaron 7 fuentes de correo no deseado (SPAM) desde las cuales llegaron correos electrónicos al banco.	- Se solicitó el bloque de los dominios desde los cuales recibimos los correos electrónicos SPAM.

Fuente: Reporte de control de eventos de seguridad de la información BNB enero 2019

Figura 28: Control de seguridad de la información

3.11 PROCESAMIENTO Y ANÁLISIS DE LA INFORMACIÓN

3.11.1 ANALISIS DE RESULTADOS DE LA ENTREVISTA

Los resultados obtenidos de las entrevistas realizadas reflejan varios elementos que podrían ser de relevancia para la investigación, que van desde el desconocimiento del estándar IEEE 802.1x, pregunta 10, hasta la implementación de controles para el filtrado de contenido dentro de la red de la organización, la ausencia de procedimientos y herramientas que ayuden a realizar el control de acceso a equipos de red de personal externo e interno. En la tabla 11 se extrae las respuestas más sobresalientes de la entrevista realizada.

⁹⁸ SOC Security Operation Center.

Cuadro 11: Análisis de entrevista.

No.	1. Evaluación de conocimientos comunes:
2	R SGSI: El SGSI está a cargo de del tratamiento de SI dentro del banco y es apoyado por 3 analistas de SI que están bajo su cargo. R SGIT: El área de tecnología no cuenta con algún personal dedicado a la SI, solo se encarga de coadyuvar al área de seguridad en la gestión de riesgos
3	R SGSI: Se apoya en las normas ISO 27001, ISO 27002, así también la ISO 31000 e ISO 27005 para la evaluación de riesgos. R SGIT: La organización está trabajando con el estándar PCI ya que es una entidad que trabaja con el manejo de tarjetas de débito y crédito.
5	R SGSI: Se desarrollan campañas de concientización sobre la seguridad de la información vía mail. R SGIT: El área apoya a la subgerencia de SI para las campañas de mail masivo.
No.	2. Evaluación de capacidades y conocimientos del entrevistado en el área de estudio:
8	R SGSI: Se cuenta con normativa de control de acceso de usuarios al dominio del banco. R SGIT: No se cuenta con controles dedicados al control de acceso a redes.
9	R SGSI: Existen varios fabricantes a nivel mundial para este tipo de soluciones. R SGIT: Si se ha estado investigando sobre la solución que tiene el fabricante CISCO, ya que la mayor parte de equipos de red pertenece a este fabricante.
10	R SGSI: No tiene conocimiento al respecto. R SGIT: La solución del fabricante CISCO trabaja con este estándar en su sistema NAC.
No.	3. Evaluación de análisis de necesidad del modelo:
11	R SGSI: No se cuenta con algún tipo de normativa al respecto R SGIT: A nivel de tecnología no se cuenta al respecto.
12	R SGSI: Se tiene una normativa del área de seguridad física que controla el acceso de equipos computadores externos. R SGIT: Se está analizando implementar controles a nivel de puertos de acceso en los siguientes de agencias alejadas.
13	R SGSI: Se cuenta con el apoyo de una empresa externa que controla los IDS de la organización, quienes bajo ciertos procedimientos alerta a la SGSI sobre eventos de seguridad. R SGIT: A principios de año se tuvo un evento de saturación de enlaces de comunicación debido al alto tráfico de un equipo
14	R SGSI: Es importante contar con procedimientos que limiten y controlen el acceso externo indebido. R SGIT: Es necesario poder implementar algún sistema que controle la conexión de equipos dentro de la red de la institución
No.	4. Evaluación de desarrollo de tareas de prevención:
15	R SGSI: Dentro de las tareas estratégicas se tiene programado contratar a una empresa externa que se encargue de realizar un hacking ético a la red de la organización. R SGIT: Se realiza el apoyo técnico a las pruebas de intrusión programados por el área de SI.

Fuente: Elaboración propia usando Excel 2019.

En lo relativo a conocimientos comunes se vio que la organización tiene un cierto nivel de madurez con respecto a la seguridad de la información, si bien se tiene un apartado definido para la seguridad de la información dentro de su plan estratégico institucional no se cuenta con

el suficiente recurso humano que realice las tareas de análisis prevención y desarrollo de políticas o normativas que coadyuven al control de eventos de seguridad dentro de la empresa, esto de acuerdo a lo expuesto por el Subgerente de Seguridad de la Información.

De acuerdo con lo expuesto por el subgerente de infraestructura tecnológica, el área de tecnología cuenta con limitado presupuesto para el desarrollo de proyectos que impliquen la implementación de controles de seguridad. De acuerdo con eventos de seguridad que afectaron a la red de servidores se tuvo que actuar de manera reactiva y se desarrollan proyectos para controlar de manera adecuada los requerimientos de navegación de la red de servidores, esto a partir de las recomendaciones del fabricante CISCO. Por lo anteriormente expuesto se hace necesario contar en el área de tecnología con un recurso que sea responsable de desarrollar proyectos tecnológicos relacionados a la seguridad de la información y que trabaje tanto con el sector de tecnología como con el área de seguridad de la información.

Finalmente, al analizar la entrevista de acuerdo con lo expuesto por el subgerente de seguridad de la información se realizan tareas de análisis de vulnerabilidades a la red de la organización con la colaboración de una empresa externa quienes emiten sus recomendaciones concernientes a la seguridad de la información, a partir de estas recomendaciones es que se toman las acciones correspondientes. Una de las observaciones recurrentes ha sido que la empresa no cuenta con segmentación de redes permitiendo así que cualquier equipo dentro de la red pueda alcanzar el segmento de red de servidores.

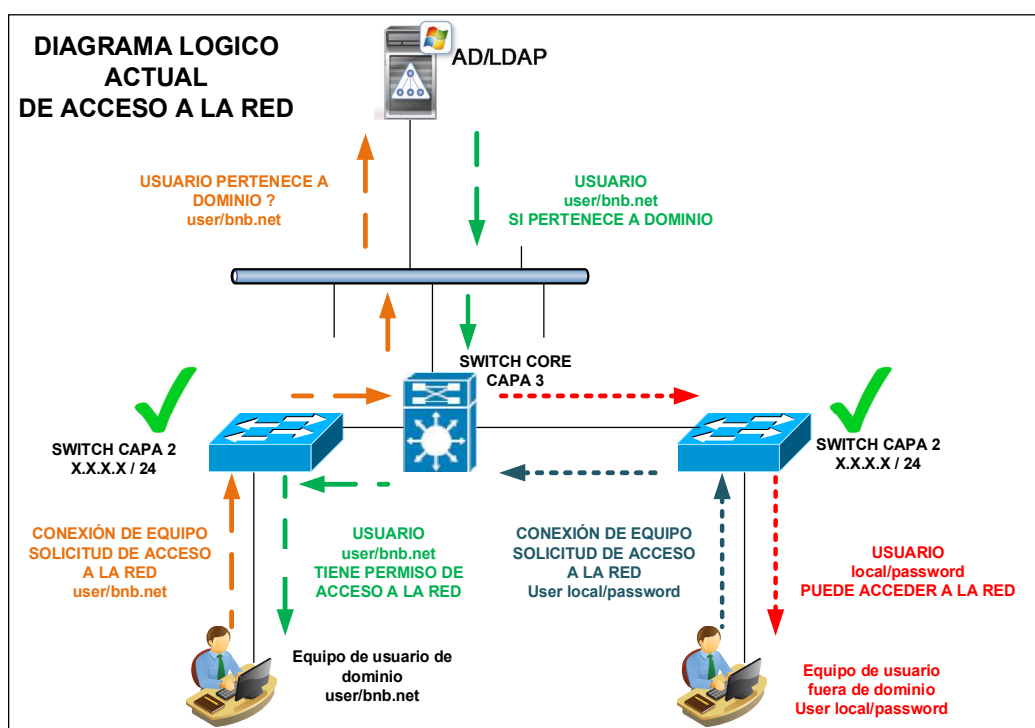
De acuerdo con la información obtenida, en la entrevista se ve la necesidad de implementar un modelo de control de acceso a la red, destacándose la recomendación de promover la implementación de algún tipo de sistema que permitan realizar el control de acceso a equipos dentro de la red de la empresa, se hace necesaria la implementación de controles ya sean procedimentales o controles tecnológicos junto a la implementación de alguna solución tecnológica que controlen de manera adecuada el acceso de dispositivos dentro de la red de datos de la organización, así también se debe desarrollar controles que segmenten la red de datos de la empresa para evitar que cualquier equipo que se conecte a la red de datos puede de alguna forma comunicarse con la red de servidores de la empresa.

3.11.2 SITUACIÓN ACTUAL DE RED BNB

Actualmente el acceso a los recursos de red en las diferentes sucursales y agencias del caso de estudio se lo realiza de forma cableada. Para el acceso a la red de forma cableada no se tiene un control establecido, más que el acceso físico a los puntos de red. Además del control de acceso a la red, es necesario definir niveles de autorización, con el fin de que solo los usuarios autorizados accedan a los recursos asignados, actualmente a nivel de red se tienen controles básicos de autorización basado en VLAN's, pero debido a que este control es basado en puertos físicos de los switches de acceso, el constante movimiento de los usuarios ocasiona complejidad en la gestión de este tipo de controles.

3.11.3 SITUACIÓN ACTUAL DE ACCESO EN RED CABLEADA

La empresa no dispone de algún tipo de control a nivel de su red LAN. Todos los puertos de los switches de acceso, tienen configurada una VLAN específica, dependiendo de la red a acceder, sin restricción alguna. En la figura 29 se muestra las conexiones a la red corporativa tanto de usuarios internos como la de usuarios externos.



Fuente: Elaboración propia usando Visio 2019.

Figura 29: Diagrama lógico de acceso a la red BNB.

En la figura se puede ver que el equipo de red de un usuario interno accede a la red de datos de la organización con sus credenciales de dominio y de acuerdo con los privilegios del usuario de dominio podrá acceder a determinados servicios, ahora bien si un dispositivo externo a la organización se desea conectar a la red de datos bastara con conectarlo a un punto de red libre que encuentre en algún ambiente y si bien no podrá acceder a los servicios de dominio, puede acceder a servicios básicos donde podrían de alguna manera acceder a la red de datos.

```
LPZ-AG-200CT-SW1#sh run int g1/0/3
Building configuration...

Current configuration : 159 bytes
!
interface GigabitEthernet1/0/3
 switchport access vlan 113
 switchport mode access
 switchport voice vlan 1
 power inline never
 spanning-tree portfast
end

LPZ-AG-200CT-SW1#
```

Fuente: Configuración de switch agencia 20 octubre BNB.

Figura 30: Configuración de puerto de switch de acceso de la agencia 20 de Octubre del BNB.

En la figura 30 se puede apreciar como ejemplo la configuración básica de uno de los puertos del switch de acceso de la agencia 20 de Octubre de La Paz el cual no cuenta con algún tipo de restricción a nivel de acceso. Luego de que un equipo es conectado a la red de datos, este adquiere una dirección IP de forma automática desde el enrutador de la agencia que tiene configurado la opción de asignación de direcciones IP como se muestra en la figura 31.

```
LPZ-AG-200CTUBRE-RT#sh run | b ip dhcp pool
ip dhcp pool AG-200CT_DATOS-POOL
 network 10.10.10.0 255.255.255.192
 default-router 10.10.10.1
 dns-server 10.10.10.10 10.10.10.11
 lease infinite
!
ip dhcp pool voice-vlan
 network 10.10.10.0 255.255.255.192
 option 242 ascii "MCIPADD=10.10.10.0, MCPORT=1719, HTTPSrvr=10.10.10.8"
 option 176 ascii "MCIPADD=10.10.10.0, MCPORT=1719, TFTPsvr=10.10.10.8"
 default-router 10.10.10.1
 lease infinite
```

Fuente: Configuración de enrutador agencia 20 octubre BNB.

Figura 31: Configuración DHCP de router de la agencia 20 de octubre del BNB.

Los controles de acceso a nivel de VLAN's si bien restringen el acceso a la red de servidores de la organización no restringe la comunicación de otros servicios de red a los cuales se puede acceder solo con conectar un equipo de red, un ejemplo de una lista de acceso que se tiene configurada en el enrutador de la agencia 20 de octubre que se muestra en la figura 32.

```

LPZ-AG-20OCTUBRE-RT#sh access-lists VALORES
Extended IP access list VALORES
 10 permit ip host 10.10.10.1 255
 20 permit ip host 10.10.10.1 255
 30 permit ip host 10.10.10.1 255
 40 permit ip 10.10.10.0 255
 50 permit tcp any any eq domain 443 www 8080 22 ftp
 60 permit ip 10.10.10.0 255 host 10.10.10.1
 70 permit ip 10.10.10.0 255 host 10.10.10.1
 80 permit ip 10.10.10.0 255 host 10.10.10.1
 90 permit ip 10.10.10.0 255 host 10.10.10.1
100 permit ip 10.10.10.0 255 host 10.10.10.1
110 permit ip 10.10.10.0 255 host 10.10.10.1
120 permit ip 10.10.10.0 255 host 10.10.10.1
130 permit ip 10.10.10.0 255 host 10.10.10.1
140 permit ip 10.10.10.0 255 host 10.10.10.1
150 permit icmp 10.10.10.0 255 host 10.10.10.1
160 permit icmp 10.10.10.0 255 host 10.10.10.1
170 permit ip host 10.10.10.1 255
180 deny ip 10.10.10.0 255 host 10.10.10.1
190 deny ip 10.10.10.0 255 host 10.10.10.1
200 permit tcp any any eq domain 443 www 8080 5060
210 permit udp any any (49099 matches)
LPZ-AG-20OCTUBRE-RT#
  
```

Fuente: Configuración de enrutador agencia 20 octubre BNB.

Figura 32: Configuración de lista de acceso de enrutador agencia 20 de octubre BNB.

3.11.4 ANÁLISIS DE NORMATIVA INTERNA BNB

En la tabla 12 se muestra un resumen de las normas más relevantes con respecto a seguridad de la información, donde se destaca la declaración de su Política de Seguridad de la Información, todas estas normativas son dependientes de la Vicepresidencia de Gestión de Riesgos del banco. También hay que mencionar que la normativa de accesos a los sistemas fue elaborada por la Vicepresidencia de Operaciones de donde dependía la gerencia de Tecnología del BNB.

Cuadro 12: Resumen normas BNB sobre seguridad de la información.

RESUMEN NORMATIVO BNB SEGURIDAD DE LA INFORMACIÓN	
VGR/024/12/RIE	POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN

VGR/034/14/RIE	POLÍTICA DE GESTIÓN INTEGRAL DE RIESGOS
VEJ/305/09/OYM	GESTIÓN DE ACCESOS Y ATRIBUCIONES EN LOS SISTEMAS
VGR/495/16/RIE	NORMA DE PROCESO SANCIONATORIO POR INFRACCIONES A LA POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN
VGR/428/12/RIE	NORMA DE SEGURIDAD - GESTIÓN DE INCIDENTES DE SEGURIDAD DE LA INFORMACIÓN
VGR/422/12/RIE	NORMA DE SEGURIDAD - IDENTIFICACIÓN Y AUTENTICACIÓN DE USUARIOS
VGR/414/12/RIE	NORMA DE SEGURIDAD - ADMINISTRACIÓN DE VULNERABILIDADES
VGR/412/12/RIE	NORMA DE SEGURIDAD - REDES DE COMUNICACIÓN
VGR/421/12/RIE	NORMA DE SEGURIDAD EN EL USO DE FIREWALL Y DISPOSITIVOS DE SEGURIDAD DE REDES
VGR/400/12/RIE	METODOLOGÍA DE EVALUACIÓN DE RIESGO
VGR/437/12/RIE	NORMA DE SEGURIDAD - PROPIEDAD DE ACTIVOS DE INFORMACIÓN
VGR/434/12/RIE	NORMA DE PREVENCIÓN DE FUGA DE INFORMACIÓN
VGR/432/12/RIE	NORMA DE SEGURIDAD - CONTROL DE CAMBIOS EN ACTIVOS DE INFORMACIÓN
VGR/431/12/RIE	NORMA DE SEGURIDAD - CONTROLES CRIPTOGRÁFICOS
VGR/425/12/RIE	NORMA DE SEGURIDAD - CONTINUIDAD DEL NEGOCIO
VGR/420/12/RIE	NORMA DE SEGURIDAD EN EL INTERCAMBIO DE INFORMACIÓN
VGR/419/12/RIE	NORMA DE SEGURIDAD - ADMINISTRACIÓN DE ACTIVIDADES LOGS
VGR/418/12/RIE	NORMA DE SEGURIDAD DE CODIGOS MALICIOSOS
VGR/417/12/RIE	NORMA DE SEGURIDAD EN EL USO DE INTERNET
VGR/413/12/RIE	NORMA DE SEGURIDAD EN COMPUTADORES PERSONALES

Fuente: Elaboración propia usando Excel 2019.

3.11.5 ANÁLISIS DE REPORTES DE SEGURIDAD DE LA INFORMACIÓN

Como se indicó mensualmente la subgerencia de seguridad de la información genera un reporte de eventos de seguridad de la información dentro de la red corporativa del BNB, en base a los reportes enviados por el SOC de NEOSECURE.

De este resumen se puede evidenciar que existe una cantidad considerable de eventos de ataques DoS de denegación dentro de la red del banco, también destacar la ocurrencia de eventos de explotación programa maligno. El reporte mostrado también considera los eventos de seguridad ocurridos en redes externas donde se tienen publicados servidores hacia la red de internet estos ataques en su mayoría son del tipo de inyecciones y sentencias SQL, en el cuadro 13 se muestra el reporte de incidentes de seguridad del caso de estudio desde el mes de agosto del 2018 hasta agosto del 2019.

Cuadro 13: Reporte de incidentes de seguridad del BNB.

REPORTES DE INCIDENTES BNB MONITOREO DE EVENTOS DE SEGURIDAD EN RED INTERNA Y RED PERIMETRAL													
EVENTO DE SEGURIDAD	AGOSTO 2018	SEPTIEMBRE	OCTUBRE 2018	NOVIEMBRE 2018	DICIEMBRE 2018	ENERO 2019	FEBRERO 2019	MARZO 2019	ABRIL 2019	MAYO 2019	JUNIO 2019	JULIO 2019	AGOSTO 2019
BNB - logger/pérdida de monitoreo	3	0	0	0	12	7	1	3	0	5	0	0	0
BNB - Creación de cuenta	0	2	0	4	2	1	4	11	0	2	0	0	0
Compromise-attack to Vulnerable Server	0	1	1	0	0	0	0	0	0	0	0	0	0
Brute Force Logins	0	0	0	0	0	1	0	0	0	0	0	0	0
Conexión rehusada / login fallido reiterado	0	0	0	4	0	2	0	9	3	25	2	6	7
DoS Attacks -High Volume Drops from Network	2	1	2	0	1	1	0	0	0	2	39	43	37
Escaneo externo de red	1	3	1	1	1	2	1	0	2	1	8	1	5
Exploit / Programa maligno	0	1	0	2	3	1	2	3	2	8	4	3	4
Firewall Denegaciones	0	4	2	0	0	0	4	1	1	12	2	9	11
Scan from Protected Network	0	0	0	0	0	0	0	0	0	3	2	0	0
WAF - Detecciones múltiples técnicas de ataque	28	31	29	26	6	0	0	17	25	5	4	1	1
WAF - Inyección de sentencias SQL	3	6	4	4	2	0	8	38	0	68	91	117	84
WAF - Ataques Cross-Site Scripting	1	3	2	0	0	0	4	25	5	29	38	22	11

Fuente: Reporte incidentes BNB.

El reporte también nos presenta un resumen de logins fallidos a servidores de dominio que son debidos a eventos de equipos de red que posiblemente cuentan con algún tipo de programa maligno que intenta afectar a los servidores de dominio de la empresa.

3.12 DESARROLLO DEL MODELO

Los modelos de seguridad de la información han dado solución a problemas específicos basados en la aplicación de buenas prácticas, los modelos son genéricos y que tienen que adaptarse a la realidad y problemática de las instituciones. Para cada problema específico es necesario definir un modelo que apoye a la gestión de la seguridad de la información de acuerdo con las necesidades de la empresa.

3.12.1 EVALUACIÓN DE LOS MODELOS

En base al estudio realizado en el capítulo II, en el acápite de Marco Referencial, se pudo identificar doce modelos de seguridad de la información, y que podrían aplicarse para la resolución del problema de investigación. Estos modelos de control de acceso son los siguientes:

- ISO/IEC 27001 (SGSI) Sistema de Gestión de Seguridad de la Información.
- Guía Metodológica del Sistema de Seguridad de la Información en el Programa de Mejoramiento de la Gestión y Metas de Eficiencia (SSI-PMGMEI).
- Modelo de Madurez de la Seguridad de la Información en el Contexto de las Organizaciones Inteligentes (MMASI).
- Modelo Mejorado de Seguridad de la Información de Red Distribuida (P2DWR2).
- Modelo de Seguridad de la Información (MSGRC).
- Modelo de Seguridad de la Información en TIC (MSI-TIC).
- Modelo de Defensa de Seguridad de Red (MDSR).
- Modelo (O-ISM3) de Madurez de Gestión de Seguridad de la Información.
- Modelo de Seguridad de Red Basado en Minería de Datos (MSRBMD).
- Modelo de Seguridad de Red de Defensa Activa (P2DR2C).
- Modelo Contextualizado de Colado & Franco (MCC&F).
- Directiva de Seguridad de la Información para la protección de datos personales (DSI-PDP).

De los 12 modelos de seguridad de la información previamente analizados se concluye que estos contemplan los siguientes elementos, los cuales se muestran en resumen en el cuadro 14:

- Fases para implementar, operar, monitorear y mejorar la seguridad de la información.
- Organización para la operación de seguridad de la información.
- Funciones definidas del responsable o de la dirección de la gestión.
- Niveles de madurez del sistema de seguridad.
- Documentos obligatorios de seguridad de la información.
- Controles definidos para reducir los riesgos de seguridad de información.
- Indicadores para medir los controles.
- Métricas para determinar el valor de los indicadores de control.

Cuadro 14: Modelos de seguridad de la información.

Elementos	MODELOS DE SEGURIDAD DE LA INFORMACIÓN												Total de modelos por elemento
	SGSI	SSI-PMGMEI	MMASI	P2DWR2	MSGRC	MSI-TIC	MDSR	O-ISM3	MSRBMD	P2DR2C	MCC&F	DSL-PDP	
Fases	04 - PDCA	04 Diagnóstico, planificación, implementación y evaluación	No	04 Protección, detección, alerta temprana, respuesta de recuperación	03 componentes	02 - Fase de elaboración y fase de aplicación	03 Seguridad tecnológica, soporte en administración y respuesta en tiempo real	04- Pirámide administrativa y proceso general	04 componentes	05 Protección, detección, respuesta, contador de ataques, prevención	03 componentes relacionados	No	10
Organización	Determinada por la entidad	Determinada por la entidad	No	No	No	No	No	No	No	No	No	Determinada por la entidad	3
Funciones	No	No	No	No	No	Del Oficial de Seguridad	No	No	No	No	No	Requisitos organizativos	2
Documento	Generales	Generales	No	No	Mención en componente conductor	Mención general	No	Generales	No	No	No	Requisitos jurídicos	6
Niveles	No	No	No	No	No	No	No	5	No	No	4	No	2
Controles	Requisitos específicos	Mención general	No	Mención general	No	Mención general	Requisitos técnicos	Especifica por fases	Requisitos técnicos	Mención general	No	Requisitos técnicos	9
Indicadores	No	No	Mención en cada nivel	No	No	No	No	Mención de 8 tipos	No	No	No	No	2
Métricas	No	No	No	No	No	No	No	Mención general	No	No	Mención general	No	2

Fuente: Elaboración propia usando Excel 2019.

Del análisis también se puede observar que: 10 modelos, se han enfocado principalmente en desarrollo por fases, 6 modelos en la documentación y 9 modelos en controles, existe poca relevancia en lo correspondiente a organización, funciones, niveles, indicadores y métricas. En el cuadro 15 se muestra la relación de elementos por modelo.

Cuadro 15: Relación de elementos identificados por modelo.

ELEMENTOS	CANTIDAD DE MODELOS POR ELEMENTO	PORCENTAJE DE MODELOS POR ELEMENTO
Fases	10	83,33
Organización	3	25,00
Funciones	2	16,67
Documento	6	50,00
Niveles	2	16,67
Controles	9	75,00
Indicadores	2	16,67
Métricas	2	16,67

Fuente: Elaboración propia usando Excel 2019

Del análisis y evaluación comparativa de los modelos realizada se ha seleccionado aquellos que describen de manera más detallada los elementos importantes que conformarán el modelo propuesto para la problemática presentada, dicho resumen se presenta en el cuadro 16.

Cuadro 16: Selección de elementos por modelo estudiado.

FASES	CICLO DE DEMING - 4 FASES PDCA		DESCRIPCIÓN
	MSIEGL	SGSI	SSI-PMGMEI
ORGANIZACIÓN	ORGANIZACIÓN DE LA EMPRESA		DESCRIPCIÓN
	MMASI		Modelo(s) de referencia
FUNCIONES	RESPONSABILIDADES DE LAS PARTES INTERESADAS OSI		DESCRIPCIÓN
	SGSI	MSI-TIC	Modelo(s) de referencia
DOCUMENTO	ESTRUCTURA - MEDIDAS DEFINIDAS		DESCRIPCIÓN
	O-ISM3	SGSI	Modelo(s) de referencia
NIVELES	NIVELES DE MADUREZ DE LA EMPRESA		DESCRIPCIÓN
	MMASI	O-ISM3	Modelo(s) de referencia

CONTROLES	DEFINIDOS POR ESTRUCTURA	DESCRIPCIÓN
	O-ISM3 SGSI MDSR P2DWR2	Modelo(s) de referencia
INDICADORES	INDICADORES DE CONTROLES REPORTES DE INCIDENTES	DESCRIPCIÓN
	MDSR P2DR2C	Modelo(s) de referencia
MÉTRICAS	ELEMENTOS DE LA MÉTRICA	DESCRIPCIÓN
	O-ISM3	Modelo(s) de referencia

Fuente: Elaboración propia usando Excel 2019

En el siguiente cuadro se muestran los elementos con los que contara el modelo de seguridad de la información con el que se pretende dar solución a la problemática presentada que se muestra en el cuadro 17.

Cuadro 17: Selección de elementos para el modelo de seguridad de la información.

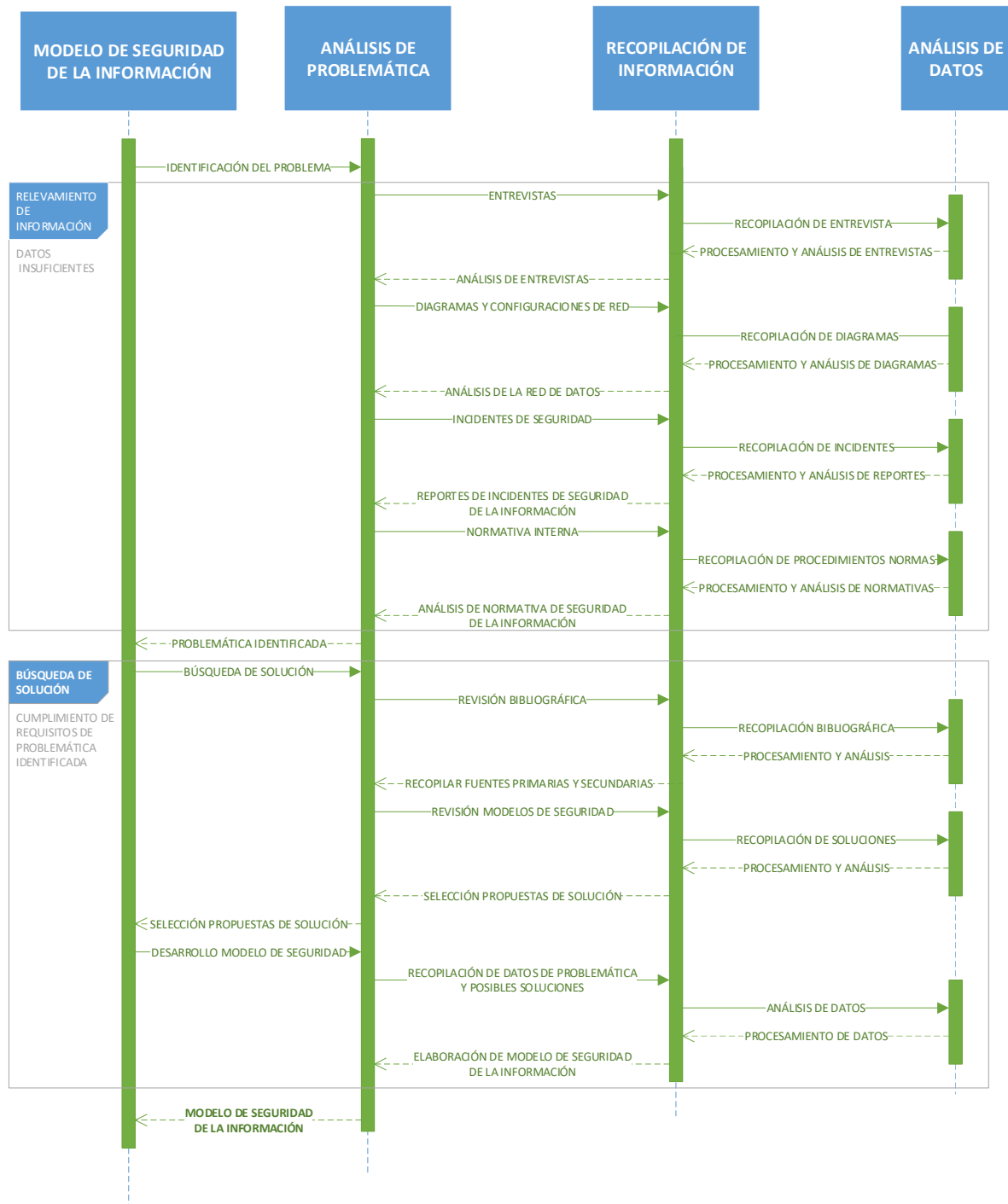
FASES	CICLO DE DEMING - 4 FASES PDCA
ORGANIZACIÓN	ESTRATÉGICA Y OPERATIVA
FUNCIONES	RESPONSABILIDADES OSI
DOCUMENTO	POLÍTICAS PROCEDIMIENTOS Y CONTROLES
NIVELES	NIVELES DE MADUREZ
CONTROLES	CONTROL PROCEDIMENTAL O TECNOLÓGICO
INDICADORES	REPORTES DE INCIDENTES
MÉTRICAS	MÉTRICAS DE LOS CONTROLES

Fuente: Elaboración propia usando Excel 2019

3.12.2 ELABORACIÓN DEL MODELO

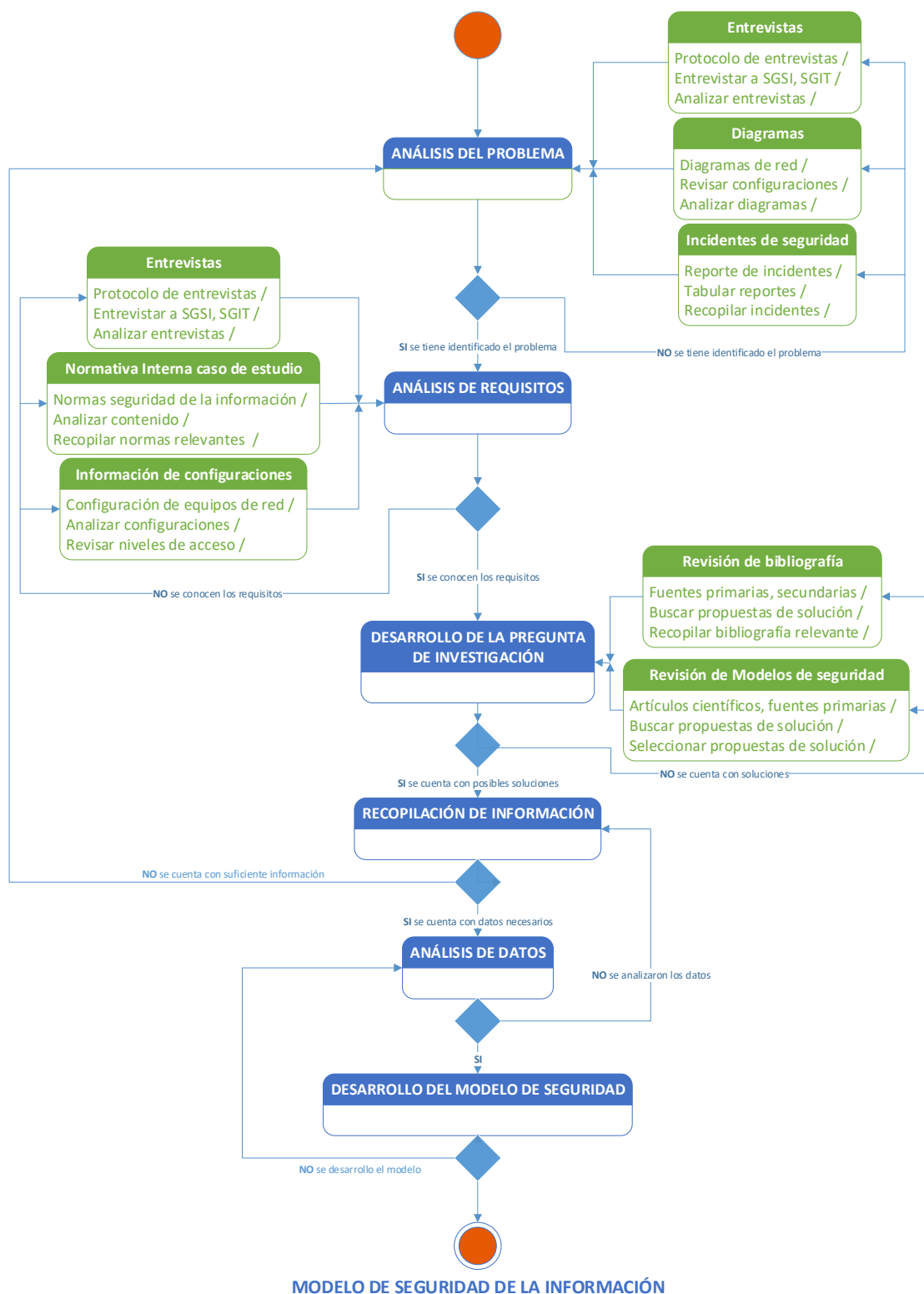
Luego de haber hecho un análisis de los diferentes modelos de seguridad de la información de diferentes autores y haber seleccionado los elementos con los que contara la propuesta de solución, considerando la información referente a entrevistas a responsables de seguridad de la información dentro de la empresa, recopilación de diagramas de red, normativa vigente en relación a la seguridad de la información, habiendo identificado los incidentes de seguridad relacionados al acceso de equipos a la red de datos, se elaboró una metodología para la elaboración del modelo de seguridad de la información, dichos pasos metodológicos se muestran

a detalle en las figuras 33 y 34, donde se observa el procedimiento seguido considerando los elementos previamente descritos.



Fuente: Elaboración propia usando Visio 2019

Figura 33: Diagrama de secuencias para elaboración del Modelo de seguridad de la información

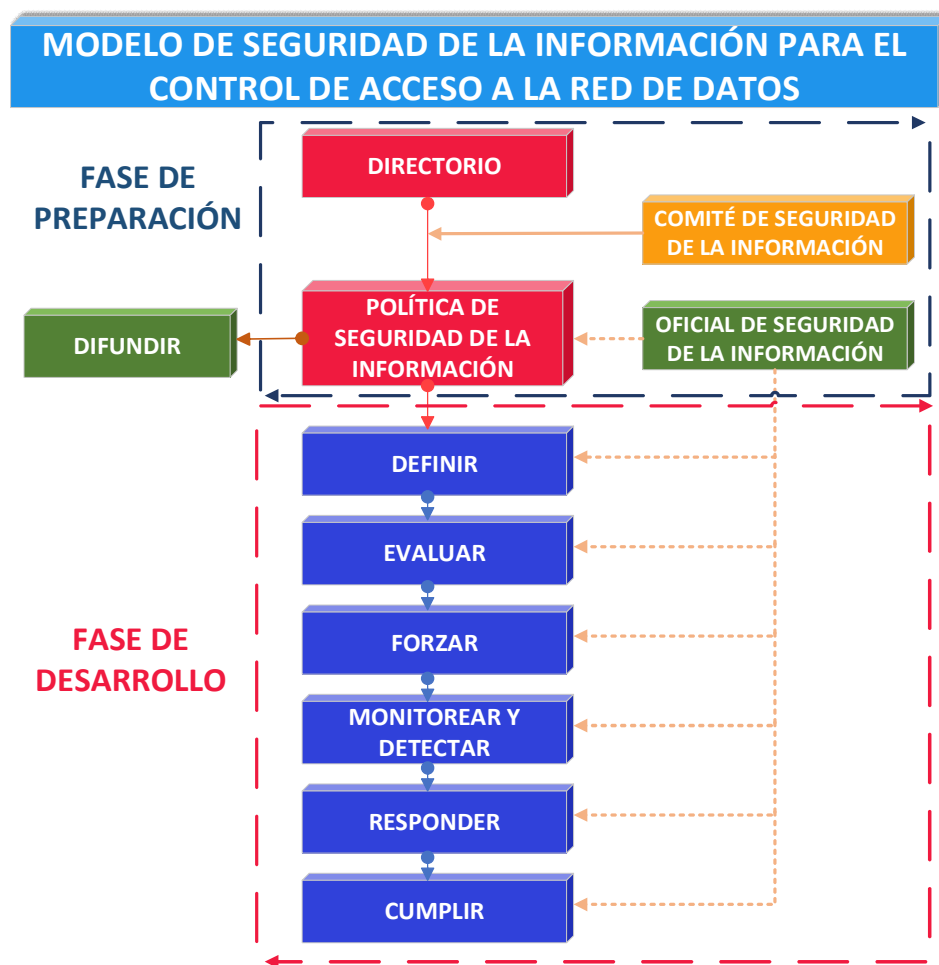


Fuente: Elaboración propia usando Visio 2019

Figura 34: Diagrama de estados para elaboración del Modelo de seguridad de la información

3.13 MODELO DE SEGURIDAD DE LA INFORMACIÓN PARA EL CONTROL DE ACCESO A LA RED A NIVEL DE LA CAPA DE ENLACE DE DATOS

Como resultado del análisis realizado se propone el Modelo de Seguridad de la Información para el control de acceso a la red. En la figura 35 se presenta una visión global del Modelo de Seguridad de la Información para el control de acceso a la red propuesto.



Fuente: Elaboración propia usando Visio 2019

Figura 35: Modelo de seguridad de la información para el control de acceso a la red.

El modelo de seguridad de la información propuesto considera en su estructuración, formación e implementación dos fases importantes las cuales son:

- a) Fase de preparación
- b) Fase de desarrollo

3.13.1 FASE DE PREPARACIÓN

En esta fase se hará el relevamiento de todas las actividades generales que la organización pueda realizar y que tengan relación con la gestión de la seguridad de la información dentro de la organización. Para esta fase se detallan a continuación las etapas donde se consideran las actividades a realizar de forma global.

3.13.2 COMITÉ DE SEGURIDAD DE LA INFORMACIÓN

La conformación de un comité de seguridad de la información dentro de la empresa resulta importante para que este sea el nexo de trabajo con el directorio ejecutivo de la empresa para la presentación del respectivo programa de seguridad de la información dentro de la organización, donde se detallaran de manera global los proyectos y actividades a desarrollar en cuanto a la gestión de la seguridad de la información que estarán alineados al plan estratégico institucional elaborado anualmente o quinquenalmente.

El comité de seguridad de la información debe estar conformado por miembros con cargos de alto nivel de los departamentos y diferentes áreas de la organización. Entre las tareas asignadas a este comité podemos mencionar:

- Hacer una revisión periódica del estado general de la seguridad de la información.
- Revisar y monitorear los incidentes relacionados a la seguridad de la información.
- Revisar y aprobar los proyectos de seguridad de la información.
- Aprobar modificaciones o creación de nuevas políticas de seguridad de la información.
- Realizar otras actividades de alto nivel relacionadas con la seguridad de la información.
- Tomar conocimiento de los incidentes de seguridad y verificar que se hayan tomado las medidas adecuadas para solucionar la situación y prevenir ocurrencias futuras.

Cuando este comité de seguridad de la información se reúna con el propósito de revisar temas concernientes a la seguridad de la información es necesario incluir la participación del Oficial de Seguridad de la Información o de algún responsable de seguridad de la información dentro de la organización.

3.13.3 APOYO DIRECTIVO

Luego de que el comité de seguridad de la información elabora el programa de seguridad de la información el mismo debe ser presentado al directorio ejecutivo, accionistas o dueños de la empresa, quienes deben apoyar las tareas para la implementación y la gestión de la seguridad de la información dentro de la organización, deben apoyar las gestiones para concretar el financiamiento y puesta en marcha de los proyectos de seguridad de la información. El directorio ejecutivo es la entidad que tomara las decisiones importantes para el tratamiento de riesgos dentro de la organización.

La gerencia o directorio, debe apoyar en forma activa a la implementación del plan de seguridad de la información dentro de la organización con la intención clara de resguardar la información relevante de la empresa de las posibles contingencias internas o externas a la organización, deben mostrar su compromiso, así también tener el conocimiento de las responsabilidades de la seguridad de la información. Este compromiso se verá reflejado a través de:

- Creación de un comité de seguridad interdisciplinario en el cual se incluya al área de tecnología de la empresa.
- Asignación de un responsable de la seguridad de la información (Oficial de seguridad) dentro de la organización.
- Aprobación del documento de políticas de seguridad de la información.
- Velar por el cumplimiento de las políticas de seguridad de la información.
- Asignación de responsabilidades asociadas al tema de la seguridad de la información.
- Conocer y comprender los riesgos inherentes a los que está expuesta la organización.
- Convocar a reuniones extraordinarias al Comité de Seguridad de la Información cuando se presenten eventos de seguridad dentro de la organización los cuales ameriten su tratamiento inmediato.

3.13.4 POLITICA DE [SEGURIDAD DE LA INFORMACIÓN

Esta etapa corresponde al diseño y elaboración de la Política de Seguridad de la Información de la organización la cual mostrara los lineamientos con respecto al tratamiento de riesgos

relacionados a la seguridad de la información para su identificación, medición, monitoreo, control, mitigación y divulgación dentro de la organización. En esta política se pretende formalizar el pensamiento de la empresa respecto de la importancia que tiene la seguridad de la información dentro de la organización.

Esta política será aplicada dentro de la empresa según como se defina previamente sus límites y alcances, así también se deben definir las responsabilidades del personal ejecutivo, los funcionarios de la empresa, y proveedores externos entre otros, teniendo en cuenta los principios sobre los que se basa el desarrollo de acciones o toma de decisiones alrededor del Sistema de Gestión de Seguridad de la Información de la empresa las cuales estarán determinadas por las siguientes definiciones:

- Minimizar el riesgo en las funciones más importantes de la entidad.
- Cumplir con los principios de seguridad de la información.
- Cumplir con los principios de la función administrativa.
- Mantener la confianza de sus clientes, socios y empleados.
- Apoyar la innovación tecnológica.
- Proteger los activos tecnológicos.
- Establecer las políticas, procedimientos e instructivos en materia de seguridad de la información.
- Fortalecer la cultura de seguridad de la información en sus miembros ejecutivos, sus funcionarios, y proveedores de la empresa.
- Garantizar la continuidad del negocio frente a incidentes de seguridad.
- Mostrar el compromiso decidido de la empresa a definir, implementar, operar y mejorar de forma continua un Sistema de Gestión de Seguridad de la Información, soportado en lineamientos claros y que estén alineados a las necesidades del negocio.

3.13.5 OFICIAL DE SEGURIDAD DE LA INFORMACIÓN (OSI)

La organización debe designar a un responsable que desarrolle las tareas de un Oficial de Seguridad de la Información, para que ejecute, apoye, dirija y pueda llevar el control de

implementación y posterior seguimiento de todo el modelo de seguridad de la información de la empresa. Además, este encargado de seguridad de la información estará presente en todas las fases de aplicación del modelo participando de forma activa y en forma coordinada con el área de tecnología de la organización.

El Oficial de Seguridad de la Información tiene la función de brindar los servicios de seguridad en la empresa, a través de la planificación, coordinación y administración de los procesos de seguridad informática, así como difundir la cultura de seguridad de la información entre todos los miembros de la organización. Entre las tareas y responsabilidades del OSI dentro de la organización podemos mencionar los siguientes puntos:

- Definir la Política de Seguridad de la Información de la organización.
- Definir la misión de seguridad informática de la organización en conjunto con los ejecutivos de la empresa.
- Definir y aplicar una metodología de análisis de riesgo para evaluar la seguridad informática en la organización.
- Desarrollar procedimientos de seguridad de la información los cuales sean detallados y que ayuden a fortalecer la política de seguridad de la información dentro de la empresa.
- Seleccionar los mecanismos y herramientas adecuados que permitan aplicar las políticas de seguridad dentro de la misión establecida.
- El responsable de seguridad de la información debe guiar al cuerpo directivo y a la administración de la organización ante incidentes de seguridad mediante un Plan de Respuesta a Incidentes, con el fin de atender en forma oportuna este tipo de eventualidades.
- Promover la aplicación de auditorías enfocadas a la seguridad, para evaluar las prácticas de seguridad informática dentro de la organización.
- Crear y vigilar los lineamientos necesarios que coadyuven a tener los servicios de seguridad de la información dentro de la organización.
- El OSI es responsable de proponer y coordinar la realización de un análisis de riesgos formal en torno a la seguridad de la información que abarque a toda la organización.

3.13.6 FASE DE APLICACIÓN.

En esta fase ya se toman acciones correspondientes a la definición, evaluación y tratamiento del riesgo en específico, el cual tendrá los lineamientos de la Política de Seguridad de la Información previamente definida, Esta fase debe contar con el apoyo del directorio ejecutivo de la organización para que su implementación dentro de la empresa cumpla con los objetivos que permitan minimizar el riesgo identificado. La participación del OSI será en todas las etapas del desarrollo del modelo.

3.13.7 DEFINIR

Se busca formalizar la problemática asociada al riesgo que implica el acceso indebido de personal externo a la red de datos de la empresa, se requiere conocer y documentar el riesgo, el ámbito sobre el que se aplica, las condiciones que se busca controlar y las responsabilidades relacionadas a los controles que se definan. Se define la política de control de acceso a la red que define la posición y las acciones que dispone la organización con respecto a este riesgo.

La política de control de acceso a la red de datos debe estar conformada principalmente por los siguientes puntos:

- La definición de la seguridad con respecto al acceso a la red de datos de la empresa, definiciones, objetivos generales, el alcance e importancia de esta política dentro de la organización, criterios de cumplimiento normativo para su implementación.
- La política debe establecer objetivos generales, definir su alcance e importancia de esta dentro de la organización.
- Definir los activos asociados al tratamiento de riesgos, definir responsabilidades de todos los miembros dentro de la organización.
- La política debe establecer las disposiciones con respecto al acceso a las redes de datos de la empresa, debe señalar el nivel de acceso de personas o entidades externas, y en caso de permitirles su acceso definir los controles que garanticen la protección de la información dentro de la empresa.
- Debe especificar las responsabilidades del personal de la empresa para responder a los riesgos relevantes o significativos una vez presentados y evaluados.

3.13.8 EVALUAR

Se refiere a los elementos que se deben disponer para que la organización se entere de la situación del riesgo identificado en cuanto a la exposición, materialización de este, la criticidad de la situación y los activos de información que se ven afectados de forma directa o indirecta. En esta fase se hace uso de herramientas de análisis o procesos de evaluación de riesgos, sean estos cuantitativos o cualitativos como por ejemplo la aplicación de un software de evaluación de vulnerabilidades o realizar el análisis de riesgos de los activos afectados.

El análisis de riesgos permitirá determinar el estado actual del acceso a la red de datos de la organización, también identificará si se cuenta con algún tipo de control para el acceso a la red de datos. Este análisis nos ayudara a determinar el o los riesgos a los que están expuestos los activos relacionados al acceso de la red de datos de la organización, para su análisis se deberán considerar los siguientes puntos:

- Determinar los activos relevantes para la Organización, su valor en el sentido del costo que supondría si se vieran afectados por algún tipo de incidente de seguridad de la información.
- Determinar a qué amenazas están expuestos los activos previamente identificados.
- Determinar la existencia de controles y cuán eficaces son estos frente al riesgo identificado.
- Estimar el impacto, definido como el daño sobre el activo derivado de la materialización de la amenaza.
- Estimar el riesgo, definido como el impacto ponderado con la tasa de ocurrencia (o expectativa de materialización) de la amenaza

Luego de la evaluación de riesgos es importante poder hacer una prueba de intrusión a la red de acceso de datos de la organización, que permitirá evaluar el nivel de seguridad de un sistema o de sistemas informáticos. Con esto se pretende realizar una simulación de un ataque informático con un objetivo malicioso dentro de la red de datos de la organización para poder ver el nivel de impacto que el mismo causaría dentro de la organización.

La simulación que se lleva a cabo dentro de la organización es tomar el papel de, por ejemplo, un empleado descontento y ver hasta dónde puede llegar este atacante con la información que ya conoce de su entorno de trabajo, es decir acceso a plataformas, contraseñas, acceso a información. Este tipo de ataque se basa en el análisis de los sistemas, para sacar información y así seguir en busca de vulnerabilidades que se puedan aprovechar para llegar a información confidencial de la empresa. Existen diferentes tipos de pruebas de intrusión de los cuales podemos mencionar:

- Test de intrusión de caja negra, en esta prueba el atacante no tiene ningún tipo de información sobre el objeto de ataque, con lo que el atacante tendrá que recolectar información.
- Test de intrusión de caja blanca, donde el atacante tiene bastante información sobre la infraestructura y los sistemas antes de realizar la prueba de intrusión.
- Test de intrusión de caja gris, que es una prueba intermedia entre caja negra y caja blanca, es decir tienes información sobre algunos sistemas de la organización, pero no de otros sistemas de la empresa.

3.13.9 FORZAR

Corresponde a las medidas específicas que la organización enfrenta al riesgo identificado. Se implementa un control que puede ser una herramienta o solución tecnológica de seguridad de la información, como un sistema de control de acceso a la red, o una medida administrativa, como el control de acceso físico de equipos de computación a la organización, también se puede implementar controles basados por ejemplo en la configuración de equipos de red como pueden ser la configuración de puertos de red en los switches de acceso de la empresa.

Tras haber determinado los riesgos existentes en la organización con respecto al acceso indebido a la red de datos se deben tomar las medidas adecuadas para hacer frente a los mismos. La gestión de riesgos es el proceso por el cual se controlan, minimizan o eliminan los riesgos que afecten a los activos de información de la organización.

Se disponen de varias opciones para afrontar los riesgos identificados de las cuales podemos mencionar las siguiente cuatro opciones:

- Eliminar el riesgo. Esto se consigue eliminando los activos a los que este riesgo está asociado. Se trata de una elección drástica por lo que suelen buscarse medidas alternativas.

- Transferir el riesgo. Para ello se considerará la subcontratación de algún servicio externo o la contratación de un seguro que cubra los gastos en el caso de que ocurra este incidente.

- Asumir el riesgo. Ello implica que no se van a tomar medidas de protección contra ese riesgo. La decisión ha de ser tomada y firmada por la dirección ejecutiva de la empresa y sólo es viable en el caso de que la organización controle el riesgo y vigile que el mismo no se incrementa.

- Mitigar el riesgo. Para ello la empresa debe implantar una serie de controles que sirvan para la protección de los activos de la empresa. Todas las medidas implantadas han de ser documentadas y gestionadas por la organización.

Los controles son medidas de seguridad orientadas a mitigar los riesgos encontrados en el análisis de riesgos, existen dos tipos de controles: los procedimentales y tecnológicos. Los controles procedimentales, pueden quedar documentados a través de procedimientos, normativas o políticas de seguridad que regulen el riesgo identificado.

Sobre los controles tecnológicos se pueden encontrar, por ejemplo, la implantación de un sistema de control de acceso a la red o algún tipo de firewall. Estos controles a la vez de ser implementados tienen que también ser documentados a través de procedimientos. Los requisitos a considerar en la selección de un sistema de control de acceso a la red se deben mínimamente poder:

- Proporcionar visibilidad y control sobre los puntos finales de sus redes corporativas, contar con un módulo de reportaría el cual pueda recolectar información en tiempo real para poder hacer un análisis de estos eventos.

- Brindar acceso a la red de acuerdo con las políticas de control de acceso que las empresas definan previamente para así mitigar las amenazas existentes en la red de datos.
- Garantizar la identidad y las autorizaciones de usuarios y dispositivos a los cuales se de acceso a la red de datos.
- Integración con sistemas de detección de amenazas, para que el sistema de control de acceso pueda aplicar automáticamente políticas adecuadas para dispositivos comprometidos que puedan ser una amenaza para la red de datos.

Se cuenta con las siguientes soluciones de acuerdo con el reporte de (Gartner Inc., 2018) donde se muestra los fabricantes mas destacados que desarrollaron sus propuestas de sistemas de control de acceso. Dicho reporte se describe en la figura 36.



Fuente: (Gartner Inc., 2018). Consultado el 25 de Septiembre de 2019, de www.gartner.com.

Figura 36: Reporte Gartner para sistemas de control de acceso a la red.

Cabe mencionar que en el mercado tambien se cuentan con herramientas gratuitas desarrolladas sobre sistemas operativos Open Source como el sistema OpenNac que es una solución de control de acceso y gestión de red que permite autenticar, autorizar y auditar los accesos de dispositivos a la red de datos. En el cuadro 18 se muestra un resumen comparativo de los tres

principales sistemas de control de acceso de acuerdo con el reporte Gartner de la gestión 2018, y dos sistemas con licencia gratuita.

Cuadro 18: Comparación de sistemas de control de acceso.

	COMPARACIÓN DE SISTEMAS DE CONTROL DE ACCESO					
	HP Aruba	Cisco ISE	Extreme Networks	FortiNAC	PacketFence	OpenNAC
						
Rubros de Uso	Educación, entretenimiento, sector salud, finanzas	Gobierno, finanzas, sector salud	Educación, entretenimiento, sector salud	Educación, sector salud, proveedores de servicio	Educación	Educación
Capacidad	10 millones de autenticaciones por día	500,000 sesiones concurrentes y 1,5 millones de clientes por despliegue	200,000 clientes	30,000 puertos	5,000 puertos	5,000 puertos
Servidor del tipo	Físico o Virtual	Físico o Virtual	Físico o Virtual	Físico o Virtual	Virtual	Virtual
Precio aproximado	Varia por cantidad de usuarios	Basada en suscripción y por cantidad de dispositivos	Por usuario	4,500 \$ por licencia profesional	Sin costo	Sin costo

Fuente: Elaboración propia usando Excel 2019.

3.13.10 MONITOREAR Y DETECTAR

Se refiere a las medidas destinadas a verificar el correcto funcionamiento del control implantado respecto de lo definido previamente por la institución. En esta etapa se utilizan herramientas de monitoreo o se establecen procedimientos que permitan conocer y verificar el correcto funcionamiento del control implantado.

El o los controles implementados deben ser revisados periódicamente para asegurar que se cumplan con los objetivos marcados por la organización. Para realizar este seguimiento es necesario establecer una serie de indicadores que nos permitan determinar el estado del sistema. El análisis de indicadores requiere que cada uno de los controles implantados esté asociado a una serie de registros que recopilen la información necesaria para el estudio del control.

Para el estudio realizado disponemos de un indicador de reporte de conexiones cuyo objetivo es mostrar la cantidad de equipos conectados, cantidad de equipos autorizados y cantidad de equipos rechazados. Para poder medir esta cantidad de conexiones, se debe crear algún tipo de registro en el que se recojan estos índices en el o los controles implementados. La revisión de estos registros permitirá observar si el sistema está funcionando tal y como se determinó en los objetivos previamente establecidos.

En caso de que el monitoreo detecte que no se están cumpliendo con los objetivos preestablecidos de acuerdo con los registros presentados por el o los controles implementados, se deben generar reportes para poder hacer los ajustes necesarios a los controles de control de acceso a la red.

Los controles tecnológicos por implementar para monitorear y detectar el correcto funcionamiento del sistema de control de acceso a la red deben tener las siguientes características:

- Registro de dispositivos
- Detección y monitorización de redes
- Detección de actividades anómalas en la red

3.13.11 RESPONDER

Corresponde a las medidas dispuestas para actuar en caso de que el monitoreo detecte un comportamiento anómalo del control o una situación que inicialmente no se haya previsto, normalmente se trata de medidas administrativas.

Tras la etapa de monitoreo y detección de haberse reportado alguna anomalía, se deberán ejecutar una serie de acciones dentro de la organización las cuales son:

- Decidir si es necesario realizar mejoras dentro del control o los controles implementados, que modificaciones se van a llevar a cabo y de existir cuál sería su repercusión económica y laboral dentro de la organización.

- Se tendrá que revisar la evaluación y la gestión de riesgos hecha inicialmente.
- Se tendrá que realizar una actualización de los procedimientos y controles si estos no cumplen con los objetivos inicialmente establecidos.

Las acciones correctivas resuelven un problema observado durante la etapa de monitoreo. Estas acciones pueden ir desde la actualización de un documento hasta el cambio en la infraestructura de red. Las acciones correctivas deben ser realizadas tan pronto como sean detectadas las incidencias.

3.13.12 CUMPLIR

Se refiere a los registros de eventos que se tienen con respecto al funcionamiento de los controles implementados y que sirven para demostrar que las acciones que la empresa ha dispuesto para controlar el riesgo efectivamente existen y funcionan. Normalmente se visualizan registros de eventos, registros de accesos de usuarios o de ejecución de tareas dentro del sistema de control de acceso a la red.

En esta etapa se pretende demostrar el cumplimiento de los objetivos previamente definidos en la etapa de definición donde se identificaron los riesgos que se tienen en cuanto al acceso indebido a personal externo de la red de datos de la empresa, se pretende contar con algún respaldo de registro de eventos de el o los controles a implementar, Estos registros nos mostraran el cumplimiento del control implementado para tratar el riesgo identificado.

Se pretende definir de manera formal los procedimientos para poder generar y almacenar los registros de eventos con respecto al control de acceso a la red. Si el control es del tipo tecnológico se debe contar con algún procedimiento para tener el respaldo de las configuraciones del sistema para ante cualquier contingencia proceder con su restauración.

El control tecnológico debe contar con la facultad de poder demostrar que se están cumpliendo con el control de acceso a la red a los diferentes dispositivos de red, para lo cual este sistema debe contar con las siguientes características:

- Administración centralizada.
- Visibilidad de los dispositivos.
- Módulo de reporte de eventos en línea o históricos.
- Almacenamiento de eventos en forma local o en repositorios externos.

3.13.13 DIFUNDIR

Esta etapa corresponde a la entrega constante de información a la organización sobre la importancia de mantener la seguridad de la información y el resguardo de todas las actividades relacionadas a Tecnologías de la Información. Es fundamental que todos los involucrados conozcan el qué y para qué de este modelo de seguridad de la información, la organización asegurará que el personal tiene conocimiento de la necesidad e importancia de las actividades de seguridad de la información que le corresponde realizar y cómo ellas contribuyen al logro de los objetivos del modelo propuesto.

Se pretende difundir en forma planificada entre todo el personal de la institución el objetivo de la empresa para la protección de la información mediante la implementación de controles que restrinjan el acceso indebido a la red de la organización, mostrar las características de los controles implementados, las áreas responsables en cuanto al tratamiento de estos riesgos. Esta difusión debe ser hecha a partir de planes de capacitación anual de la institución con actividades permanentes y que también deben ser parte del proceso de inducción del nuevo personal, también se puede hacer uso de boletines informativos que pueden ser enviados a través de correos electrónicos a todo el personal de la organización.

CAPITULO IV

MARCO PRACTICO

4.1 DIAGNOSTICO ACTUAL DE LA EMPRESA

En este apartado, se detalla la situación actual del Banco Nacional de Bolivia, para tener como antecedente para la presentación de la propuesta del modelo de seguridad de la información.

4.1.1 DIAGRAMA DE OBJETIVOS

El diagrama de objetivos representa de forma gráfica los objetivos que la empresa desea conseguir, los cuales están alineados a su visión y misión empresarial. Para el caso del Banco Nacional de Bolivia tiene la siguiente misión institucional mostrada en la figura 37.



Fuente: Plan estratégico BNB 2019

Figura 37: Misión BNB.

Sobre la vision que tiene trazado el BNB se puede apreciar que para brindar la mejor experiencia bancaria a sus clientes hacen énfasis en la innovación de nuevos productos que estén enfocados en la transformación digital. En la figura 38 se muestra la visión corporativa de la institución.

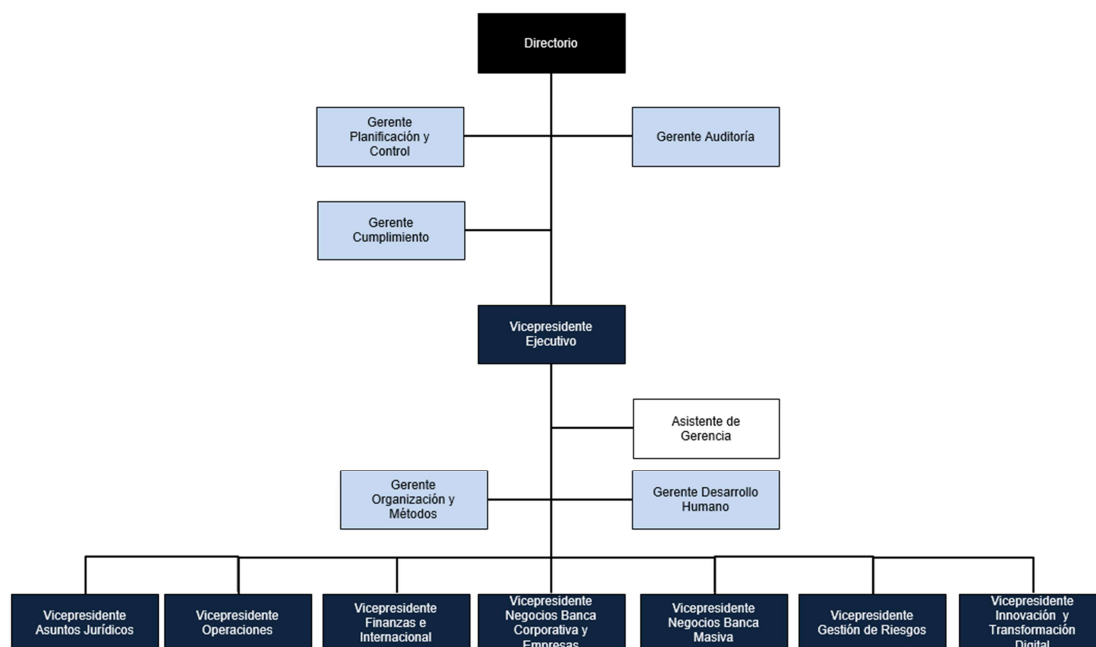


Fuente: Plan estratégico BNB 2019

Figura 38: Visión BNB.

4.1.2 ESTRUCTURA ORGANIZACIONAL

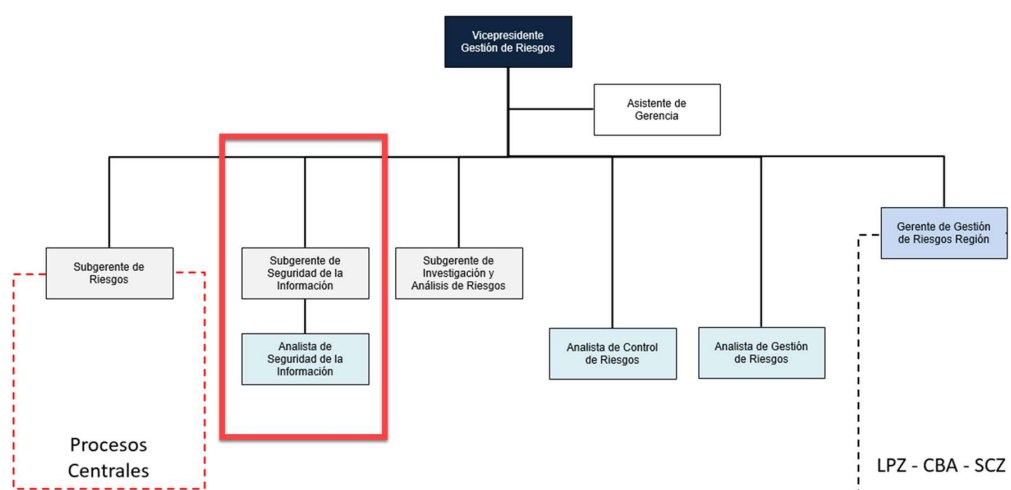
El organigrama representa de forma gráfica la estructura organizacional de la empresa. Para el caso de estudio se tiene la siguiente estructura organizacional que se muestra en la figura 39.



Fuente: Estructura Organizacional BNB 2019

Figura 39: Organigrama BNB.

En la siguiente figura 40, se muestra la estructura organizacional de la Vicepresidencia de gestión de riesgos donde se ve la dependencia de la Subgerencia de seguridad de la información.

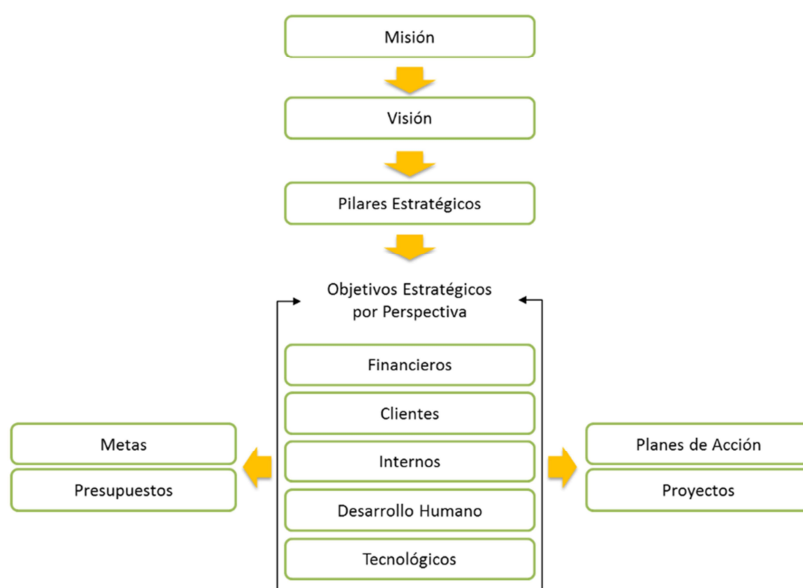


Fuente: Estructura Organizacional BNB 2019

Figura 40: Organigrama Vicepresidencia de gestión de riesgos BNB.

4.1.3 PLAN ESTRATÉGICO

El caso de estudio desarrollo el siguiente modelo de planificación estratégica el cual este compuesto por la misión, visión y pilares estratégicos descritos previamente, y desarrolla sus planes estratégicos que son divididos en las áreas de: financiera, de clientes, de usuarios internos, de desarrollo humano y el área tecnológica. En la figura 41 se hace una descripción del modelo estratégico del caso de estudio.



Fuente: Plan estratégico BNB 2019

Figura 41: Modelo de planificación estratégica BNB.

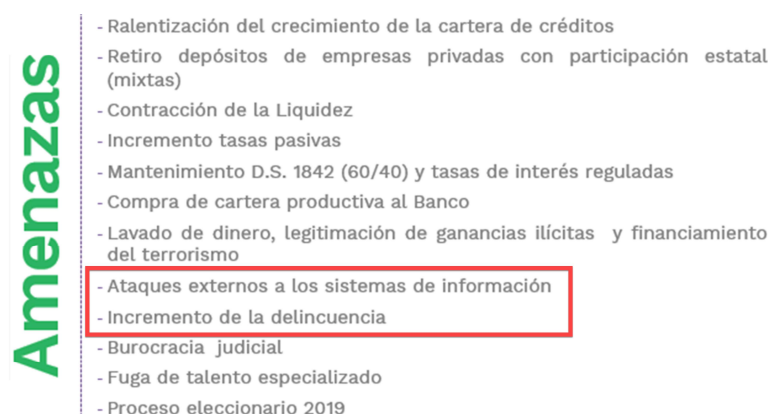
Para poder realizar la planificación estratégica anual se hizo una evaluación de las fortalezas, debilidades, oportunidades y amenazas las cuales son mostradas en las siguientes figuras.



Fuente: Plan estratégico BNB 2019

Figura 42: Análisis de fortalezas BNB.

En la figura 43 se muestra el detalle del análisis de amenazas del caso de estudio de la cual podemos destacar que se considera a los ataques externos a los sistemas de seguridad de la información de la institución como una amenaza importante a tratar.

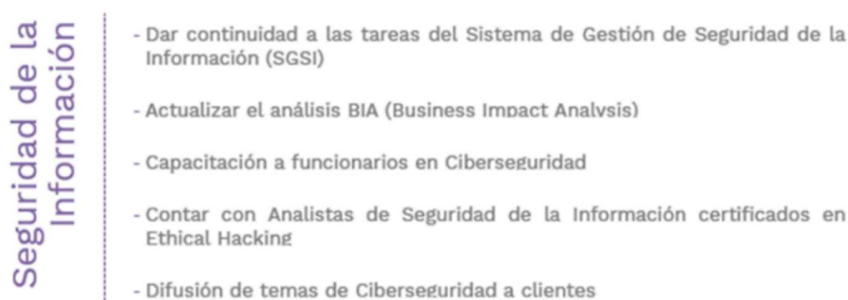


Fuente: Plan estratégico BNB 2019

Figura 43: Análisis de amenazas BNB.

En base al análisis realizado se traza el plan estratégico de la gestión 2019 del BNB que tiene al proceso de gestión de riesgos como parte importante dentro de todos los procesos ya que el mismo es transversal. Este plan estratégico para la gestión de riesgos considera dos tareas importantes: la de mitigar los riesgos asociados al negocio y el de asegurar la continuidad de los servicios. Para la prevención de riesgos asociados a la seguridad de la información se tiene como tareas el de dar continuidad a las tareas del sistema de gestión de seguridad de la información, actualizar el análisis de impacto del negocio BIA ⁹⁹, estas tareas se muestran en la figura 44.

Prevenir los Riesgos Asociados al Negocio

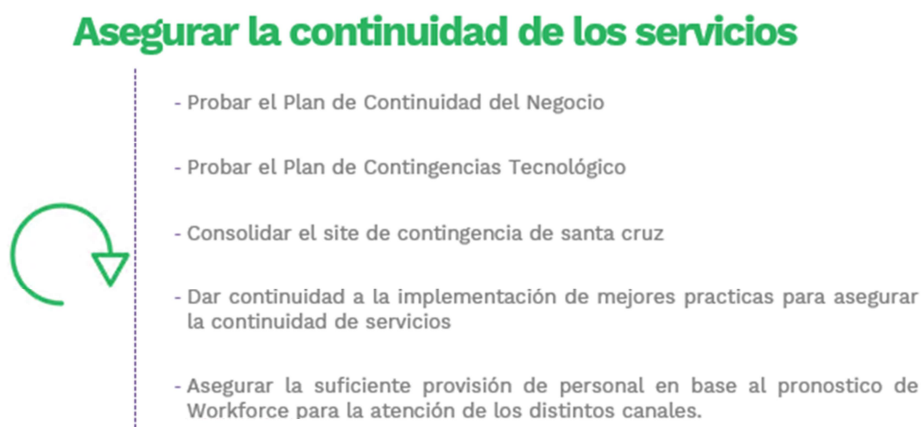


Fuente: Plan estratégico BNB 2019

Figura 44: Mapa estratégico, seguridad de la información BNB.

⁹⁹ BIA Business Impact Analysis.

Otra tarea importante en la gestión de riesgos es la de asegurar la continuidad de sus servicios, esto a través de planes de continuidad del negocio, y de contingencias tecnológicas, otra tarea importante es la consolidar su sitio de contingencias en su sucursal de la ciudad de Santa Cruz, en la figura 45 se muestra el detalle del plan estratégico para la continuidad de servicios.



Fuente: Plan estratégico BNB 2019

Figura 45: Mapa estratégico, continuidad de servicios BNB.

4.2 APLICACIÓN DEL MODELO PROPUESTO CASO DE ESTUDIO BNB

En esta sección se desarrollará el modelo previamente establecido en el capítulo III de este documento, y se tomara como caso de estudio al Banco Nacional de Bolivia, institución de donde se recopilaron los papeles de trabajo previamente presentados en las secciones de: diagnostico actual de la empresa, revisión de normativa interna y entrevistas realizadas al personal a cargo de la seguridad de la información e infraestructura tecnológica.

Considerando lo descrito previamente, el o las áreas responsables de la definición, formalización e implementación del modelo de seguridad de la información para el control de acceso a la red son principalmente la Subgerencia de Seguridad de la Información en conjunto con la Subgerencia de Infraestructura Tecnológica quienes, para efectos de su implementación, realizaran las tareas de ejecución, medición, ajuste y la determinación de los recursos que sean necesarios para la aplicación del modelo propuesto. En la figura 46 se muestra el modelo propuesto aplicado en el Banco nacional de Bolivia.



Fuente: Elaboración propia usando Visio 2019.

Figura 46: Modelo de seguridad de la información para el control de acceso a la red del BNB.

En la fase de preparación haremos una descripción de las etapas con las que ya cuenta la empresa para que en la fase de desarrollo se aplique de lleno el modelo propuesto. Es por eso por lo que a continuación se hace una descripción de las etapas de la fase de preparación.

4.2.1 COMITÉ DE GESTIÓN INTEGRAL DE RIESGOS BNB

a) Objetivo

El comité de gestión integral de riesgos tiene como objetivo principal el control de la gestión de los riesgos asumidos por el Banco, como parte de sus actividades de intermediación financiera. Esta instancia es la encargada del diseño de políticas, sistemas, metodologías, modelos y procedimientos para la eficiente gestión integral de riesgo y de los límites de exposición al riesgo dentro del BNB.

b) Control

El comité tiene reuniones mínimamente cada tres meses, o a requerimiento de cualquiera de sus miembros, previa aprobación del presidente del comité. En este comité entre otras tareas se definen proyectos de tecnología que impliquen la aplicación de Seguridad de la Información dentro del banco, aprueban las principales iniciativas para incrementar la Seguridad de la Información. Los temas tratados y las principales decisiones adoptadas por este comité son incluidas en actas que están a cargo del secretario designado y las mismas son firmadas por los participantes de este comité y permanecen en poder del secretario designado.

c) Procedimiento de implementación

El BNB cuenta con un comité de gestión integral de riesgos, que es la entidad encargada del diseño de políticas, sistemas, metodologías modelos y procedimientos para la gestión integral de riesgo y de los límites de exposición a los diferentes tipos de riesgo dentro del BNB como son: riesgo crediticio, operativo, legal, de liquidez, de mercado y de seguridad de la información.

Este comité es responsable de diseñar y proponer para la aprobación del directorio, políticas, estrategias y procedimientos de riesgos integrales y específicos del banco, para su consideración en el directorio, tomando en cuenta las etapas de identificación, medición, monitoreo, control, mitigación y divulgación de riesgos.

Este comité se encarga de proponer al directorio ejecutivo del BNB, mecanismos para que se asegure la correcta ejecución de las estrategias, políticas, metodologías, procesos y procedimientos para la gestión integral de riesgos por parte de la Vicepresidencia Ejecutiva y de las áreas involucradas.

En cuanto a las responsabilidades específicas de este comité con respecto a la gestión de riesgos de seguridad de la información tiene como responsabilidades:

- Conocer el estado de la seguridad de la información.
- Revisar y recomendar la aprobación de políticas, normas y demás definiciones en lo que respecta a Seguridad de la Información.
- Formalizar la postura corporativa respecto a la Seguridad de la Información.

- Revisar y recomendar la aprobación de políticas, normas y demás definiciones en lo que respecta a seguridad de la información.
- Revisar y recomendar la asignación de recursos para priorizar los proyectos de seguridad, así como realizar el seguimiento correspondiente.
- Tomar conocimiento de los incidentes de seguridad y verificar que se hayan tomado las medidas adecuadas para solucionar la situación y prevenir ocurrencias futuras.
- Definir acciones correctivas o preventivas a partir de situaciones que puedan representar un riesgo para la organización.

El comité de Gestión Integral de Riesgos del BNB está conformado por los siguientes miembros permanentes:

- Presidente del directorio BNB (presidente)
- Director Vocal
- Vicepresidente Ejecutivo
- Vicepresidente Negocios
- Vicepresidente Gestión de Riesgos

Eventualmente en algunas reuniones de este comité participa el Subgerente de Seguridad de la Información cuando se presentan a consideración de este comité temas específicos con referencia a incidentes o proyectos relacionados a la Seguridad de la Información.

4.2.2 APOYO DIRECTIVO BNB

a) Objetivo

El comité de Directorio del BNB, tiene como objetivo principal considerar todo tipo de solicitudes y operaciones que correspondan a este nivel jerárquico, velando por el cumplimiento de las políticas y normativas del banco dispuestas para este efecto. Este comité representa una instancia decisoria y fundamental en la toma de decisiones sobre los procesos críticos del banco. Para el modelo propuesto debe existir un apoyo de parte del directorio a los temas relacionados a la seguridad de la información.

b) Control

El comité de Directorio del BNB tiene reuniones mínimamente de forma mensual, o a requerimiento de cualquiera de sus miembros, previa aprobación del presidente del comité. Los temas tratados y las principales decisiones adoptadas por este comité de directorio son incluidas en actas que están a cargo del Vicepresidente de Asuntos Jurídicos, las mismas son firmadas por los participantes de este comité y permanecen en poder del Vicepresidente de Asuntos Jurídicos para su seguimiento.

c) Procedimiento de implementación

El comité de directorio del BNB tiene como principales atribuciones:

- Conocer y comprender los riesgos inherentes a los que está expuesto el Banco o el Grupo Financiero del BNB a fin de establecer una estrategia y lineamientos para la gestión integral de riesgos, así como el perfil de riesgos que sea aceptable.
- Aprobar y revisar periódicamente el marco conceptual para la gestión integral de riesgos y de cada riesgo en particular.
- Aprobar, revisar, actualizar y realizar seguimiento a las estrategias, políticas y procedimientos para identificar, medir, monitorear, controlar, mitigar y divulgar la gestión integral de riesgos.
- Aprobar las metodologías de medición de niveles de exposición para los distintos tipos de riesgo dentro de la organización.
- Asegurar que el Banco cuente con sistemas de información que permiten una adecuada gestión integral de riesgos y que los informes periódicos presentados al Directorio reflejen el perfil de riesgos del banco.
- Convocar a reunión extraordinaria con el Comité de Gestión Integral de Riesgos cuando se detecten desviaciones a los límites, políticas o procedimientos a los riesgos dentro del BNB y cuando la desviación detectada así lo amerite.
- Revisar y aprobar los planes de contingencia de acuerdo con el tipo de riesgo, así como el plan de continuidad de las operaciones del banco.
- Designar a los miembros del Comité de Gestión Integral de Riesgos y conformar una Unidad de Gestión de Riesgos designando al responsable de esta área.
- Asegurar que el nivel patrimonial del banco sea suficiente para cubrir sus niveles de riesgo.

- Presidente del directorio BNB (presidente)
- Primer vicepresidente
- Segundo vicepresidente
- Secretario del directorio
- Director vocal 1
- Director vocal 2

Resoluciones - 064	
VER  Editar elemento  Compartido con  Eliminar elemento Historial de versiones  Enviar alertas Administrar Acciones	
Resolución	064
Gestión	2019
Directorio	07
Fecha	25/03/2019
Descripción	9. CONSIDERACIÓN INFORME DE ANÁLISIS DE RIESGOS EN SEGURIDAD DE LA INFORMACIÓN GESTIÓN 2018.- En uso de la palabra, el Vicepresidente Gestión de Riesgos, con gráficos preparados el efecto, presentó los resultados del informe de actualización al Análisis de Riesgos en Seguridad de la Información correspondiente a activos de información críticos que, de manera previa, fue considerado y aprobado por el Comité de Gestión Integral de Riesgos del Banco. El mismo concluye que los riesgos identificados presentan un resultado de valoración de nivel bajo a medio y están debidamente tratados. Luego de una serie de consideraciones por parte de los señores Directores en referencia al Informe sobre el Análisis de Riesgos en Seguridad de la Información al 31 de diciembre de 2018 del Banco Nacional de Bolivia S.A., fue aprobado por unanimidad. (Resolución N° 064/2019)

Creado el 02/05/2019 12:39 por

Última modificación realizada el 02/05/2019 12:39 por

Cerrar

Figura 47: Consideración informe de análisis de riesgos.

EL BNB cuenta con una política de seguridad de la información cuyo objetivo fundamental es el de formalizar el pensamiento de la empresa respecto de la importancia que la información tiene para el BNB y las medidas de protección a implementar para protegerla a través del

desarrollo de procedimientos concretos de seguridad. Con esta política se busca divulgar y homologar la forma en que los trabajadores y la alta dirección entienden la importancia que tiene la seguridad de la información dentro de la empresa.

b) Control

El presente documento declara el apoyo de la dirección ejecutiva compuesta por el Directorio, presidente, y vicepresidentes y otras áreas que apoyen a la gestión de la seguridad de la información de acuerdo con los objetivos estratégicos del banco. El BNB cuenta con este documento el cual fue analizado previamente en la sección de revisión de normativa interna. Este documento es revisado y modificado anualmente de acuerdo con las consideraciones hechas por el comité de gestión de riesgos y es aprobado por el comité de directorio del BNB.

c) Procedimiento de implementación

El documento de la política de seguridad de la información cuenta con las siguientes directrices:

- El BNB debe velar que la información, los sistemas de información y los activos de información estén apropiadamente resguardados frente a las amenazas que se ven expuestos.
- La seguridad de la información y de los activos asociados a su tratamiento, es responsabilidad de todos los miembros de la organización, que, por motivo de sus funciones, la utilicen en cualquier grado.
- La organización declara su decisión de cumplir con la normativa y legislación vigente de los organismos fiscalizadores relacionados con aspectos de seguridad y protección de la información de sus clientes, trabajadores y accionistas.
- Las disposiciones relacionadas con la seguridad de la información serán debidamente controladas en su cumplimiento por los estamentos definidos por la organización, los que monitorean y medirán el estado de la seguridad y tomarán acciones para corregir riesgos o debilidades e incrementar el nivel de protección existente.
- El Banco reconoce que la sensibilización, capacitación y entrenamiento adecuados a su personal en las materias de Seguridad de la Información son tareas prioritarias. Las instancias responsables para la seguridad de la información en el Banco son:
- Directorio: Que es la instancia responsable de la aprobación de políticas, procedimientos y otros instrumentos, relacionados con la Gestión de Seguridad de la Información. Debe definir

los objetivos de la función de Seguridad de la Información y la estrategia para alcanzarlos.

- Comité de Gestión Integral de Riesgos: Tiene a su cargo la discusión y definición de los lineamientos estratégicos de la Seguridad de la Información del banco para ser puestos en consideración del Directorio.
- Vicepresidencia Ejecutiva: Responsable a través de la Vicepresidencia de Gestión de Riesgos y a su vez, a través de la Subgerencia de la Seguridad de la Información de la implementación, difusión interna en todos los niveles de la organización y cumplimiento de esta Política.
- Subgerente de Seguridad de la Información: Es el principal encargado de asegurar que las políticas, procedimientos y definiciones hechas por el Directorio, se cumplan respecto de lo definido en el Sistema de Gestión de Seguridad de la Información.

4.2.4 SUBGERENTE DE SEGURIDAD DE LA INFORMACIÓN BNB

El banco cuenta con un responsable de Seguridad de la Información que tiene el cargo de Subgerente de Seguridad de la Información quien es la persona que gestiona la seguridad de la información del banco a través del desarrollo e implementación de un Sistema de Gestión de Seguridad de la Información, este cargo tiene como visión la de mitigar y minimizar riesgos asociados a la seguridad de la Información a través de un Sistema de Gestión de Seguridad de la Información propio del banco, basado en la normativa emitida por el organismo regulador ASFI y mejores prácticas y estándares internacionales. Esta persona trabaja con distintas áreas del BNB de acuerdo con lo que se muestra en el cuadro 19.

Cuadro 19: Mapa de interrelación del Subgerente de Seguridad de la Información.

MAPA DE INTERRELACIONES SUBGERENTE DE S.I.		
PROVEEDORES	PRODUCTO / SERVICIO	CLIENTE
Vicepresidente Gestión de Riesgos	Misión, visión, objetivos, plan operativo anual, políticas, procedimientos y estrategias relacionados con gestión de riesgos informáticos.	Subgerente de Seguridad de la Información.
Gerente de Tecnología/ Subgerente de Desarrollo	Información sobre temas relacionados con: software interno y externo y su documentación.	Subgerente de Seguridad de la Información.

Subgerente de Infraestructura Tecnológica/ Subgerente de Producción	Información sobre temas relacionados con hardware, conexiones y redes	Subgerente de Seguridad de la Información.
Subgerente de Seguridad de la Información.	Reportes e informes referidos a: - Cumplimiento de políticas, normas y procedimientos de seguridad. - Resultado de seguimiento a la implementación de nuevos controles. - Propuesta de acciones de mitigación de riesgos en la seguridad de la información. - Resultado de planes de acción adoptados para mitigar riesgos identificados.	Vicepresidente Gestión de Riesgos.
Vicepresidentes/ Gerentes de División/ Gerentes de Sucursal/ Subgerente de Riesgos.	Definición de propiedad y carácter cualitativo de la información, necesarios para desarrollar la cultura de seguridad de esta.	Subgerente de Seguridad de la Información.

Fuente: Manual de funciones RRHH BNB.

También hay que indicar que la organización considero la necesidad de un recurso humano que trabaje en el área de tecnología que tenga conocimientos de seguridad informática para lo cual lanzo una convocatoria externa como se muestra en la figura 48.



Fuente: (LinkedIn). Consultado el 26 de Octubre de 2019, de www.linkedin.com

Figura 48: Convocatoria RRHH BNB.

Este recurso tendrá dependencia directa de la Gerencia de Tecnología del BNB y coadyuvará en el desarrollo de proyectos tecnológicos con respecto a la seguridad de la información dentro de la organización, trabajará en forma conjunta tanto con el área de seguridad de la información como con el área de tecnología.

4.2.5 DEFINIR LA POLÍTICA DE CONTROL DE ACCESO A LA RED DE DATOS

a) Objetivo

Extender orientación a la organización con respecto a los riesgos que implican el acceso indebido de personal externo dentro de la red de datos del BNB.

b) Control

Este documento declara el apoyo del directorio ejecutivo a la gestión de la seguridad de la información para el control de acceso a la red de datos que están alineados a la política de seguridad de la información de la organización.

c) Procedimiento de implementación

El documento de la política de control de acceso a la red de datos propuesto por el investigador se muestra en forma inextensa en el Anexo III de este documento, y está conformado principalmente con las declaraciones relacionadas a:

- La definición de la seguridad con respecto al acceso a la red de datos de la empresa, definiciones, objetivos generales, alcance e importancia, directrices y cumplimiento normativo para la implementación de esta política.
- La empresa debe dar valor a la información, los sistemas de información y sus activos estén apropiadamente resguardados frente a las amenazas a las que se ven expuestos.
- La Seguridad de la Información y los activos asociados a su tratamiento, es responsabilidad de todos los miembros de la organización que la utilicen en cualquier grado.
- Los accesos a las redes de datos no deben quedar disponibles a personas o entidades externas a la empresa, salvo en situaciones establecidas con controles que garanticen su protección.
- Todo empleado o colaborador tiene la obligación de notificar cualquier actividad o situación que afecte o pueda afectar la seguridad de los activos de información.

- Es propiedad del banco toda información que se genere procese y transmita haciendo uso de los recursos de tecnología de la organización.
- El directorio es responsable de determinar cómo responder a los riesgos relevantes o significativos una vez presentados y evaluados los mismos.

4.2.6 EVALUAR EL RIESGO DEL ACCESO NO AUTORIZADO

a) Objetivo

En esta etapa se realiza una evaluación de riesgos de los activos de información que son parte del proceso de acceso a la red de datos para de esta manera poder implementar los controles adecuados para mitigar el riesgo identificado.

b) Control

Como controles de esta fase del modelo de seguridad de la información, se presentan una planilla Excel que muestre la evaluación de activos de información y la evaluación de riesgos con respecto al acceso no autorizado a la red. También se presentará evidencias de pruebas de intrusión las cuales mostraran el riesgo que se presenta con respecto al acceso indebido a la red.

c) Procedimiento de implementación

Para la implementación de esta fase para la evaluación de riesgos nos apoyaremos en la normativa interna del BNB con respecto a la metodología de evaluación de riesgos analizada previamente en la sección de revisión de normativa interna. En primera instancia se hace la identificación de activos de información a los cuales se hará una evaluación de riesgos. En el cuadro 20 se muestra el inventario de activos relacionados al acceso de la red de datos.

Cuadro 20: Inventario de activos de acceso a la red de datos.

INVENTARIO DE ACTIVOS RELACIONADOS AL ACCESO DE LA RED DE DATOS				
N. ACTIVO	NOMBRE DE ACTIVO	DESCRIPCION DEL ACTIVO	CATEGORIA DEL ACTIVO	UBICACIÓN DEL ACTIVO DE INFORMACIÓN
A1	Dispositivos de red de capa de acceso	Dispositivos encargados de la conectividad de la red. Switch de capa de acceso.	Equipamiento Informático	Cuarto de equipos, el cual cumple también la función del cuarto de comunicaciones en las instalaciones de la organización.

A2	Cuarto de equipos	Instalación física donde residen los dispositivos de red.	Instalaciones	Instalación física de la organización
A3	Red de área local - LAN	Red LAN corporativa de la entidad	Redes de comunicaciones	Instalación física de la organización

Fuente: Elaboración propia con Excel 2019.

Ya identificados los activos se estableció su valoración en términos de confidencialidad, integridad y disponibilidad teniendo presente la importancia del activo para la continuidad del negocio, así como el impacto que puede causar para la organización a nivel financiero, jurídico y de imagen corporativa la pérdida de alguna de estas características. En el cuadro 21 se muestra cómo se hará la valoración de criticidad del activo de información.

Cuadro 21: Determinación de criticidad de activos.

DETERMINACIÓN DE CRITICIDAD DEL ACTIVO		
DIMENSIÓN DE SEGURIDAD	ASPECTO AFECTADO	PREGUNTA FORMULADA
Confidencialidad	Financiero	¿La divulgación no autorizada de un activo de información sensible afecta la estrategia del negocio y el estado financiero de la organización?
	Jurídico	¿La divulgación no autorizada de un activo de información sensible ocasiona el incumplimiento de la normatividad y/o puede generar demanda de terceros?
	Imagen Corporativa	¿La divulgación no autorizada de un activo de información afecta la credibilidad y buen nombre de la organización?
Integridad	Financiero	¿La modificación no autorizada de un activo de información genera costos en reprocesos, afectación de estrategias de negocio y posibles costos en procesos jurídicos?
	Jurídico	¿La modificación no autorizada de un activo de información incurre en aplicación de sanciones legales y jurídicas?
	Imagen Corporativa	¿La modificación no autorizada de un activo de información afecta negativamente la imagen institucional?
Disponibilidad	Financiero	¿La indisponibilidad de un activo de información afecta los ingresos económicos de la organización y las estrategias del negocio?
	Jurídico	¿La indisponibilidad de un activo de información genera sanciones legales y jurídicas?
	Imagen Corporativa	¿La indisponibilidad de un activo de información afecta la operación y la imagen corporativa ante terceros?

Fuente: Elaboración propia con Excel 2019.

Las dimensiones de seguridad serán valoradas teniendo presente los siguientes aspectos y criterios de valoración que se muestran en el cuadro 22 donde se muestran los criterios de valoración de los activos de información

Cuadro 22: Criterios de valoración de los activos de información.

CRITERIOS DE VALORACIÓN DE LOS ACTIVOS DE INFORMACIÓN			
ASPECTO	CONSECUENCIAS DE LA PERDIDA DEL ACTIVO	CRITERIO DE VALORACIÓN	VALOR ASIGNADO
Financiero	Pérdida de recursos económicos que pueden afectar la continuidad del negocio. (Porcentaje definido sobre la utilidad operacional de la línea de negocio)	Entre 0% y 0.9%	1
		Entre 1% y 10%	2
		Entre 11% y 20%	3
		Superior al 20%	4
Jurídicos	Incumplimiento de la ley de protección de datos o del contrato ocasionando demandas legales por parte de sus clientes.	No se presenta una afectación al interior de la organización.	1
		Genera procesos de auditoria y/o control interno para determinar las acciones correctivas y preventivas según aplique.	2
		Cancelación del contrato del personal que afecto el activo de información.	3
		Inicio de un proceso penal por afectación de la confidencialidad, integridad y/o disponibilidad de la información.	4
Financiero	Pérdida de prestigio y buen nombre de la organización ante sus clientes, proveedores y terceros.	No hay una afectación en la imagen de la organización.	1
		Es conocido de manera interna solo por el área de desarrollo.	2
		Afectación de la imagen al interior de la organización, sin ser de dominio público.	3
		Desprestigio de la organización ante terceros (Clientes, Proveedores y demás).	4

Fuente: Elaboración propia con Excel 2019.

Valorando la afectación que puede tener la pérdida parcial y/o total de confidencialidad, integridad y /o disponibilidad a nivel financiero, jurídico y de imagen corporativa se determina el nivel de criticidad del activo relacionado con el sistema de información aplicando la siguiente ponderación que se muestra en el cuadro 23.

Cuadro 23: Nivel de criticidad del activo de información.

NIVEL DE CRITICIDAD DEL ACTIVO DE INFORMACIÓN		
ASPECTO	VALOR DE CRITICIDAD DEL ACTIVO	NIVEL CRITICIDAD
Cuando el promedio de valoración del activo en términos de confidencialidad, integridad y disponibilidad es igual a 1	Muy bajo	Es igual a 1
Cuando el promedio de valoración del activo en términos de confidencialidad, integridad y disponibilidad es mayor a 1 y menor a 2	Bajo	Mayor a 1 y menor o igual a 2
Cuando el promedio de valoración del activo en términos de confidencialidad, integridad y disponibilidad es mayor a 2 y menor a 3	Medio	Mayor a 2 y menor o igual a 3
Cuando el promedio de valoración del activo en términos de confidencialidad, integridad y disponibilidad es mayor a 3 y menor a 4	Alto	Mayor a 3 y menor o igual a 4

Fuente: Elaboración propia con Excel 2019.

De acuerdo con el procedimiento de clasificación y valoración de los activos relacionados con el control de acceso a la red el cual se visualiza en la tabla 24.

Cuadro 24: Valoración de activos relacionados al control de acceso a la red.

VALORACION DE ACTIVOS RELACIONADOS CON EL CONTROL DE ACCESO A LA RED														
IDENTIFICACION DEL ACTIVO DE INFORMACION		CONFIDENCIALIDAD			INTEGRIDAD			DISPONIBILIDAD			CONSOLIDADO DE VALORACION			
N. ACTIVO	NOMBRE DEL ACTIVO	FINANCIERO	JURIDICO	IMAGEN	FINANCIERO	JURIDICO	IMAGEN	FINANCIERO	JURIDICO	IMAGEN	CONFIDENCIAL	INTEGRIDAD	DISPONIBILIDAD	CRITICIDAD DEL ACTIVO
A1	Dispositivos de red de acceso	4	4	3	4	2	3	4	2	3	4	4	4	Alto
A2	Cuarto de equipos	4	2	3	2	2	3	3	2	3	4	3	3	Alto
A3	Red de área local - LAN	4	4	3	4	2	3	4	2	3	4	4	4	Alto

Fuente: Elaboración propia con Excel 2019.

De acuerdo con los activos seleccionados para realizar el análisis de riesgos definidos anteriormente, se realizó la identificación de vulnerabilidades, amenazas y posibles

consecuencias de la materialización de una amenaza sobre alguna vulnerabilidad a partir de la información recopilada en la fase de análisis la cual se muestra en el cuadro 25.

Cuadro 25: Determinación de vulnerabilidades y amenazas sobre los activos de información.

IDENTIFICACIÓN DE VULNERABILIDADES Y AMENAZAS			
ACTIVO DE INFORMACIÓN	CAUSAS		CONSECUENCIAS (IMPACTO)
	VULNERABILIDADES	AMENAZAS	
Red LAN corporativa	• No existe un registro de los equipos de red que tienen acceso a la red de datos del banco, no se identifica su estado (Activo, Bloqueado, Deshabilitado). • Ausencia de configuraciones de red bajo criterios de seguridad de la información. • No existe una política de control de acceso a la red. • Pérdida de confidencialidad de información que puede ser sensible para la entidad debido a que es compartida a través de la infraestructura de red de la organización, permitiendo su visualización a personas no autorizadas. • No existe segregación de redes entre los diferentes segmentos de red del banco.	• Fuga de información debido al acceso de usuarios no autorizados a la infraestructura de red de la organización. • Indisponibilidad del servicio de la red debido a ataques de denegación de servicios (DoS). • Terceros realizan procesos de suplantación de identidad para acceder a los aplicativos tecnológicos de la entidad que se encuentran disponibles a través de la red de datos corporativa. • Equipos externos que se conectan a la red de datos pueden tener algún tipo de virus informático que puede expandirse en la red de datos. • Equipos externos pueden acceder a los segmentos de red como la red de servidores.	• Pérdida de disponibilidad, integridad y confidencialidad de la información de la entidad, generando un impacto negativo en la continuidad del negocio. • Afectación en los ingresos económicos de la organización debido a la pérdida de clientes a causa de la divulgación no autorizada de información a la competencia. • Indisponibilidad de los servicios que se brindan a través de la red ocasionando tiempos no productivos de la organización. • Desprestigio de la imagen corporativa debido a la divulgación no autorizada de información confidencial por parte del personal interno y/o externo de la entidad

Fuente: Elaboración propia con Excel 2019.

Para efectuar la valoración de los riesgos es importante realizar el respectivo análisis de los hallazgos detectados en cada una de las situaciones descritas que afectan la seguridad de la información, teniendo presente la probabilidad de ocurrencia del riesgo y el impacto que puede generar para la organización la materialización de este. En la tabla 26 se muestra la escala a emplear para realizar la respectiva valoración de los riesgos.

Cuadro 26: Valoración de la probabilidad en términos de ocurrencia

VALORACIÓN DE LA PROBABILIDAD EN TÉRMINOS DE OCURRENCIA		
PROBABILIDAD	FRECUENCIA DE OCURRENCIA	VALOR
Muy Bajo	Por lo menos una vez cada año	1
Bajo	Por lo menos una vez cada semestre	2
Medio	Por lo menos una vez cada trimestre	3
Alto	Por lo menos una vez cada mes	4
Muy Alto	Por lo menos una vez cada quince días	5

Fuente: Elaboración propia con Excel 2019.

La valoración del impacto se realizó teniendo en cuenta la afectación al nivel económico y operativo al interior de la organización el mismo se muestra en el cuadro 27, el mismo es obtenido de la normativa interna del banco en cuanto a la evaluación de riesgos.

Cuadro 27: Descripción del impacto

IMPACTO	DESCRIPCION DEL IMPACTO	IMPACTO CUALITATIVO	VALOR
Muy Bajo	Pérdida económica de entre el 0.1 y 0.4 % del presupuesto anual. Disminución en la prestación del servicio entre un 0.1% y 4.9%	- No afecta la seguridad de la información. - No hay afectación de la imagen de la entidad ante los clientes y terceros. - Se puede recuperar la información con la misma calidad. - Se presentan reprocesos que no tienen mayor importancia.	1
Bajo	Pérdida económica de entre el 0.5 y 0.9 % del presupuesto anual. Disminución en la prestación del servicio entre un 5% y 9.9%	- No afecta la seguridad de la información. - Se presenta una leve afectación a la imagen de la entidad ante los clientes y terceros. - Se puede recuperar la información con la misma calidad en un tiempo moderado. - Se presentan reprocesos menores en las actividades de la entidad.	2
Medio	Pérdida económica de entre el 1 y 10% del presupuesto anual. Disminución	- Hay una afectación en menor grado de la seguridad de la información de la entidad. - Afecta medianamente la imagen corporativa de la entidad ante sus clientes y terceros.	3

	en la prestación del servicio entre un 10% y 20%	- Se presentan retrocesos moderados en las actividades. - La información se puede recuperar.	
Alto	Pérdida económica de entre el 11 y 20% del presupuesto anual. Disminución en la prestación del servicio en 21%	- Se genera una afectación importante en la seguridad de la información de la entidad. - Afecta altamente la imagen corporativa de la entidad. - Se generan mayores retrocesos en las actividades. - Es difícil de recuperar la información	4
Muy Alto	Pérdida económica superior al 20% del presupuesto anual. Disminución en la prestación del servicio hasta en un 50%	- Se presenta una afectación crítica a la seguridad de la información. - Se afecta negativamente y en gran proporción la imagen corporativa de la entidad ante terceros. - Es difícil realizar la recuperación de la información. - Puede afectar las decisiones estratégicas de la organización y la continuidad del negocio.	5

Fuente: Elaboración propia con Excel 2019.

La valoración de los riesgos en términos de probabilidad e impacto de ocurrencia se obtiene de aplicar la siguiente ecuación.

$$\text{Riesgo Inherente} = \text{Probabilidad} * \text{Impacto}$$

En el cuadro 28 se muestra la valoración de riesgos de forma cualitativa en base a la probabilidad de ocurrencia y el impacto de esta.

Cuadro 28: Valoración del riesgo en términos de probabilidad e impacto

PROBABILIDAD	IMPACTO				
	MUY BAJO	BAJO	MEDIO	ALTO	MUY ALTO
MUY BAJO	Muy Bajo	Muy Bajo	Bajo	Bajo	Medio
BAJO	Muy Bajo	Bajo	Medio	Medio	Alto
MEDIO	Bajo	Medio	Medio	Alto	Alto
ALTO	Bajo	Medio	Alto	Crítico	Crítico
MUY ALTO	Medio	Alto	Alto	Crítico	Crítico

Fuente: Elaboración propia con Excel 2019.

En el cuadro 29 se muestra la valoración de riesgos de forma cuantitativa en base a la valoración que se hace en la normativa de Metodología de evaluación de riesgos del BNB.

Cuadro 29: Valoración del riesgo en términos numéricos de probabilidad e impacto

PROBABILIDAD	IMPACTO				
	M. BAJO (1)	BAJO (2)	MEDIO (3)	ALTO (4)	M. ALTO (5)
MUY BAJO (1)	1	2	3	4	5
BAJO (2)	2	4	6	8	10
MEDIO (3)	3	6	9	12	15
ALTO (4)	4	8	12	16	20
MUY ALTO (5)	5	10	15	20	25

Fuente: Elaboración propia con Excel 2019.

De acuerdo con la valoración establecida previamente para el riesgo inherente en términos de probabilidad de ocurrencia e impacto se obtienen los siguientes resultados de valoración de riesgos de seguridad que se muestra en la tabla 30.

Cuadro 30: Valoración de los riesgos de seguridad asociados a los activos de información

ACTIVO DE INFORMACIÓN	RIESGOS DE SEGURIDAD	VALORACIÓN DEL RIESGO			
		PROBABILIDAD	IMPACTO	CALIFICACIÓN	NIVEL DEL RIESGO
Red LAN corporativa	R1 - Sustracción y/o pérdida de información sensible de la organización debido a la ausencia de políticas y controles en el establecimiento de control de acceso a los dispositivos tecnológicos de la entidad.	2	5	10	Alto
	R2 - Indisponibilidad de la información y/o servicios que se acceden a través de la red corporativa por deficiencias en su diseño e implementación.	2	3	6	Medio

Fuente: Elaboración propia con Excel 2019.

Para la implementación de esta fase se puede realizar la evaluación realizando pruebas de intrusión en los puertos de acceso de la red de datos del BNB, para lo cual se hizo uso de las herramientas wireshark ¹⁰⁰ y nmap ¹⁰¹ dentro de un ambiente controlado donde se dispuso de un switch de acceso capa 2 marca Cisco que cuenta con la configuración base de los puertos de red de los switches de acceso del banco como se muestra en la figura 49.

```
LPZ-AG-200CT-SW1#sh run int g1/0/3
Building configuration...

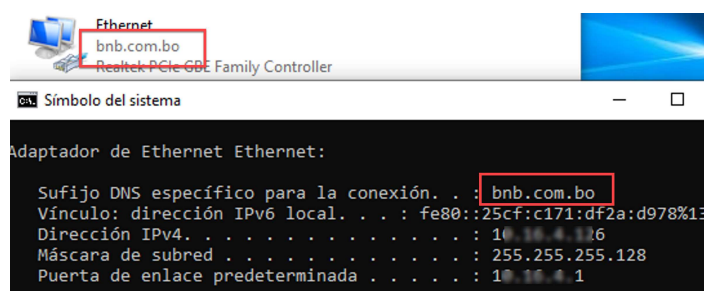
Current configuration : 159 bytes
!
interface GigabitEthernet1/0/3
 switchport access vlan 113
 switchport mode access
 switchport voice vlan 11
 power inline never
 spanning-tree portfast
end

LPZ-AG-200CT-SW1#
```

Fuente: Captura de switch de acceso BNB.

Figura 49: Configuración puerto de switch BNB.

Para esta prueba de intrusión hicimos uso de una laptop que no estaba en el dominio de red del banco, no tenía configurada ninguna dirección IP pero tenía habilitada la configuración de red DHCP y se hizo la conexión al puerto de red del switch de acceso de laboratorio del piso 3 de la oficina principal del BNB, luego de la conexión se pudo verificar que el servidor DHCP asignó una dirección IP al equipo de forma automática como se muestra en la figura 50.



Fuente: Captura de equipo externo BNB.

Figura 50: Asignación de dirección IP dentro de la red de datos.

Una vez dentro de la red de datos se pudo indagar que dirección IP tiene el servidor de dominio de la organización como se muestra en la figura 51.

¹⁰⁰ Wireshark Analizador de protocolos utilizado para realizar análisis y solucionar problemas en redes de comunicaciones.

¹⁰¹ NMAP Programa de código abierto que sirve para efectuar rastreo de puertos.

```
C:\Users\bnbcomunicaciones>ping bnb.com.bo

Haciendo ping a bnb.com.bo [192.168.1.2] con 32 bytes de datos:
Respuesta desde 192.168.1.2: bytes=32 tiempo=10ms TTL=124
Respuesta desde 192.168.1.2: bytes=32 tiempo=11ms TTL=124
Respuesta desde 192.168.1.2: bytes=32 tiempo=10ms TTL=124
Respuesta desde 192.168.1.2: bytes=32 tiempo=10ms TTL=124
```

Fuente: Captura de equipo externo BNB.

Figura 51: Verificación de dirección IP de servidor de dominio.

Se pudo validar a que equipos de red se podría conectar como se muestra en la figura 52.

```
C:\Users\bnbcomunicaciones>arp -a

Interfaz: 169.254.160.150 --- 0x3
Dirección de Internet      Dirección física      Tipo
169.254.255.255            ff-ff-ff-ff-ff-ff    estático
224.0.0.2                  01-00-5e-00-00-02    estático
224.0.0.22                 01-00-5e-00-00-16    estático
224.0.0.251                01-00-5e-00-00-fb    estático
224.0.0.252                01-00-5e-00-00-fc    estático
239.255.255.250            01-00-5e-7f-ff-fa    estático
255.255.255.255            ff-ff-ff-ff-ff-ff    estático

Interfaz: 169.254.160.150 --- 0xd
Dirección de Internet      Dirección física      Tipo
1 1 2c-33-11-98-d2-00      dinámico
1 11 44-39-c4-56-dd-81      dinámico
1 23 54-e1-ad-c3-a9-f0      dinámico
1 74 d8-cb-8a-42-3a-25      dinámico
1 98 44-8a-5b-55-e5-ed      dinámico
1 106 d8-cb-8a-42-3a-26     dinámico
1 124 54-ee-75-4d-c7-e7     dinámico
1 127 ff-ff-ff-ff-ff-ff     estático
2 22 01-00-5e-00-00-16      estático
2 251 01-00-5e-00-00-fb     estático
2 252 01-00-5e-00-00-fc     estático
2 255.255.255.250 01-00-5e-7f-ff-fa     estático
2 255.255.255.255 ff-ff-ff-ff-ff-ff     estático
```

Fuente: Captura de equipo externo BNB.

Figura 52: Equipos conectados en el mismo segmento de red.

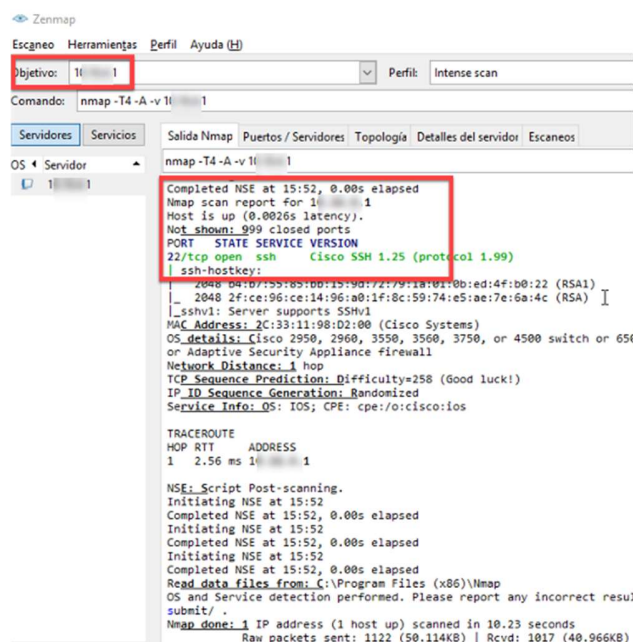
Desde el equipo conectado y haciendo uso de la herramienta wireshark se pudo ver el tráfico de red existente en la red de datos como se muestra en la figura 53.

No.	Time	Source	Destination	Protocol	Length	Info
202	1.453320	192.168.1.2	192.168.1.2	TCP	66	5357 → 54163 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM=1
203	1.455387	192.168.1.2	192.168.1.2	TCP	60	54163 → 5357 [ACK] Seq=1 Ack=1 Win=65536 Len=0
204	1.455388	192.168.1.2	192.168.1.2	TCP	278	54163 → 5357 [PSH, ACK] Seq=1 Ack=1 Win=65536 Len=224 [TCP segment of a ...]
206	1.455561	192.168.1.2	192.168.1.2	TCP	54	5357 → 54163 [ACK] Seq=1 Ack=958 Win=130304 Len=0
207	1.455645	192.168.1.2	192.168.1.2	TCP	60	62459 → 5357 [ACK] Seq=1 Ack=1 Win=65536 Len=0
208	1.455646	192.168.1.2	192.168.1.2	TCP	278	62459 → 5357 [PSH, ACK] Seq=1 Ack=1 Win=65536 Len=224 [TCP segment of a ...]
210	1.455828	192.168.1.2	192.168.1.2	TCP	54	5357 → 62459 [ACK] Seq=1 Ack=958 Win=130304 Len=0
212	1.461543	192.168.1.2	192.168.1.2	TCP	60	55690 → 5357 [FIN, ACK] Seq=958 Ack=2352 Win=65536 Len=0
213	1.462785	192.168.1.2	192.168.1.2	TCP	54	5357 → 55690 [FIN, ACK] Seq=2352 Ack=959 Win=130304 Len=0
214	1.462840	192.168.1.2	192.168.1.2	TCP	60	54163 → 5357 [ACK] Seq=958 Ack=2352 Win=65536 Len=0
216	1.463690	192.168.1.2	192.168.1.2	TCP	60	55690 → 5357 [ACK] Seq=959 Ack=2353 Win=65536 Len=0
220	1.467066	192.168.1.2	192.168.1.2	TCP	60	62459 → 5357 [ACK] Seq=958 Ack=2352 Win=65536 Len=0
221	1.470243	192.168.1.2	192.168.1.2	TCP	66	54773 → 5357 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 SACK_PERM=1
222	1.470438	192.168.1.2	192.168.1.2	TCP	66	5357 → 54773 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM=1
223	1.473230	192.168.1.2	192.168.1.2	TCP	60	54773 → 5357 [ACK] Seq=1 Ack=1 Win=65536 Len=0
224	1.473231	192.168.1.2	192.168.1.2	TCP	273	54773 → 5357 [PSH, ACK] Seq=1 Ack=1 Win=65536 Len=219 [TCP segment of a ...]
226	1.473419	192.168.1.2	192.168.1.2	TCP	54	5357 → 54773 [ACK] Seq=1 Ack=953 Win=130304 Len=0
228	1.479247	192.168.1.2	192.168.1.2	TCP	60	54773 → 5357 [ACK] Seq=953 Ack=2372 Win=65536 Len=0
229	1.479249	192.168.1.2	192.168.1.2	TCP	60	54773 → 5357 [FIN, ACK] Seq=953 Ack=2372 Win=65536 Len=0
230	1.479352	192.168.1.2	192.168.1.2	TCP	54	5357 → 54773 [ACK] Seq=2372 Ack=954 Win=130304 Len=0
231	1.482358	192.168.1.2	192.168.1.2	TCP	60	54163 → 5357 [FIN, ACK] Seq=958 Ack=2352 Win=65536 Len=0
232	1.482525	192.168.1.2	192.168.1.2	TCP	54	5357 → 54163 [ACK] Seq=2352 Ack=959 Win=130304 Len=0
233	1.484065	192.168.1.2	192.168.1.2	TCP	60	54163 → 5357 [ACK] Seq=959 Ack=2353 Win=65536 Len=0
234	1.484091	192.168.1.2	192.168.1.2	TCP	60	62459 → 5357 [FIN, ACK] Seq=958 Ack=2352 Win=65536 Len=0
235	1.484227	192.168.1.2	192.168.1.2	TCP	54	5357 → 62459 [FIN, ACK] Seq=2352 Ack=959 Win=130304 Len=0

Fuente: Captura de equipo externo BNB.

Figura 53: Captura de tráfico Wireshark.

Haciendo uso de la herramienta nmap se puede ver los puertos de red a los que se puede acceder hacia la puerta de red predeterminada de la red de datos como se muestra en la figura 54.



Fuente: Captura de equipo externo BNB.

Figura 54: Escaneo de puertos con Nmap.

4.2.7 FORZAR LA IMPLEMENTACION DE CONTROLES

a) Objetivo

En base al análisis de riesgos sobre el acceso no autorizado a la red de datos y las pruebas de intrusión realizadas en la anterior etapa del modelo, se tomarán acciones para controlar el acceso a la red de datos sobre la base de los requisitos de seguridad establecidos por la organización.

b) Control

En esta etapa se puede realizar la implementación de controles del tipo normativo o del tipo tecnológico, en este estudio se realizó una prueba piloto para la implementación del control del tipo tecnológico de un sistema de control de acceso que viene acompañado de una normativa de control de acceso a la red y un procedimiento del sistema de control de acceso a la red.

c) Procedimiento de implementación

La normativa de control de acceso a la red de datos propuesto se muestra en el Anexo IV y del cual podemos mencionar los siguientes puntos importantes como resumen de esta normativa:

- Objetivo. - Establecer un procedimiento formal para la administración de usuarios que permiten establecer el acceso a la red de datos y por ende a la información de la entidad de acuerdo con sus niveles de permisos asignados. Acceso y atribuciones en el Dominio del BNB en su entorno de red de datos.

- Definiciones. – Algunas de las definiciones establecidas en esta norma son:

Dominio. - Es un nombre base que agrupa a un conjunto de equipos o dispositivos de red que permite la administración para la: inclusión, modificación o exclusión de estos mediante la asignación de nombres de equipo.

Perfil de usuario. - Conjunto de actividades que se pueden realizar de acuerdo con un determinado nivel de autorización, relacionado con un cargo específico perteneciente a la jerarquía y la estructura organizacionales definida dentro de la organización.

Usuario. - El usuario es la persona física a la que se le asigna un perfil de usuario determinado. Cada usuario podrá tener definido únicamente un perfil, sin embargo, en caso de solicitudes excepcionales con el objeto de cubrir reemplazos, vacancias u otros, las mismas deberán ser previamente analizadas por el Gerente de División y/o Subgerente de Organización y Métodos.

Contraseña. - Es un conjunto de caracteres definidos de uso único, exclusivo y confidencial por un usuario que permite autenticarlo en un sistema informático.

Identificación de Usuario. - Es la identificación asignada al usuario, que permite a un sistema informático distinguir a un usuario de otro al momento de ingresar al mismo.

- Clasificación de usuarios. - Por la naturaleza del registro de información y las características en cuanto a la asignación de atribuciones en el sistema de directorio activo AD se establece la siguiente clasificación en cuanto a la administración de cada uno de los sistemas:

Usuario funcionario BNB. - funcionarios de planta regulares o en periodo de prueba del BNB.

Usuarios de Sistemas. - Usuarios que por su naturaleza son registrados en el directorio activo AD sin que los mismos guarden relación con un determinado usuario como: cuentas de sistemas, equipos remotos, servidores.

Usuarios Temporales. - Usuarios requeridos para dar acceso temporal al dominio como: pasantías, auditorías externas, consultorías, empresas de seguridad privada entre otros.

- Alta de Usuarios. - Una vez cumplidos los procesos de incorporación de personal según lo establecido en la norma de “Contratación y Desvinculación Laboral”, y siempre que se haya efectuado el registro del alta de personal, el Asistente de Administración de Sistemas es responsable de efectuar el alta de usuarios una vez recibida la solicitud.

- Criterios para cambio de contraseñas. - Las contraseñas asignadas al usuario del directorio activo AD son válidas para acceder al dominio BNB solo por primera vez. Por lo que cuando el usuario se identifica ante el sistema, este exige el cambio inmediato de contraseña, para lo cual deberán considerarse los criterios descritos en la normativa de “Gestión de Accesos y Atribuciones en los sistemas”.

- Baja de Usuarios. - Por la importancia que tiene la optimización continua del ambiente de control y con el objeto de mantener la confidencialidad de la información se establece que toda desvinculación laboral de cualquier funcionario o personal externo por cesación de contrato deberá ser comunicado en un plazo no mayor a diez días, por el Gerente de servicios y operaciones regionales. Una vez que el Asistente de Administración de Sistemas haya verificado la solicitud de baja de perfil procederá al registro, baja, en el sistema AD.

- Control de Conexión a Redes. - El proceso de Gestión de Tecnologías de Comunicación e Información debe asegurar el bloqueo al acceso de equipos de red de personal externo a la red de datos del BNB que represente riesgo potencial para la entidad mediante el uso de algún tipo de firewall o software que mejor se ajuste a la necesidad. Excepciones de acceso, serán aprobados por el jefe inmediato, según la necesidad del cargo y verificación previa del dispositivo. La infraestructura de red del Banco deberá estar separada por redes de acceso virtuales VLAN's para garantizar la confidencialidad de los datos que se transmitan en cada departamento de la organización.

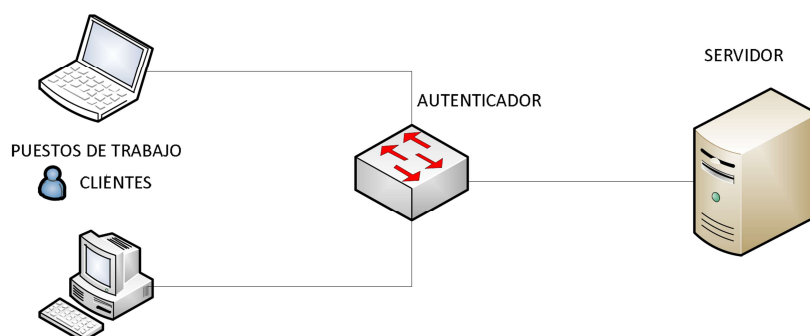
- Seguridad en los Servicios de Red. - La Subgerencia de Infraestructura Tecnológica es la encargada de mantener instalados y habilitados sólo aquellos servicios y puertos de red que sean utilizados por los sistemas de información del banco. Controlar el acceso lógico a los servicios, tanto a su uso como a su administración mediante bloqueo de puertos en los dispositivos de red.

- Limitación del Tiempo de Conexión. - Las restricciones al horario de conexión deben suministrar seguridad adicional a las aplicaciones. Limitar los tiempos de conexión al horario normal de oficina, de no existir un requerimiento operativo de horas extras o extensión horaria. Documentar los funcionarios o personal externo que no tienen restricciones horarias y los motivos y evidencia de la autorización expedida por la Gerencia de Organización y Métodos.

- Sesiones Inactivas: Si el usuario debe abandonar la estación de trabajo momentáneamente, activará protectores de pantalla con contraseñas, con el fin de evitar que terceros puedan ver su trabajo o continuar con la sesión habilitada. Si los sistemas de información detectan inactividad por un periodo igual o superior a diez minutos, deben automáticamente finalizar esta sesión.

- Cada funcionario es responsable sobre el uso y aplicación de identificación de usuario y su contraseña asignados al mismo. Las operaciones que sean realizadas por el funcionario mediante su usuario en el sistema AD, podrán ser controladas y verificadas por la subgerencia de seguridad de la información.

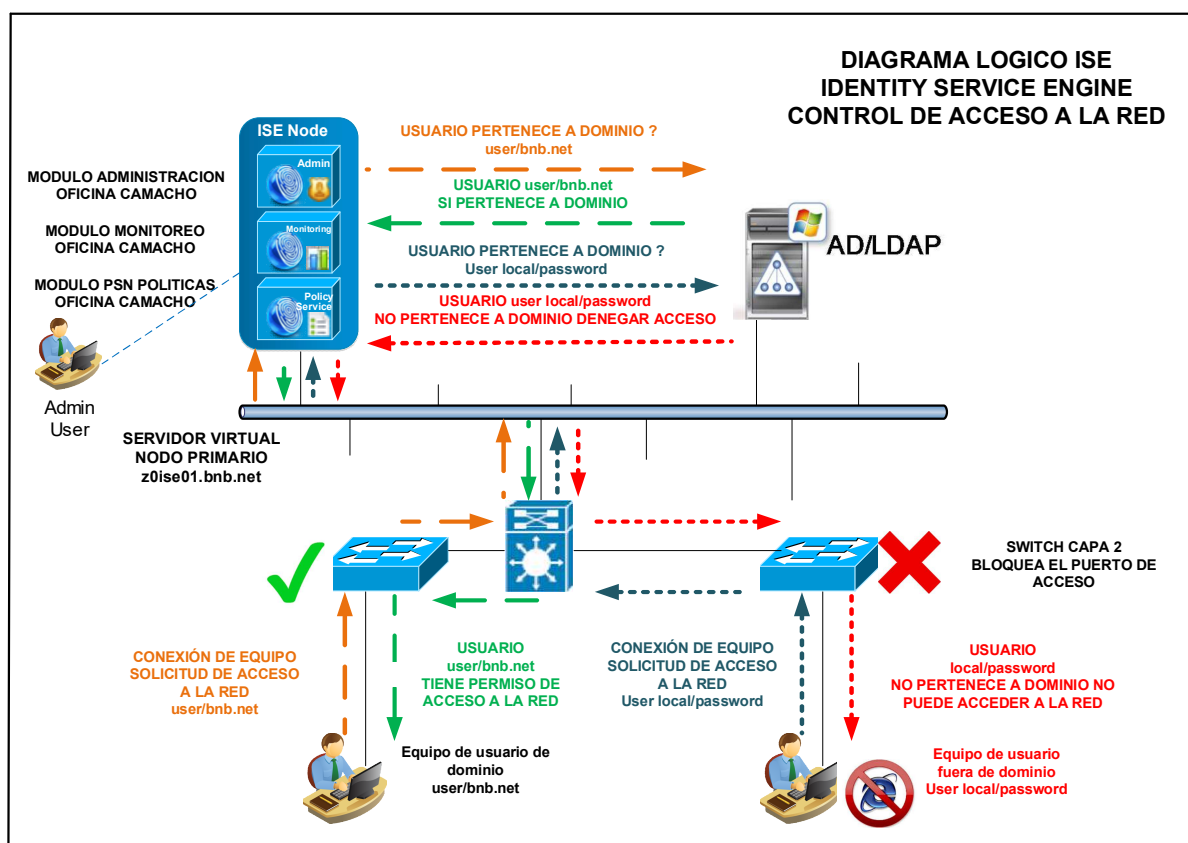
Fuera del control normativo se propone la implementación de un control tecnológico que consiste en la implementación de un sistema de control de acceso que está compuesto por tres entidades: un dispositivo intentando conectarse a la red, un segundo dispositivo que brindara conexión al dispositivo que intenta conectarse y una base de datos que contiene información de credenciales para validar esta conexión. En la figura 55 se describen estas tres entidades.



Fuente: Elaboración propia según descripción de (Lyle Brown, 2007, pág. 4).

Figura 55: Entidades de control de acceso.

Para el caso del BNB luego de haber analizado a los fabricantes de acuerdo con el reporte de (Gartner Inc., 2018) sobre los sistemas de control de acceso, buscando cumplir con los requerimientos que el modelo solicita se ha seleccionado al sistema de control de acceso de la empresa CISCO, el banco cuenta con la infraestructura de equipos de Virtualización y equipos de red de la misma marca del fabricante seleccionado por lo que presenta compatibilidad y manejabilidad del sistema de control de acceso. Otro factor para la selección de este fabricante es que el mismo cuenta con soporte local especializado para la implementación de este tipo de sistemas, además que el banco cuenta con un convenio del tipo económico con esta empresa que brinda descuentos especiales para este tipo de implementaciones.



Fuente: Elaboración propia con Visio 2019.

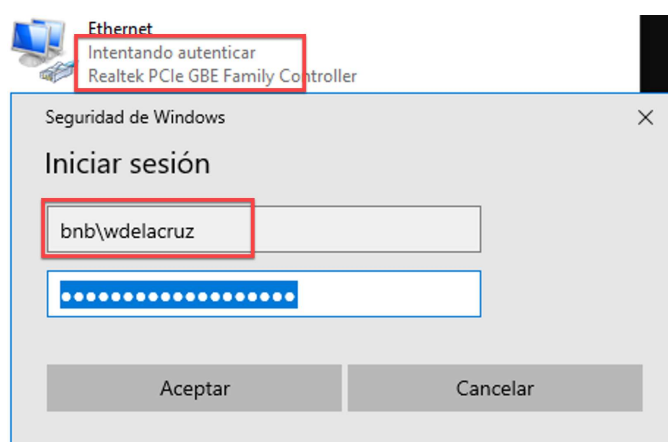
Figura 56: Diagrama lógico de sistema de control de acceso a la red ISE.

En la figura 56 se describe el diagrama lógico del sistema ISE con las tres entidades mencionadas anteriormente. El sistema ISE¹⁰² Sistema de Servicio de Identidad, por sus siglas

¹⁰² ISE Identity Service Engine.

en inglés, está conformado por las tres entidades previamente indicadas donde el autenticador será el switch de acceso capa dos, el autenticador será el servidor RADIUS que tiene el sistema NAC de Cisco, este servidor RADIUS hará consultas sobre la identidad de los usuarios de dominio de la red corporativa al servidor de Directorio Activo AD del banco. Para la configuración y administración del sistema de control de acceso a la red se tiene un Procedimiento del sistema de control de acceso a la red NAC el cual esta descrito en el Anexo V de este documento, este procedimiento puede ser adaptado a otro sistema de control de acceso.

Una vez implementado el sistema de control de acceso a la red y luego que se aplicaron las configuraciones de puerto de red del switch de acceso y se aplicaron las políticas GPO¹⁰³ a los equipos de dominio del banco, se pudo evidenciar los resultados con el acceso autorizado a equipos de la red corporativa del BNB, para lo cual hacen uso de las credenciales de dominio que son utilizadas en el proceso de autorización y autenticación para los equipos computacionales de los usuarios, en la figura 57 se muestra el proceso de autenticación y autorización de un equipo de red.



Fuente: Captura de equipo autorizado BNB.

Figura 57: Solicitud de credenciales para el acceso a la red.

Una vez autenticado y autorizado el equipo de dominio de la red del BNB ingresa a la red de datos, en el puerto de switch donde se conectó el equipo se puede verificar su acceso como se muestra en la figura 58 donde se observa que el método de autenticación es por el modo 802.1x.

¹⁰³ GPO Group Policy Object.

```

SW-TEST#sh auth se int f0/2
  Interface: FastEthernet0/2
  MAC Address: 54ab.3ab2.cad1
  IP Address: 192.168.1.6
  User-Name: bnb\wdelacruz
  Status: Authz Success
  Domain: DATA
  Oper host mode: multi-auth
  Oper control dir: both
  Authorized By: Authentication Server
  Vlan Group: N/A
  Session timeout: N/A
  Idle timeout: N/A
  Common Session ID: 0A10740F0000004F155E235B
  Acct Session ID: 0x0000007F
  Handle: 0xD200004F

Runnable methods list:
  Method  State
  dot1x   Authc Success
  mab     Not run

```

Fuente: Captura de switch de acceso BNB.

Figura 58: Autorización de equipo de red a través del estándar IEEE 801.1x.

En cuanto al proceso de denegación de acceso a la red de datos de equipos externos, se tiene las siguientes figuras donde se evidencia la denegación de acceso a la red. En la figura 59 se muestra el estado del puerto de switch que muestra autorización fallida al cumplir las condiciones previamente establecidas.

```

SW-TEST#sh auth sessions int f0/2
  Interface: FastEthernet0/2
  MAC Address: 54ab.3ab2.cad1
  IP Address: Unknown
  User-Name: UNRESPONSIVE
  Status: Authz Failed
  Domain: DATA
  Oper host mode: multi-auth
  Oper control dir: both
  Session timeout: N/A
  Idle timeout: N/A
  Common Session ID: 0A10740F000000411536E557
  Acct Session ID: 0x00000071
  Handle: 0x75000041

Runnable methods list:
  Method  State
  dot1x   Failed over
  mab     Failed over

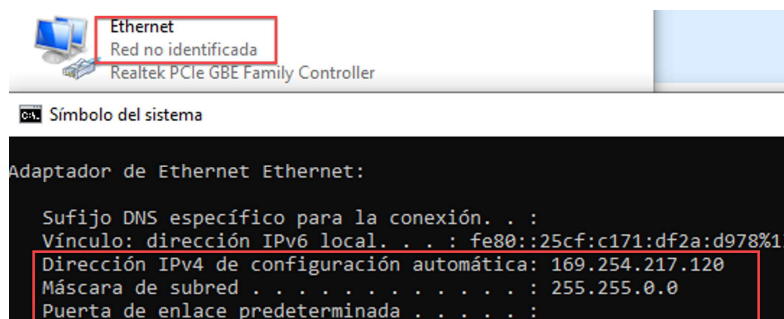
```

Fuente: Captura de switch de acceso BNB.

Figura 59: Denegación de acceso a la red a equipo externo.

En la figura 60 se muestra como la tarjeta de red del equipo externo a la red del banco no logra obtener una dirección IP y por ende no logra ingresar a la red de datos del BNB, como se observa

está en proceso de solicitar una dirección IP a algún servidor DHCP que se pueda tener en la red, sin embargo, al bloquearse este puerto el equipo tiene esta solicitud sin respuesta.



Fuente: Captura de equipo no autorizado BNB

Figura 60: Proceso de solicitud de dirección IP.

4.2.8 MONITOREO Y DETECCIÓN

a) Objetivo

En esta etapa se pretende implementar las medidas destinadas a verificar el correcto funcionamiento del control de acceso a la red implantado respecto de lo definido previamente con el análisis de riesgo realizado. Se utilizan herramientas de monitoreo o se establecen procedimientos que permitan conocer y verificar el correcto funcionamiento del control.

b) Control

Se puede realizar la implementación de controles del tipo normativo o del tipo tecnológico, en este estudio como se implementó un sistema de control de acceso el cual hace un monitoreo en línea de la actividad que se tiene en el proceso de autenticación de dispositivos de red, adicionalmente este sistema almacena los registros de eventos de conexión de equipos autorizados en la red del banco en una base de datos interna de este servidor.

c) Procedimiento de implementación

El Procedimiento del sistema de control de acceso a la red propuesto que se muestra en el Anexo V de este documento, en este se muestra la configuración del sistema para mantener registros de eventos de conexiones de equipos autorizados y rechazados a la red de datos. En la figura 61 se muestra el registro en línea de equipos autorizados a través del sistema de control de acceso implementado.

Time	Status	Details	Repeat ...	Identity	Endpoint ID	Authentic...	Authoriza...	Authorization Profiles	IP Address	Network Device
Nov 05, 2019 10:11:50.539 AM	●		0	frivas	94:65:9C:54:9B:4C	BNB-VPN...	BNB-VPN...	PermitAccess		
Nov 05, 2019 10:11:50.539 AM	●			frivas	94:65:9C:54:9B:4C	BNB-VPN...	BNB-VPN...	PermitAccess		LP2-OF-FTDi-A
Nov 05, 2019 10:10:27.559 AM	●			CP-8845-SEP007...	00:76:86:FC:F1:E9				10.16.224.4	SW_LLP_EC_P3_01
Nov 05, 2019 10:09:27.227 AM	●			00:76:86:FC:F1:E9	00:76:86:FC:F1:E9	BNB-USE...	BNB-USERS		10.16.224.4	SW_LLP_EC_P3_01
Nov 05, 2019 10:09:27.210 AM	●			CP-8845-SEP007...	00:76:86:FC:F1:E9	BNB-USE...	BNB-USERS		10.16.224.4	SW_LLP_EC_P3_01
Nov 05, 2019 10:09:06.518 AM	●			00:76:86:FC:F1:E9	00:76:86:FC:F1:E9					
Nov 05, 2019 10:08:41.717 AM	●			mirahola	70:48:0F:7F:62:CB					LP2-OF-CPD-WLC
Nov 05, 2019 10:06:41.661 AM	●			mirahola	70:48:0F:7F:62:CB					LP2-OF-CPD-WLC
Nov 05, 2019 10:06:21.278 AM	●			mirahola	70:48:0F:7F:62:CB					LP2-OF-CPD-WLC
Nov 05, 2019 10:04:27.266 AM	●		0	mtorres	68:FE:F7:A1:34:41	BNB-WIRE...	BNB-WIRE...	BNBV77	10.16.7.110	
Nov 05, 2019 10:03:32.617 AM	●			mtorres	68:FE:F7:A1:34:41	BNB-WIRE...	BNB-WIRE...	BNBV77		LP2-OF-CPD-WLC
Nov 05, 2019 09:51:50.394 AM	●		0	JDMoscoco	6A:FE:F7:9B:43:BA	BNB-VPN...	BNB-VPN...	PermitAccess		
Nov 05, 2019 09:51:50.394 AM	●			JDMoscoco	6A:FE:F7:9B:43:BA	BNB-VPN...	BNB-VPN...	PermitAccess		LP2-OF-FTDi-A
Nov 05, 2019 09:50:05.358 AM	●		2	amovando	24:2E:02:2E:0A:1D	BNB-WIRE...	BNB-WIRE...	BNBV77	10.16.7.104	
Nov 05, 2019 09:44:05.733 AM	●			USERNAME	68:5D:43:7A:49:96	BNB-WIRE...	BNB-WIRE...			LP2-OF-CPD-WLC
Nov 05, 2019 09:43:38.845 AM	●		4	jguierrez	48:2C:A0:C8:79:CB	BNB-WIRE...	BNB-WIRE...	BNBV77	10.16.8.168	
Nov 05, 2019 09:40:29.990 AM	●		0	jdmoscoco	181.114.123.108	BNB-VPN...	BNB-VPN...	PermitAccess		
Nov 05, 2019 09:40:29.990 AM	●			jdmoscoco	181.114.123.108	BNB-VPN...	BNB-VPN...	PermitAccess		LP2-OF-FTDi-A
Nov 05, 2019 09:26:56.796 AM	●		0	jaramirez	E8:B1:FC:42:E3:84	BNB-VPN...	BNB-VPN...	PermitAccess		
Nov 05, 2019 09:26:56.796 AM	●			jaramirez	E8:B1:FC:42:E3:84	BNB-VPN...	BNB-VPN...	PermitAccess		LP2-OF-FTDi-A
Nov 05, 2019 09:24:59.743 AM	●			jhessey	24:00:BA:A5:8A:19					LP2-OF-CPD-WLC
Nov 05, 2019 09:20:14.254 AM	●			amovando	24:2E:02:2E:0A:1D	BNB-WIRE...	BNB-WIRE...	BNBV77		LP2-OF-CPD-WLC

Fuente: Captura Sistemas de Control de Acceso ISE

Figura 61: Registro de equipos en línea a través del sistema NAC.

En esta consola de administración del Sistema de Control de Acceso a la red se pueden filtrar conexiones de equipos como el que se muestra en la figura 62 donde se muestra como un equipo de red del dominio BNB fue autenticado y autorizado para acceder a la red de datos.

Time	Status	Details	Repeat ...	Identity	Endpoint ID	Endpoint Profile	Authentication Policy	Authorization Policy	Authorizati...
Oct 18, 2019 04:54:44.207 PM	●		0	bnblwdelacruz	54:AB:3A:B2:CA:D1	Windows7-Workstation	BNB-USERS >> Wired_802.1X	BNB-USERS >> Authorization Rule 3	PermitAccess
Oct 18, 2019 04:54:43.171 PM	●			bnblwdelacruz	54:AB:3A:B2:CA:D1	Windows7-Workstation	BNB-USERS >> Wired_802.1X	BNB-USERS >> Authorization Rule 3	PermitAccess

Fuente: Captura Sistemas de Control de Acceso ISE

Figura 62: Autorización de equipo de red a través del sistema NAC.

En la figura 63 se muestra el log de eventos detallado de la conexión de un equipo a la red de datos, el sistema ISE detalla el proceso de autenticación y autorización del equipo de dominio a la red del banco.

Overview

Event	5200 Authentication succeeded
Username	bnbldelacruz
Endpoint Id	54-AB-3A-B2-CA-D1
Endpoint Profile	Windows7-Workstation
Authentication Policy	BNB-USERS >> Wired_802.1X
Authorization Policy	BNB-USERS >> Authorization Rule 3
Authorization Result	PermitAccess

Authentication Details

Source Timestamp	2019-10-18 16:54:43.17
Received Timestamp	2019-10-18 16:54:43.171
Policy Server	bnbise
Event	5200 Authentication succeeded
Username	bnbldelacruz
Endpoint Id	54-AB-3A-B2-CA-D1
Calling Station Id	54-AB-3A-B2-CA-D1
Endpoint Profile	Windows7-Workstation
Authentication Identity Store	BNB-AD
Identity Group	Workstation
Audit Session Id	0A10740F000004F155E235B
Authentication Method	dot1x
Authentication Protocol	PEAP (EAP-MSCHAPv2)
Service Type	Framed
Network Device	SWITCH-BNB
Device Type	All Device Types#SWITCH_ACCESS
Location	All Locations#LA_PAZ

Steps

```

11001 Received RADIUS Access-Request
11017 RADIUS created a new session
15049 Evaluating Policy Group
15008 Evaluating Service Selection Policy
15048 Queried PIP - Normalised Radius.RadiusFlowType
15048 Queried PIP - Radius.NAS-Port-Type
11507 Extracted EAP-Response#identity
12500 Prepared EAP-Request proposing EAP-TLS with challenge
12625 Valid EAP-Key-Name attribute received
11006 Returned RADIUS Access-Challenge
11001 Received RADIUS Access-Request
11018 RADIUS is re-using an existing session
12301 Extracted EAP-Response#NAK requesting to use PEAP instead
12300 Prepared EAP-Request proposing PEAP with challenge
12625 Valid EAP-Key-Name attribute received
11006 Returned RADIUS Access-Challenge
11001 Received RADIUS Access-Request
11018 RADIUS is re-using an existing session
12302 Extracted EAP-Response containing PEAP challenge-response and accepting PEAP as negotiated
12318 Successfully negotiated PEAP version 0
12800 Extracted first TLS record; TLS handshake started
12805 Extracted TLS ClientHello message
12806 Prepared TLS ServerHello message
12807 Prepared TLS Certificate message
12808 Prepared TLS ServerKeyExchange message
12810 Prepared TLS ServerDone message
12811 Extracted TLS Certificate message containing client certificate
12305 Prepared EAP-Request with another PEAP challenge
11006 Returned RADIUS Access-Challenge
11001 Received RADIUS Access-Request
11018 RADIUS is re-using an existing session
12304 Extracted EAP-Response containing PEAP challenge-response
12305 Prepared EAP-Request with another PEAP challenge
11006 Returned RADIUS Access-Challenge
11001 Received RADIUS Access-Request
11018 RADIUS is re-using an existing session
12304 Extracted EAP-Response containing PEAP challenge-response
  
```

Fuente: Captura Sistemas de Control de Acceso ISE

Figura 63: Log de eventos de autenticación y autorización de equipo de red.

El intento de autenticación y autorización se puede ver en la consola de administración del Sistema de Control de Acceso a la red que se muestra en la figura 64.

Summary Statistics:

- Misconfigured Supplicants: 2
- Misconfigured Network Devices: 0
- RADIUS Drops: 0
- Client Stopped Responding: 40
- Repeat Counter: 6

Live Logs Table:

Time	Status	Details	Repeat	Identity	Endpoint ID	Endpoint Profile	Authentication Policy	Authorization Policy
Oct 18, 2019 04:13:52.988 PM	Success	Authentication succeeded	1	Identity	54-AB-3A-B2-CA-D1	Endpoint Profile	Authentication Policy	Authorization Policy

Fuente: Captura Sistemas de Control de Acceso ISE

Figura 64: Autorización de equipo de red a través del sistema NAC.

En la figura 65 se muestra el log de eventos en el sistema ISE donde se muestra el proceso de autenticación y autorización del equipo externo de la red del banco.

Identity Services Engine

Overview

Event	5400 Authentication failed
Username	54-AB-3A-B2-CAD1
Endpoint Id	54-AB-3A-B2-CAD1
Endpoint Profile	
Authentication Policy	BNB-USERS >> Default
Authorization Policy	BNB-USERS
Authorization Result	

Authentication Details

Source Timestamp	2019-10-18 16:12:21.371
Received Timestamp	2019-10-18 16:12:21.373
Policy Server	bnbise
Event	5400 Authentication failed
Failure Reason	22017 Selected Identity Source is DenyAccess
Resolution	Select a different Identity Source
Root cause	Selected Identity Source is DenyAccess

Steps

```

11001 Received RADIUS Access-Request
11017 RADIUS created a new session
11027 Detected Host Lookup UseCase (Service-Type = Call Check (10))
15049 Evaluating Policy Group
15008 Evaluating Service Selection Policy
15048 Queried PIP - Normalised Radius.RadiusFlowType
15048 Queried PIP - Radius.NAS-Port-Type
15041 Evaluating Identity Policy
15013 Selected Identity Source - DenyAccess
22017 Selected Identity Source is DenyAccess
11003 Returned RADIUS Access-Reject

```

Fuente: Captura Sistemas de Control de Acceso ISE

Figura 65: Log de eventos de autenticación y autorización de equipo externo.

Con estos registros podemos evidenciar que se están monitoreando y detectando los equipos externos a la red del banco están intentando acceder a la red de datos de la empresa.

4.2.9 RESPUESTA A INCIDENTES

a) Objetivo

En esta etapa luego de que en la fase de monitoreo y detección a incidentes se tuvo reportes de eventos, en esta fase se toman medidas al respecto para poder subsanar algún comportamiento anómalo del sistema o alguna situación que no haya sido prevista inicialmente en el diseño o implementación del sistema de control de acceso.

b) Control

En esta fase se hace la implementación de controles del tipo normativo donde se pretende definir de manera formal a los responsables de la toma de decisiones sobre las acciones a realizar una vez que se hayan reportados las mismas.

c) Procedimiento de implementación

En esta etapa el banco no contaba con algún tipo de control para el acceso de red y se procedió

a implementar este nuevo control, en esta etapa de pruebas no se reportaron incidencias sobre la funcionalidad de este, más al contrario se está generando y recopilando una gran cantidad de eventos que ayudaran a afinar las políticas de control de acceso.

Cabe mencionar que el BNB cuenta con una normativa interna de Gestión de Incidentes de Seguridad de la Información, donde se establecen los lineamientos generales que debe considerar el banco, para la adecuada gestión de incidentes de seguridad de la información que abarca desde el conocimiento del incidente hasta las acciones de análisis post incidente.

- En esta norma se establece un equipo de respuesta a incidentes que son los funcionarios responsables del manejo de incidentes de seguridad de la información. Este equipo está conformado por la Gerencia de Tecnología, Subgerencia de servicios y operaciones y la Subgerencia de Seguridad de la Información, cada una de estas áreas designara a los empleados que puedan aportar en la gestión de incidentes de seguridad.
- La Subgerencia de Seguridad de la Información deberá gestionar y coordinar con el Equipo de respuesta a incidentes, procedimientos para la respuesta a incidentes conocidos, debiendo desarrollar y mantener actualizados dichos procedimientos.
- Para lo cual y partiendo de la información generada del registro de incidentes definido en la normativa interna de Registro de Incidentes, el Subgerente de Seguridad de la Información deberá mantener actualizada la base de datos de incidentes de seguridad de la información.
- La Subgerencia de seguridad de la información deberá establecer los mecanismos necesarios que permitan identificar la tipología, los volúmenes y costos de los incidentes de seguridad de la información, así como las medidas asumidas para mitigarlos, garantizando que estos sean registrados, cuantificados y monitoreados.
- Procedimiento de respuesta a incidentes: Entre los principales incidentes que deben considerarse están los siguientes:

- Sobrecarga o mal funcionamiento del sistema
- Errores humanos
- Incumplimiento de políticas o procedimientos
- Cambios incontrolables en el sistema
- Malfuncionamiento de software o hardware

- Violaciones de accesos
- Ataques de virus y otros tipos de programa maligno
- Ataques de denegación de servicios
- Violaciones en la confidencialidad e integridad de la información
- Ataques de intrusión u otros ataques de origen externo

- El Subgerente de Seguridad de la información debe realizar un análisis y calificar el evento según la tabla 31.

Cuadro 31: Valoración de incidentes de seguridad

Valor	Significado	Efecto	Confidencialidad	Integridad	Disponibilidad
1	Violación de política	Sin daño	Sin daño	Sin daño	Sin daño
2	Bajo	Poco daño o daño sobre pocos elementos	Se divulgan pocos datos o datos no relevantes al interior de la organización	Se generan algunos datos inconsistentes, descuadraturas menores o faltan pocos datos	Deterioro del tiempo de respuesta o no disponibilidad de servicios menores
3	Medio	Daño controlado o sobre un ámbito limitado	Se divulgan datos de un ámbito específico o sistema no fundamental	Se generan datos inconsistentes o incompletos en una aplicación de impacto menor	Deterioro sostenido del tiempo de respuesta o no disponibilidad de servicios
4	Alto	Daño importante o compromiso de un amplio conjunto de activos	Se divulgan datos de un sistema importante o una importante cantidad de datos	Se presentan inconsistencias en varios sistemas o se comprometen sistemas relevantes	No disponibilidad de varios servicios o de servicios relevantes
5	Crítico	Daño grave o compromiso generalizado	Se divulgan datos de una aplicación estratégica o se divulgan muchos datos de la organización	Se presentan inconsistencias en sistemas estratégicos o en la mayoría de los sistemas de la organización	Falta de disponibilidad de sistemas estratégicos o de una importante cantidad de servicios

Fuente: Normativa interna de Gestión de Incidentes de Seguridad de la Información.

- Actividades generales: Los procedimientos a ser desarrollados deben considerar mínimamente:

- Identificación del tipo de incidente
- Ponderación de la gravedad de este
- Identificación de el o los procedimientos que apliquen
- Escalamiento del incidente, dependiendo de su gravedad y permanencia en el tiempo
- Análisis de las acciones tomadas, una vez superado el incidente

4.2.10 CUMPLIMIENTO DE CONTROLES

a) Objetivo

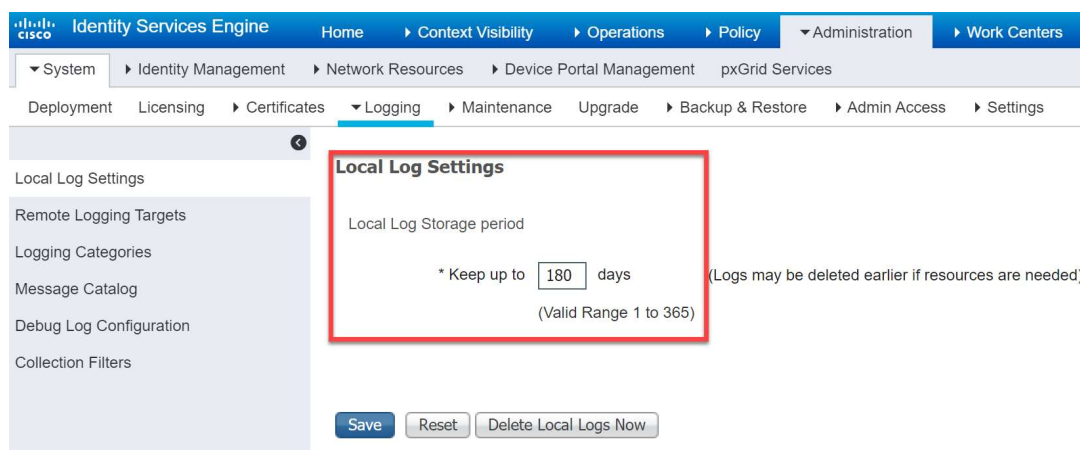
En esta etapa se pretende contar con registros de eventos que se tiene con respecto al o los controles implementados y que sirven para demostrar que las acciones tomadas por el banco para mitigar el riesgo identificado existen y funcionan.

b) Control

En esta fase se hace la implementación de controles del tipo normativo donde se pretende definir de manera formal los procedimientos para poder generar y almacenar los registros de eventos con respecto al control de acceso a la red. También se debe tener el respaldo de las configuraciones del sistema para ante cualquier contingencia proceder con su restauración.

c) Procedimiento de implementación

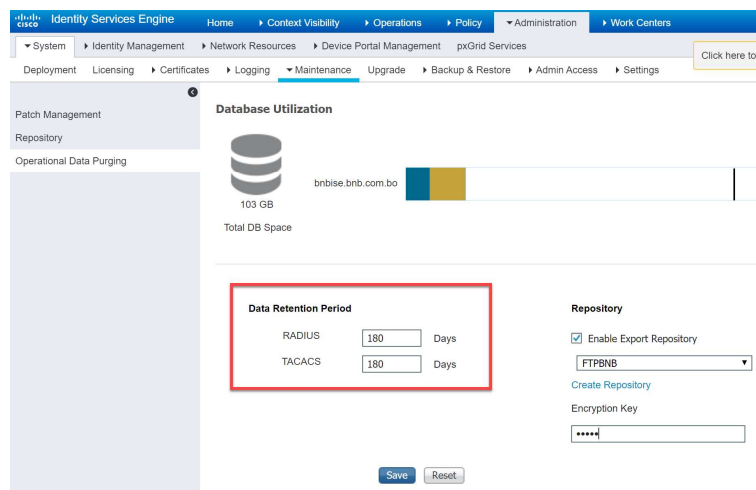
Para poder contar con los registros de eventos del sistema de control de acceso como primera tarea se realiza la configuración para tener el respaldo de la máquina virtual de este servidor junto al respaldo de configuraciones dicho procedimiento se muestra en El procedimiento del sistema de control de acceso a la red se muestra en el Anexo IV, de este procedimiento también se desprende la configuración del respaldo local de los eventos de configuración que son almacenados 180 días, de acuerdo a lo normado en el reglamento de seguridad de la información de la ASFI sobre el resguardo de respaldo de configuración, en la figura 66 se muestra la configuración del servidor NAC para mantener los logs de eventos.



Fuente: Captura Sistemas de Control de Acceso ISE

Figura 66: Configuración para mantener el log de eventos del servidor NAC.

Sobre los logs de eventos de acceso de los equipos de red hacia el sistema de control de acceso se realiza el respaldo de 180 días como se muestra en la figura 67.



Fuente: Captura Sistemas de Control de Acceso ISE

Figura 67: Configuración para mantener el log de conexión de equipos.

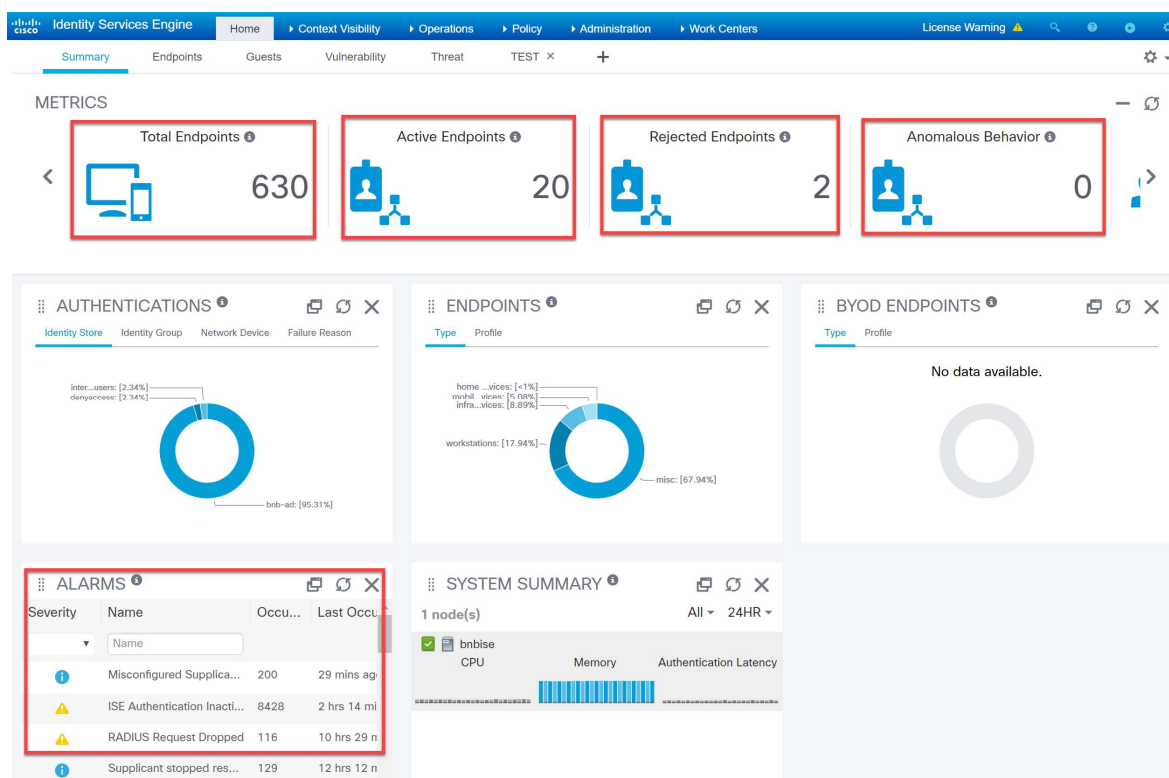
Con estas configuraciones previas se puede contar con el registro de eventos de conexiones de equipos de red en sistema NAC, en la figura 68 se puede obtener el reporte de conexiones de equipos de red donde se identifica al usuario de dominio y la fecha de conexión de este.

Logged At	RADIUS Status	Details	Identity	Endpoint ID	Endpoint Profile	Authorization Rule
2019-10-27 10:13:41.317	✓		evargas	90:32:4B:AF:8E:A1	Workstation	Authorization Rule 1
2019-10-27 10:11:39.534	✓		jgutierrez	98:5F:D3:51:B7:02	Workstation	Authorization Rule 1
2019-10-27 09:53:25.393	✓		davallejos	48:D2:24:35:AC:39	Unknown	Authorization Rule 1
2019-10-27 09:38:14.172	✓		SEZurita	40:25:C2:B0:54:F0	Workstation	Authorization Rule 1
2019-10-27 09:12:22.131	✓		cangulo	F8:94:C2:60:A0:9F	Workstation	Authorization Rule 1
2019-10-27 09:07:55.671	✓		cangulo	F8:94:C2:60:A0:9F	Workstation	Authorization Rule 1
2019-10-27 08:41:53.141	✓		rucabrera	94:65:9C:54:9B:B5	Workstation	Authorization Rule 1
2019-10-27 08:25:13.495	✓		juignacio	34:E6:AD:B8:D8:28	Workstation	Authorization Rule 1
2019-10-27 08:00:32.411	✓		evargas	08:3E:8E:6C:8C:D0	Workstation	Authorization Rule 1
2019-10-27 01:46:42.675	✓		sfigueroa	94:B8:6D:40:78:42	Windows7-Workstation	Authorization Rule 1
2019-10-27 00:24:02.294	✓		sfigueroa	94:B8:6D:40:78:42	Windows7-Workstation	Authorization Rule 1
2019-10-26 23:07:42.388	✓		EMoralesc	44:85:00:80:B7:BD	Workstation	Authorization Rule 1
2019-10-26 21:58:26.205	✓		pmartinez	38:F9:D3:2E:8C:79	Macintosh-Workstation	Authorization Rule 1
2019-10-26 21:51:59.264	✓		evargas	90:32:4B:AF:8E:A1	Workstation	Authorization Rule 1
2019-10-26 20:05:16.339	✓		sfigueroa	94:B8:6D:40:78:42	Windows7-Workstation	Authorization Rule 1

Fuente: Captura Sistemas de Control de Acceso ISE

Figura 68: Log de conexión de equipos.

- En cuanto al monitoreo del sistema de control de acceso se habilito una cuenta en el servidor AD del banco para que el operador de monitoreo del área de tecnología acceda a la consola de monitoreo de este servidor, dicha consola se muestra en la figura 69.



Fuente: Captura Sistemas de Control de Acceso ISE

Figura 69: Monitoreo de eventos servidor ISE.

- El operador de monitoreo es responsable de reportar eventos de dispositivos rechazados, también debe reportar si se genera algún evento anómalo sobre el funcionamiento del sistema, estas alertas son enviadas a los Analistas de Seguridad de la Información y a los Analistas de Infraestructura de acuerdo con el tipo de reporte de incidente.
- Los Analistas de Seguridad de la Información y a los Analistas de Sistemas de infraestructura una vez que sean alertados sobre anomalías que detecte el Sistema de Control de Acceso harán una revisión a detalle estos incidentes y tomaran acciones correctivas al respecto.
- La administración del servidor NAC se realiza mediante la consola Web en la cual se tienen diferentes niveles de usuarios para su administración, en la tabla 32 se detalla los usuarios que tienen acceso al sistema NAC.

Cuadro 32: Usuarios autorizados para acceso al sistema NAC.

USUARIO	PRIVILEGIO	AUTENTICACION	CUSTODIA	CLAVE	ESTADO	OBSERVACIONES
admin	Super Usuario	Local	Bóveda	Compartida	activo	Usuario bajo custodia de Seguridad de la Información y auditoria de sistemas.
UserNACPro	Group Reviewer	Active Directory	Subgerencia de Infraestructura Tecnológica	No Compartida	activo	Usuario de lectura creado para que el área producción pueda realizar una lectura de eventos en caso de ser necesario.
UserNACSII	Group Reviewer	Active Directory	Subgerencia de Seguridad de la Información	No Compartida	activo	Usuario de lectura creado para que el área SSII pueda realizar la revisión de los eventos.
UserNACMON	Group Monitor	Active Directory	Personal de monitoreo de TI	No Compartida	activo	Usuario de lectura para que el Operador de monitoreo pueda revisar los eventos en el sistema NAC.

Fuente: Elaboración propia con Excel 2019.

4.2.11 DIFUNDIR EL MODELO

a) Objetivo

En esta etapa se pretende hacer conocer a los miembros de la empresa sobre las medidas que se están tomando con respecto al riesgo que implica brindar acceso a dispositivos de personal externo, se pretende concientizar sobre la importancia de mantener la seguridad de la información dentro de la empresa. Es fundamental que todos los involucrados conozcan el por qué y para qué de este modelo de seguridad de la información dentro de la organización.

b) Control

El control para implementar en esta etapa de comunicación y difusión pueden ser realizados con el envío de correos electrónicos, y cartillas de capacitación al personal de la organización con respecto a la importancia del modelo de seguridad a implementar dentro de la empresa.

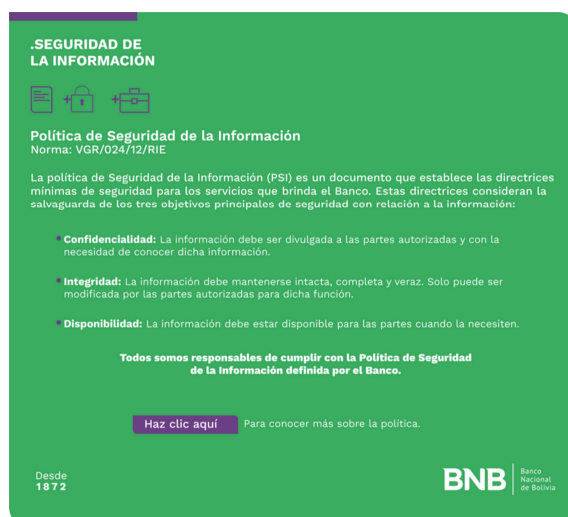
c) Procedimiento de implementación

Las actividades para la socialización y sensibilización incluyen:

- Concienciar al personal de la importancia que el modelo tiene para la organización.
- Garantizar la divulgación, el conocimiento y comprensión de las políticas y normas de seguridad que se implementan.
- Informar a los usuarios en las medidas y procedimientos que se van a implantar.
- Lograr que el personal esté consciente de los roles a cumplir dentro del modelo.

La participación de los encargados de áreas es determinante, pues corresponde a ellos asegurar que los controles que se establezcan y den respuesta a los requerimientos de protección de cada área de la empresa.

El BNB envía constantemente correos electrónicos internos de forma masiva a todos sus empleados, sobre lo que representa la seguridad de la información dentro del banco, en la figura 70 se muestra un ejemplo de cómo el banco hace conocer que se cuenta con una Política de seguridad de la información la cual se encuentra vigente dentro de la empresa.



Fuente: Captura de campaña de correo electrónico BNB.

Figura 70: Boletín informativo de Política de seguridad de la información.

En la figura 71 se muestra un comunicado vía correo electrónico el cual en sus enlaces dan acceso a los documentos que son los entregables de esta investigación los cuales son:

- Anexo II Modelo de Control de Acceso a la Red de Datos.
- Anexo III Política de Control de Acceso a la Red de Datos.
- Anexo IV Normativa de gestión de Control de Acceso a la Red.

Estos documentos son los que se envían a los empleados de la institución para hacerles conocer las medidas de seguridad que se están tomando dentro de la empresa.

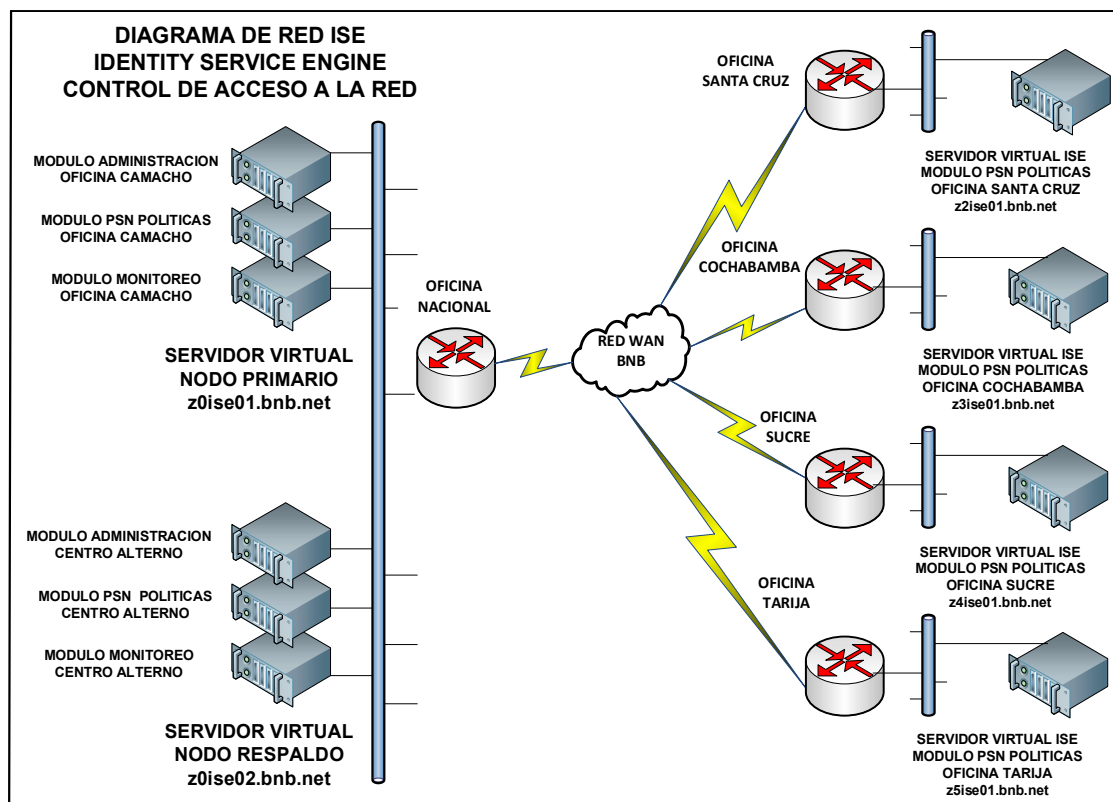


Fuente: Captura de campaña de correo electrónico BNB.

Figura 71: Boletín informativo del modelo de seguridad de la informacion.

4.2.12 ARQUITECTURA DE RED PROPUESTA

Para el despliegue del sistema de control de acceso a la red se está proponiendo la siguiente arquitectura de red para la instalación de los módulos del sistema NAC a nivel nacional. Cada servidor virtual del sistema de control de acceso a la red puede estar compuesto por tres módulos: el de administración, el de políticas y el de monitoreo. En la oficina principal de La Paz y en su centro alterno se pretende instalar estos tres módulos en cada nodo ya que a través de ellos se hará la gestión y configuración de políticas de acceso a la red, por la cantidad de oficinas, de usuarios y de dispositivos de red se pretende instalar el servidor con el módulo de políticas en las oficinas de Santa Cruz, Cochabamba Sucre y Tarija. Los switches de acceso de las oficinas de Oruro, Potosí, Trinidad y Cobija consultaran al servidor de la oficina principal para controlar el acceso de red de los dispositivos del banco. En la figura 72 se muestra el detalle de la arquitectura de red propuesta para el caso de estudio.



Fuente: Elaboración propia con Visio 2019.

Figura 72: Arquitectura de red propuesta del sistema NAC.

4.3 EVALUACIÓN DEL MODELO DE SEGURIDAD DE LA INFORMACIÓN

Para realizar una evaluación de los resultados alcanzados con la implementación de este modelo de seguridad de la información se buscará evidencias de que las medidas tomadas están bloqueando el acceso de personal externo a la red para lo cual en primera instancia revisaremos la cantidad de equipos conectados de la red del banco en los switches de acceso de las 13 agencias de la ciudad de La Paz del banco, el detalle de switches y equipos por agencia se muestra en la tabla 33.

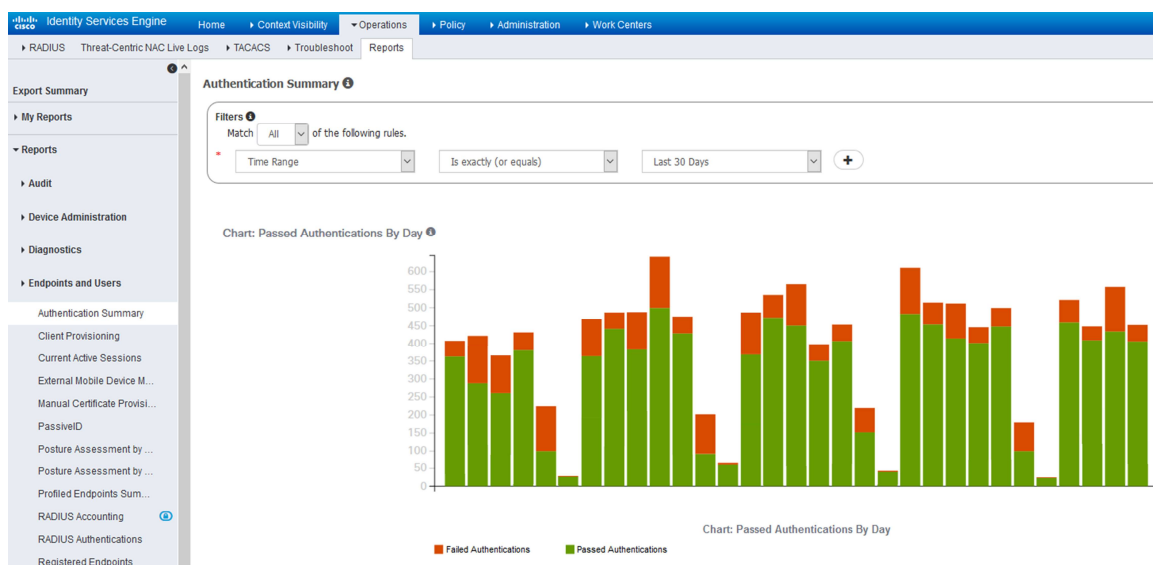
Cuadro 33: Cantidad de equipos de red por agencia.

SUCURSALES AGENCIAS OF LA PAZ BNB		
AGENCIAS SUCURSAL LA PAZ	CANTIDAD DE SWITCHES DE ACCESO DE 24 PUERTOS	CANTIDAD EQUIPOS CONECTADOS
20 DE OCTUBRE	3	49
TORREZ DEL POETA	3	47

SAN MIGUEL	3	41
ACHUMANI	3	39
PEREZ VELASCO	2	38
BUENOS AIRES	2	37
VILLA FATIMA	2	32
EDIFICIO ANEXO	2	29
MIRAFLORES	2	27
OBRAJES	1	21
MEGACENTER	1	19
CEMENTERIO	1	18
GRAN PODER	1	14
TOTAL	26	411

Fuente: Elaboración propia con Excel 2019.

Para la consulta de reporte de conexiones dentro del servidor de acceso a la red accedemos al módulo de reportes donde podemos acceder a reportes de eventos de conexiones donde seleccionamos la opción de dispositivos y usuarios y seleccionamos el reporte de sumario de autenticación y obtenemos el reporte por días del mes de octubre del 2019 que se muestra a detalle en la figura 73.



Fuente: Captura Sistema de Control de Acceso ISE

Figura 73: Reporte de autenticación del sistema NAC.

De este reporte realizamos la tabulación de datos y pudimos obtener el siguiente reporte de eventos del mes de octubre del 2019 que se muestra a detalle en la tabla 34.

Cuadro 34: Reporte de conexiones sistema de control de acceso a la red.

REPORTE DE CONEXIONES				
Día	Conexiones aceptadas	Conexiones rechazadas	Conexiones totales	Conexiones rechazadas %
1-oct-19	404	357	47	11,63
2-oct-19	418	293	125	29,90
3-oct-19	358	262	96	26,82
4-oct-19	406	364	42	10,34
5-oct-19	202	108	94	46,53
6-oct-19	17	14	3	17,65
7-oct-19	467	361	106	22,70
8-oct-19	468	442	26	5,56
9-oct-19	465	372	93	20,00
10-oct-19	721	494	227	31,48
11-oct-19	459	436	23	5,01
12-oct-19	175	93	82	46,86
13-oct-19	63	57	6	9,52
14-oct-19	486	373	113	23,25
15-oct-19	468	442	26	5,56
16-oct-19	536	478	58	10,82
17-oct-19	384	348	36	9,38
18-oct-19	488	406	82	16,80
19-oct-19	217	153	64	29,49
20-oct-19	51	47	4	7,84
21-oct-19	588	492	96	16,33
22-oct-19	504	458	46	9,13
23-oct-19	506	412	94	18,58
24-oct-19	443	397	46	10,38
25-oct-19	501	453	48	9,58
26-oct-19	168	104	64	38,10
27-oct-19	40	36	4	10,00
28-oct-19	509	462	47	9,23
29-oct-19	441	412	29	6,58
30-oct-19	543	426	117	21,55
31-oct-19	418	392	26	6,22

Fuente: Reporte de Sistema de Control de Acceso ISE.

Las conexiones rechazadas se debieron a que equipos de dominio no tenían correctamente configurados su cliente de acceso, que el usuario haya colocado su contraseña de dominio en forma incorrecta o debido a que la conexión de un equipo que no pertenece la red. Para simular la conexión de dispositivos externos a la red del banco se dispuso de dos equipos que no pertenecen a la red y se los conecto a puertos de red de agencias donde se realizó esta prueba y se logró obtener el siguiente reporte de equipos rechazados el cual se muestra en la figura 74 donde se observa la dirección de los equipos que intentaron ingresar a la red de datos del banco.

Changed At	Endpoint ID	Server	Status	Failure Reason
2019-10-27 10:47:42.841	70:20:84:08:01:C3	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 10:47:42.84	00:76:86:FC:F1:E9	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 10:37:02.914	00:76:86:FC:F1:E9	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 10:37:02.914	70:20:84:08:01:C3	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 10:30:02.27	70:20:84:08:01:C3	bnbise	Released	
2019-10-27 10:30:02.27	00:76:86:FC:F1:E9	bnbise	Released	
2019-10-27 10:26:22.959	70:20:84:08:01:C3	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 10:26:22.959	00:76:86:FC:F1:E9	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 10:11:08.99	70:20:84:08:01:C3	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 10:11:08.99	00:76:86:FC:F1:E9	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 09:55:54.79	00:76:86:FC:F1:E9	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 09:55:54.789	70:20:84:08:01:C3	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 09:40:40.731	00:76:86:FC:F1:E9	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 09:40:40.73	70:20:84:08:01:C3	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 09:30:00.761	00:76:86:FC:F1:E9	bnbise	Rejected	22017 Selected Identity Source is DenyA...

Fuente: Captura Sistema de Control de Acceso ISE

Figura 74: Reporte de equipos rechazados del sistema NAC.

En la figura 75 donde se muestra el reporte de autorizaciones de equipos se puede evidenciar que los intentos de conexión de los equipos externos a la red de datos fueron rechazados.

Identity	Passed	Failed	Total	Failed %
lgutierrez	172	1	173	0.58
70:20:84:08:01:C3	0	82	82	100
00:76:86:FC:F1:E9	0	82	82	100
amovando	66	1	67	1.49
jaramirez	40	7	47	14.89
wdeacruz	42	3	45	6.67
evargas	28	0	28	0
sfigueroa	11	14	25	56
sezurita	18	0	18	0
juignacio	16	1	17	5.88
bnbiccama	13	4	17	23.53
jochoque	13	1	14	7.14
SEZurita	11	2	13	15.38
alburgos	10	2	12	16.67
fasoliz	3	8	11	72.73
hulahore	8	2	10	20
rucabrera	10	0	10	0
hulahore	8	2	10	20
rucabrera	10	0	10	0

Fuente: Captura Sistema de Control de Acceso ISE

Figura 75: Reporte de equipos autorizados por el sistema NAC.

De esta serie de reportes también podemos obtener el de los dispositivos junto a la identificación de usuarios conectados a la red de datos este detalle se muestra en la figura 76.

Logged At	RADIUS Status	Details	Identity	Endpoint ID	Endpoint Profile	Authorization Rule
2019-10-27 10:13:41.317	✓		evargas	90:32:4B:AF:8E:A1	Workstation	Authorization Rule 1
2019-10-27 10:11:39.534	✓		jgutierrez	98:5F:D3:51:B7:02	Workstation	Authorization Rule 1
2019-10-27 09:53:25.393	✓		davallejos	48:D2:24:35:AC:39	Unknown	Authorization Rule 1
2019-10-27 09:38:14.172	✓		SEZurita	40:25:C2:B0:54:F0	Workstation	Authorization Rule 1
2019-10-27 09:12:22.131	✓		cangulo	F8:94:C2:60:A0:9F	Workstation	Authorization Rule 1
2019-10-27 09:07:55.671	✓		cangulo	F8:94:C2:60:A0:9F	Workstation	Authorization Rule 1
2019-10-27 08:41:53.141	✓		rucabrera	94:65:9C:54:9B:B5	Workstation	Authorization Rule 1
2019-10-27 08:25:13.495	✓		juignacio	34:E6:AD:B8:D8:28	Workstation	Authorization Rule 1
2019-10-27 08:00:32.411	✓		evargas	08:3E:8E:6C:8C:D0	Workstation	Authorization Rule 1
2019-10-27 01:46:42.675	✓		sfigueroa	94:B8:6D:40:78:42	Windows7-Workstation	Authorization Rule 1
2019-10-27 00:24:02.294	✓		sfigueroa	94:B8:6D:40:78:42	Windows7-Workstation	Authorization Rule 1
2019-10-26 23:07:42.388	✓		EMoralesc	44:85:00:80:B7:BD	Workstation	Authorization Rule 1
2019-10-26 21:58:26.205	✓		pmartinez	38:F9:D3:2E:8C:79	Macintosh-Workstation	Authorization Rule 1
2019-10-26 21:51:59.264	✓		evargas	90:32:4B:AF:8E:A1	Workstation	Authorization Rule 1
2019-10-26 20:05:16.339	✓		sfigueroa	94:B8:6D:40:78:42	Windows7-Workstation	Authorization Rule 1

Fuente: Captura Sistema de Control de Acceso ISE

Figura 76: Reporte de usuarios conectados al sistema NAC.

De acuerdo con la normativa interna del banco relacionada a la Metodología de evaluación de riesgos, habiendo hecho la identificación de activos de información a los cuales se hizo la evaluación de riesgos concerniente al acceso de red de datos podemos indicar que en las 13 agencias de la ciudad de La Paz donde se realizaron las pruebas de campo del sistema de control de acceso existe el control que se ejecuta continuamente, esta valoración se la hace comparando al anterior escenario donde no existía algún tipo de control de acceso y de acuerdo con la escala de la metodología de evaluación de riesgos que se muestra en la tabla 35.

Cuadro 35: Eficacia del control de seguridad.

EFICACIA CONTROL			
Valor	Efectividad	Criterio de ejecución	Valoración
0	ninguna	No existe	0
1	muy bajo	Existe y se ejecuta raramente	25%
2	bajo	Existe y se ejecuta a menudo	50%
3	medio	Existe y se ejecuta frecuentemente	75%
4	alto	Existe y se ejecuta continuamente	85%

Fuente: Metodología de evaluación de riesgos BNB.

Por ende, la aplicación del modelo de seguridad propuesto es funcional dentro de la red de datos del BNB, la aplicación normativa de la política y la normativa de control de acceso acompañadas del procedimiento del sistema de control de acceso a la red son funcionales en la red del banco.

A continuación, como parte de la evaluación del modelo propuesto se muestra tablas comparativas con los distintos modelos de seguridad alternativos en base al estudio realizado en el capítulo II, en el acápite de Marco Referencial donde se pudo identificar doce modelos de seguridad que podrían aplicarse para la resolución del problema de investigación. Estos modelos de seguridad son:

- ISO/IEC 27001 (SGSI) Sistema de Gestión de Seguridad de la Información.
- Guía Metodológica del Sistema de Seguridad de la Información en el Programa de Mejoramiento de la Gestión y Metas de Eficiencia (SSI-PMGMEI).
- Modelo de Madurez de Seguridad de la Información en Organizaciones Inteligentes (MMASI).
- Modelo Mejorado de Seguridad de la Información de Red Distribuida (P2DWR2).
- Modelo de Seguridad de la Información (MSGRC).
- Modelo de Seguridad de la Información en TIC (MSI-TIC).
- Modelo de Defensa de Seguridad de Red (MDSR).
- Modelo (O-ISM3) de Madurez de Gestión de Seguridad de la Información.
- Modelo de Seguridad de Red Basado en Minería de Datos (MSRBMD).
- Modelo de Seguridad de Red de Defensa Activa (P2DR2C).
- Modelo Contextualizado de Colado & Franco (MCC&F).
- Directiva de Seguridad de la Información para la protección de datos personales (DSI-PDP).

Del análisis realizado se puede ver que de los 12 modelos de seguridad estudiados por lo menos cuentan con algunos de los siguientes elementos:

- Fases para implementar, operar, monitorear y mejorar la seguridad de la información.
- Organización para la operación de seguridad de la información.
- Funciones definidas del responsable o de la dirección de la gestión.
- Niveles de madurez del sistema de seguridad.
- Documentos obligatorios de seguridad de la información.
- Controles definidos para reducir los riesgos de seguridad de información.
- Indicadores para medir los controles.

En el cuadro 36 se muestran los 12 modelos y los elementos con los que cuenta cada uno.

Cuadro 36: Modelos de seguridad de la información.

Elementos	MODELOS DE SEGURIDAD DE LA INFORMACIÓN											
	SGSI	SSI-PMGMEI	MMASI	P2DWR2	MSGRC	MSI-TIC	MDSR	O-ISM3	MSRBMD	P2DR2C	MCC&F	DSI-PDP
Fases	04 - PDCA	04 Diagnostico, planificación, implementación y evaluación	No	04 Protección, detección, alerta temprana, respuesta de recuperación	03 componentes	02 - Fase de elaboración y fase de aplicación	03 Seguridad tecnológica, soporte en administración y respuesta en tiempo real	04- Pirámide administrativa y proceso general	04 componentes	05 Protección, detección, respuesta, contador de ataques, prevención	03 componentes relacionados	No
Organización	Determinada por la entidad	Determinada por la entidad	No	No	No	No	No	No	No	No	No	Determinada por la entidad
Funciones	No	No	No	No	No	Del Oficial de Seguridad	No	No	No	No	No	Requisitos organizativos
Documento	Generales	Generales	No	No	Mención en componente conductor	Mención general	No	Generales	No	No	No	Requisitos jurídicos
Niveles	No	No	No	No	No	No	No	5	No	No	4	No
Controles	Requisitos específicos	Mención general	No	Mención general	No	Mención general	Requisitos técnicos	Especifica por fases	Requisitos técnicos	Mención general	No	Requisitos técnicos
Indicadores	No	No	Mención en cada nivel	No	No	No	No	Mención de 8 tipos	No	No	No	No

Fuente: Elaboración propia con Excel 2019.

En el cuadro anterior podemos ver que los 12 modelos estudiados no cuentan con todos los elementos analizados, mientras que el modelo de seguridad propuesto en este estudio cuenta con estos elementos en su estructura. En el cuadro 37 se muestra el modelo planteado con una descripción de los elementos con los que cuenta el mismo.

Cuadro 37: Evaluación del modelo de seguridad de la información para el control de acceso a la red de datos.

Elementos	MODELO DE SEGURIDAD DE LA INFORMACIÓN PARA EL CONTROL DE ACCESO A LA RED DE DATOS
Fases	02 - Fase de preparación y Fase de desarrollo
Organización	Definido por el Comité de Gestión integral de Riesgos
Funciones	Del Subgerente de Seguridad de la Información
Documento	02 - Política de Seguridad de la Información. Política de control de acceso a la red de datos.
Niveles	6 Niveles en la Fase de desarrollo
Controles	Específicos por cada nivel
Indicadores	Definidos en la fase de evaluación de riesgos

Fuente: Elaboración propia con Excel 2019.

4.4 VALIDACIÓN DE RESULTADOS

Para hacer una valoración de los resultados alcanzados con la implementación de este modelo de seguridad de la información se hará una recopilación de eventos de conexiones no autorizadas bloqueadas, así como la cantidad de eventos de seguridad que se obtienen de los reportes de la empresa NEOSECURE. Con lo cual se pretenden identificar en que porcentaje se pudo mejorar los controles de acceso en la red de datos y también se verá en que porcentaje se redujeron los incidentes de seguridad de la información relacionados al acceso de red. Estos datos serán obtenidos antes y después de aplicar la propuesta de solución. Para la validación de resultados recurriremos a la operacionalización de la variable dependiente de este estudio la cual fue presentada en el primer capítulo y se muestra en el cuadro 38.

Cuadro 38: Operacionalización de variable dependiente.

VARIABLE Y DEFINICIÓN	DIMENSIÓN	INDICADOR	ÍNDICE
<u>Control de acceso a la red de datos</u> Proporcionan herramientas que permitirán brindar o denegar acceso a los equipos que se conecten.	Dispositivos autorizados para acceder a la red de datos.	- Reporte de conexiones	- Cantidad de equipos conectados. - Cantidad de equipos conectados autorizados. - Cantidad de equipos rechazados. - Cantidad de eventos de conexión de equipos

Fuente: Elaboración propia con Excel 2019.

Hacemos la valoración de los indicadores antes de aplicar el modelo de seguridad en las agencias previamente definidas para su estudio, este resumen se muestra en la tabla 39.

Cuadro 39: Reporte de conexiones antes de aplicar el modelo

REPORTE DE CONEXIONES ANTES DE APLICAR EL MODELO				
AGENCIAS SUCURSAL LA PAZ	CANTIDAD EQUIPOS CONECTADOS	CANTIDAD DE EQUIPOS CONECTADOS AUTORIZADOS	CANTIDAD DE EQUIPOS RECHAZADOS	CANTIDAD DE EVENTOS DE CONEXIÓN
20 DE OCTUBRE	49	49	Sin datos	Sin datos
TORREZ DEL POETA	47	47	Sin datos	Sin datos
SAN MIGUEL	41	41	Sin datos	Sin datos

PEREZ VELASCO	38	38	Sin datos	Sin datos
BUENOS AIRES	37	37	Sin datos	Sin datos
VILLA FATIMA	32	32	Sin datos	Sin datos
EDIFICIO ANEXO	29	29	Sin datos	Sin datos
MIRAFLORES	27	27	Sin datos	Sin datos
OBRAJES	21	21	Sin datos	Sin datos
MEGACENTER	19	19	Sin datos	Sin datos
CEMENTERIO	18	18	Sin datos	Sin datos
GRAN PODER	14	14	Sin datos	Sin datos
TOTAL	411	411	Sin datos	Sin datos

Fuente: Elaboración propia con Excel 2019.

Para obtener los datos de cantidad de equipos conectados se realizó la consulta en cada uno de los switches de acceso de cada agencia donde se realizado el estudio, haciendo uso del comando de consulta que se muestra en la figura 77 a cada switch de las agencias.

```
LPZ-AG-ACHUMANI-SW3#sh int status
```

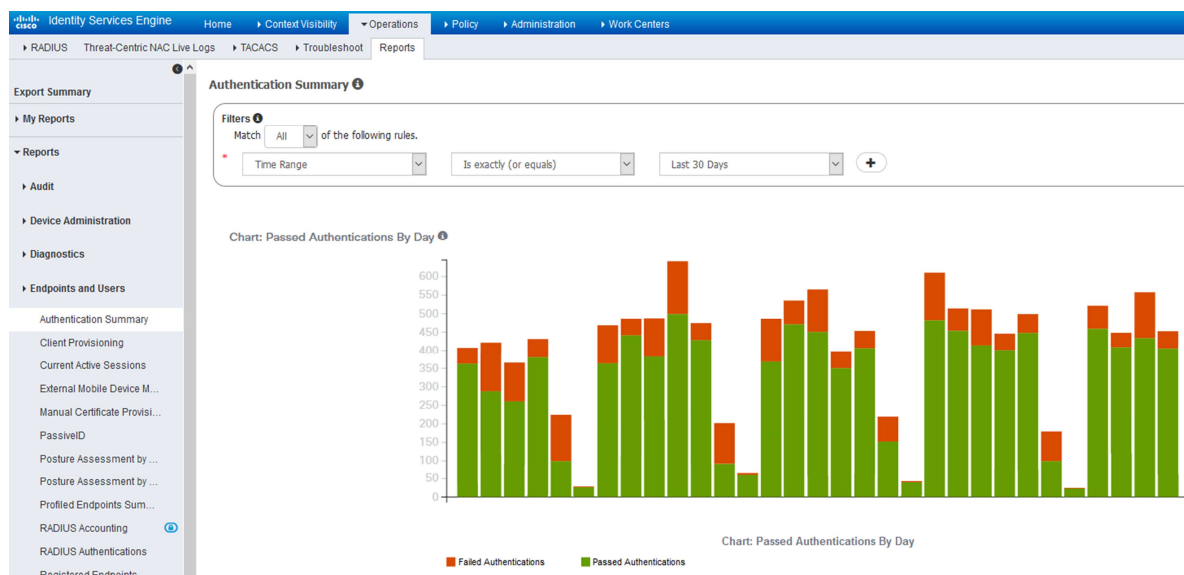
Port	Name	Status	Vlan
Fa0/1		connected	
Fa0/2		connected	
Fa0/3		connected	
Fa0/4		connected	
Fa0/5		connected	
Fa0/6		connected	
Fa0/7		connected	
Fa0/8		connected	
Fa0/9		connected	
Fa0/10		connected	
Fa0/11		connected	
Fa0/12		connected	
Fa0/13		connected	
Fa0/14		connected	
Fa0/15		connected	
Fa0/16		connected	
Fa0/17		connected	
Fa0/18		connected	
Fa0/19		connected	
Fa0/20		connected	
Fa0/21		connected	
Fa0/22		connected	
Fa0/23		connected	
Fa0/24		notconnect	
Gi0/1		connected	
Gi0/2		connected	

```
LPZ-AG-ACHUMANI-SW3#exit
```

Fuente: Captura Switch de Acceso agencia Achumani

Figura 77: Reporte de equipos conectados antes de aplicar el modelo.

Debido a que no existía ningún control en los switches de acceso es que se autoriza la conexión a todos los equipos conectados sin restricción alguna, tampoco se cuenta con estadísticas de cantidad de equipos rechazados ni registro de eventos de conexión de equipos. Luego de aplicar el modelo de seguridad con la ayuda del sistema de control de acceso a la red es que se logra tener visibilidad sobre las conexiones que se hacen a nivel de capa de acceso en las agencias donde se aplicó el modelo, este resumen de conexiones se muestra en la figura 78.



Fuente: Captura Sistema de Control de Acceso ISE

Figura 78: Reporte de autenticación del sistema NAC.

De los reportes que se generan en el sistema de control de acceso también se obtiene el reporte de equipos rechazados que intencionalmente fueron conectados para que el sistema genere registros de denegación de acceso el cual se presenta en el cuadro 79.

Changed At	Endpoint ID	Server	Status	Failure Reason
2019-10-27 10:47:42.841	70:20:84:08:01:C3	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 10:47:42.84	00:76:86:FC:F1:E9	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 10:37:02.914	00:76:86:FC:F1:E9	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 10:37:02.914	70:20:84:08:01:C3	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 10:30:02.27	70:20:84:08:01:C3	bnbise	Released	
2019-10-27 10:30:02.27	00:76:86:FC:F1:E9	bnbise	Released	
2019-10-27 10:26:22.959	70:20:84:08:01:C3	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 10:26:22.959	00:76:86:FC:F1:E9	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 10:11:08.99	70:20:84:08:01:C3	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 10:11:08.99	00:76:86:FC:F1:E9	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 09:55:54.79	00:76:86:FC:F1:E9	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 09:55:54.789	70:20:84:08:01:C3	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 09:40:40.731	00:76:86:FC:F1:E9	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 09:40:40.73	70:20:84:08:01:C3	bnbise	Rejected	22017 Selected Identity Source is DenyA...
2019-10-27 09:30:00.761	00:76:86:FC:F1:E9	bnbise	Rejected	22017 Selected Identity Source is DenyA...

Fuente: Captura Sistema de Control de Acceso ISE

Figura 79: Reporte de equipos rechazados del sistema NAC.

Sobre los registros de eventos de conexión de equipos también se puede acceder al reporte RADIUS del servidor de control de acceso el cual se muestra en la figura 80 donde se puede apreciar el tiempo de conexión de cada equipo que accedió a la red de datos.

Logged At	Details	Account Status Type	Identity	Endpoint...	Account Term...	Account S...	Network Device IP
2019-10-26 00:41:56.71		Start	00-e0-1c-00-27-27	10.10.10.10			10.10.10.10
2019-10-26 00:41:14.242		Stop	00-e0-1c-00-27-27	10.10.10.10	Lost Service	7min 25sec	10.10.10.10
2019-10-26 00:39:36.562		Stop	d4-ae-05-fa-fd-8f	10.10.10.10	Idle Timeout	42min 8sec	10.10.10.10
2019-10-26 00:39:25.125		Start	e4-b3-18-76-f9-d5	E4-B3-18-76-F9-D5...			10.10.10.10
2019-10-26 00:38:27.358		Start	8c-85-90-92-e4-c9	8C-85-90-92-E4-C9...			10.10.10.10
2019-10-26 00:35:27.533		Interim-Update	4c-34-88-48-05-da	1.10.10.10		1days 15hr 4...	10.10.10.10
2019-10-26 00:33:49.061		Start	00-e0-1c-00-27-27	10.10.10.10			10.10.10.10
2019-10-26 00:33:06.321		Stop	00-e0-1c-00-27-27	10.10.10.10	Lost Service	4min 23sec	10.10.10.10
2019-10-26 00:31:29.371		Stop	d4-ae-05-f9-a7-01	d4-ae-05-f9-a7-01...	Idle Timeout	5min 39sec	10.10.10.10

Fuente: Captura Sistemas de Control de Acceso ISE

Figura 80: Registro de conexión y desconexión de equipos del sistema NAC.

Con las evidencias recolectadas se generó el siguiente reporte de conexiones luego de aplicar el modelo de seguridad en el mes de octubre del 2019, dicho reporte se muestra en el cuadro 40.

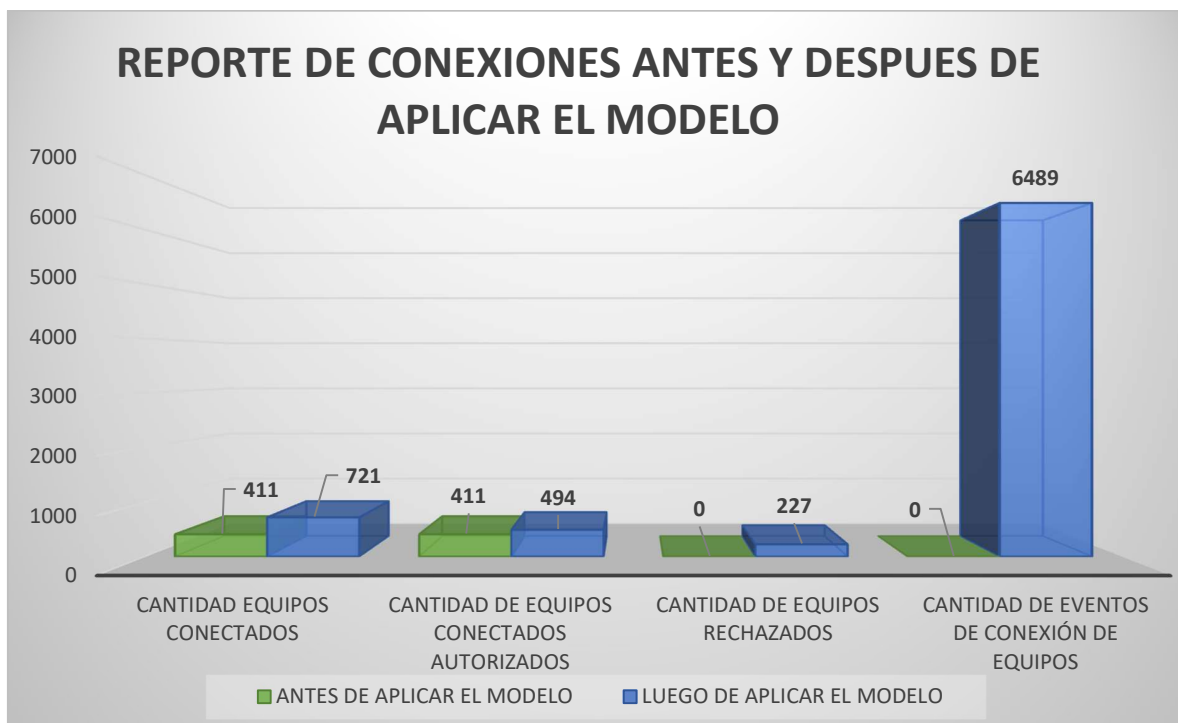
Cuadro 40: Reporte de conexiones luego de aplicar el modelo en el mes de octubre 2019

REPORT DE CONEXIONES LUEGO DE APLICAR EL MODELO DE SEGURIDAD					
DÍA	CANTIDAD EQUIPOS CONECTADOS	CANTIDAD DE EQUIPOS AUTORIZADOS	CANTIDAD DE EQUIPOS RECHAZADOS	CANTIDAD DE EVENTOS DE CONEXIÓN	CONEXIONES RECHAZADAS %
1-oct-19	404	357	47	1212	11,63
2-oct-19	418	293	125	1254	29,90
3-oct-19	358	262	96	1074	26,82
4-oct-19	406	364	42	1218	10,34
5-oct-19	202	108	94	404	46,53
6-oct-19	17	14	3	34	17,65
7-oct-19	467	361	106	4203	22,70
8-oct-19	468	442	26	4212	5,56
9-oct-19	465	372	93	4185	20,00
10-oct-19	721	494	227	6489	31,48
11-oct-19	459	436	23	4131	5,01
12-oct-19	175	93	82	1575	46,86
13-oct-19	63	57	6	126	9,52
14-oct-19	486	373	113	5346	23,25

15-oct-19	468	442	26	5148	5,56
16-oct-19	536	478	58	5896	10,82
17-oct-19	384	348	36	4224	9,38
18-oct-19	488	406	82	5368	16,80
19-oct-19	217	153	64	2387	29,49
20-oct-19	51	47	4	102	7,84
21-oct-19	588	492	96	7056	16,33
22-oct-19	504	458	46	6048	9,13
23-oct-19	506	412	94	6072	18,58
24-oct-19	443	397	46	5316	10,38
25-oct-19	501	453	48	6012	9,58
26-oct-19	168	104	64	2016	38,10
27-oct-19	40	36	4	124	10,00
28-oct-19	509	462	47	6617	9,23
29-oct-19	441	412	29	5733	6,58
30-oct-19	543	426	117	7059	21,55
31-oct-19	418	392	26	5434	6,22
Promedio	384,32	320,77	63,55	3744,35	17,51

Fuente: Elaboración propia con Excel 2019.

Con los datos recopilados se obtiene el siguiente reporte de conexiones antes y después de aplicar el modelo de seguridad los cuales se resumen en la figura 81 y el cuadro 41.



Fuente: Elaboración propia con Excel 2019.

Figura 81: Reporte de conexiones antes y después de aplicar el modelo.

Cuadro 41: Reporte de conexiones promedio antes y después de aplicar el modelo

REPORTE DE CONEXIONES PROMEDIO ANTES Y DESPUÉS DE APLICAR EL MODELO				
	CANTIDAD EQUIPOS CONECTADOS	CANTIDAD DE EQUIPOS AUTORIZADOS	CANTIDAD DE EQUIPOS RECHAZADOS	CANTIDAD DE EVENTOS DE CONEXIÓN
ANTES del MODELO	411	411	0	0
LUEGO del MODELO	721	494	227	6489

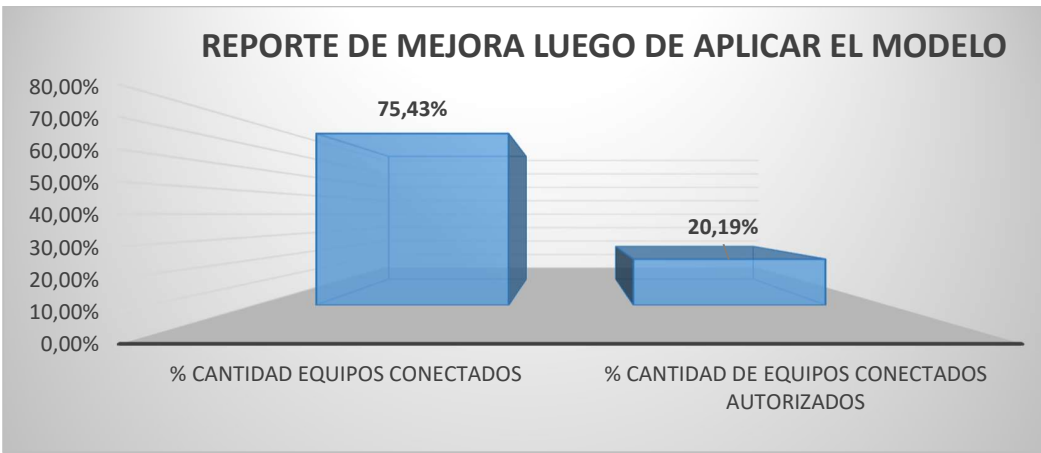
Fuente: Elaboración propia con Excel 2019.

Como se observa el promedio de eventos mensual de equipos conectados es de 384,32 sin embargo se tubo días pico de equipos conectados de 721 y de 494 equipos rechazados dichas estadísticas y porcentajes se muestran en la tabla 42 y grafico 82.

Cuadro 42: Reporte de conexiones antes y después de aplicar el modelo

REPORTE DE CONEXIONES ANTES Y DE APLICAR EL MODELO		
	CANTIDAD EQUIPOS CONECTADOS	CANTIDAD DE EQUIPOS AUTORIZADOS
ANTES DE APLICAR EL MODELO	411	411
LUEGO DE APLICAR EL MODELO	721	494
PORCENTAJE DE MEJORA %	75,43%	20,19%

Fuente: Elaboración propia con Excel 2019.



Fuente: Elaboración propia con Excel 2019.

Figura 82: Reporte de conexiones después de aplicar el modelo.

Para la validación de resultados de la variable independiente recurrimos a los índices previamente definidos para esta variable que se muestran en el cuadro 43.

Cuadro 43: Operacionalización de variable independiente.

VARIABLE INDEPENDIENTE	DIMENSIÓN	INDICADOR	ÍNDICE
<u>Modelo de seguridad de la información en la capa de enlace de datos de una red corporativa</u>	- Disponibilidad en comunicaciones.	- Reporte e informe de incidentes	- Cantidad de eventos de incidentes DoS denegación de servicio.
	- Confidencialidad en comunicaciones.	- Reporte e informe de incidentes	- Cantidad de eventos de incidentes de Escaneo de red.

Fuente: Elaboración propia usando Excel 2019.

Para su validación recurrimos a los reportes de seguridad del monitoreo de eventos brindado por NEOSECURE, de este reporte se genera tiene la siguiente tabla resumen 44.

Cuadro 44: Reporte de incidentes de NEOSECURE antes de aplicar el modelo

REPORTE DE INCIDENTES BNB MONITOREO DE EVENTOS DE SEGURIDAD ANTES DE APLICAR EL MODELO														
EVENTO DE SEGURIDAD	ago-18	sep-18	oct-18	nov-18	dic-18	ene-19	feb-19	mar-19	abr-19	may-19	jun-19	jul-19	ago-19	PROMEDIO
EVENTOS DoS Denegación de servicio	2	1	2	0	1	1	0	0	0	2	39	43	37	9,85
EVENTOS Escaneo de trafico de red	1	3	1	1	1	2	1	2	2	1	8	1	5	2,23

Fuente: Elaboración propia con Excel 2019.

Luego de haber implementado el modelo de seguridad se solicitó el reporte de incidentes a la empresa NEOSECURE quienes brindaron el siguiente resumen que se muestra en la tabla 45.

Cuadro 45: Reporte de incidentes de NEOSECURE luego de aplicar el modelo

REPORTE DE INCIDENTES BNB MONITOREO DE EVENTOS DE SEGURIDAD DESPUES DE APLICAR EL MODELO	
EVENTO DE SEGURIDAD	oct-19
EVENTOS DoS Denegación de servicio	3
EVENTOS Escaneo de trafico de red	2

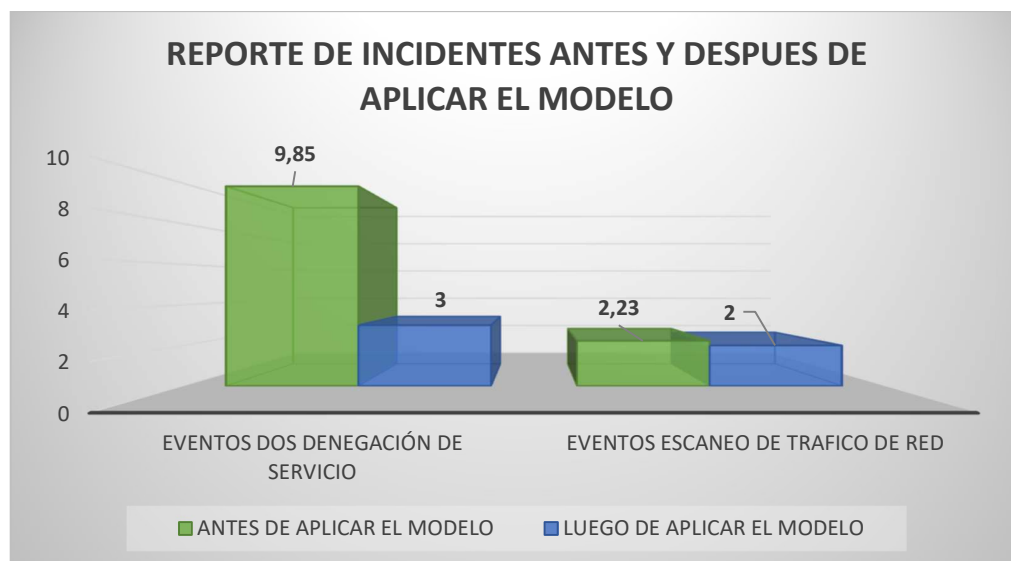
Fuente: Elaboración propia con Excel 2019.

Con los datos recopilados se obtiene el siguiente reporte de conexiones antes y después de aplicar el modelo de seguridad los cuales se resumen en el cuadro 46 y figuras 83 y 84.

Cuadro 46: Reporte de conexiones antes y después de aplicar el modelo

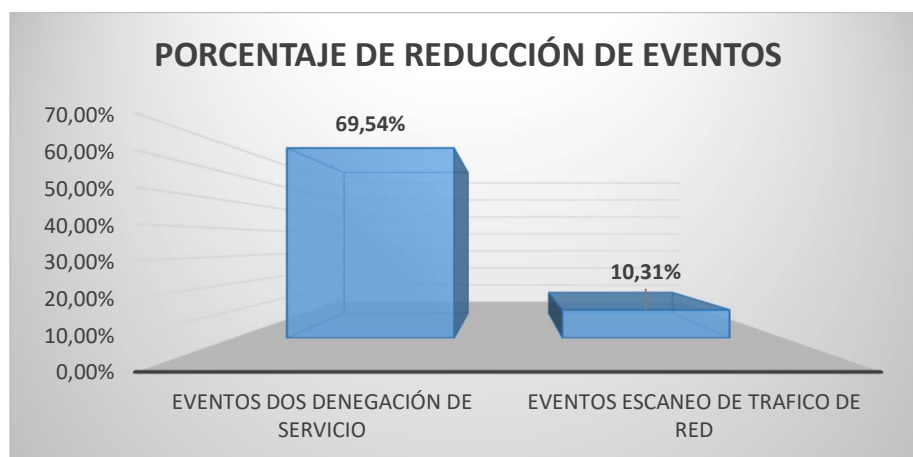
REPORTE DE INCIDENTES BNB MONITOREO DE EVENTOS DE SEGURIDAD ANTES DE APLICAR EL MODELO		
	EVENTOS DoS Denegación de servicio	EVENTOS Escaneo de trafico de red
ANTES DE APLICAR EL MODELO	9,85	2,23
LUEGO DE APLICAR EL MODELO	3	2
% DE REDUCCIÓN DE EVENTOS	69,54%	55,16%

Fuente: Elaboración propia con Excel 2019.



Fuente: Elaboración propia con Excel 2019.

Figura 83: Reporte de conexiones antes y después de aplicar el modelo.



Fuente: Elaboración propia con Excel 2019.

Figura 84: Porcentaje de reducción de eventos de seguridad luego de aplicar al modelo.

4.4.1 VERIFICACIÓN DE HIPÓTESIS

Para la verificación de la hipótesis se ha utilizado el método Ji Cuadrado, que para (Hernández Sampieri, Fernández Collado, & Baptista Lucio, 2014, pág. 318) es una prueba estadística para evaluar una hipótesis acerca de la relación entre dos variables categóricas.

4.4.2 PLANTEAMIENTO DE HIPÓTESIS

- Modelo lógico

H₀: La implementación de un modelo de control de acceso a la red a nivel de la capa de enlace de datos basado en el estándar IEEE 802.1x **NO** evitara el acceso indebido a personal externo a la red de datos del Banco Nacional de Bolivia.

H₁: La implementación de un modelo de control de acceso a la red a nivel de la capa de enlace de datos basado en el estándar IEEE 802.1x **SI** evitara el acceso indebido a personal externo a la red de datos del Banco Nacional de Bolivia.

- Modelo Matemático

$$H_0: O = E \quad O - E = 0$$

$$H_1: O \neq E \quad O - E \neq 0$$

4.4.3 APLICACIÓN DE LA PRUEBA ESTADÍSTICA

Se elaboraron tablas resumen de la operacionalización de variables considerando las cantidades con cada indicador y los índices correspondientes a cada variable que se muestra en las siguientes tablas 47, 48 y 49.

Cuadro 47: Cálculo de frecuencias de la variable independiente

VARIABLE INDEPENDIENTE	DIMENSIÓN	INDICADOR	ÍNDICE	TOTAL DE FRECUENCIAS	
				OBSERVADAS	ESPERADAS
Modelo de seguridad de la información en la capa de enlace de datos de una red corporativa	- Disponibilidad en comunicaciones	- Reporte e informe de incidentes	- EVENTOS DoS Denegación de servicio	3	9,85
	Confidencialidad en comunicaciones	- Reporte e informe de incidentes	- EVENTOS Escaneo de trafico de red	2	2,23
PROMEDIO VI				2,50	6,04

Fuente: Elaboración propia con Excel 2019.

Cuadro 48: Cálculo de frecuencias de la variable dependiente

VARIABLE DEPENDIENTE	DIMENSIÓN	INDICADOR	ÍNDICE	TOTAL DE FRECUENCIAS	
				OBSERVADAS	ESPERADAS
Control de acceso a la red de datos	Dispositivos autorizados para acceder a la red de datos.	Reporte de conexiones	- Cantidad de equipos conectados.	384,32	411
			- Cantidad de equipos conectados autorizados.	320,77	411
			- Cantidad de equipos rechazados.	63,55	0
			PROMEDIO VD	480,67	274,00

Fuente: Elaboración propia con Excel 2019.

Cuadro 49: Cálculo de frecuencias de la variable independiente y dependiente

VARIABLE	TOTAL DE FRECUENCIAS	
	OBSERVADAS	ESPERADAS
VI: Modelo de seguridad de la información	2,50	6,04
VD: Control de acceso a la red de datos	480,67	274,00

Fuente: Elaboración propia con Excel 2019.

Por la información obtenida a través de los indicadores obtenidos, se procede a verificar la hipótesis planteada, con el uso de la prueba Ji-Cuadrado, con la siguiente fórmula:

$$X^2 = \sum_i \frac{(O_i - E_i)^2}{E_i}$$

En donde: X^2 = Ji-Cuadrado

$\sum$ = Sumatoria

O = Frecuencia observada

E = Frecuencia esperada o teórica

$$X^2_{prueba} = \frac{(2,50 - 6,04)^2}{6,04} + \frac{(480,67 - 274,00)^2}{274,00}$$

$$X^2_{prueba} = 5,01 + 88,86$$

$$X^2_{prueba} = 93,87$$

- Nivel de significancia:

Para este estudio se tomó un nivel de significancia del 95% y con un porcentaje de error del 5%,

el cual se consideró por las siguientes razones:

Por el cálculo de la muestra poblacional

Por el establecimiento de hipótesis y operacionalización de variables

La aleatoriedad sobre el proceso de recolección de información

- Grado de libertad

Para obtener este dato, utilizamos la siguiente fórmula:

$$GL = (c-1) (h-1)$$

Donde

GL = Grado de libertad.

c = Columnas de la tabla.

h = Hileras de la tabla.

$$GL = (c-1) (h-1)$$

$$GL = (2-1) (2-1)$$

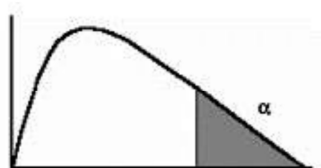
$$GL = 1$$

Con los datos de

Nivel de significancia = 0.05

Grado de Libertad = 1

Consultando en la tabla de distribución JI-cuadrado que se muestra en la figura 85.



Grados de libertad	$\alpha=.995$	$\alpha=.99$	$\alpha=.975$	$\alpha=.95$	$\alpha=.90$	$\alpha=.10$	$\alpha=.05$	$\alpha=.025$	$\alpha=.01$	$\alpha=.005$
1	0.0000	0.0002	0.0010	0.0039	0.0158	2.7055	3.8415	5.0239	6.6349	7.8794
2	0.0100	0.0201	0.0506	0.1026	0.2107	4.6052	5.9915	7.3778	9.2103	10.597
3	0.0717	0.1148	0.2158	0.3518	0.5844	6.2514	7.8147	9.3484	11.345	12.838
4	0.2070	0.2971	0.4844	0.7107	1.0636	7.7794	9.4877	11.143	13.277	14.860
5	0.4117	0.5543	0.8312	1.1455	1.6103	9.2364	11.070	12.833	15.086	16.750
6	0.6757	0.8721	1.2373	1.6354	2.2041	10.645	12.592	14.449	16.812	18.548
7	0.9893	1.2390	1.6899	2.1673	2.8331	12.017	14.067	16.013	18.475	20.278
8	1.3444	1.6465	2.1797	2.7326	3.4895	13.362	15.507	17.535	20.090	21.955
9	1.7349	2.0879	2.7004	3.3251	4.1682	14.684	16.919	19.023	21.666	23.589

Fuente: (Departamento de Matemática de la Universidad de Atacama, 2019, pág. 85).

Figura 85: Tabla de distribución JI cuadrada.

Obtenemos el grado de significancia

$$\alpha = 0.95$$

$$X^2_t = 0.0039$$

Decisión estadística

$$X^2_{prueba} = 93,87 \quad \text{Valor obtenido del cálculo del Ji-cuadrado.}$$

$$X^2_t = 0.0039 \quad \text{Valor obtenido de la tabla de distribución del Ji – Cuadrado}$$

Entonces debido a que los valores encontrados:

$$X^2_{prueba} = 93,87 > X^2_t = 0.0039$$

Por lo que el valor que se obtuvo del cálculo es mayor al valor de la distribución, se rechaza la hipótesis nula con un nivel de significancia del 95%, y se acepta la hipótesis alterna, es decir:

“La implementación de un modelo de control de acceso a la red a nivel de la capa de enlace de datos basado en el estándar IEEE 802.1x **SI** evitara el acceso indebido a personal externo a la red de datos del Banco Nacional de Bolivia”.

4.5 ENTREGABLES DE LA INVESTIGACIÓN

Con la presente investigación se desarrolló un modelo de seguridad de la información para el control de acceso a la red de datos el cual ayudara a denegar el acceso no autorizado de equipos de red de personal externo a la red de datos del Banco Nacional de Bolivia, se establecieron controles y procedimientos que regulan el acceso a la red a dispositivos autorizados del caso de estudio que responda a las necesidades de acceso a información de la organización y el cumplimiento de los objetivos institucionales.

Los documentos elaborados como resultado de la investigación que son los entregables de esta son los siguientes:

- Modelo de Control de Acceso a la Red de Datos, que se lo puede ver en forma inextensa en el Anexo II de este documento, en este archivo se presenta una visión global del Modelo de Control de Acceso a la red de Datos en el que se describen las fases y niveles para la aplicación de este.

- Política de Control de Acceso a la Red de Datos, que se lo puede ver en el Anexo III, este documento tiene como objetivo fundamental formalizar el pensamiento del caso de estudio respecto a la importancia que tiene el acceso a la información, las medidas de protección a implementar para regular el acceso a la red de datos a través del desarrollo de procedimientos y controles de acceso.

- Normativa de gestión de Control de Acceso a la Red, que se encuentra en el Anexo IV, donde se establece un procedimiento formal y uniforme para la administración de usuarios que permiten establecer el acceso a la red de datos y por defecto a la información de acuerdo con su nivel de clasificación dentro de la red de datos del caso de estudio.

Adicionalmente a la documentación anteriormente indicada en la presente investigación se logró implementar un control del tipo tecnológico haciendo uso de la herramienta del fabricante CISCO, es en base a esto es que se elaboró un Procedimiento del Sistema de Control de Acceso a la Red cuyo detalle se lo puede ver en el Anexo V, este documento describe los pasos a seguir para la instalación, configuración y administración de equipos computacionales de usuarios, switches de acceso capa dos y sobre todo del servidor del Sistema de Control de Acceso a la red para restringir la conexión de equipos de red a usuarios externos.

CAPITULO V

MARCO DE RESULTADOS

5.1 CONCLUSIONES Y RECOMENDACIONES

5.1.1 ESTADO DE LOS OBJETIVOS

Se realizo el diagnóstico de la red de comunicaciones del BNB, en los apartados 3.9.3 y 3.10 de este documento, donde se recopiló información con respecto a los diagramas de red del área de comunicaciones, se logró acceder al estado de configuración de los switches de acceso de la red de datos, se hizo la revisión de la normativa interna con respecto a la seguridad de información con la que actualmente cuenta el banco, se obtuvo estadísticas provistas por la empresa NEOSECURE que hace el monitoreo de la red de datos a través de los IPS 's instalados en la red de la empresa, se entrevistó a los Subgerentes de seguridad de la información y al de infraestructura tecnológica, con quienes se identificó la necesidad de contar con un modelo de seguridad de información para el control de acceso a la red de datos.

Se analizo 12 modelos de seguridad, en la sección 3.9.4 de este documento, donde se revisó las propuestas de diversos autores sobre modelos de seguridad de la información, a consecuencia de este análisis se pudo observar que 10 de estos modelos se han enfocado principalmente en fases, 6 modelos consideran la documentación y 9 modelos se enfocan en controles, existe poca relevancia en lo correspondiente a organización, funciones, niveles, indicadores y métricas.

Se logro definir un modelo de seguridad de la información para el control de acceso a la red de datos del BNB, en los apartados 3.11 y 3.12 de este documento, en base a los datos recopilados de normativa interna, entrevistas al personal relacionado al tratamiento de seguridad de la información, documentación de la red de datos de la empresa y sobre los análisis previos hechos con respecto a modelos de seguridad de la información se logró adecuar el mismo a los requerimientos de seguridad de la información de la institución.

Se estableció un entorno de pruebas en base a la delimitación geográfica previamente definida en las secciones 3.5 y 3.6 de este documento, donde se consideraron a las 13 agencias de la oficina La Paz del caso de estudio. En este entorno de pruebas se logró aplicar el modelo de

seguridad propuesto, en el apartado 4.2 de este documento, donde se implementó el servidor de control de acceso a la red de datos ISE de la empresa CISCO con el cual se logró obtener estadísticas de conexión de equipos de red, se logró identificar la identidad de los equipos de red conectados, en este entorno de pruebas se hizo la simulación de conexión de dos equipos que no pertenecen a la red del banco y se logró evidenciar el bloqueo de acceso de estos equipos a la red de datos del BNB.

En base a los resultados obtenidos luego de aplicar el modelo de seguridad se pudo obtener un reporte mensual el cual es analizado en la sección 4.4 de este documento, donde se logró obtener un promedio de 721 equipos conectados de los cuales 494 equipos fueron autorizados y a un promedio de 227 equipos se bloqueó el acceso a la red, indicar que estos registros se debieron a que algunos usuarios estaban colocando sus contraseñas de dominio de forma errónea, se logró obtener un promedio de 6489 registros de eventos de conexiones de equipos. Con este control también se pudo evidenciar que el promedio de incidentes de seguridad de escaneo de tráfico de red del BNB se redujeron en un 10.31 % así también se redujo en un 69.54 % la cantidad de incidentes relacionados a la denegación de servicio. De esta forma se logró verificar la efectividad para el control de acceso a la red de datos del modelo propuesto dentro de la red de datos del Banco Nacional de Bolivia.

5.1.2 ESTADO DE LA HIPÓTESIS

Para la verificación de la hipótesis se utilizó el método Ji Cuadrado, en el apartado 4.4.1 de este documento, al ser esta una prueba estadística que ayudo a evaluar la hipótesis inicialmente planteada. Para la verificación estadística nos apoyamos en los resultados obtenidos de las variables dependiente e independiente, de la hipótesis planteada, antes y después de aplicar el modelo de seguridad de la información.

El valor que se obtuvo de este cálculo igual 93,87 se encontró que es mayor al valor de la distribución Ji cuadrado a un nivel de significancia del 95 % por ende se rechaza la hipótesis nula y se acepta la hipótesis alterna, es decir: “La implementación de un modelo de control de acceso a la red a nivel de la capa de enlace de datos basado en el estándar 802.1x SI evitara el acceso indebido a personal externo a la red de datos del Banco Nacional de Bolivia”.

5.2 RECOMENDACIONES

Es recomendable que para poder verificar la efectividad del modelo de seguridad planteado el encargado de seguridad de la información de la institución debería revisar por lo menos una vez al año la normativa relacionada a la seguridad de la información con respecto al control de acceso a la red, debiendo verificar que las mismas se encuentren actualizadas tomando en cuenta los siguientes aspectos:

- Resultados del monitoreo y detección de nuevas amenazas tecnológicas.
- Incidentes de seguridad de la información.
- Acciones resultantes del comité de gestión integral de riesgos que requieran medidas correctivas y preventivas para un determinado caso.
- Tendencias en seguridad de la información.
- Recomendaciones y exigencias de la autoridad reguladora.

5.3 PROPUESTAS DE MEJORAMIENTO

Por su presentación este modelo puede ser implementado en cualquiera de los bancos múltiples de nuestro país de acuerdo con la clasificación hecha por la ASFI, de manera que con este modelo se logre controlar el acceso indebido a la red de datos de este tipo de instituciones. El modelo propone procedimientos normas e instructivos que sienta las bases para el desarrollo del control de acceso a la red sin embargo cada empresa tiene sus propios entornos y realidades, por lo cual, el desarrollo del modelo propuesto requiere de un detalle dependiendo del tipo de organización en la cual se aplique.

El modelo presentado pretende ser una solución y aporte en la implementación de la seguridad de la información para el control de acceso a la red de datos a nivel de capa dos, sin embargo, se propone ampliar el análisis a otros niveles de acceso, así también se propone ampliar el análisis de los indicadores de las variables dependiente e independiente inicialmente propuestos. Como mejora se propone también ampliar el análisis de acceso hacia redes inalámbricas, aunque no es recomendable su implementación algunas organizaciones hacen uso de este tipo de acceso hacia su red interna siendo necesario hacer el análisis respectivo dentro del modelo propuesto.

BIBLIOGRAFÍA

- Alabady, S. (Junio de 2009). Design and Implementation of a Network Security Model for Cooperative Network. *International Arab Journal of e-Technology*, 1(2), 26 - 36.
- Amiri, E., Afshar, E., Reza Naji, H., & Maleknasab Ardekani, M. (2012). Survey on Network Access Control Technology in MANETs. *Conference: 2012 International Conference on Innovation Management and Technology*, 1 - 6.
- Autoridad de Supervisión del Sistema Financiero ASFI. (4 de Diciembre de 2017). Modificaciones al reglamento para la gestión de seguridad de la información. La Paz, Murillo, Bolivia.
- Autoridad de Supervisión Financiera ASFI. (1 de Junio de 2019). *Autoridad de Supervisión Financiera ASFI*. Recuperado el 24 de Septiembre de 2019, de www.asfi.gob.bo:
<https://www.asfi.gob.bo/index.php/bancos-multiples-boletines.html>
- Bolivia, G. O. (10 de Septiembre de 2015). *Ley de modificaciones al código penal*. Recuperado el 15 de Junio de 2019, de www.gacetaoficialdebolivia.gob.bo:
<http://gacetaoficialdebolivia.gob.bo/index.php/normas/descargar/22174>
- Bosworth, S., Kabay, M. E., & Whyne, E. (2014). *Computer Security Handbook* (Sexta ed., Vol. 1). New Jersey: John Wiley & Sons, Inc.
- Burgos, J., & Campos, P. (Noviembre de 2011). Modelo de Seguridad de la información en TIC. *CEUR Workshop Proceedings 2do Encuentro Informática y Gestión*, 20 - 21.
- Charles, J. (2018). *CAB: Retos en la promoción de una industria de servicios financieros cibersegura del Caribe*. Canada: Organización de los Estados Americanos.
- Ciampa, M. (2015). *CompTIA® Security+ Guide to Network Security Fundamentals* (5 ed.). Boston: Cengage Learning.
- Cisco Systems. (2011). *Wired 802.1X Deployment Guide*. California: Cisco Systems, Inc.
- Cuzme-Rodríguez, F., Yépez, C., Domínguez-Limaico, H., Cardenas, C., & Zambrano-Romero, W. (2018). Access Network Improvement for a WLAN Based on 802.1X and CAPsMAN Protocols. *Computer Science & Information Technology (CS & IT)*, 43 - 49.
- Departamento de Matemática de la Universidad de Atacama. (26 de Octubre de 2019). *Departamento de Matemática de la Universidad de Atacama*. Recuperado el 26 de Octubre de 2019, de www.mat.uda.cl:
<http://www.mat.uda.cl/hsalinas/cursos/2010/eyp2/Tabla%20Chi-Cuadrado.pdf>
- Dildy, T. (2016). Network Access Control—Has It Evolved Enough for Enterprises? *ISACA Journal*, 4, 40.
- Dirección de Presupuestos del Ministerio de Hacienda. (2013). *Programa de mejoramiento de la gestión y metas de eficiencia institucional sistema de seguridad de la información*. Santiago de Chile: Dirección de Presupuestos del Ministerio de Hacienda.
- Disterer, G. (1 de Enero de 2013). ISO/IEC 27000, 27001 and 27002 for Information Security Management. *Journal of Information Security*, 92 - 100.

- Foro Económico Mundial 2009-2019. (2019). *Informes de riesgos mundiales 2019*. Ginebra: World Economic Forum.
- García Alfaro, J., & Perramón Tornil, X. (2007). *Aspectos avanzados de seguridad en redes*. Barcelona, España: UOC.
- Gartner Inc. (14 de Julio de 2018). *Magic Quadrant for Network Access Control*. Obtenido de Magic Quadrant for Network Access Control: <https://www.gartner.com/doc/reprints?id=1-586B7BU&ct=180720&st=sb&ccid=cc000098&oid=psten010442&dtid=oblgzzz000659>
- Gonzales Manzano, L., & De Fuentes Garcia-Romero de Tejada, J. (2014). *Sistemas Seguros de Acceso y Transmisión de Datos*. Malaga: IC Editorial.
- Hernández Sampieri, R., Fernández Collado, C., & Baptista Lucio, M. (2014). *Metodología de la Investigación* (Sexta edición ed.). México D.F.: McGRAW-HILL.
- International Organization for Standardization. (Octubre de 2013). *International Organization for Standardization*. Recuperado el 25 de Septiembre de 2019, de www.iso.org: <https://www.iso.org/iso/home.html>
- Jean-Marc, R. (2004). *Seguridad en la informática de empresa: riesgos, amenazas, prevención y soluciones*. Paris, Francia: ENI.
- Jirasek, V. (2012). Practical application of information security models. *Information Security Technical Report*, 1 - 8.
- Kreutz, D., Ramos, F., Esteves Veríssimo, P., Rothenberg, C. E., Azodolmolky, S., & Uhlig, S. (2015). Software-Defined Networking: A Comprehensive Survey. *Proceedings of the IEEE*, 103, 14 - 76.
- Li, J., Wang, H.-x., Han, R.-f., & Jing, X.-p. (2009). Construction and Application of Network Security Defense Model. *2009 5th International Conference on Wireless Communications, Networking and Mobile Computing*, 1 - 3.
- Lyle Brown, E. (2007). *802.1x Port-based Authentication*. New York, Estados Unidos: Auerbach Publications.
- Microsoft Corporation. (29 de Julio de 2019). *Microsoft Docs*. Obtenido de <https://docs.microsoft.com>: https://docs.microsoft.com/en-us/openspecs/windows_protocols/ms-gpnap/cf9e1d82-a78d-401d-89a7-f897d3d3e170
- Ministerio de Justicia y Derechos Humanos. (2013). *Directiva de Seguridad: Autoridad Nacional de Protección de Datos Personales APDP*. Ministro de Justicia y Derechos Humanos. Lima: Editora Diskcopy S.A.C. Obtenido de <https://www.minjus.gob.pe/wp-content/uploads/2014/02/Cartilla-de-Directiva-de-Seguridad.pdf>
- Nadiammai, G., & Hemalatha, M. (2013). Effective approach toward Intrusion Detection System. *Egyptian Informatics Journal*(15), 37 - 50.
- Nunoo-Mensah, H., Kofi Akowuah, E., & Osei Boateng, K. (2014). A Review of Opensource Network Access Control (NAC) Tools for Enterprise. *International Journal of Computer Applications*, 28 - 33.

- Oerting, T., & Doyle, S. (2018). *Foro Económico Mundial: El panorama de las amenazas a la ciberseguridad en los Bancos de América Latina y el Caribe*. Canada: Organización de los Estados Americanos.
- Organización de los Estados Americanos. (2018). *Estado de la Ciberseguridad en el Sector Bancario en América Latina y el Caribe*. Canada: Organización de los Estados Americanos.
- Paredes S., M. P., Urbina G., W. M., & Espinoza O., N. D. (2016). *Implementación de un plan piloto de seguridad bajo el protocolo IEEE 802.1x para el departamento de gestión tecnológica del ministerio de telecomunicaciones y Sociedad de la Información*. Sangolquí: Univeridad ESPE.
- PCI Security Standards Council, L. (2018). *Norma de seguridad de datos de la industria de tarjetas de pago (PCI)*. Massachusetts: PCI Security Standards Council.
- Ping Ping, S. (2010). An improved model of distributed network information security. *2010 International Conference on Educational and Information Technology*, 391 - 393.
- Qu, Z., & Jia, Y. (2008). The Design of the Network Security Model of Active Defense. *2008 4th International Conference on Wireless Communications Networking and Mobile Computing*, 14.
- Rodríguez V., S. (2018). *FELABAN: LA CIBERSEGURIDAD EN LA BANCA DE AMÉRICA LATINA Y EL CARIBE*. Federación Latinoamericana de Bancos (FELABAN). Canada: Organización de los Estados Americanos.
- Rossiñol Ruiz, P. (2015). *Verificación y resolución de incidencias en una red de área local*. Madrid: Elearning.
- Salah A. Jaro, A. (2008). Design and Implementation of a Network Security Model using Static VLAN and AAA Server. *2008 3rd International Conference on Information and Communication Technologies: From Theory to Applications*, 1- 6.
- Stalling, W. (2000). *Comunicaciones y redes de computadores* (Sexta ed.). Madrid: Prentice Hall.
- Stallings, W. (2004). *FUNDAMENTOS DE SEGURIDAD EN REDES. APLICACIONES Y ESTÁNDARES*. (Segunda edición ed.). Madrid, España: PEARSON EDUCACIÓN, S.A.
- Tanenbaum, A., & Wetherall, D. (2012). *Redes de computadoras* (Quinta ed.). Mexico D.F.: PEARSON EDUCACIÓN.
- The Open Group. (Febrero de 2011). *The Open Group*. Recuperado el 29 de Septiembre de 2019, de [www.opengroup.org: https://publications.opengroup.org/c17b](https://publications.opengroup.org/c17b)
- Villegas, M., Meza, M., & León, P. (2011). Las métricas, elemento fundamental en la construcción de modelos de madurez de la seguridad informática. *Redalyc (Red de revistas Científicas de América Latina, el Caribe, España y Portugal) – Universidad Rafael Belloso Chacín*, 15(1), 16.
- Villegas, M., Viloria, O., & Blanco, W. (2009). Modelo de madurez de la seguridad de la información en el contexto de las organizaciones inteligentes. *7ma Conferencia de Latinoamérica y el Caribe para ingeniería y tecnología (LACCEI'2009)*, 72 - 95.
- Woland, A., & Heary, J. (2017). *Cisco ISE for BYOD and Secure Unified Access*. Indianapolis: Cisco Press.

ANEXO I.

PROTOCOLO DE ENTREVISTA

A continuación, se incluye un resumen de las entrevistas efectuadas al personal involucrado y a cargo de la gestión de la seguridad de la información en el caso de estudio.

Apertura

Buenas tardes, ¿cómo se encuentra?, le informo que estoy haciendo mi trabajo final de maestría, en la UMSA. Soy estudiante y estoy realizando una investigación titulada: Modelo de seguridad de la información para el control de acceso a la red a nivel de la capa de enlace de datos aplicando el estándar IEEE 802.1x para evitar el acceso indebido a personal externo a la red de datos del BNB. Por lo cual le agradezco, que me responda con toda naturalidad.

Objetivo

La entrevista tiene como objetivo conocer los proyectos, planes, propuestas de la organización, que contribuyan a implementar controles de acceso a nivel de redes de datos en el BNB

Desarrollo

1. Establecer conocimientos comunes:

Pregunta 1

¿Cuenta su organización con un Plan Estratégico Institucional - PEI? ¿Dentro del mismo se tiene algún objetivo relacionado a seguridad de la información? Indicar el objetivo relacionado.

Pregunta 2

¿Cómo se gestiona la seguridad de la información en su organización? ¿Existe algún rol o responsable de SI? ¿Cuáles son sus funciones? ¿Qué procesos se tienen implementados?

Pregunta 3

¿Han adoptado algún estándar internacional o buenas prácticas para la implementación de la SI en su organización? ¿Cuál?

Pregunta 4

¿Tiene algún proyecto previsto o iniciado relacionado a la seguridad de la información en su organización? ¿Manejan presupuestos para los temas de seguridad de la información?

Pregunta 5

¿Cómo se maneja la cultura organizacional en temas de seguridad de la información?

2. Capacidades y conocimientos del entrevistado en el área de estudio:

Pregunta 6

¿Se administran y controlan las redes de datos de la organización para proteger la información en sistemas y aplicaciones?

Pregunta 7

¿Las redes de datos son separadas en función de los grupos de servicios, usuarios y sistemas de información?

Pregunta 8

¿Existen políticas y procedimientos de control de acceso dentro de la organización? ¿Existen controles específicos para el acceso a redes de datos?

Pregunta 9

¿Tiene conocimiento acerca de sistemas de control de acceso a la red?

Pregunta 10

¿Conoce el funcionamiento del estándar IEEE 802.1x?

3. Análisis de necesidad del modelo de control de acceso a la red**Pregunta 11**

¿Se cuenta con algún procedimiento para la conexión de personal externo a la red de datos?

Pregunta 12

¿De qué forma se controla la conexión de equipos externos a la red de datos de la empresa en agencias remotas donde no se cuenta con personal del área de sistemas?

Pregunta 13

¿Recientemente han tenido algún evento de seguridad informática relacionado a infecciones o ataques de denegación de servicio dentro de la organización?

Pregunta 14

¿Considera que se debería implementar algún tipo de control que limite el acceso indebido a la red de datos de la empresa?

4. Desarrollo de tareas de prevención y aseguramiento.**Pregunta 15**

¿Se realizan tareas de hacking ético, test de penetración, con regularidad en la empresa?

Pregunta 16

Para el aseguramiento de la información de las operaciones bancarias, ¿Qué soluciones tecnológicas vienen utilizando? ¿Tiene planes de fortalecerlo? ¿Cuáles?

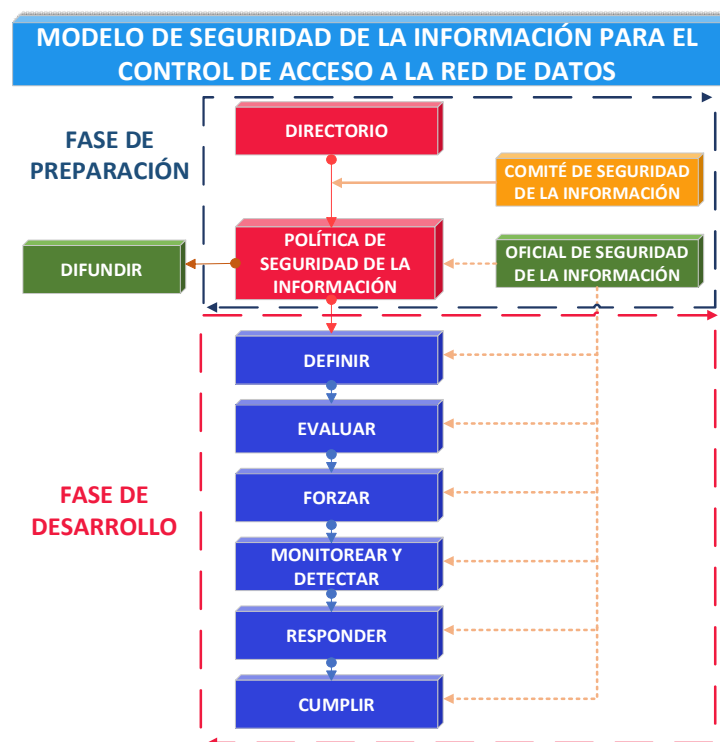
ANEXO II.

MODELO DE CONTROL DE ACCESO A LA RED DE DATOS

SECCIÓN 1 ASPECTOS GENERALES

Artículo 1 Introducción

En el contexto de los servicios de Fortalecimiento de la Función de Seguridad de la Información, se ha desarrollado un marco conceptual que agrupa las distintas iniciativas con respecto al control de acceso a la red de datos, por lo que se presenta este Modelo de Control de Acceso a la Red de Datos.



Artículo 1 Antecedentes

Uno de los aspectos más importantes en la organización relacionados a la seguridad de la información es determinar los controles necesarios y suficientes para mitigar el riesgo relacionado al acceso de la red de datos. Los enfoques utilizados normalmente no cubren necesariamente las distintas implicancias que plantea un riesgo descubierto y existe la posibilidad cierta de no mitigar adecuadamente este tipo de riesgos.

De la misma forma que en el caso anteriormente planteado, cuando se trata de evaluar la efectividad del control implantado, es necesario disponer de una forma ordenada y sistemática de verificar si se cubren los distintos aspectos de exposición que pueden plantearse.

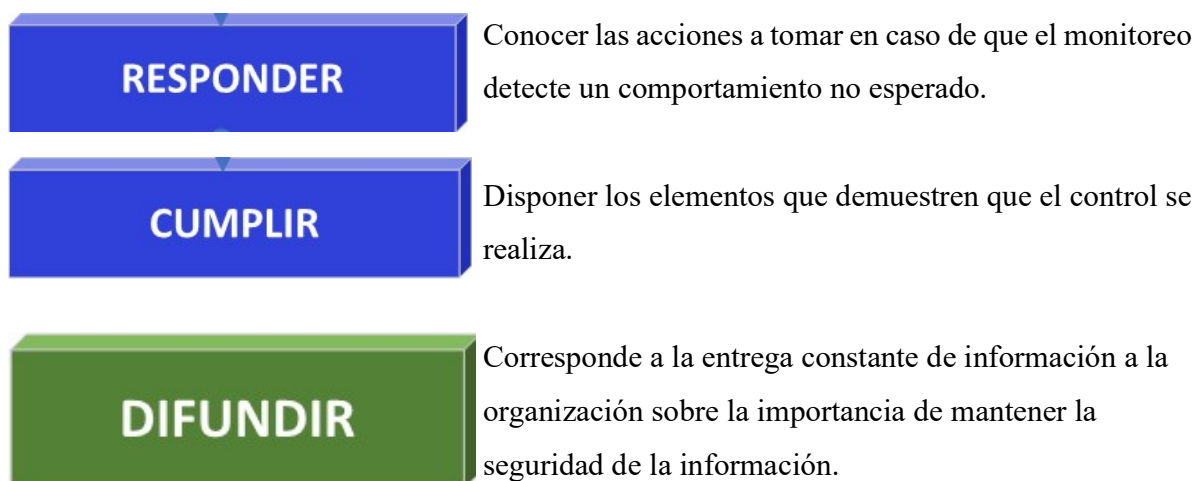
A raíz de lo indicado, se ha establecido un conjunto de factores a considerar al momento de seleccionar controles que mitigan un riesgo o revisar si las medidas adoptadas son adecuadas a los riesgos identificados.

SECCIÓN 2 DESCRIPCIÓN

Artículo 1 Visión general

En el diagrama siguiente, se presenta una visión global del Modelo de Control de Acceso a la red de Datos, el que es descrito más adelante.





Artículo 2 Visión Detallada

Las consideraciones que promueve el Modelo de Control de Acceso a la Red de Datos son:

- **Comité de seguridad de la información.** La conformación de un comité de seguridad de la información dentro de la empresa resulta importante para que este sea el nexo de trabajo con el directorio ejecutivo de la empresa para la presentación del respectivo programa de seguridad de la información dentro de la organización, donde se detallaran de manera global los proyectos y actividades a desarrollar en cuanto a la gestión de la seguridad de la información que estarán alineados al plan estratégico institucional. Entre las tareas asignadas a este comité podemos mencionar:
 - Hacer una revisión periódica del estado general de la seguridad de la información.
 - Revisar y monitorear los incidentes relacionados a la seguridad de la información.
 - Revisar y aprobar los proyectos de seguridad de la información.
 - Aprobar modificaciones o creación de nuevas políticas de seguridad de la información.
 - Realizar otras actividades de alto nivel relacionadas con la seguridad de la información.
 - Tomar conocimiento de los incidentes de seguridad y verificar que se hayan tomado las medidas adecuadas para solucionar la situación y prevenir ocurrencias futuras.
- **Apoyo directivo.** Luego de que el comité de seguridad de la información elabora el programa de seguridad de la información el mismo debe ser presentado al directorio ejecutivo, de la empresa, quienes deben apoyar las tareas para la implementación y la gestión de la seguridad de la información dentro de la organización, deben apoyar las gestiones para concretar el financiamiento y puesta en marcha de los proyectos de seguridad de la información. El directorio ejecutivo es la entidad que tomara las

decisiones importantes para el tratamiento de riesgos dentro de la organización. Este compromiso se verá reflejado a través de:

- Creación de un comité de seguridad interdisciplinario en el cual se incluya al área de tecnología de la empresa.
 - Asignación de un responsable de la seguridad de la información (Oficial de seguridad) dentro de la organización.
 - Aprobación del documento de políticas de seguridad de la información.
 - Velar por el cumplimiento de las políticas de seguridad de la información.
 - Asignación de responsabilidades asociadas al tema de la seguridad de la información.
 - Conocer y comprender los riesgos inherentes a los que está expuesta la organización.
 - Convocar a reuniones extraordinarias al Comité de Seguridad de la Información cuando se presenten eventos de seguridad dentro de la organización los cuales ameriten su tratamiento inmediato.
- **Política de seguridad de la información.** Esta etapa corresponde al diseño y elaboración de la Política de Seguridad de la Información de la organización la cual mostrara los lineamientos con respecto al tratamiento de riesgos relacionados a la seguridad de la información para su identificación, medición, monitoreo, control, mitigación y divulgación dentro de la organización. En esta política se pretende formalizar el pensamiento de la empresa respecto de la importancia que tiene la seguridad de la información dentro de la organización, estarán determinadas por las siguientes definiciones:
 - Minimizar el riesgo en las funciones más importantes de la entidad.
 - Cumplir con los principios de seguridad de la información.
 - Cumplir con los principios de la función administrativa.
 - Mantener la confianza de sus clientes, socios y empleados.
 - Apoyar la innovación tecnológica.
 - Proteger los activos tecnológicos.
 - Establecer las políticas, procedimientos e instructivos en materia de seguridad de la información.
 - Fortalecer la cultura de seguridad de la información en sus miembros ejecutivos, sus funcionarios, y proveedores de la empresa.

- **Oficial de seguridad de la información (OSI).** La organización debe designar a un responsable que desarrolle las tareas de un Oficial de Seguridad de la Información, para que ejecute, apoye, dirija y pueda llevar el control de implementación y posterior seguimiento de todo el modelo de seguridad de la información de la empresa. Además, este encargado de seguridad de la información estará presente en todas las fases de aplicación del modelo participando de forma activa y en forma coordinada con el área de tecnología de la organización. Entre las tareas y responsabilidades del OSI dentro de la organización podemos mencionar los siguientes puntos:
 - Definir la Política de Seguridad de la Información de la organización.
 - Definir la misión de seguridad informática de la organización en conjunto con los ejecutivos de la empresa.
 - Definir y aplicar una metodología de análisis de riesgo para evaluar la seguridad informática en la organización.
 - Desarrollar procedimientos de seguridad de la información los cuales sean detallados y que ayuden a fortalecer la política de seguridad de la información dentro de la empresa.
 - Seleccionar los mecanismos y herramientas adecuados que permitan aplicar las políticas de seguridad dentro de la misión establecida.
- **Definir.** Busca formalizar la problemática asociada al riesgo que implica el acceso indebido de personal externo a la red de datos de la empresa, se requiere conocer y documentar el riesgo, el ámbito sobre el que se aplica, las condiciones que se busca controlar y las responsabilidades relacionadas a los controles que se definan. Se define la política de control de acceso a la red que define la posición y las acciones que dispone la organización con respecto a este riesgo. La política de control de acceso a la red de datos debe estar conformada principalmente por los siguientes puntos:
 - La definición de la seguridad con respecto al acceso a la red de datos de la empresa, definiciones, objetivos generales, el alcance e importancia de esta política dentro de la organización, criterios de cumplimiento normativo para su implementación.
 - La política debe establecer objetivos generales, definir su alcance e importancia de esta dentro de la organización.
 - Definir los activos asociados al tratamiento de riesgos, definir responsabilidades de todos los miembros dentro de la organización.

- Debe especificar las responsabilidades del personal de la empresa para responder a los riesgos relevantes o significativos una vez presentados y evaluados.
- **Evaluar.** Se refiere a los elementos que se deben disponer para que la organización se entere de la situación del riesgo identificado en cuanto a la exposición, materialización de este, la criticidad de la situación y los activos de información que se ven afectados de forma directa o indirecta. En esta fase se hace uso de herramientas de análisis o procesos de evaluación de riesgos, sean estos cuantitativos o cualitativos como por ejemplo la aplicación de un software de evaluación de vulnerabilidades o realizar el análisis de riesgos de los activos afectados, su análisis deberá considerar los siguientes puntos:
 - Determinar los activos relevantes para la Organización, su valor en el sentido del costo que supondría si se vieran afectados por algún tipo de incidente de seguridad de la información.
 - Determinar a qué amenazas están expuestos los activos previamente identificados.
 - Determinar la existencia de controles y cuán eficaces son estos frente al riesgo identificado.
 - Estimar el impacto, definido como el daño sobre el activo derivado de la materialización de la amenaza.
 - Estimar el riesgo, definido como el impacto ponderado con la tasa de ocurrencia (o expectativa de materialización) de la amenaza
- **Forzar.** Corresponde a las medidas específicas que la organización enfrenta al riesgo identificado. Se implementa un control que puede ser una herramienta o solución tecnológica de seguridad de la información, como un sistema de control de acceso a la red, o una medida administrativa, como el control de acceso físico de equipos de computación a la organización, también se puede implementar controles basados por ejemplo en la configuración de equipos de red como pueden ser la configuración de puertos de red en los switches de acceso de la empresa. Los requisitos para considerar en la selección de un sistema de control de acceso a la red se deben mínimamente poder:
 - Proporcionar visibilidad y control sobre los puntos finales de sus redes corporativas, contar con un módulo de reportaría el cual pueda recolectar información en tiempo real para poder hacer un análisis de estos eventos.

- Brindar acceso a la red de acuerdo con las políticas de control de acceso que las empresas definan previamente para así mitigar las amenazas existentes en la red.
- Garantizar la identidad y las autorizaciones de usuarios y dispositivos a los cuales se de acceso a la red de datos.
- Integración con sistemas de detección de amenazas, para que el sistema de control de acceso pueda aplicar automáticamente políticas adecuadas para dispositivos comprometidos que puedan ser una amenaza para la red de datos.

- **Monitorear y detectar.** Se refiere a las medidas destinadas a verificar el correcto funcionamiento del control implantado respecto de lo definido previamente por la institución. En esta etapa se utilizan herramientas de monitoreo o se establecen procedimientos que permitan verificar el funcionamiento del control implantado. En caso de que el monitoreo detecte que no se están cumpliendo con los objetivos preestablecidos de acuerdo con los registros presentados por el o los controles implementados, se deben generar reportes para poder hacer los ajustes necesarios a los controles de control de acceso a la red.

Los controles tecnológicos por implementar para monitorear y detectar el correcto funcionamiento del sistema de control de acceso a la red deben tener las siguientes características:

- Registro de dispositivos
- Detección y monitorización de redes
- Detección de actividades anómalas en la red

- **Responder.** Corresponde a las medidas dispuestas para actuar en caso de que el monitoreo detecte un comportamiento anómalo del control o una situación que inicialmente no se haya previsto, normalmente se trata de medidas administrativas.

Tras la etapa de monitoreo y detección de haberse reportado alguna anomalía, se deberán ejecutar una serie de acciones dentro de la organización las cuales son:

- Decidir si es necesario realizar mejoras dentro del control o los controles implementados, que modificaciones se van a llevar a cabo y de existir cuál sería su repercusión económica y laboral dentro de la organización.
- Se tendrá que revisar la evaluación y la gestión de riesgos hecha inicialmente.
- Se tendrá que realizar una actualización de los procedimientos y controles si estos no

cumplen con los objetivos inicialmente establecidos.

- **Cumplir.** Se refiere a los registros de eventos que se tienen con respecto al funcionamiento de los controles implementados y que sirven para demostrar que las acciones que la empresa ha dispuesto para controlar el riesgo efectivamente existen y funcionan. Normalmente se visualizan registros de eventos, registros de accesos de usuarios o de ejecución de tareas dentro del sistema de control de acceso a la red.

El control tecnológico debe contar con la facultad de poder demostrar que se están cumpliendo con el control de acceso a la red a los diferentes dispositivos de red, para lo cual este sistema debe contar con las siguientes características:

- Administración centralizada.
- Visibilidad de los dispositivos.
- Módulo de reporte de eventos en línea o históricos.
- Almacenamiento de eventos en forma local o en repositorios externos.

- **Difundir.** Esta etapa corresponde a la entrega constante de información a la organización sobre la importancia de mantener la seguridad de la información y el resguardo de todas las actividades relacionadas a Tecnologías de la Información. Es fundamental que todos los involucrados conozcan el qué y para qué de este modelo de seguridad de la información, la organización asegurará que el personal tenga conocimiento de la necesidad e importancia de las actividades de seguridad de la información que le corresponde realizar y cómo ellas contribuyen al logro de los objetivos del modelo.

Artículo 3 Aplicación

Considerando lo descrito, es responsabilidad de la Subgerencia de Seguridad de la información definir, formalizar e implementar el “Modelo de Control de Acceso a la Red de Datos” descrito en la presente norma en los riesgos relacionados a la seguridad de la información, dependientes de los resultados del análisis de riesgo tecnológico, para efectos de su implementación, ejecución, medición, ajuste y la determinación de los recursos que sean necesarios.

Artículo 4 Control Normativo

Con el objeto de verificar la efectividad de los objetivos de control planteados en las distintas normas de seguridad que forman parte del Sistema de Seguridad de la Información, es responsabilidad del Subgerente de Seguridad de la Información revisar por lo menos una vez al

año la normativa relacionada a la Seguridad de la Información debiendo verificar que las mismas se encuentren actualizadas tomando en cuenta mínimamente los siguientes aspectos:

- Cambios en la normativa vigente del Banco que estén relacionados de alguna manera con la seguridad y al tratamiento de la información.
- Resultados del monitoreo y detección de nuevas amenazas tecnológicas que requieran algún tipo de tratamiento especial.
- Incidentes de Seguridad de la Información.
- Acciones resultantes del Comité de Gestión Integral de Riesgos que requieran medidas correctivas y preventivas para un determinado caso.
- Tendencias en seguridad de la información.
- Recomendaciones y exigencias de la autoridad reguladora.

Asimismo, la formalización de los cambios existentes se realizará conforme a lo establecido en el documento de “Sistema de Emisión y Registro de Normas Internas”

SECCIÓN 4 OTRAS DISPOSICIONES

Artículo 1 Responsabilidades

Además de las responsabilidades establecidas en la presente norma, se establecen los siguientes centros de responsabilidades para su cumplimiento:

Vicepresidente gestión de riesgos, como responsable de la difusión, capacitación y monitoreo al cumplimiento de los procesos, procedimientos y definiciones descritas de la presente norma.

Gerente Auditoria, como responsable de verificar el cumplimiento de los procesos, procedimientos y definiciones descritas en la presente norma.

Subgerente de Seguridad de la Información, como responsable de garantizar el cumplimiento de los procesos, procedimientos y definiciones descritas en la presente norma.

Artículo 2 Incumplimiento y sanciones

El incumplimiento a estas disposiciones normativas dará lugar a la aplicación de sanciones de acuerdo con la norma de proceso sancionatorio por infracciones a esta normativa.

Artículo 2 Actualización

Las actualizaciones posteriores a la presente norma serán de responsabilidad de la Subgerencia de Seguridad de la Información, instancia que periódicamente deberá verificar su cumplimiento en cuanto a los procesos establecidos, los niveles de aprobación y a la organización del Banco.

ANEXO III.

POLITICA DE CONTROL DE ACCESO A LA RED DE DATOS

1. DECLARACIÓN INSTITUCIONAL

La Seguridad de la información está destinada a la protección de la información frente a un amplio rango de amenazas, con el propósito de asegurar la continuidad operativa de la organización, minimizar el daño a la que pueda verse expuesta. Es así como la subgerencia de seguridad de la información se compromete a mantener políticas en el ámbito de la seguridad de la información, con el fin de asegurar que sus procesos operativos tengan la debida continuidad operacional que se requiere. Este documento presenta los lineamientos necesarios en temas de control de acceso a la red de datos, donde todo usuario interno de la institución deberá poseer una cuenta de usuario personal, que actuará como una credencial que lo identifique, y que le permitirá brindar acceso a sus dispositivos de red a los recursos de la red corporativa. Para el acceso a la red todo equipo de computación perteneciente a la organización deberá identificarse haciendo uso de las credenciales de dominio del propietario del equipo, y luego deberá comprobar que es quien dice ser autenticándose hacia el servidor de dominio quien posteriormente con el apoyo del sistema de control de acceso autorizara su acceso a la red.

2. ALCANCE

Esta política se aplica a todo ámbito de la organización y a todos los funcionarios que tengan derechos de acceso a la información que puedan afectar de alguna manera a los activos de información de la organización y a todas sus relaciones con personal externo que implique el acceso a sus datos, recursos y/o a la administración y control de sus sistemas de información.

3. MARCO REFERENCIAL

Se considera como marco referencial para la presente, los requerimientos mínimos descritos en el Libro 3°, Título VII, Capítulo II, Sección 7, del reglamento para la Gestión de Seguridad de la Información de la Autoridad de Supervisión del Sistema Financiero, así como las mejores prácticas para la seguridad de la información descritas en el estándar ISO/IEC 27002.

4. OBJETIVO GENERAL

La presente política tiene como objetivo fundamental formalizar el pensamiento de la empresa respecto de la importancia que tiene el acceso a la información para la empresa, las medidas de protección a implementar para regular el acceso a la red de datos a través del desarrollo de procedimientos concretos. Con esta política se busca divulgar y controlar la forma en que los

trabajadores del BNB acceden con sus equipos computacionales a la red de datos y a la información de la organización, estos accesos deberán ser controlados sobre la base de los requisitos de seguridad de la empresa. Para ello, a través de sus diferentes áreas de: Organización y métodos, Tecnología, Seguridad de la Información y Soporte a usuarios permitirá administrar el ciclo de acceso de los equipos computacionales de los usuarios, desde la creación de cuentas hasta su baja en el servidor de directorio activo de la organización.

4.1 Objetivos específicos

- Cumplir con la Política General de Seguridad de la Información.
- Definir el acceso a los sistemas institucionales.
- Definir la composición que tienen las credenciales de acceso.
- Controlar el acceso a los Sistemas y a la Información de la empresa.
- Prevenir acceso no autorizado a los Sistemas de Información.
- Proteger adecuadamente la red y los servicios de red de la Institución.

5. DEFINICIONES PARA EL CONTROL DE ACCESO

5.1 Reglas para el control de acceso

Las reglas para el control de acceso, estará documentado a través del procedimiento de control de acceso a la red de datos.

5.2 Gestión de usuarios

Se deberá asegurar el acceso de usuarios autorizados y prevenir el acceso no autorizado a los sistemas de información. Se usará para la asignación de las credenciales de accesos a los diferentes sistemas a través de un formulario con el nombre del sistema y nombre de usuario.

5.3 Responsabilidad de los usuarios

Todos los funcionarios que tengan un usuario en el directorio activo de la organización deberán conocer y cumplir con su uso de esta Política específica, donde se dictan pautas sobre derechos y deberes con respecto al uso adecuado de los usuarios.

5.4 Control de acceso a la red

Las conexiones no seguras a la red corporativa pueden afectar a toda la institución, por lo tanto, se controlará el acceso a los servicios de la red interna. Esto es necesario para garantizar que los usuarios que tengan acceso a las redes y a sus servicios no comprometan la seguridad de estos.

5.5 Utilización de los servicios de red

Se desarrollarán procedimientos para la activación y desactivación, los cuales comprenderán:

- Controlar el acceso a los servicios de red tanto internos como externos.
- Identificar las redes y servicios de red a los cuales se permite el acceso.
- Establecer controles y procedimientos para proteger el acceso y servicios de red.

5.6 Identificación de equipos en la Red

La Subgerencia de Infraestructura Tecnológica controlará e identificará los equipos conectados a su red, mediante el sistema de control de acceso, asignación manual o dinámica de direcciones.

5.7 Separación de redes

La Subgerencia de Infraestructura Tecnológica hará uso de dispositivos de seguridad como firewalls, para controlar el acceso de una red a otra. La segmentación se realizará en los equipos de comunicaciones switch capa 3 mediante la configuración de VLAN's.

5.8 Control de enrutamiento de red

El acceso a redes desde y hacia afuera de la red de datos de la empresa cumplirá con los lineamientos del Control de acceso a la red y adicionalmente se utilizarán métodos de autenticación de protocolo de enrutamiento, rutas estáticas y listas de control de acceso.

4. DIRECTRICES

- La empresa debe valer para que la información, los sistemas de información y sus activos estén apropiadamente resguardados frente a las amenazas a las que se ven expuestos.
- La Seguridad de la Información y de los activos asociados, es responsabilidad de todos los miembros de la organización que, por motivos de sus funciones, la utilicen en cualquier grado.
- Los accesos a las redes de datos no deben quedar disponibles a personas o entidades externas a la empresa, salvo en situaciones establecidas con controles que garanticen su protección.
- Todo empleado o colaborador tiene la obligación de notificar cualquier actividad o situación que afecte o pueda afectar la seguridad de los activos de información.
- La empresa reconoce que la sensibilización, capacitación y entrenamiento adecuados a su personal en materia a la seguridad de la información es tarea prioritaria.

5. PERIODO DE REVISIÓN

Esta política de seguridad debe ser revisada cada 3 años, para mantener al día su vigencia.

6. EVALUACIÓN DE CUMPLIMIENTO

La revisión del cumplimiento de esta Política la efectuara anualmente la subgerencia de seguridad de la información. Adicionalmente podría requerirse una revisión de cumplimiento

por parte de la División de auditoría interna o el comité de seguridad de la información para garantizar su idoneidad, adecuación y efectividad.

7. MECANISMOS DE DIFUSIÓN.

La subgerencia de seguridad de la información difundirá esta política de seguridad mediante un conjunto de actividades planificadas, que tienen como objetivo dar a conocer y sensibilizar a los usuarios internos a través de la publicación en secciones destinadas a la seguridad de la información en el portal intranet de la empresa, difusión mediante correo electrónico. De existir modificaciones se hará la notificación vía correo electrónico al personal relacionado.

8. RESPONSABILIDADES.

La seguridad de la información es responsabilidad de todos los miembros de la organización, quienes deben velar por la protección de la confidencialidad, integridad y disponibilidad de este activo. Siendo responsables del cumplimiento de esta política el:

- **Directorio:** Instancia responsable de la aprobación de las políticas, procedimientos y otros instrumentos, relacionados con la gestión de seguridad de la información.
- **Comité de gestión integral de riesgos:** Está a cargo de la discusión y definición de los lineamientos estratégicos de seguridad de la información para ser puestos a consideración.
- **Gerencia de División de auditoria:** Asegurar la ejecución de auditorías para velar el cumplimiento de la política de seguridad. Revisar reportes de auditoria y pruebas de seguridad y asegurar que se hayan tomado acciones apropiadas para atender debilidades identificadas.
- **Vicepresidencia Ejecutiva:** Responsable a través de la Vicepresidencia de riesgos y a través de Subgerencia de Seguridad de la Información, de la implementación, difusión interna en todos los niveles de la organización y cumplimiento del presente documento.
- **Subgerencia de Seguridad de la Información:** Encargado de asegurar que las políticas, procedimientos y definiciones hechas por el directorio se cumplan. Es el responsable de la implantación de sistemas de control de acceso, y de mantener un adecuado nivel de sensibilización y educación respecto a este tema a los empleados de la empresa.
- **Funcionarios:** Asegurar que la información de clientes y del banco se encuentre protegida. Son responsables de reportar cualquier incumplimiento a los inmediatos superiores.

8. SANCIONES

El incumplimiento de lo dispuesto en esta política da lugar a la aplicación de sanciones, según lo dispuesto en la norma de proceso sancionatorio por infracciones a la presente política.

ANEXO IV.

NORMATIVA DE GESTIÓN DE CONTROL DE ACCESO A LA RED

SECCION 1 ASPECTOS GENERALES

Artículo 1° Antecedentes

Uno de los aspectos críticos en el desarrollo de las actividades cotidianas del banco está referido al acceso a las redes de datos y el uso de información en los sistemas informáticos. A través de estos accesos se definen los niveles de responsabilidad que otorga la administración del banco a cada funcionario. Adicionalmente, a través de este medio se definen gran parte de las funciones del personal y en cierta manera se delimita la estructura funcional de cada unidad de trabajo. Es en este sentido y con el propósito de gestionar los riesgos asociados a la gestión de cuentas, el cumplimiento y monitoreo de los accesos asociados a los mismos, la mejora del ambiente de control interno, la Vicepresidencia Ejecutiva ha establecido un programa de administración de control de accesos a la red que ayude al banco a implementar las mejores prácticas.

Artículo 2° Objetivo

Establecer un procedimiento formal y uniforme para la administración de usuarios que permiten establecer el acceso a la red de datos y por ende a la información de acuerdo con su nivel de clasificación, en base al principio de menor privilegio.

- Acceso y atribuciones en el Dominio del BNB en su entorno de red de datos

Artículo 3° Base Legal

La presente norma se basa en las siguientes disposiciones:

- Reglamento para la Gestión de Seguridad de la Información Libro 3°, Título VII, Capítulo II, Sección 7, emitido por la Autoridad de Supervisión del Sistema Financiero
- Estándar ISO/IEC 27002.

Artículo 4° Definiciones

Dominio. Es un nombre base que agrupa a un conjunto de equipos o dispositivos de red y que permite la administración para la: inclusión, modificación o exclusión de estos mediante la asignación de nombres de equipo.

Directorio Activo. Es una aplicación informática que permite guardar información relativa a los recursos, usuarios, de red en el Dominio de la empresa. En adelante, nos referiremos al Directorio Activo como “AD” por sus siglas en inglés.

Atribuciones del Dominio. Son servicios y permisos asociados a las diferentes herramientas y aplicaciones que el banco provee a los usuarios como ser correo electrónico, internet, pertenencia grupos de seguridad.

Perfil de usuario. Conjunto de transacciones que puede utilizar un determinado nivel de autorización, relacionado con un cargo específico perteneciente a la jerarquía organizacional de la institución y que se enmarca en la estructura organizacional definida por cada sucursal.

Usuario. El usuario es la persona física a la que se le asigna un perfil determinado. Cada usuario podrá tener definido únicamente un perfil, sin embargo, en caso de solicitudes excepcionales con el objeto de cubrir reemplazos, vacancias u otros, las mismas deberán ser previamente analizadas por el Gerente de División y/o Subgerente de Organización y Métodos.

Contraseña. Es un conjunto de caracteres definidos de uso único, exclusivo y confidencial por un usuario que permite autenticarlo en un sistema informático.

Identificación de Usuario. Es la identificación asignada al usuario, que permite a un sistema informático distinguir a un usuario de otro al momento de ingresar al mismo.

Ataque de fuerza bruta. La fuerza bruta es un método de prueba y error utilizado por los programas de aplicación para decodificar datos cifrados, como contraseñas a través de esfuerzos exhaustivos en lugar de emplear estrategias intelectuales.

Ataque de diccionario. Método utilizado para romper sistemas de seguridad, específicamente sistemas de seguridad basados en contraseña, en los que el atacante comprueba sistemáticamente todas las contraseñas posibles comenzando por palabras que tienen una mayor posibilidad de ser utilizadas, como nombres y lugares.

Ataque de denegación de servicio. Es un ataque a un sistema de computadoras o red de datos que causa que un servicio o recurso sea inaccesible a los usuarios legítimos. Normalmente provoca la pérdida de la conectividad con la red por el consumo del ancho de banda de la red de la víctima o sobrecarga de los recursos computacionales del sistema atacado.

Principio de menor privilegio. Principio básico en seguridad de la información que permite la asignación de accesos autorizados para los usuarios de manera que puedan ejecutar las funciones asignadas a los mismos y de acuerdo con los objetivos de la organización.

SECCION 2 NORMATIVA GENERAL

Con el objetivo de mantener la uniformidad en la información y registro de funcionarios, se establece que los funcionarios del banco deben ser registrados, para la asignación de clave y

usuario, en el sistema AD y otros sistemas de acuerdo con: sus funciones, al principio del menor privilegio y la apropiada segregación de funciones.

Artículo 1° Clasificación de usuarios

Por la naturaleza del registro de información y las características den cuanto a la asignación de atribuciones en el sistema AD se establece la siguiente clasificación y responsabilidad en cuanto a la administración de cada uno de los sistemas:

PERFIL DE USUARIO	CRITERIO	ASIGNACIÓN DE USUARIO	RESPONSABLE ADMINISTRACIÓN
“Usuario funcionario BNB”	Funcionarios de planta regulares o en periodo de prueba del BNB.	Sistema AD	Gerencia División Organización y Métodos
Usuarios “Sistemas”	Sistemas: Usuarios que por su naturaleza son registrados en el AD sin que los mismos guarden relación con un determinado funcionario: Cuentas de sistemas, equipos remotos, servidores.	Sistema AD	Subgerencia de Infraestructura Tecnológica
	“Users” Usuarios que por su naturaleza son registrados en el AD a objeto de Administrar el Dominio y/o usuarios asociados a diversas aplicaciones	Sistema AD	Subgerencia de Infraestructura Tecnológica
Usuarios “Temporales”	Usuarios requeridos para dar acceso temporal al AD (Pasantías, auditorías externas, consultorías, empresas de seguridad privada, entidades de fiscalización, servicios contratados, etc.)	Sistema AD	Gerencia División Organización y Métodos

Artículo 2° Contraseña para usuarios “Sistemas”

El subgerente de infraestructura tiene la responsabilidad de supervisar la creación de cuentas, grupos de usuarios, permisos de accesos a la red y privilegios de comunicación. Hay que aclarar que el administrador del sistema AD tiene a su cargo la administración del acceso al sistema.

Artículo 3° Accesos para pasantías

Considerando que las pasantías tiene como objetivo principal coadyuvar con el desarrollo académico de estudiantes universitarios y que el banco no establece ninguna relación laboral o contractual con el pasante, se establece que los “pasantes” no deben asumir ninguna responsabilidad o trabajo operativo relacionado con el giro del negocio es decir que durante el periodo de formación el pasante únicamente tendrá acceso al dominio del banco a través del AD según corresponda y previo análisis y/o evaluación de la Gerencia de Organización y métodos.

Artículo 4° Servicios Contratados

Considerando que los servicios contratados son una alternativa al trabajo especializado y básicamente se trata de una modalidad a través de la cual empresas, grupos o personas ajenas a

la institución son contratadas para hacerse cargo de “parte del negocio” o de un servicio puntual dentro de ella, el banco ha definido contratar los servicios de personas o empresas para desarrollar ciertas actividades específicas, estas personas podrán, según la naturaleza de la actividad que desempeñan en el banco acceder a los sistemas del banco previo análisis y/o evaluación de la gerencia de organización y métodos.

SECCION 3 ADMINISTRACIÓN DE GRUPOS DE SEGURIDAD EN EL AD

La creación de grupos de seguridad relacionados a usuarios de funcionarios o personal temporal es responsabilidad de la Gerencia de Organización y métodos, asegurar que los grupos activos guarden relación con la estructura y funcionalidad del banco.

Artículo 1° Definición de grupos de seguridad

Con el objetivo de optimizar la administración de accesos y atribuciones en el AD, este cuenta con la funcionalidad de permitir la agrupación de usuarios, que por su naturaleza podrían ser administrados de manera masiva.

SECCION 4 ALTA DE USUARIOS EN EL SISTEMA AD

El alta de usuarios en el sistema AD de usuarios de funcionarios BNB o temporales es responsabilidad exclusiva de la gerencia de organización y métodos, instancia que de manera previa al registro correspondiente deberá verificar el cumplimiento de las disposiciones y procedimientos descritos en la presente norma, así como verificar que la solicitud se ajuste a la estructura organizacional definida para cada sucursal. Los usuarios de tipo “sistemas”, son dados de “alta” bajo responsabilidad de la Subgerencia de Infraestructura Tecnológica.

Artículo 1° Alta de Usuarios (funcionarios)

Una vez cumplidos los procesos de incorporación de personal según lo establecido en la norma de “Contratación y Desvinculación Laboral”, y siempre que se haya efectuado el registro del alta de personal a través del sistema de alta de usuarios, el Asistente de Administración de Sistemas es responsable de efectuar el alta de usuarios una vez recibido el caso.

Artículo 2° Registro (alta) del usuario en el sistema AD.

Una vez que el Asistente Administración de Sistemas haya recibido el caso a través del Sistema de altas y bajas, procederá al registro, alta, en el sistema AD a través del sistema AD Manager, el Asistente de Administración de Sistemas registrara los datos generales conforme a la naturaleza de cada sistema al que accederá el nuevo usuario para proceder con su alta.

Artículo 3° Procedimientos previos al inicio de las actividades del funcionario

- Personalización y/o configuración del equipo

De manera previa al inicio de las actividades del nuevo funcionario, el operador de sistemas deberá proceder con la personalización y/o configuración del equipo asignado al usuario previa asignación del caso a través del sistema de altas de usuarios.

- Criterios para cambio de contraseñas

Las contraseñas asignadas al usuario AD son válidas para acceder al dominio BNB solo por primera vez. De esta manera que cuando el usuario se identifica ante el sistema, este exige el cambio inmediato de contraseña, para lo cual deberán considerarse los criterios descritos en la normativa de “Gestión de Accesos y Atribuciones en los sistemas”

SECCION 5 BAJA DE USUARIOS EN EL SISTEMA AD

Artículo 1° Baja de Usuarios

Por la importancia implícita que tiene la optimización continua del ambiente de control y con el objeto de mantener la confidencialidad de la información y prevenir posibles actos dolosos por mantener los accesos vigentes del personal desvinculado de la institución, se establece que toda desvinculación laboral de cualquier funcionario o director, personal externo por cesación de contrato deberá ser comunicado en un plazo no mayor a diez días, por el Gerente de servicios y operaciones regional y/o el Gerente/Subgerente según corresponda el sector a la Gerencia de Organización y Métodos. Una vez que el Asistente de Administración de Sistemas haya verificado la solicitud de baja de perfil a través del sistema de Altas y bajas de usuarios procederá al registro (baja) en el sistema AD y otros sistemas en atención a la solicitud.

SECCION 6 BLOQUEO, DESBLOQUEO Y CAMBIO DE CONTRASEÑA EN EL SISTEMA AD.

Artículo 1° Bloqueo de los Sistemas

Para prevenir que una contraseña sea comprometida a través de ataques de “fuerza bruta” o mediante el uso de “diccionarios de datos”, el número de intentos de autenticación a los sistemas informáticos debe ser limitado. En este sentido, se deben considerar los siguientes criterios:

- El sistema admite al usuario ingresar una contraseña errada hasta 3 veces antes de que esta contraseña quede bloqueada
- Pasado el tiempo establecido de 15 minutos, el usuario podrá intentar ingresar nuevamente.
- En caso de que el usuario no recuerde la contraseña, este deberá solicitar el cambio de clave siguiendo lo establecido en el artículo 2°.

Artículo 2° Desbloqueo y/o cambio de contraseñas en el Sistema AD

En caso de bloqueos de contraseña de acceso al AD los funcionarios podrán solicitar el desbloqueo únicamente en caso de urgencia y antes de haber transcurrido el tiempo establecido de 15 minutos para el intento de nuevo ingreso. Las solicitudes de cambio de contraseña por olvido o error de escritura en el sistema AD deberán ser registradas y aprobadas a través del sistema de Altas y bajas de usuarios. Una vez que el Asistente de Administración de Sistemas haya verificado la respectiva solicitud, procederá al desbloqueo y/o cambio de contraseña del usuario. Posteriormente se hará la notificación vía telefónica y/o correo electrónico, al momento de realizar esta notificación se aplicarán los protocolos de seguridad necesarios.

SECCION 7 CONTROL DE ACCESO A LA RED

El proceso de Gestión de Tecnologías de Comunicación e Información debe asegurar el bloqueo al acceso de páginas de contenido para adultos, redes sociales, hacking, mensajería instantánea y cualquier página que represente riesgo potencial para la Entidad mediante el uso de servidor proxy, firewall o el software que mejor se ajuste a la necesidad. Excepciones de acceso, serán aprobados por el jefe inmediato, según la necesidad del cargo y verificación previa de que las paginas solicitadas no contengan código malicioso con el visto bueno del OSI.

Artículo 1° Control de Conexión a Redes

La infraestructura de red del Banco deberá estar separada por VLAN's para garantizar la confidencialidad de los datos que se transmitan en cada departamento de la organización.

Artículo 2° Seguridad en los Servicios de Red

La Subgerencia de Infraestructura Tecnológica es la encargada de mantener instalados y habilitados sólo aquellos servicios y puertos de red que sean utilizados por los sistemas de información y software de la entidad. Controlar el acceso lógico a los servicios, tanto a su uso como a su administración mediante bloqueo de puertos en los firewalls de la entidad.

Artículo 3° Sesiones Inactivas

Si el usuario debe abandonar la estación de trabajo momentáneamente, activará protectores de pantalla con contraseñas, con el fin de evitar que terceros puedan ver su trabajo o continuar con la sesión de usuario habilitada. Si los sistemas de información detectan inactividad por un periodo igual o superior a diez minutos, deben automáticamente finalizar la sesión de usuario

Artículo 4° Limitación del Tiempo de Conexión

Las restricciones al horario de conexión deben suministrar seguridad adicional a las aplicaciones

Limitar los tiempos de conexión al horario normal de oficina, de no existir un requerimiento operativo de horas extras o extensión horaria. Documentar los funcionarios o personal externo que no tienen restricciones horarias y los motivos y evidencia de la autorización expedida por la Gerencia de Organización y Métodos.

SECCION 8 RESPONSABILIDAD SOBRE EL REGISTRO DE USUARIO Y CONTRASEÑAS.

Cada funcionario es responsable sobre el uso y aplicación de identificación de usuario y su contraseña asignados al mismo. Las operaciones que sean realizadas por el funcionario mediante su usuario en el sistema AD, podrán ser controladas y verificadas por la subgerencia de seguridad de la información, por tanto:

Queda terminantemente prohibido divulgar o permitir que otro funcionario conozca y/o utilice su identificación de usuario y contraseña de acceso.

Toda la información a la que accede el funcionario mediante su usuario es estrictamente de uso interno, por lo tanto, deberá tratarse de manera confidencial conforme a lo descrito en la Ley de Servicios Financieros Ley 393.

SECCION 9 OTRAS DISPOSICIONES

Artículo 1° Responsabilidades

Se establecen los siguientes centros de responsabilidad generales:

Gerente División Auditoria, es responsable de verificar el cumplimiento de los procesos, procedimientos y definiciones descritas en la presente norma.

Gerente Organización y métodos, responsable de la difusión de los procesos, procedimientos y definiciones descritas en la presente norma.

Artículo 2° Incumplimiento y sanciones

El incumplimiento a la presente norma constituye según el caso, infracciones graves cuando directa o indirectamente ocasionan daño o perjuicio material y/o moral al banco, constituyendo causal de retiro cuando por la gravedad de estas causen mayor daño al banco.

En la aplicación de sanciones se observará el reglamento interno del banco.

Artículo 3° Actualizaciones

Las actualizaciones posteriores a la presente norma serán responsabilidad de la Gerencia de Organización y Métodos, en coordinación con la Gerencia de Tecnología y la Subgerencia de Seguridad de la Información.

ANEXO V.

PROCEDIMIENTO - SISTEMA DE CONTROL DE ACCESO A LA RED

1. OBJETIVO

El objetivo del actual procedimiento es el de describir la configuración y administración de equipos de usuarios, switches de acceso capa dos y servidor del Sistema de Control de Acceso a la red para restringir la conexión de equipos de red a usuarios externos al Banco.

2. RESPONSABILIDADES

Gerencia de Tecnologías de la Información:

Realizar revisiones sorpresa para verificar el cumplimiento de las políticas y procedimientos establecidos en este documento.

Aprobar el plan de acción a tomar en casos de anomalías e incidentes de seguridad.

Aprobar los cambios en el Procedimiento del Sistema de Control de Acceso a la red.

Subgerente de Infraestructura Tecnológica:

Establecer parámetros y esquemas sobre la Administración del Sistema de Control de Acceso a la red (NAC).

Supervisor de Redes y Comunicaciones:

Evaluar la factibilidad técnica de las solicitudes, actualizar el presente procedimiento, y revisar las configuraciones necesarias para la ejecución de las solicitudes.

Definir el plan de acciones a tomar en casos de mal funcionamiento de este sistema.

Analista de Redes y Comunicaciones:

Ejecutar los requerimientos aprobados que mencionen configuraciones de políticas, creación de listas de acceso, y alta de equipos de red en el sistema NAC.

Sugerir mejoras o cambios en provecho de la seguridad y mejor administración.

Tener el respaldo de configuraciones con las últimas modificaciones.

Actualizar el presente procedimiento juntamente con el Supervisor de redes.

Supervisor de Infraestructura:

El sistema NAC, cómo parte componente de comunicaciones en el Centro de Cómputo, debe estar cubierto por los procedimientos respectivos que aseguren el buen funcionamiento de los equipos controlando la estabilidad y disponibilidad de la red eléctrica, red de datos, así como también niveles aceptables de temperatura donde se instale y opera el servidor de este sistema.

Seguridad Tecnológica:

Realizar la revisión de los eventos reportados por el sistema NAC de forma periódica con el propósito de tomar una acción en el caso que se encuentren eventos anómalos. En el caso de requerir una configuración debido a un requerimiento específico deberá coordinar con la Subgerencia de Infraestructura Tecnológica las acciones a tomar.

3. ANTECEDENTES

Para entender mejor el contenido de este documento, a continuación, se presenta de manera breve, los principales conceptos relacionados con la implementación de mecanismos de seguridad para el control de acceso en redes de datos cableadas.

Control de Acceso: Es la capacidad de controlar la interacción de un elemento activo como un usuario o dispositivo con un recurso de la red de datos. Adicionalmente, el control de acceso implica procedimientos de identificación, autenticación y autorización para permitir o denegar el uso de los recursos, así como para llevar un registro de este.

IEEE 802.1x Es un estándar para el control de acceso a red basada en puertos. Es parte del grupo de protocolos IEEE 802 (IEEE 802.1). Permite la autenticación de dispositivos conectados a un puerto LAN. En la implementación del estándar 802.1x se requieren, mínimo, los siguientes componentes:

- PC de usuario que intenta acceder a la red, o “**suplicante**”
- Punto de acceso de red de un switch capa 2 que habilita o impide el ingreso del suplicante, también llamado “**Autenticador**”
- Y el “**servidor de autenticación**”, quien negocia y valida la identidad del suplicante; y le informa el éxito o fracaso de este proceso al autenticador para que ejecute la acción indicada.

AAA Es el acrónimo de Authentication, Authorization y Accounting.

AD Active Directory (AD), es un servicio establecido en uno o varios servidores en donde se crean objetos tales como usuarios, equipos o grupos, con el objetivo de administrar los inicios de sesión en los equipos conectados a la red.

Dirección MAC Es un identificador de 48 bits que corresponde al identificador único de la tarjeta de red (media access control).

DNS (Domain Name System). Protocolo de resolución de nombres por direcciones IP.

EAP (Extensible Authentication Protocol). Protocolo de autenticación extensible que admite distintos métodos de autenticación empleando intercambio de credenciales e información.

RADIUS (Remote Authentication Dial-In User Service) Es un protocolo de autenticación el cual su principal función es asegurar las redes de un acceso no autorizado. El cual permite tener autenticación, autorización y la contabilidad del acceso a la red.

4. DESCRIPCIÓN DEL PROCEDIMIENTO

4.1 ACCESO ADMINISTRATIVO:

El acceso administrativo al servidor NAC es vía un equipo pivote. Debido a que el mismo se encuentra en un segmento de servidores que está aislado de la red de usuarios.

4.2 ACCESO POR PUERTO DE CONSOLA:

El acceso administrativo físico a la consola de los switches de acceso, capa dos, que forman parte del sistema 802.1x está restringido.

4.3 ALMACENAMIENTOS DE LOGS:

Los logs del servidor NAC son almacenados de forma remota en el servidor SIEM Qradar del banco, para tener el respaldo de eventos.

4.4 PROCEDIMIENTO DE INSTALACIÓN Y CONFIGURACIÓN

El archivo de instalación del sistema ISE es un template OVA que es una máquina virtual que se instala sobre la plataforma VMware, este archivo es provisto por el proveedor local. Posterior al proceso de instalación de la máquina virtual se asigna la interfaz de red correspondiente a la máquina virtual ISE. En la consola del servidor ISE en la maquina VMware configuramos los parámetros de: Dominio [bnb.com], nombre de equipo [z0ise01], dirección IP [x.x.x.x], Mascara [x.x.x.x], Gateway [x.x.x.x], NTP Server [x.x.x.x], DNS Servers [x.x.x.x] [x.x.x.x].

Luego de este proceso de instalación, el servidor se reinicia, y podemos acceder por la interfaz web del servidor. Para realizar las configuraciones posteriores.

En el repositorio de certificados del servidor ISE, **Administration/System/Certificates/System Certificates**, se hace la carga del certificado para el servidor firmado por el CA Certificate Authority de la red de la empresa.

Identity Services Engine

Home

Context Visibility

Operations

Policy

Administration

Work Centers

License Warning

System

Identity Management

Network Resources

Device Portal Management

pxGrid Services

Deployment

Licensing

Certificates

Logging

Maintenance

Upgrade

Backup & Restore

Admin Access

Settings

Certificate Management

System Certificates

Trusted Certificates

OCSP Client Profile

Certificate Signing Requests

Certificate Periodic Check Settings

Certificate Authority

System Certificates

Edit

Generate Self Signed Certificate

Import

Export

Delete

View

For disaster recovery it is recommended to export certificate and private key pairs of all system certificates.

Friendly Name	Used By	Portal group tag	Issued To	Issued By	Valid From	Expiration Date
bnbise						
☐ BNB-EAP#BNB-EAP#000002 OU=Certificate Services System Certificate CN=bnbise.bnb.com.bo#Certificate Services Endpoint Sub CA - bnbise#000001 Default self-signed saml server certificate - CN=SAML_bnbise.bnb.com.bo Default self-signed server certificate	EAP Authentication Admin, Portal, pxGrid SAML RADIUS DTLS	BNB Default Portal Certificate Group (f)	BNB bnbise.bnb.com.bo SAML_bnbise.bnb.com.bo bnbise.bnb.com.bo	BNB Certificate Services Endpoint Sub CA - bnbise SAML_bnbise.bnb.com.bo bnbise.bnb.com.bo	Mon, 29 Jul 2019 Tue, 9 Jul 2019 Wed, 10 Jul 2019 Wed, 10 Jul 2019	Wed, 28 Jul 2021 Tue, 10 Jul 2029 Thu, 9 Jul 2020 Thu, 9 Jul 2020

De igual forma se hace la carga del certificado root del CA en el repositorio de certificados de confianza del servidor ISE.

Trusted Certificates

Edit Import Export Delete View Show All

Friendly Name	Status	Trusted For	Serial Number	Issued To	Issued By
☐ Thawte Primary Root CA	Enabled	Cisco Services	34 4E D5 57 20 D5...	thawte Primary Root CA	thawte Primary Root CA
☒ Default self-signed server certificate	Enabled	Endpoints Infrastructure AdminAuth	5D 26 9A BF 00 00...	bnbise.bnb.com.bo	bnbise.bnb.com.bo

En el nodo principal se registra un nuevo servidor para que sea parte de los equipos ISE en:
Administration / System / Deployment /

Identity Services Engine Home Context Visibility Operations Policy Administration Work Centers License Warning

System Identity Management Network Resources Device Portal Management pxGrid Services

Deployment Licensing Certificates Logging Maintenance Upgrade Backup & Restore Admin Access Settings

Deployment

Deployment Nodes

Register Syncup Deregister Show All

Hostname	Personas	Role(s)	Services	Node Status
☐ bnbise	Administration, Monitoring, Policy Service	STANDALONE	SESSION, PROFILER, DEVICE ADMIN	✓

Introducimos las credenciales de acceso al servidor, junto al nombre del servidor.

Deployment Nodes List > Specify Hostname

Register ISE Node - Step 1: Specify Node Host FQDN (hostname.domain-name) and Credentials

* Host FQDN

* User Name

* Password

Se definen los módulos a instalar en el servidor: el de Políticas, Monitoreo, Administración, en el caso de los nodos de Oficina Principal y centro alternativo, tienen estos tres módulos configurados. Para el caso de servidores del interior solo se instala el módulo de políticas.

Deployment Nodes List > bnbise

Edit Node

General Settings

Hostname: bnbise
FQDN: bnbise.bnb.com.bo
IP Address: 10.10.10.5
Node Type: Identity Services Engine (ISE)

Role: STANDALONE **Make Primary**

☒ Administration

☒ Monitoring **PRIMARY**

Other Monitoring Node:

☒ Policy Service

☒ Enable Session Services (i)
Include Node in Node Group: None (i)

☒ Enable Profiling Service (i)

☐ Enable Threat Centric NAC Service (i)

☐ Enable SXP Service (i)

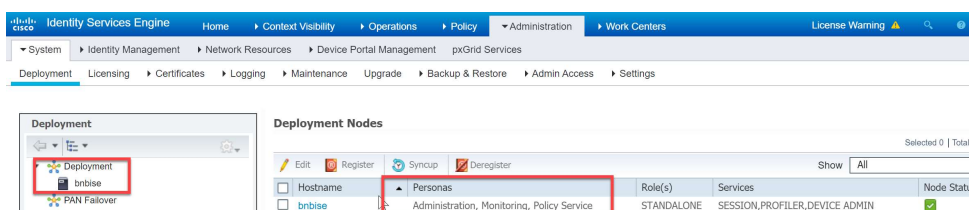
☒ Enable Device Admin Service (i)

☐ Enable Passive Identity Service (i)

☐ pxGrid (i)

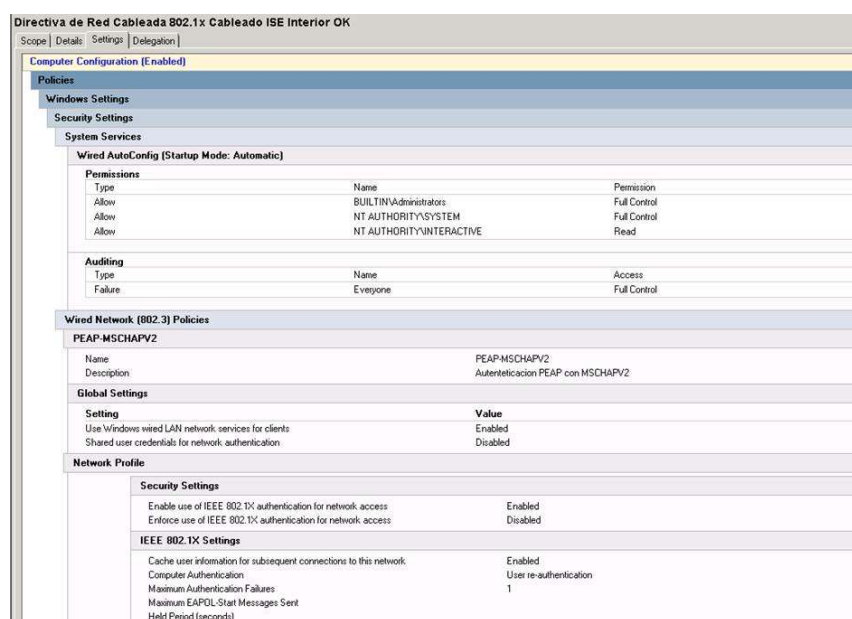
Save Reset

Una vez terminado el proceso de registro del nuevo servidor como nodo ISE en la consola principal, se puede verificar su estado en la consola principal en: **Administration / System / Deployment / Deployment Nodes**, Así se verifica que el nodo se encuentre activo y replicando.

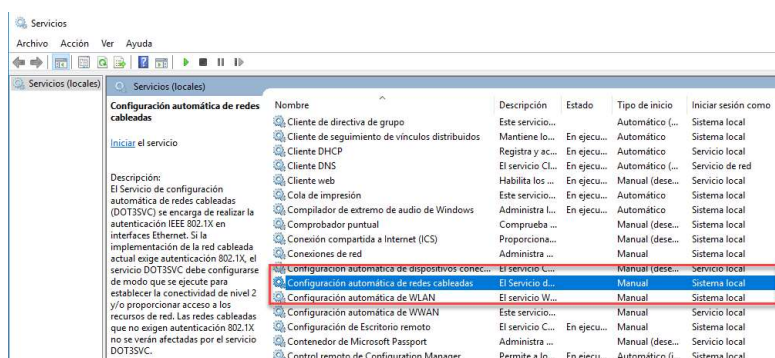


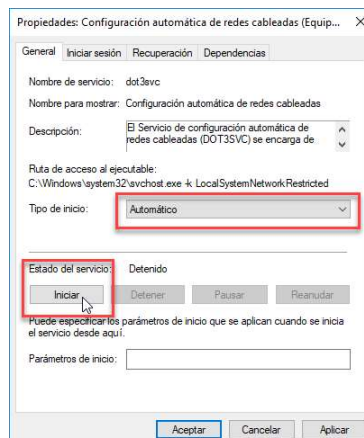
4.5 HABILITACIÓN SUPPLICANTE EN EQUIPOS DE RED

Para la habilitación del cliente suplicante en los equipos de red que se encuentren en dominio, se debe habilitar una directiva de red en el servidor AD que habilite la opción de autenticación en la tarjeta de red de los equipos computacionales, para lo cual la Política de Grupo del servidor AD debe habilitar los siguientes parámetros en los equipos de red de los usuarios de dominio:

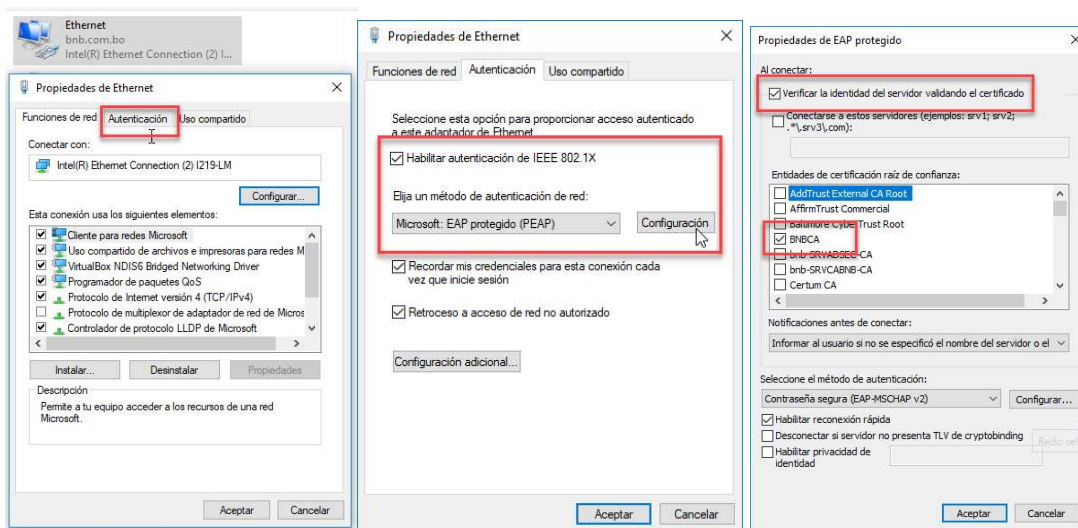


El servicio de Configuración automática de redes cableadas.





Con este servicio activo se habilitará la pestaña de autenticación en la configuración de la tarjeta de red del equipo donde se deben configurar los parámetros de autenticación de IEEE 802.1x, verificación de identidad a través del certificado CA de la entidad certificadora del banco.



4.6 CONFIGURACIÓN DE SWITCH DE ACCESO A LA RED

La siguiente configuración se hará en los switches de acceso donde se habilitará el control de acceso. En la configuración global del switch de acceso se debe agregar los siguientes comandos

```
COM1 - PuTTY
aaa new-model
!
aaa group server radius bnbise
server 10.1.1.1.35 auth-port 1812 acct-port 1813
!
aaa authentication dot1x default group bnbise
aaa authorization network default group bnbise
aaa accounting update newinfo
aaa accounting dot1x default start-stop group bnbise
!
aaa server radius dynamic-author
client 10.1.1.1.35
server-key 7 03075218055F701E1D49
auth-type any
```

```
radius-server attribute 6 on-for-login-auth
radius-server attribute 8 include-in-access-req
radius-server attribute 25 access-request include
radius-server dead-criteria time 10 tries 3
radius-server host 10.10.10.35 auth-port 1812 acct-port 1813 key 7 14341B180F547B7977
radius-server key 7 05080F1C221C1F5B4A45
radius-server vsa send accounting
radius-server vsa send authentication
```

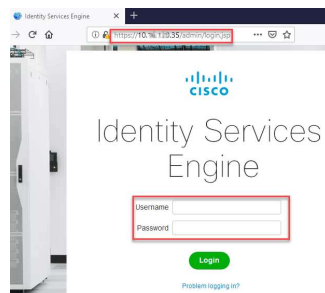
En la configuración del puerto de switch donde se habilitará el control de acceso a red se deben agregar las siguientes líneas de comando.

```
SW-TEST#sh run int 10/2
Building configuration...

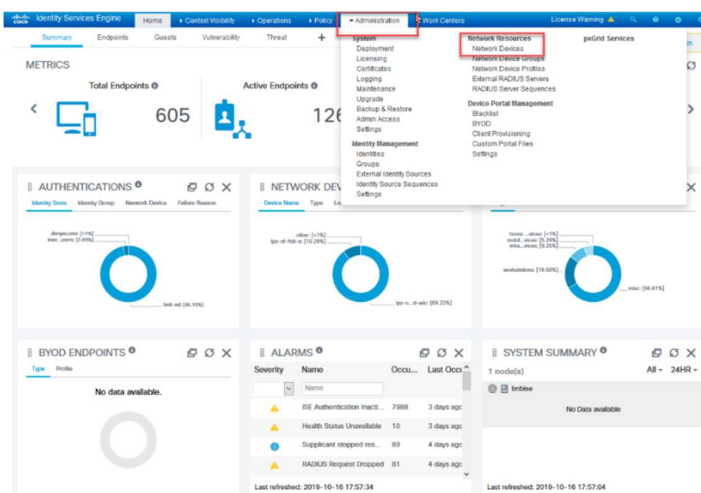
Current configuration : 330 bytes
!
interface FastEthernet0/2
 switchport access vlan #3
 switchport mode access
 switchport voice vlan #
 authentication host-mode multi-auth
 authentication order dot1x mab
 authentication port-control auto
 authentication violation restrict
 mab
 dot1x pae authenticator
 dot1x timeout tx-period 10
 spanning-tree portfast
end
```

4.7 CONFIGURACIÓN DEL SERVIDOR DEL SISTEMA NAC

Una vez realizados los pasos de configuración del cliente suplicante el equipo autenticador queda la configuración del servidor del sistema NAC, que en este caso es el servidor ISE de Cisco, para lo cual luego de su despliegue e instalación accedemos vía web al sistema



Para poder agregar nuevos switches de acceso que ejecutarán la tarea de autenticación accedemos a la opción / **Administration** / **Network Resources** / **Network Devices**/ del servidor

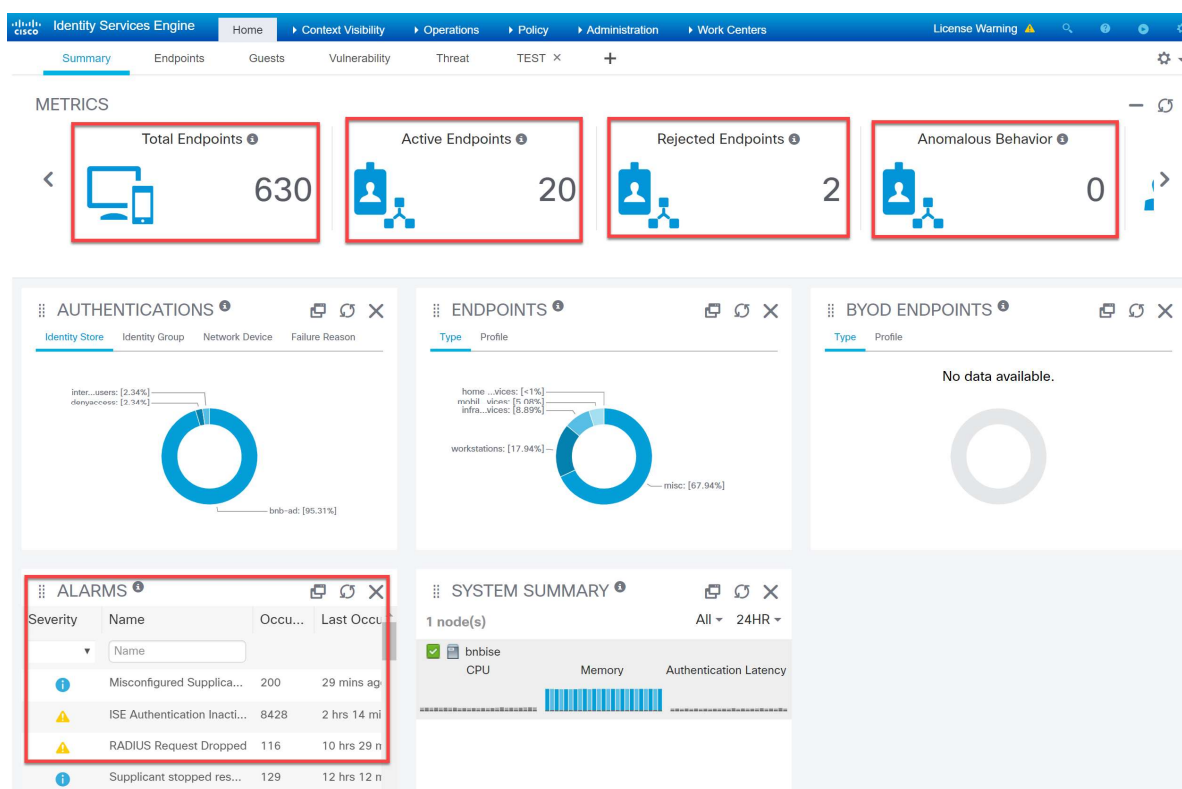


4.9 MONITOREO DE EVENTOS DE SEGURIDAD:

Se debe habilitar una cuenta en el servidor AD del banco para que el operador de monitoreo del área de tecnología acceda a la consola de monitoreo del servidor ISE.

En esta consola se tiene un dashbore de resumen de:

- Total de dispositivos.
- Dispositivos activos.
- Dispositivos rechazados.
- Comportamiento anómalo.
- Alarmas.

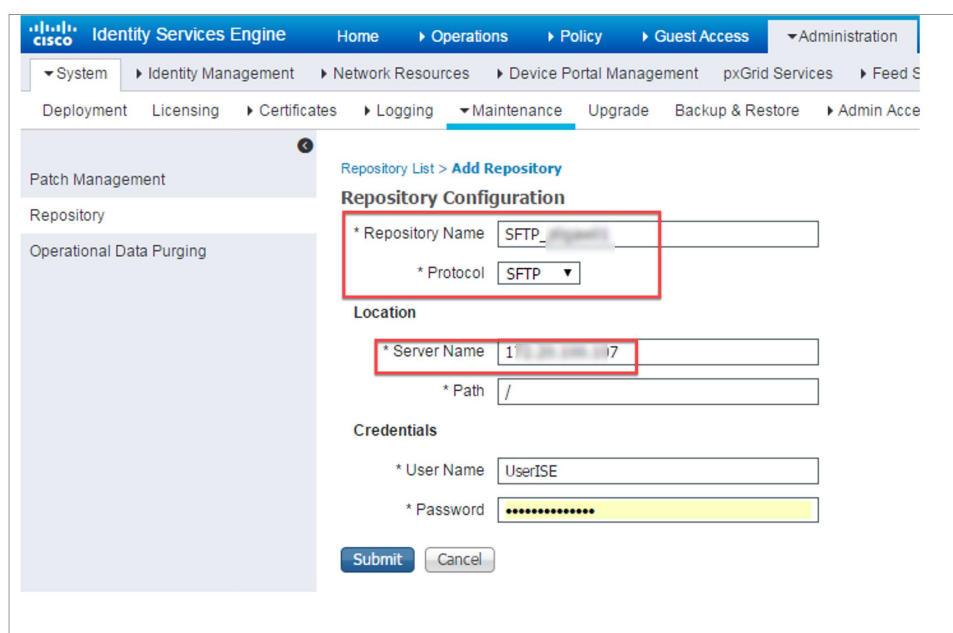


El operador de monitoreo está a cargo de informar de algún evento anómalo sobre el funcionamiento del sistema ISE a los Analistas de Seguridad de la Información y a los Analistas de Sistemas de infraestructura.

Los Analistas de Seguridad de la Información y a los Analistas de Sistemas de infraestructura una vez que sean informados sobre estos incidentes que se detecten el Sistema de Control de Acceso harán una revisión a detalle de los eventos y tomaran acciones para que el sistema de control de acceso funcione de manera adecuada.

4.10 DEFINICIÓN DE BACKUPS:

Se cuenta con un esquema de procedimiento de respaldo de máquinas virtuales de los servidores de producción, donde también se considera a la máquina virtual del servidor ISE. Se cuenta con una copia de seguridad de la configuración que apunta a un servidor SFTP donde se almacenan los archivos de configuración en forma diaria, a su vez este servidor SFTP tiene un respaldo diario a cinta de esta configuración junto a la de otros servidores. El repositorio se encuentra configurado en la ruta: **Administration / System / Maintenance / Repository**,

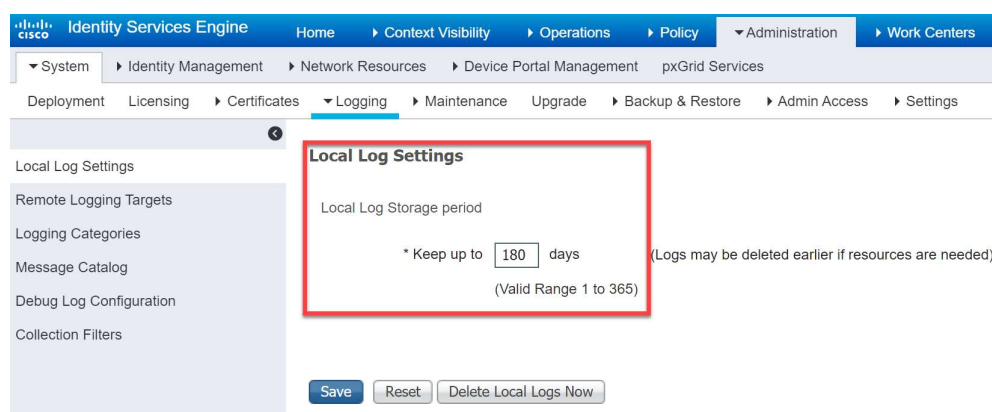


The screenshot shows the Cisco Identity Services Engine (ISE) Administration console. The breadcrumb navigation is: Administration > System > Maintenance > Repository. The page title is "Repository Configuration". The configuration fields are:

- * Repository Name: SFTP_...
- * Protocol: SFTP
- Location
 - * Server Name: 10.10.10.17
 - * Path: /
- Credentials
 - * User Name: UserISE
 - * Password: masked

Buttons: Submit, Cancel.

Se cuenta con un respaldo local de los eventos de configuración que son almacenados 180 días, de acuerdo con la recomendación de la ASFI en cuanto al resguardo de respaldo de configuración.

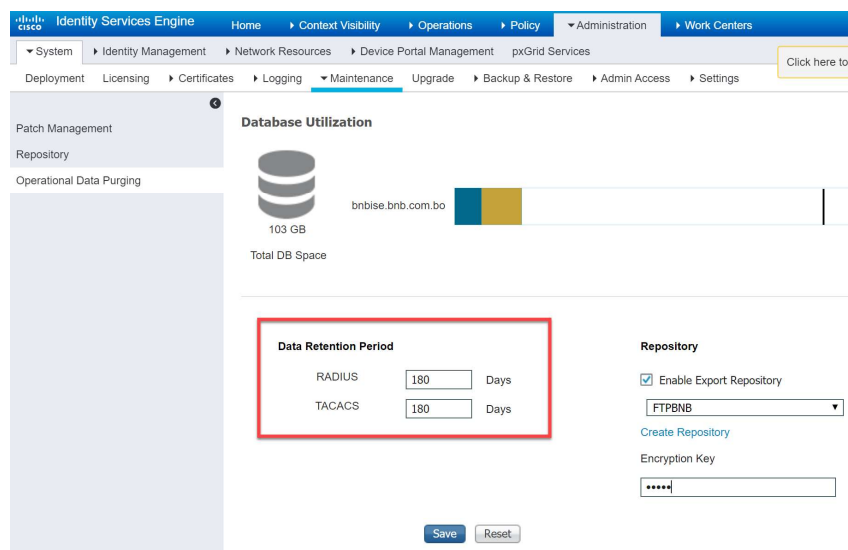


The screenshot shows the Cisco Identity Services Engine (ISE) Administration console. The breadcrumb navigation is: Administration > Settings > Local Log Settings. The page title is "Local Log Settings". The configuration field is:

- Local Log Storage period
 - * Keep up to 180 days (Valid Range 1 to 365)

Buttons: Save, Reset, Delete Local Logs Now.

Los logs de eventos de acceso de los usuarios tienen un respaldo de 180 días.



4.11 GRUPOS Y USUARIOS:

La administración del servidor NAC se realiza mediante la consola Web en la cual tienen diferentes niveles de usuarios para la administración que a continuación se describen. La autenticación de usuarios para gestionar los servidores del sistema NAC es vía Active Directory.

USUARIO	PRIVILEGIO	AUTENTI CACION	CUSTODIA	CLAVE	ESTADO	OBSERVACIONES
admin	Super Usuario	Local	Bóveda	Compar tida	activo	Usuario bajo custodia de Seguridad de la Información y auditoria de sistemas.
UserNAC Prod	Group Reviewer	Active Directory	Subgerencia de Infraestructu ra Tecnológica	No Compar tida	activo	Usuario de lectura creado para que el área producción pueda realizar una lectura de algún evento en caso de ser necesario
UserNAC SSII	Group Reviewer	Active Directory	Subgerencia de Seguridad de la Información	No Compar tida	activo	Usuario de lectura creado para que el área SSII pueda realizar la revisión de los eventos en el sistema NAC.
UserNAC MON	Group Monitor	Active Directory	Personal de monitoreo de TI	No Compar tida	activo	Usuario de lectura creado para que el Operador de monitoreo pueda realizar la revisión de los eventos en el sistema NAC.

GLOSARIO

AAA	Authentication, Authorization and Accounting
ANSI	American National Standard International
AP	Access Point
APT	Advance Persistent Threat
ARP	Address Resolution
ASFI	Autoridad de Supervisión del Sistema Financiero
BIA	Business Impact Analysis
BYOD	Bring Your Own Device
CAPsMAN	Controlled Access Point System Manager
CEH	Certified Ethical Hacking
DDoS	Distributed Denial of Service
DHCP	Dynamic Host Configuration Protocol
DIB	Directory Information Base
DIT	Directory Information Tree
DLP	Data Loss Prevention
DoS	Denial of Service
EAP-MD5	Extensible Authentication Protocol - Message-Digest Algorithm 5
EAP-TTLS	Extensible Authentication Protocol - Transport Layer Security
ENTEL	Empresa Nacional de Telecomunicaciones
GRPS	Global Risks Perception Survey
HRA	Health Registration Authority
IEEE	Institute of Electrical and Electronics Engineers
IP	Internet Protocol
ISE	Identity Service Engine
ISO	International Organization for Standardization
ISO	International Standard Organization
LAN	Local Area Network.
LDAP	Lightweight Directory Access Protocol
LDAPS	LDAP over SSL
MAC	Medium Access Control
MANET	Mobile Ad hoc Network
MIT	Massachusetts Institute of Technology

MPLS	Multi-Protocol Label Switching
NAC	Network Access Control
NAP	Network Access Protection
OSI	Open System Interconnection
OSI	Oficial de Seguridad de la Información
OISM3	Open Information Security Management Maturity Model
PCI	Payment Card Industry
PDCA	Plan Do Check Act
PEAP	Protected Extensible Authentication Protocol
PEI	Plan Estratégico Institucional
PIN	Personal Identification Number
RADIUS	Remote Authentication Dial In User Service
SGSI	Sistema de Gestión de Seguridad de la Información
SGSI	Subgerente de Seguridad de la Información
SGIT	Subgerente de Infraestructura Tecnológica
SHA	System Health Agent
SI	Seguridad de la Información
SoH	Statement of Health
SOC	Security Operation Center
SSID	Service Set Identifier
SSL	Secure Sockets Layer
TACACS+	Terminal Access Controller Access Control System
TCP / IP	Transmission Control Protocol / Internet Protocol.
TIC	Tecnologías de la Información y las Comunicación
TLS	Transport Layer Security
UDP	User Datagram Protocol
VLAN	Virtual Local Area Network
VSM	Vector Support Machine
WLAN	Wireless Local Area Network
WAN	Wide Area Network
WEF	World Economic Forum